Australian Government
Australian Signals Directorate

cyber.gov.au

Information security manual

September 2026

First published: 07 September 2026



Table of contents

Using the cyber security framework 1

Executive summary 1

Applying a risk-based approach to cyber security 2

Cyber security principles 7

The cyber security principles 7

Guidelines for cyber security roles 13

Board of directors and executive committee 13

Chief information security officer 15

System owners 20

Guidelines for cyber security incidents 22

Managing cyber security incidents 22

Responding to cyber security incidents 26

Guidelines for procurement and outsourcing 29

Cyber supply chain risk management 29

Managed services and cloud services 32

Guidelines for cyber security documentation 39

Development and maintenance of cyber security documentation 39

System-specific cyber security documentation 43

Guidelines for physical security 47

Facilities and systems 47

IT equipment and media 50

Guidelines for personnel security 52

Cyber security awareness training 52

Guidelines for communications infrastructure 58

Cabling infrastructure 58

Emanation security 67

Guidelines for communications systems 69

Telephone systems 69

Video conferencing and Internet Protocol telephony 71

Multifunction devices 74

Fax machines and services 75

Guidelines for enterprise mobility 76

Enterprise mobility 76

Mobile device management 78

Mobile device usage 81

Guidelines for evaluated products 87

Evaluated product procurement 87

Evaluated product usage 89

Guidelines for information technology equipment 91

IT equipment usage 91

IT equipment maintenance or repairs 93

IT equipment sanitisation and destruction 94

IT equipment disposal 98

Guidelines for media 99

Media usage 99

Media sanitisation 102

Media destruction 106

Media disposal 110

Guidelines for system hardening 112

Operating system hardening 112

User application hardening 122

Server application hardening 128

Virtualisation hardening 136

Guidelines for system access 139

Identity and access management 139
Credential management 153
Guidelines for system management 161
System administration 161
System maintenance 164
Data backup and restoration 168
Guidelines for security assurance 172
Security monitoring 172
Security assessments 177
Guidelines for software development 181
Software development fundamentals 181
Artificial intelligence application development 194
Mobile application development 197
Web application development 198
Guidelines for database systems 201
Database servers 201
Databases 202
Guidelines for email 205
Email usage 205
Email gateways and servers 207
Guidelines for networking 211
Network design and configuration 211
Wired networks 221
Wireless networks 222
Service continuity for online services 227
Guidelines for cryptography 230
Cryptographic fundamentals 230
Cryptographic algorithms 234

Cryptographic protocols 242
Internet Protocol Security 243
Secure Shell 245
Secure/Multipurpose Internet Mail Extensions 247
Transport Layer Security 248
Guidelines for gateways 250
Gateways 250
Cross domain solutions 255
Firewalls 257
Web application firewalls 258
Diodes 258
Web proxies 259
Web content filters 260
Content filtering 261
Peripheral switches 265
Guidelines for data transfers 266
Data transfers 266
Cyber security terminology 269
Glossary of abbreviations 269
Glossary of cyber security terms 272

Using the cyber security framework

Executive summary

Purpose

The purpose of the *Information security manual* (ISM) is to outline a cyber security framework that an organisation can apply, using their risk management framework, to protect their information technology (IT) and operational technology (OT) systems from cyber threats.

Intended audience

The ISM is intended for chief information security officers (CISOs), chief information officers, cyber security professionals, and IT and OT managers.

Authority

The ISM represents the considered advice of the Australian Signals Directorate (ASD). This advice is provided in accordance with ASD's designated functions under the *Intelligence Services Act 2001*.

ASD also provides cyber security advice in the form of Australian Communications Security Instructions and other cyber security-related publications. In these cases, operating system, application and device-specific advice may take precedence over the advice in the ISM.

Legislation and legal considerations

An organisation is not required as a matter of law to comply with the ISM, unless legislation, or a direction given under legislation or by some other lawful authority, compels them to comply. Furthermore, the ISM does not override any obligations imposed by legislation or law. Finally, if the ISM conflicts with legislation or law, the latter takes precedence.

While the ISM contains examples of when legislation or laws may be relevant for an organisation, there is no comprehensive consideration of such issues. When designing, operating and decommissioning systems, an organisation is encouraged to familiarise themselves with relevant legislation, such as the *Archives Act 1983*, *Privacy Act 1988*, *Security of Critical Infrastructure Act 2018* and *Telecommunications (Interception and Access) Act 1979*.

Cyber security principles

The purpose of the cyber security principles within the ISM is to provide strategic guidance on how an organisation can protect their IT and OT systems from cyber threats. These cyber security principles are grouped into six functions: govern, identify, protect, detect, respond and recover.

An organisation should be able to demonstrate that the cyber security principles are being adhered to within their organisation.

Cyber security guidelines

The purpose of the cyber security guidelines within the ISM is to support the cyber security principles by providing practical guidance on how an organisation can protect their IT and OT systems from cyber threats. An organisation should consider the cyber security guidelines that are relevant to each of the systems they operate.

Applying a risk-based approach to cyber security

Using a risk management framework

The risk management framework defined by the ISM draws from National Institute of Standards and Technology (NIST) Special Publication (SP) 800-37 Rev. 2, *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy*. Broadly, the risk management framework defined by the ISM has six steps: define the system, select security controls, implement security controls, assess security controls, authorise the system and monitor the system.

Define the system

Determine the system boundary, business criticality, and security and resilience objectives for the system based on an assessment of the impact if it were to be compromised or attacked.

When embarking upon the design of a system, the system boundary, business criticality, and security and resilience objectives for the system should be determined. This will ultimately guide activities, such as selecting and tailoring security controls, to meet those security and resilience objectives as well as determining the level of residual security risk that will be accepted before the system is authorised to operate.

Following the determination of the system boundary, business criticality, and security and resilience objectives for a system, a description of the system and its characteristics should be documented in the system's system security plan.

Select security controls

Select security controls for the system and tailor them to achieve desired security and resilience objectives.

Each cyber security guideline discusses security risks associated with the topics it covers. Paired with these discussions are security controls that ASD considers to provide efficient and effective mitigations based on their suitability to achieve the security and resilience objectives for a system. To assist with selecting and tailoring security controls for a system, each security control is assigned an applicability marking. For example, 'NC' for the protection of non-classified systems

(including both government and non-government systems), ‘OS’ for the protection of OFFICIAL: Sensitive systems, ‘P’ for the protection of PROTECTED systems, ‘S’ for the protection of SECRET systems and ‘TS’ for the protection of TOP SECRET systems.

While security risks and security controls are discussed in the cyber security guidelines, and act as a baseline, they should not be considered an exhaustive list for a specific system type or technology. As such, the cyber security guidelines provide an important input into an organisation’s risk identification and risk treatment activities; however, they do not represent the full extent of such activities.

While the cyber security guidelines can assist with risk identification and risk treatment activities, an organisation will still need to undertake their own risk analysis and risk evaluation activities due to the unique nature of each system, its operating environment and the organisation’s risk tolerances.

Following the selection and tailoring of security controls for a system, including the identification of any inherited security controls, they should be documented along with the details of their planned implementation in the system’s system security plan annex. In addition, and as appropriate, security controls should also be documented in the system’s cyber security incident response plan, change and configuration management plan, and continuous monitoring plan.

Finally, the selection of security controls for a system, as documented in the system’s system security plan annex, should be approved by the system’s authorising officer.

Implement security controls

Implement security controls for the system and its operating environment.

Once suitable security controls have been identified for a system, and approved by the authorising officer, they should be implemented. In doing so, the details of their actual implementation, if different from their planned implementation, should be documented in the system’s system security plan annex.

Assess security controls

Assess security controls for the system and its operating environment to determine if they have been implemented correctly and are operating as intended.

In conducting a security control assessment, it is important that the assessor, system owner and authorising officer first agree to the scope, type and extent of assessment activities, which may be documented in a security assessment plan, such that any risks associated with the security control assessment can be appropriately managed. Generally, the scope of the security control assessment will be determined by the type of system and the security controls implemented for the system and its operating environment.

For TOP SECRET systems, including sensitive compartmented information systems, security control assessments can be undertaken by ASD assessors (or their delegates). For non-classified, OFFICIAL: Sensitive, PROTECTED and SECRET systems, security control assessments can be undertaken by an

organisation's own assessors or Infosec Registered Assessors Program (IRAP) assessors. In all cases, assessors should hold an appropriate security clearance and have an appropriate level of experience and understanding of the type of system they are assessing.

At the conclusion of a security control assessment, a security assessment report should be produced outlining the scope of the security control assessment, the system's strengths and weaknesses, security risks associated with the operation of the system, the effectiveness of the implementation of security controls, and any recommended remediation actions. This will assist in performing any initial remediation actions as well as guiding the development of the system's plan of action and milestones.

Authorise the system

Authorise the system to operate based on the acceptance of the security risks associated with its operation.

Before a system can be granted an authorisation to operate, sufficient information should be provided to the authorising officer for them to make an informed decision as to whether to accept the security risks associated with its operation or not. This information should take the form of an authorisation package that includes the system's system security plan, cyber security incident response plan, change and configuration management plan, continuous monitoring plan, security assessment report, and plan of action and milestones.

In some cases, the security risks associated with a system's operation will be acceptable and it will be granted an ongoing authorisation to operate. However, in other cases the security risks associated with the operation of a system may be unacceptable. In such cases, the authorising officer may request further work be undertaken by the system owner. In the intervening time, the authorising officer may choose to grant an authorisation to operate but with constraints placed on the system's use, such as limiting the system's functionality or specifying an expiration date for an authorisation to operate. Finally, if the authorising officer deems the security risks to be unacceptable, regardless of any potential constraints placed on the system's use, they may deny an authorisation to operate until such time that sufficient remediation actions, if possible, have been completed to an acceptable standard.

For non-classified, OFFICIAL: Sensitive, PROTECTED and SECRET systems, the authorising officer is an organisation's CISO (or their delegate). For TOP SECRET systems, including sensitive compartmented information systems, the authorising officer is Director-General ASD (or their delegate).

For commercial providers providing services to an organisation, the authorising officer is the CISO of the supported organisation (or their delegate).

For multinational, multi-organisation and multi-stakeholder systems, a single authorising officer may be identified and assigned, via a formal agreement, to consider whether to accept the security risks associated with a system's operation and, if so, grant a traditional authorisation to operate. Alternatively, it may be more appropriate for multiple authorising officers to consider

jointly whether to accept the security risks associated with a system's operation and, if so, grant a joint authorisation to operate.

In all cases, the authorising officer should have an appropriate level of seniority and understanding of security risks they are accepting. In cases where an organisation does not have a CISO, the authorising officer could be a chief security officer, a chief information officer or other senior executive within the organisation.

Monitor the system

Continuously monitor the system and associated cyber threats, security risks and security controls.

Real-time monitoring of cyber threats, security risks and security controls associated with a system and its operating environment, as outlined in a continuous monitoring plan, is essential to maintaining its security posture. In doing so, specific events may necessitate additional risk management activities. Such events may include:

- changes in security policies relating to the system
- detection of new or emerging cyber threats to the system or its operating environment
- the discovery that security controls for the system are not as effective as planned
- a major cyber security incident involving the system
- major architectural changes to the system.

Following the implementation or modification of any security controls as a result of risk management activities, another security control assessment should be completed. In doing so, the system's authorisation package should be updated. This in turn allows the authorising officer to make an informed decision as to whether the security risks associated with the system's operation are still acceptable. If the security risks are no longer acceptable, the authorising officer may choose to either place constraints on the system's use, such as introducing or amending an expiration date for an authorisation to operate or revoke an authorisation to operate altogether.

Further information

Further information on various risk management practices can be found in the following publications:

- International Organization for Standardization (ISO) 31000:2018, *Risk management – Guidelines*
- International Electrotechnical Commission 31010:2019, *Risk management – Risk assessment techniques*
- ISO/International Electrotechnical Commission 27005:2022, *Information security, cybersecurity and privacy protection – Guidance on managing information security risks*

- NIST SP 800-30 Rev. 1, *Guide for Conducting Risk Assessments*
- NIST SP 800-37 Rev. 2, *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy*.

Further information on the purpose of IRAP is available from ASD.

Cyber security principles

The cyber security principles

Purpose of the cyber security principles

The purpose of the cyber security principles is to provide strategic guidance on how an organisation can protect their information technology and operational technology systems from cyber threats. These cyber security principles are grouped into six functions:

- **Govern:** Develop and maintain a strong and resilient cyber security culture.
- **Identify:** Identify assets and associated security risks.
- **Protect:** Implement and maintain security controls to manage security risks.
- **Detect:** Detect and analyse cyber security events to identify cyber security incidents.
- **Respond:** Respond to cyber security incidents.
- **Recover:** Resume normal business operations following cyber security incidents.

Implementing the cyber security principles

Within each function, the cyber security principles are listed in a logical sequence that reflects how they should be considered for implementation. The numbers used for the cyber security principles are identifiers only and do not indicate an implementation order.

When implementing the cyber security principles, each cyber security principle should be supported by administrative and technical security controls proportionate to an organisation's size, complexity, operating environment and risk profile. These security controls should be subject to ongoing risk-based monitoring and assurance activities. Where the term 'systems' is used, the elements listed in brackets define the scope of that cyber security principle.

Overall, the cyber security principles are interdependent and must be implemented collectively to achieve comprehensive cyber security outcomes.

Govern cyber security principles

The Govern (GOV) cyber security principles are:

- **GOV-01 – Executive cyber security accountability:** The board of directors or executive committee is accountable for cyber security.
- **GOV-08 – Executive artificial intelligence accountability:** The board of directors or executive committee is accountable for ensuring that artificial intelligence is secure, controllable, human-supervised and used in an ethical and accountable manner.

- **GOV-02 – Cyber security leadership:** A chief information security officer provides leadership and oversight of cyber security activities and delivers regular and timely risk-based reporting to the board of directors or executive committee on their organisation's cyber security posture, the effectiveness of security controls, current security risks and emerging cyber threats.
- **GOV-04 – Cyber security resourcing:** Suitable and sufficient personnel and resources are identified, acquired and maintained in support of cyber security activities.
- **GOV-09 – Security risk management responsibilities:** Security risk management responsibilities for an organisation and their suppliers, partners and customers, including any shared responsibilities, are documented and communicated to all relevant parties with accountability arrangements in place to ensure their effective implementation.
- **GOV-03 – Security risk management assurance:** Security risk management activities for an organisation and their systems (infrastructure, operating systems, applications and data) are embedded into organisational risk management frameworks and subject to ongoing monitoring and assurance activities by the board of directors or executive committee.
- **GOV-05 – Security risk acceptance:** Residual security risks for systems (infrastructure, operating systems, applications and data), including inherited and shared security risks, are accepted before they are authorised for use and continuously monitored and managed throughout their operational life.
- **GOV-06 – Security risk communication:** Residual security risks for systems (infrastructure, operating systems, applications and data), including inherited and shared security risks, are transparently and mutually communicated with stakeholders.
- **GOV-10 – System exposure minimisation:** Information about the design, configuration and operation of systems (infrastructure, operating systems, applications and data) is not publicly disclosed or shared externally unless necessary for commercial, legal, regulatory or security purposes, with any disclosure minimised, controlled and logged.
- **GOV-11 – Supplier cyber security assurance:** Systems (infrastructure, operating systems, applications and data) are delivered and supported by trustworthy suppliers whose cyber security practices are regularly independently verified or otherwise risk-assessed.
- **GOV-12 – Personnel suitability assurance:** Personnel are granted access to systems (infrastructure, operating systems, applications and data) only where their suitability and trustworthiness have been established and are subject to ongoing assurance.
- **GOV-13 – Cyber security and safety:** Security controls for systems (infrastructure, operating systems, applications and data) do not compromise human, physical or environmental safety.
- **GOV-14 – Legacy system management:** Systems (infrastructure, operating systems, applications and data) that are not capable of meeting cyber security requirements are managed using compensating security controls, along with enhanced monitoring and

assurance activities, to maintain an acceptable level of residual risk until they can be decommissioned or replaced.

- **GOV-07 – Continuous cyber security improvement:** Security risk management and associated cyber security activities are continually measured and reviewed using cyber threat intelligence and assurance activities, including exercises informed by real-world cyber threats, to identify, prioritise and incorporate improvements in governance arrangements, shared responsibilities and the effectiveness of security controls.

Identify cyber security principles

The Identify (IDE) cyber security principles are:

- **IDE-01 – Asset identification:** Systems (infrastructure, operating systems, applications, identities, credentials and data) are continually and centrally identified and documented.
- **IDE-05 – Asset interdependencies:** Interdependencies between systems (infrastructure, operating systems, applications and data) are continually and centrally identified and documented, including how the compromise of one system could affect the security or business operations of other dependent systems.
- **IDE-02 – Business criticality rating identification:** Business criticality ratings for systems (infrastructure, operating systems, applications and data) are identified and documented.
- **IDE-03 – Security requirement identification:** Security requirements for systems (infrastructure, operating systems, applications and data) are identified and documented.
- **IDE-06 – Resilience requirement identification:** Resilience requirements for systems (infrastructure, operating systems, applications and data) are identified and documented.
- **IDE-04 – Security risk identification:** Security risks for an organisation and their systems (infrastructure, operating systems, applications and data) are identified, including by using current strategic and sector-specific cyber threat intelligence and threat modelling, and are documented along with any associated risk management decisions.

Protect cyber security principles

The Protect (PRO) cyber security principles are:

- **PRO-01 – Secure system lifecycle:** Systems (infrastructure, operating systems and applications) are planned, designed, developed, tested, deployed, maintained and decommissioned according to their business criticality ratings and security and resilience requirements using Secure by Design and Secure by Default principles and practices.
- **PRO-16 – Cyber supply chain security:** Cyber supply chains supporting systems (infrastructure, operating systems, applications and data) are secure, resilient and support effective and coordinated cyber security incident response.

- **PRO-13 – Identity, credential and access management:** Robust and secure identity, credential and access management is used to establish, maintain and control access to systems (infrastructure, operating systems, applications and data) and to support effective detection of identity and credential misuse.
- **PRO-12 – Least privilege access:** Users are granted the minimum access to systems (infrastructure, operating systems, applications and data) required to undertake their duties or functions.
- **PRO-05 – Secure administration:** Systems (infrastructure, operating systems, applications and data) are administered in a secure, accountable and auditable manner.
- **PRO-04 – Secure configuration management:** Systems (infrastructure, operating systems and applications) are securely configured to approved and maintained baselines, including by reducing attack surfaces and attack paths, with configurations continually monitored and consistently enforced.
- **PRO-06 – Vulnerability management:** Vulnerabilities in systems (infrastructure, operating systems, applications and data) are identified, documented, validated and prioritised for remediation or mitigation in a timely manner, with all remediation and mitigation actions verified for effectiveness.
- **PRO-07 – Trustworthy software:** Systems (operating systems and applications) only permit the execution of software that is supported, verified and authorised.
- **PRO-08 – Cryptographic protection:** Data is encrypted and authenticated at rest and in transit using ASD-approved cryptography to protect its confidentiality and integrity.
- **PRO-17 – Cryptographic agility:** Systems (infrastructure, operating systems and applications) are designed, configured and managed to support timely, prioritised and orderly changes to cryptography, including post-quantum cryptography.
- **PRO-10 – Regular and proven backups:** Systems (infrastructure, operating systems, applications and data) are regularly backed up in a secure and proven manner, including through the validation of restoration capabilities.
- **PRO-18 – Network segmentation and segregation:** Systems (infrastructure, operating systems and applications) are segmented into network zones based on business criticality and trust levels, with only authorised, controlled and monitored inbound and outbound communication paths between network zones permitted.
- **PRO-19 – Operational technology isolation:** Operational technology systems (infrastructure) are logically and physically isolated from information technology systems (infrastructure) and all external infrastructure, with only authorised, controlled and monitored communication paths between systems permitted.
- **PRO-20 – Remote access to operational technology:** Access to operational technology systems (infrastructure, operating systems, applications and data) over untrusted infrastructure is authorised, controlled and monitored.

- **PRO-09 – Content filtering:** Data communicated between different security domains for systems (infrastructure and applications) is controlled and subject to inspection and verification.
- **PRO-14 – Cyber security awareness training:** Personnel are provided with ongoing cyber security awareness training, including operational security considerations, tailored to their duties, access levels and current cyber threats.
- **PRO-15 – Physical access control:** Physical access to facilities and systems (infrastructure and data) is restricted to authorised personnel and monitored for unusual activities.

Detect cyber security principles

The Detect (DET) cyber security principles are:

- **DET-01 – Centralised event logging:** Security-relevant event logs and configuration changes for systems (infrastructure, operating systems, applications and data) are centrally collected, protected against unauthorised modification or deletion, and retained to support effective cyber security event detection and investigation.
- **DET-04 – Baselined high-risk access activities:** Baseline patterns of identity and credential access activities, privileged access activities, and remote access activities are established and maintained for systems (infrastructure, operating systems, applications and data) to enable the detection of anomalous or unexpected behaviour.
- **DET-02 – Cyber security event detection:** Anomalous or unexpected events and behaviours for systems (infrastructure, operating systems, applications and data) are analysed in a timely manner to detect cyber security events.
- **DET-03 – Cyber security incident identification:** Cyber security events are analysed in a timely manner to identify cyber security incidents.
- **DET-05 – Detection capability efficacy:** Cyber security event detection capabilities are regularly evaluated for effectiveness and continuously refined, including by using current strategic and sector-specific cyber threat intelligence, to improve the detection of cyber security events.

Respond cyber security principles

The Respond (RES) cyber security principles are:

- **RES-01 – Cyber security incident planning:** Cyber security incident response, business continuity and disaster recovery plans for systems (infrastructure, operating systems, applications and data) support continued business operations during cyber security incidents, and the resumption of normal business operations following cyber security incidents.

- **RES-05 – Cyber security incident coordination:** Cyber security incident roles and responsibilities are defined, documented and exercised to support the internal and external coordination and management of cyber security incidents, including responsibilities for declaring cyber security incidents and undertaking pre-approved response and recovery activities.
- **RES-03 – Cyber security incident response:** Cyber security incidents are contained, eradicated and recovered from in a timely manner.
- **RES-02 – Cyber security incident reporting:** Cyber security incidents, including associated response and recovery activities, are reported internally and externally to relevant bodies and stakeholders in a timely manner.
- **RES-04 – Cyber security incident insights:** Lessons learnt from cyber security incidents are captured, and areas for improvement are identified, prioritised and actioned in a timely manner.

Recover cyber security principles

The Recover (REC) cyber security principles are:

- **REC-02 – System recovery assurance:** Following cyber security incidents, systems (infrastructure, operating systems, applications and data) are verified through assurance activities to ensure they are secure and capable of supporting the resumption of normal business operations.
- **REC-01 – Business operations resumption:** Residual security risks for systems (infrastructure, operating systems, applications and data), including inherited and shared security risks, are accepted prior to the resumption of normal business operations following cyber security incidents.

Guidelines for cyber security roles

Board of directors and executive committee

Embedding cyber security

To ensure that cyber security is embedded throughout an organisation, it is important that the board of directors or executive committee commits to defining clear roles and responsibilities for cyber security and integrating cyber security throughout all business functions within their organisation. They should also align their organisation's cyber security strategy with their organisation's overarching strategic direction and business strategy and seek regular briefings or reporting on the cyber security posture of their organisation and the threat environment in which it operates.

Control: ISM-1997; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee defines clear roles and responsibilities for cyber security both within the board of directors or executive committee and broadly within their organisation.

Control: ISM-1998; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee ensures that cyber security is integrated throughout all business functions within their organisation.

Control: ISM-1999; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee ensures the cyber security strategy for their organisation is aligned with the overarching strategic direction and business strategy for their organisation.

Control: ISM-2000; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee seeks regular briefings or reporting on the cyber security posture of their organisation, as well as the threat environment in which they operate, from internal and external subject matter experts.

Championing a positive cyber security culture

To provide cyber security leadership within an organisation, it is important that the board of directors or executive committee champions a positive cyber security culture, including through leading by example.

Control: ISM-2001; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee champions a positive cyber security culture within their organisation, including through leading by example.

Building cyber security expertise

To assist with embedding cyber security throughout an organisation, it is important that the board of directors or executive committee maintains a sufficient level of cyber security literacy to fulfil both their fiduciary duties and any legislative or regulatory obligations. In addition, the board of directors or executive committee should maintain awareness of key cyber security recruitment activities, retention rates for cyber security personnel, and cyber security skills and experience gaps for their organisation. Finally, the board of directors or executive committee should support the development of cyber security skills and experience for all personnel within their organisation.

Control: ISM-2002; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee maintains a sufficient level of cyber security literacy to fulfil both their fiduciary duties and any legislative or regulatory obligations.

Control: ISM-2003; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee maintains awareness of key cyber security recruitment activities, retention rates for cyber security personnel, and cyber security skills and experience gaps within their organisation.

Control: ISM-2004; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee supports the development of cyber security skills and experience for all personnel via internal and external cyber security awareness raising and training opportunities.

Identifying critical business assets

For the board of directors or executive committee to fulfil both their fiduciary duties and any legislative or regulatory obligations, it is important that they understand the business criticality of their organisation's systems. This includes a basic understanding of what systems exist, their value, where they reside, who has access, who might seek access, how they are protected and how that protection is verified.

Control: ISM-2005; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee understands the business criticality of their organisation's systems, including at least a basic understanding of what systems exist, their value, where they reside, who has access, who might seek access, how they are protected, and how that protection is verified.

Planning for major cyber security incidents

For the board of directors or executive committee to fulfil both their fiduciary duties and any legislative or regulatory obligations, it is important that they plan for major cyber security incidents, including by participating in exercises, and understand their duties in relation to such cyber security incidents.

Control: ISM-2006; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The board of directors or executive committee plans for major cyber security incidents, including by participating in exercises, and understands their duties in relation to such cyber security incidents.

Further information

Further information on how the board of directors or executive committee can protect themselves from cyber threats can be found in the Australian Signals Directorate's (ASD) *Practical cyber security tips for business leaders* publication.

Further information on questions the board of directors or executive committee should be asking of their organisation can be found in ASD's *Ten things to know about data security* publication.

Further information on how the board of directors or executive committee can plan for major cyber security incidents can be found in ASD's *Planning for critical vulnerabilities: What the board of directors needs to know* publication.

Further information on cyber security considerations for the board of directors or executive committee during mergers, acquisitions and Machinery of Government changes can be found in ASD's *Mergers, acquisitions and Machinery of Government changes* publication.

Further information on cyber security responsibilities and duties of the board of directors or executive committee can be found in the United Kingdom's National Cyber Security Centre's Cyber Security Toolkit for Boards.

Chief information security officer

Context

The role of the chief information security officer (CISO) is to anticipate changes in the threat and technology environment and lead proportionate and evidence-based improvements to their organisation's cyber security capabilities. This requires a combination of technical and soft skills, such as business acumen, leadership, communications and relationship building. In support of this, a CISO should adopt a continuous approach to learning and up-skilling to maintain pace with evolving cyber security frameworks and emerging technologies.

The role of the CISO within an organisation should cover both information technology (IT) and operational technology (OT). However, where appropriate and practical to do so, responsibility for OT cyber security may be delegated by the CISO. Within this section, the breadth of responsibilities for IT and OT is collectively referenced under the banner of cyber security.

Providing cyber security leadership and guidance

To provide cyber security leadership and guidance within an organisation (for IT and OT), it is important that the organisation appoints a CISO.

Control: ISM-0714; Revision: 6; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A CISO is appointed to provide cyber security leadership and guidance for their organisation (covering IT and OT).

Overseeing the cyber security program

The CISO within an organisation is responsible for overseeing their organisation's cyber security program and ensuring compliance with cyber security policy, standards, regulations and legislation. They are likely to work with a chief security officer, a chief information officer and other senior executives within their organisation.

Control: ISM-1478; Revision: 1; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO oversees their organisation's cyber security program and ensures their organisation's compliance with cyber security policy, standards, regulations and legislation.

Control: ISM-1617; Revision: 0; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO regularly reviews and updates their organisation's cyber security program to ensure its relevance in addressing cyber threats and harnessing business and cyber security opportunities.

Control: ISM-1966; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO develops, implements, maintains and regularly verifies a register of systems used by their organisation.

Control: ISM-0724; Revision: 2; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO implements cyber security measurement metrics and key performance indicators for their organisation.

Coordinating cyber security

The CISO is responsible for ensuring the alignment of cyber security and business objectives within their organisation. To achieve this, they should facilitate communication between cyber security and business stakeholders. This includes translating cyber security concepts and language into business concepts and language, as well as ensuring that business teams consult with cyber security teams to determine appropriate security controls when planning new business projects. Additionally, as the CISO is responsible for the development of their organisation's cyber security program, they are best placed to advise projects on the strategic direction of cyber security within their organisation.

Control: ISM-0725; Revision: 4; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO coordinates cyber security and business alignment through a cyber security steering committee or advisory board, comprising key cyber security and business executives, which meets formally and regularly.

Control: ISM-0726; Revision: 2; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO coordinates security risk management activities between cyber security and business teams.

Reporting on cyber security

The CISO is responsible for reporting cyber security matters to their organisation's board of directors or executive committee, as well as their organisation's audit, risk and compliance committee (or equivalent). In doing so, it is important that reporting is done directly by the CISO rather than via other senior executives within their organisation. This ensures reporting remains accurate and free of any conflicts of interest.

Reporting should cover:

- the organisation's security risk profile
- the status of key systems and any outstanding security risks
- any planned cyber security uplift activities
- any recent cyber security incidents
- expected returns on cyber security investments.

Reporting on cyber security matters should be structured by business functions, regions or legal entities and support a consolidated view of an organisation's security risks.

It is important that the CISO can translate security risks into operational risks for their organisation, including financial and legal risks, to enable more holistic conversations about their organisation's risks.

Control: ISM-0718; Revision: 6; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO regularly reports directly to their organisation's board of directors or executive committee on cyber security matters.

Control: ISM-1918; Revision: 0; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO regularly reports directly to their organisation's audit, risk and compliance committee (or equivalent) on cyber security matters.

Overseeing cyber security incident response activities

To ensure the CISO can accurately report to their organisation's board of directors or executive committee on cyber security matters, it is important they are fully aware of all cyber security incidents within their organisation.

The CISO is also responsible for overseeing their organisation's response to cyber security incidents, including how internal teams respond and communicate with each other during cyber security incidents. In the event of a major cyber security incident, the CISO should be prepared to step into a crisis management role. They should understand how to bring clarity to the situation and communicate effectively with internal and external stakeholders.

Control: ISM-0733; Revision: 2; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO is fully aware of all cyber security incidents within their organisation.

Control: ISM-1618; Revision: 0; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO oversees their organisation's response to cyber security incidents.

Contributing to business continuity and disaster recovery planning

The CISO is responsible for contributing to the development, implementation and maintenance of their organisation's business continuity and disaster recovery plans, with the aim to improve business resilience and ensure the continued operation of critical business processes.

Control: ISM-0734; Revision: 4; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO contributes to the development, implementation and maintenance of business continuity and disaster recovery plans for their organisation to ensure that business-critical services are supported appropriately in the event of a disaster.

Communicating a cyber security vision and strategy

To assist in facilitating cyber security cultural change and awareness within their organisation, across their organisation's cyber supply chain and among their organisation's customers, the CISO should act as a cyber security leader and regularly communicate the cyber security vision and strategy for their organisation. In doing so, a cyber security communications strategy can be helpful in achieving this outcome. As part of this, communication styles and content should be tailored to different target audiences.

Control: ISM-0720; Revision: 3; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO oversees the development, implementation and maintenance of a cyber security communications strategy to assist in communicating the cyber security vision and strategy for their organisation.

Working with suppliers

The CISO is responsible for ensuring that consistent vendor management processes are applied across their organisation, from discovery through to management. As supplier relationships come with additional security risks, the CISO should assist personnel with assessing cyber supply chain risks and understanding the security impacts of entering into contracts with suppliers.

Control: ISM-0731; Revision: 2; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO oversees cyber supply chain risk management activities for their organisation.

Receiving and managing a dedicated cyber security budget

Receiving and managing a dedicated cyber security budget will ensure the CISO has sufficient access to funding to support their cyber security program, including cyber security uplift activities and responding to cyber security incidents.

Control: ISM-0732; Revision: 2; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO receives and manages a dedicated cyber security budget for their organisation.

Overseeing cyber security personnel

The CISO is responsible for the cyber security workforce within their organisation, including plans to attract, train and retain cyber security personnel. The CISO should also delegate relevant tasks to cyber security managers and other personnel as required to support cyber security activities within their organisation and provide them with adequate authority and resources to perform their duties.

Control: ISM-0717; Revision: 2; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO oversees the management of cyber security personnel within their organisation.

Control: ISM-2020; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO ensures sufficient cyber security personnel, with the right skills and experience, are acquired to support cyber security activities within their organisation.

Overseeing cyber security awareness training

To ensure personnel are actively contributing to the security culture of their organisation, a cyber security awareness training program should be developed, implemented and maintained. As the CISO is responsible for cyber security within their organisation, they should oversee the development, implementation and maintenance of the cyber security awareness training program.

Control: ISM-0735; Revision: 3; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CISO oversees the development, implementation and maintenance of their organisation's cyber security awareness training program.

Further information

Further information on responding to cyber security incidents can be found in the 'Managing cyber security incidents' section of the *Guidelines for cyber security incidents*.

Further information on the development of a cyber security strategy can be found in the 'Development and maintenance of cyber security documentation' section of the *Guidelines for cyber security documentation*.

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on the procurement of outsourced services can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Further information on cyber security awareness training programs can be found in the 'Cyber security awareness training' section of the *Guidelines for personnel security*.

System owners

System ownership and oversight

System owners are responsible for ensuring the secure operation of their systems. However, system owners may delegate the day-to-day management and operation of their systems to system managers. It is recommended that system owners collaborate with their organisation's internal cyber security teams or engage external cyber security specialists to assist them with their cyber security responsibilities.

Control: ISM-1071; Revision: 1; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Each system has a designated system owner.

Control: ISM-1525; Revision: 1; Updated: Jan-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners register each system with its authorising officer.

Protecting systems and their resources

Broadly, the risk management framework defined by the *Information security manual* has six steps: define the system, select security controls, implement security controls, assess security controls, authorise the system and monitor the system. System owners are responsible for the implementation of this six-step risk management framework for each of their systems.

Control: ISM-1633; Revision: 2; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners, in consultation with each system's authorising officer, determine the system boundary, business criticality, and security and resilience objectives for each system based on an assessment of the impact if it were to be compromised or attacked.

Control: ISM-1203; Revision: 1; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners, in consultation with each system's authorising officer, conduct a threat and risk assessment for each system.

Control: ISM-1634; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners, in consultation with each system's authorising officer, select security controls for each system and tailor them to achieve desired security and resilience objectives.

Control: ISM-0009; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners, in consultation with each system's authorising officer, identify any supplementary security controls required based upon the unique nature of each system, its operating environment and the organisation's risk tolerances.

Control: ISM-1635; Revision: 3; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners implement security controls for each system and its operating environment.

Control: ISM-1636; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S; Essential 8: N/A
System owners, in consultation with each system's authorising officer, ensure security controls for each non-classified, OFFICIAL: Sensitive, PROTECTED and SECRET system and its operating environment undergo a security control assessment by their organisation's own assessors or

Infosec Registered Assessor Program (IRAP) assessors to determine if they have been implemented correctly and are operating as intended.

Control: ISM-1967; Revision: 2; Updated: Sep-26; Applicable: TS; Essential 8: N/A
System owners, in consultation with each system's authorising officer, ensure security controls for each TOP SECRET system and its operating environment, including each sensitive compartmented information system and its operating environment, undergo a security control assessment by ASD assessors (or their delegates) to determine if they have been implemented correctly and are operating as intended.

Control: ISM-0027; Revision: 6; Updated: Mar-26; Applicable: NC, OS, P, S; Essential 8: N/A
System owners obtain an authorisation to operate for each non-classified, OFFICIAL: Sensitive, PROTECTED and SECRET system from its authorising officer.

Control: ISM-1968; Revision: 1; Updated: Mar-26; Applicable: TS; Essential 8: N/A
System owners obtain an authorisation to operate for each TOP SECRET system, including for each sensitive compartmented information system, from Director-General ASD (or their delegate).

Control: ISM-1526; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners continuously monitor the security of each system, and manage associated cyber threats, security risks and security controls.

Control: ISM-2021; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners implement and maintain data minimisation practices for each of their systems.

Annual reporting of system security status

Annual reporting by system owners on the security status of their systems to their authorising officer can assist the authorising officer in maintaining awareness of the security posture of systems within their organisation.

Control: ISM-1587; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners report the security status of each system to its authorising officer at least annually.

Further information

Further information on using the *Information security manual*'s six-step risk management framework can be found in the 'Applying a risk-based approach to cyber security' section of *Using the cyber security framework*.

Further information on the purpose of IRAP is available from ASD.

Further information on conducting security assessment activities as part of continuously monitoring the security of systems can be found in the 'Security assessments' section of the *Guidelines for security assurance*.

Guidelines for cyber security incidents

Managing cyber security incidents

Cyber security incident management policy

Establishing a cyber security incident management policy can increase the likelihood of successfully planning for, detecting and responding to malicious activity on networks and hosts, such as cyber security events and cyber security incidents. In doing so, a cyber security incident management policy will likely cover the following:

- responsibilities for planning for, detecting and responding to cyber security incidents
- resources assigned to cyber security incident planning, detection and response activities
- guidelines for triaging and responding to cyber security events and cyber security incidents.

Furthermore, as part of maintaining the cyber security incident management policy, it is important that it, along with its associated cyber security incident response plan, is exercised at least annually to ensure it remains fit for purpose.

Control: ISM-0576; Revision: 10; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A cyber security incident management policy, and associated cyber security incident response plan, is developed, implemented and maintained.

Control: ISM-1784; Revision: 1; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The cyber security incident management policy, including the associated cyber security incident response plan, is exercised at least annually.

Cyber security incident register

Developing, implementing and maintaining a cyber security incident register can assist in ensuring that appropriate remediation activities are undertaken in response to cyber security incidents. In addition, the types and frequency of cyber security incidents, along with the costs of any remediation activities, can be used as input to future risk assessment activities.

Control: ISM-0125; Revision: 6; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A cyber security incident register is developed, implemented and maintained.

Control: ISM-1803; Revision: 0; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A cyber security incident register contains the following for each cyber security incident:

- *the date the cyber security incident occurred*
- *the date the cyber security incident was discovered*
- *a description of the cyber security incident*

- *any actions taken in response to the cyber security incident*
- *to whom the cyber security incident was reported.*

Insider threat mitigation program

As an insider's authorised access to systems and their resources may make them harder to detect when intentionally performing malicious activities, establishing and maintaining an insider threat mitigation program can assist an organisation to detect and respond to indicators of potential insider threats before they occur, or limit damage if they do occur. In doing so, an organisation will likely obtain the most benefit by logging and analysing the following activities:

- excessive copying or modification of data
- unauthorised or excessive use of removable media
- connecting devices capable of data storage to systems
- unusual system usage outside of normal business hours
- excessive data access or printing compared to their peers
- data transfers to unauthorised cloud services or webmail
- use of unauthorised virtual private networks, file transfer applications or anonymity networks.

Control: ISM-1625; Revision: 2; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An insider threat mitigation program is developed, implemented and maintained.

Control: ISM-1626; Revision: 1; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Legal advice is sought regarding the development and implementation of an insider threat mitigation program.

Reporting cyber security incidents

Reporting cyber security incidents to the chief information security officer, or one of their delegates, as soon as possible after they occur or are discovered provides senior management with the opportunity to assess the impact to their organisation and to oversee any cyber security incident response activities. In addition, an organisation should be cognisant of any legislative obligations regarding the reporting of cyber security incidents to authorities.

Control: ISM-0123; Revision: 4; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Cyber security incidents are reported to the chief information security officer, or one of their delegates, as soon as possible after they occur or are discovered.

Reporting cyber security incidents to ASD

The Australian Signals Directorate (ASD) uses the cyber security incident reports it receives as the basis for assisting organisations. In addition, cyber security incident reports are used to identify trends and maintain an accurate threat environment picture. Finally, ASD utilises this understanding to assist in the development of new and updated cyber security advice, capabilities and techniques to better prevent and respond to evolving cyber threats. Under ASD's limited use obligation, any information voluntarily provided to ASD about cyber security incidents, or potential cyber security incidents, cannot be used for regulatory purposes.

An organisation is recommended to coordinate their reporting of cyber security incidents to ASD. In doing so, the organisation should be cognisant of any legislative obligations regarding the reporting of cyber security incidents to ASD.

The types of cyber security incidents that should be reported to ASD include:

- suspicious privileged user account lockouts
- suspicious remote access authentication events
- service accounts suspiciously communicating with internet-based infrastructure
- compromise of sensitive or classified data
- unauthorised access or attempts to access a system
- emails with suspicious attachments or links
- denial-of-service attacks
- ransomware attacks
- suspected tampering of electronic devices.

Control: ISM-0140; Revision: 8; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Cyber security incidents are reported to ASD as soon as possible after they occur or are discovered.

Reporting cyber security incidents to customers and the public

Reporting cyber security incidents to customers and the public in a timely manner after they occur or are discovered is one way that an organisation can demonstrate their commitment to transparency. In addition, an organisation should be cognisant of any legislative obligations regarding the reporting of cyber security incidents to customers and the public.

Control: ISM-1880; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cyber security incidents that involve customer data are reported to customers and the public in a timely manner after they occur or are discovered.

Control: ISM-1881; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cyber security incidents that do not involve customer data are reported to customers and the public in a timely manner after they occur or are discovered.

Further information

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on cyber security incident response plans can be found in the 'System-specific cyber security documentation' section of the *Guidelines for cyber security documentation*.

Further information on preparing for and responding to cyber security incidents can be found in ASD's *Cyber security incident response planning: Executive guidance* and *Cyber security incident response planning: Practitioner guidance* publications.

Further information on understanding, identifying and preventing the insider threat can be found in the Attorney-General's Department's *Countering the Insider Threat: A guide for Australian Government* publication.

Further information on understanding, identifying and preventing the insider threat can also be found in the Australian Security Intelligence Organisation's *Countering the insider threat* brochure and *Countering the insider threat: A security manager's guide* publication.

Further information on understanding, identifying and preventing the insider threat can also be found on the United Kingdom's National Protective Security Authority's Insider Risk Guidance website.

Further information on developing, implementing and maintaining an insider threat mitigation program can be found in the United States' Cybersecurity & Infrastructure Security Agency's *Insider Threat Mitigation Guide*.

Further information on developing, implementing and maintaining an insider threat mitigation program can also be found in Carnegie Mellon University's Software Engineering Institute's *Common Sense Guide to Mitigating Insider Threats, Seventh Edition* publication.

Further information on reporting of cyber security incidents by service providers can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Further information on reporting cybercrime incidents and reporting cyber security incidents, including ASD's limited use obligation, is available from ASD.

Responding to cyber security incidents

Enacting cyber security incident response plans

Following a cyber security incident being identified, an organisation's cyber security incident response plan should be enacted.

Control: ISM-1819; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Following the identification of a cyber security incident, the cyber security incident response plan is enacted.

Handling and containing data spills

When a data spill occurs, an organisation should inform data owners and restrict access to the data. In doing so, affected systems can be powered off, have their network connectivity removed or have additional access controls applied to the data. However, powering off systems could destroy data that would be useful for forensic investigations. Furthermore, human users should be made aware of appropriate actions to take in the event of a data spill, such as not deleting, copying, printing or emailing the data.

Control: ISM-0133; Revision: 2; Updated: Jun-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When a data spill occurs, data owners are advised and access to the data is restricted.

Handling and containing malicious code infections

Taking immediate remediation steps after the discovery of malicious code can minimise the time and cost spent eradicating and recovering from the infection. As a priority, all infected systems and media should be isolated to prevent the infection from spreading. Once isolated, infected systems and media can be scanned by antivirus applications to potentially remove the infection or recover data. It is important to note though, a complete system restoration from a known good backup or rebuild may be the only reliable way to ensure that malicious code can be truly eradicated.

Control: ISM-0917; Revision: 8; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When malicious code is detected, the following steps are taken to handle the infection:

- *the infected systems are isolated*
- *all previously connected media used in the period leading up to the infection are scanned for signs of infection and isolated if necessary*
- *antivirus applications are used to remove the infection from infected systems and media*
- *if the infection cannot be reliably removed, systems are restored from a known good backup or rebuilt.*

Control: ISM-1969; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Malicious code, when stored or communicated, is treated beforehand to prevent accidental execution.

Control: ISM-1970; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Malicious code processing for cyber security incident response or research purposes is conducted in a dedicated analysis environment segregated from other systems.

Handling and containing intrusions

When an intrusion is detected on a system, an organisation may, in limited circumstances, choose to allow the intrusion to continue for a short period to better understand the extent of the compromise or to assist with planning intrusion remediation activities. However, an organisation allowing an intrusion to continue in order to collect data or evidence should first establish with their legal advisors whether such activities would breach the *Telecommunications (Interception and Access) Act 1979*.

To increase the likelihood of eradicating malicious actors from a system, an organisation can take preventative measures to ensure malicious actors have limited awareness of planned intrusion remediation activities. Specifically, using trusted systems separate from a compromised system to plan and coordinate intrusion remediation activities prevents alerting malicious actors if they have already compromised communication or collaboration services. In addition, coordinating and sequencing intrusion remediation activities can reduce opportunities for re-compromise of the system while balancing operational risk and business continuity requirements.

Finally, following intrusion remediation activities, an organisation should determine whether malicious actors have been eradicated from the system and have not re-established access. Enhanced monitoring should be conducted until there is sufficient evidence-based confidence that this has been achieved.

In determining whether sufficient evidence-based confidence has been achieved, an organisation should consider the scope and quality of its digital forensic investigations, including whether:

- the initial access vector and full extent of the compromise have been identified
- persistence mechanisms, malicious infrastructure and unauthorised access paths have been identified and remediated
- the affected system has been rebuilt, restored from known-good backups or otherwise verified as trustworthy
- compromised accounts, credentials, certificates, keys and trust relationships have been remediated
- threat hunting has identified no continuing or renewed indicators of malicious activity.

Control: ISM-0137; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Legal advice is sought before allowing intrusion activity to continue on a system for the purpose of collecting further data or evidence.

Control: ISM-1609; Revision: 2; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System owners are consulted before allowing intrusion activity to continue on a system for the purpose of collecting further data or evidence.

Control: ISM-1731; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Planning and coordination of intrusion remediation activities are conducted using trusted systems separate from a compromised system.

Control: ISM-1732; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Intrusion remediation activities are coordinated and sequenced to minimise opportunities for re-compromise of a system while balancing operational risk and business continuity requirements.

Control: ISM-1213; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Following intrusion remediation activities, enhanced monitoring is conducted until there is sufficient evidence-based confidence that malicious actors have been eradicated from a system and have not re-established access.

Maintaining the integrity of evidence

When gathering evidence following a cyber security incident, it is important that it is gathered in an appropriate manner and that its integrity is maintained. In addition, if ASD is requested to assist with investigations, no actions that could affect the integrity of evidence should be carried out before ASD becomes involved.

Control: ISM-0138; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The integrity of evidence gathered during an investigation is maintained by investigators:

- *recording all their actions*
- *maintaining a proper chain of custody*
- *following all instructions provided by relevant law enforcement agencies.*

Further information

Further information on cyber security incident response plans can be found in the ‘System-specific cyber security documentation’ section of the *Guidelines for cyber security documentation*.

Further information on handling malicious code infections can be found in National Institute of Standards and Technology Special Publication 800-61 Rev. 3, *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*.

Guidelines for procurement and outsourcing

Cyber supply chain risk management

Cyber supply chain risk management activities

Cyber supply chain risk management activities should be conducted during the procurement of operating systems, applications, information technology (IT) equipment, operational technology (OT) equipment and services. This includes considering security risks as systems and their components are being designed, built, stored, delivered, installed, operated, maintained and decommissioned. Furthermore, this also includes identifying and managing jurisdictional, governance, privacy and security risks associated with the use of suppliers, such as software developers, IT equipment manufacturers, OT equipment manufacturers, service providers and other organisations involved in distribution channels. For example, managed services or outsourced cloud services may be located offshore and subject to lawful and covert data collection without their customers' knowledge. Additionally, use of offshore services introduces jurisdictional risks as foreign countries' laws could change with little warning. Finally, foreign-owned suppliers operating in Australia may be subject to a foreign government's lawful access to data belonging to their customers.

When procuring operating systems, applications, IT equipment, OT equipment and services, it is important for an organisation to choose vendors that have demonstrated a commitment to the security of their products and services. This will assist in not only reducing the potential number of vulnerabilities, but also increasing the likelihood that timely patches, updates or vendor mitigations will be released to remediate any vulnerabilities that are found. Furthermore, it is important for an organisation to choose suppliers that have demonstrated a commitment to transparency and that have a strong track record of maintaining the security of their own systems. In support of this, suppliers should openly provide evidence of their implementation of such commitments, especially when requested by their customers. Finally, a shared responsibility model that clearly defines the responsibilities of suppliers and their customers can be highly beneficial and should be created and shared between both parties.

Control: ISM-1631; Revision: 4; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Suppliers of operating systems, applications, IT equipment, OT equipment and services associated with systems are identified.

Control: ISM-1452; Revision: 7; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A supply chain risk assessment is performed for suppliers of operating systems, applications, IT equipment, OT equipment and services to assess the impact to a system's security risk profile.

Control: ISM-1567; Revision: 2; Updated: Sep-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Suppliers identified as high risk by a cyber supply chain risk assessment are not used.

Control: ISM-1568; Revision: 7; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Operating systems, applications, IT equipment, OT equipment and services are procured from suppliers that have demonstrated a commitment to the security of their products and services.

Control: ISM-1882; Revision: 3; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Operating systems, applications, IT equipment, OT equipment and services are procured from suppliers that have demonstrated a commitment to transparency for their products and services.

Control: ISM-1632; Revision: 6; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Operating systems, applications, IT equipment, OT equipment and services are procured from suppliers that have a strong track record of maintaining the security of their own systems.

Control: ISM-1569; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A shared responsibility model is created, documented and shared between suppliers and their customers to articulate the security responsibilities of each party.

Supplier relationship management

Developing, implementing and maintaining a supplier relationship management policy can assist an organisation in identifying, prioritising and maintaining strong relationships with suppliers that have demonstrated a commitment to the security of their products and services. In doing so, these suppliers should be documented on an approved supplier list.

Control: ISM-1785; Revision: 1; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A supplier relationship management policy is developed, implemented and maintained.

Control: ISM-1786; Revision: 1; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An approved supplier list is developed, implemented and maintained.

Sourcing operating systems, applications, IT equipment, OT equipment and services

In sourcing operating systems, applications, IT equipment, OT equipment and services, an organisation should use trustworthy suppliers as part of cyber supply chain risk management assessments and subsequently documented on their approved supplier list.

Furthermore, to support system availability, an organisation should aim to identify multiple potential suppliers for critical operating systems, applications, IT equipment, OT equipment and services. This coupled with keeping sufficient spares of critical IT equipment and OT equipment in reserve, can assist in mitigating the impact of cyber supply chain disruptions.

Control: ISM-1787; Revision: 3; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Operating systems, applications, IT equipment, OT equipment and services are sourced from approved suppliers.

Control: ISM-1788; Revision: 3; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Multiple potential suppliers are identified for sourcing critical operating systems, applications, IT equipment, OT equipment and services.

Control: ISM-1789; Revision: 2; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Sufficient spares of critical IT equipment and OT equipment are sourced and kept in reserve.

Delivery of operating systems, applications, IT equipment, OT equipment and services

As part of the delivery of operating systems, applications, IT equipment, OT equipment and services, measures should be implemented to protect their integrity, with these measures differing depending on whether delivery relates to digital or physical distribution channels. For example, operating systems and applications may benefit from delivery via encrypted communication channels while IT equipment and OT equipment may benefit from tracking and tamper-evident packaging. In doing so, such measures are only beneficial if they are assessed as part of acceptance of products and services. In all cases, suppliers should be consulted on how best to confirm the integrity of their products and services.

While ensuring the integrity of operating systems, applications, IT equipment, OT equipment and services is important, so is ensuring their authenticity. For example, a counterfeit product or service securely delivered is still a counterfeit product or service that may not operate as intended or pose a risk to the security of a system. To assist in identifying counterfeit products and services, suppliers should be consulted on how best to confirm the authenticity of their products and services.

Control: ISM-1790; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Operating systems, applications, IT equipment, OT equipment and services are delivered in a manner that maintains their integrity.

Control: ISM-1791; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The integrity of operating systems, applications, IT equipment, OT equipment and services are assessed as part of acceptance of products and services.

Control: ISM-1792; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The authenticity of operating systems, applications, IT equipment, OT equipment and services are assessed as part of acceptance of products and services.

Further information

Further information on cyber supply chain risk management can be found in the following Australian Signals Directorate (ASD) publications:

- *Choosing secure and verifiable technologies: Executive guidance*
- *Choosing secure and verifiable technologies*
- *Cyber supply chain risk management*
- *Identifying cyber supply chain risks*.

Further information on cyber supply chain risk management can also be found in the following publications:

- Canada's Canadian Centre for Cyber Security's *Cyber supply chain: An approach to assessing risk*
- New Zealand's National Cyber Security Centre's *Supply Chain Cyber Security: In Safe Hands*
- United Kingdom's National Cyber Security Centre's *Supply chain security guidance*
- United States' Cybersecurity & Infrastructure Security Agency's *Secure by Demand: Priority Considerations for Operational Technology Owners and Operators when Selecting Digital Products*.

Further information on cyber supply chain risk management can also be found on the United States' Cybersecurity & Infrastructure Security Agency's ICT Supply Chain Resource Library website.

Further information on cyber supply chain integrity can be found in National Institute of Standards and Technology Special Publication 800-161 Rev. 1, *Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations*.

Further information on outsourced products and services can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Further information on the procurement and use of evaluated operating systems, applications and IT equipment can be found in the 'Evaluated product procurement' and 'Evaluated product usage' sections of the *Guidelines for evaluated products*.

Further information on suppliers that have made a pledge to implement Secure by Design and Secure by Default principles and practices can be found on the United States' Cybersecurity & Infrastructure Security Agency's Secure by Design Pledge website.

Managed services and cloud services

Context

An outsourced cloud service may also constitute a managed service. In such cases, security controls for outsourced cloud services should be applied in place of equivalent security controls for managed services.

An artificial intelligence (AI) application or service may constitute a managed service, an outsourced cloud service, both or neither, depending on how it is deployed and who manages it, regardless of whether it uses a closed source, open source or open weight AI model.

Managed services

Managed service providers manage the services of an organisation on their behalf. This may include application services, authentication services, backup services, desktop services, enterprise

mobility services, gateway services, hosting services, network services, procurement services, security services, support services, and many other business-related services. In doing so, managed service providers may manage services from their customers' premises or their own premises. In considering security risks associated with managed services, an organisation should consider all managed service providers that have access to their facilities, systems or data.

Control: ISM-1736; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A managed service register is developed, implemented, maintained and regularly verified.

Control: ISM-1737; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A managed service register contains the following for each managed service:

- *managed service provider's name*
- *managed service's name*
- *purpose for using the managed service*
- *sensitivity or classification of data involved*
- *due date for the next security control assessment of the managed service*
- *contractual arrangements for the managed service*
- *organisational point of contact for the managed service*
- *24/7 contact details for the managed service provider.*

Assessment of managed service providers

Managed service providers will need to undergo regular security control assessments against the requirements of the *Information security manual* (ISM) to determine their security posture and security risks associated with their use. Following an initial security control assessment, subsequent security control assessments should focus on any new services that are being offered as well as any ISM or security-related system changes that have occurred since the previous security control assessment.

Control: ISM-1793; Revision: 1; Updated: Dec-24; Applicable: NC, OS, P, S; Essential 8: N/A
Managed service providers and their non-classified, OFFICIAL: Sensitive, PROTECTED and SECRET managed services undergo an Infosec Registered Assessor Program (IRAP) assessment, using the latest release of the ISM available prior to the beginning of the IRAP assessment (or a subsequent release), at least every 24 months.

Control: ISM-1971; Revision: 1; Updated: Sep-26; Applicable: TS; Essential 8: N/A
Managed service providers and their TOP SECRET managed services, including sensitive compartmented information managed services, undergo a security control assessment by ASD assessors (or their delegates), using the latest release of the ISM available prior to the beginning of the security control assessment (or a subsequent release), at least every 24 months.

Outsourced cloud services

Outsourcing can be a cost-effective option for providing cloud services, as well as potentially delivering a superior service. However, outsourcing can affect an organisation's security risk profile. Ultimately, an organisation will still need to decide whether a particular outsourced cloud service represents an acceptable security risk and, if appropriate to do so, authorise it for their own use.

Control: ISM-1637; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An outsourced cloud service register is developed, implemented, maintained and regularly verified.

Control: ISM-1638; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An outsourced cloud service register contains the following for each outsourced cloud service:

- *cloud service provider's name*
- *cloud service's name*
- *purpose for using the cloud service*
- *sensitivity or classification of data involved*
- *due date for the next security control assessment of the cloud service*
- *contractual arrangements for the cloud service*
- *organisational point of contact for the cloud service*
- *24/7 contact details for the cloud service provider.*

Control: ISM-1529; Revision: 2; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
Only community or private clouds are used for outsourced SECRET and TOP SECRET cloud services.

Assessment of outsourced cloud service providers

Outsourced cloud service providers and their cloud services will need to undergo regular security control assessments against the requirements of the ISM to determine their security posture and security risks associated with their use. Following an initial security control assessment, subsequent security control assessments should focus on any new cloud services that are being offered as well as any ISM or security-related system changes that have occurred since the previous security control assessment.

Control: ISM-1570; Revision: 2; Updated: Dec-24; Applicable: NC, OS, P, S; Essential 8: N/A
Outsourced cloud service providers and their non-classified, OFFICIAL: Sensitive, PROTECTED and SECRET cloud services undergo an IRAP assessment, using the latest release of the ISM available prior to the beginning of the IRAP assessment (or a subsequent release), at least every 24 months.

Control: ISM-1972; Revision: 1; Updated: Sep-26; Applicable: TS; Essential 8: N/A
Outsourced cloud service providers and their TOP SECRET cloud services, including sensitive compartmented information cloud services, undergo a security control assessment by ASD

assessors (or their delegates), using the latest release of the ISM available prior to the beginning of the security control assessment (or a subsequent release), at least every 24 months.

Contractual security requirements with service providers

Obligations for protecting data are no different when using a managed service or cloud service than when using an in-house service. As such, contractual arrangements with service providers should address how data entrusted to them, including to any of their subcontractors, will be protected during contractual arrangements and following the completion or termination of such contractual arrangements. However, in some cases an organisation may require managed services or cloud services to be used before all security requirements have been implemented by a service provider. In such cases, contractual arrangements with service providers should include appropriate timeframes for the implementation of security requirements and break clauses if these are not achieved.

In addition, although data ownership resides with service providers' customers, this can become less clear in some circumstances, such as when a service provider is legally required to provide access to, or data from, their assets. To mitigate the likelihood of data being unavailable or compromised, an organisation can document the types of data and their ownership in contractual arrangements with service providers.

Furthermore, an organisation may make the decision to move from their current service provider for strategic, operational or governance reasons. This may involve changing to another service provider, moving to a different service with the same service provider or moving back to an on-premises solution. In many cases, transferring data and functionality between old and new services or systems will be desired. Service providers can assist their customers by ensuring data is as portable as possible and that as much data can be exported as possible. As such, data should be stored in a documented format, preferably an open standard, as undocumented or proprietary formats may make it more difficult for an organisation to perform backup, service migration or service decommissioning activities.

Finally, to ensure that an organisation is given sufficient time to download their data or move to another service provider should a service provider cease offering a particular service, a one-month notification period should be documented in contractual arrangements with service providers.

Control: ISM-1395; Revision: 7; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Service providers, including any subcontractors, provide an appropriate level of protection for any data entrusted to them or their services.

Control: ISM-0072; Revision: 10; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security requirements associated with the confidentiality, integrity and availability of data are documented in contractual arrangements with service providers and regularly reviewed to ensure they remain fit for purpose.

Control: ISM-1571; Revision: 3; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The right to verify compliance with security requirements is documented in contractual arrangements with service providers.

Control: ISM-1738; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The right to verify compliance with security requirements documented in contractual arrangements with service providers is regularly exercised.

Control: ISM-1804; Revision: 0; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Break clauses associated with failure to meet security requirements are documented in contractual arrangements with service providers.

Control: ISM-0141; Revision: 7; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The requirement for service providers to report cyber security incidents to a designated point of contact as soon as possible after they occur or are discovered is documented in contractual arrangements with service providers.

Control: ISM-1794; Revision: 1; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A minimum notification period of one month by service providers for significant changes to their own service provider arrangements is documented in contractual arrangements with service providers.

Control: ISM-1451; Revision: 4; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Types of data and its ownership is documented in contractual arrangements with service providers.

Control: ISM-1572; Revision: 3; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The regions or availability zones where data will be processed, stored and communicated, as well as a minimum notification period for any configuration changes, is documented in contractual arrangements with service providers.

Control: ISM-1573; Revision: 3; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Access to all logs relating to an organisation's data and services is documented in contractual arrangements with service providers.

Control: ISM-1574; Revision: 4; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The storage of data in a portable manner that enables backups, service migration and service decommissioning without any loss of data is documented in contractual arrangements with service providers.

Control: ISM-1575; Revision: 1; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A minimum notification period of one month for the cessation of any services by a service provider is documented in contractual arrangements with service providers.

Access to systems by service providers

To perform their contracted duties, service providers may need to access their customers' systems. However, without appropriate measures in place, such access could leave systems vulnerable, especially when access originates outside Australia or involves privileged administrative activities. As such, service provider access should be subject to all measures otherwise applicable to unprivileged users, privileged users, remote access and administrative activities. Depending on the nature of the access, this may include the use of individually attributable accounts, least privilege access, multi-factor authentication, separate privileged

operating environments and secure administrative infrastructure. Service provider-specific restrictions, such as remote management tools, source network addresses and time windows approved by the customer, should be applied as additional safeguards rather than as substitutes for these measures.

An organisation should also ensure that its systems are not accessed or administered by service providers unless such requirements, and the measures used to control them, are documented in contractual arrangements. Service provider access should also be independently logged and analysed by the organisation in a timely manner to detect any anomalous, unexpected or unauthorised activity. Records of approved remote management tools, source network addresses and time windows should be maintained and made available to personnel responsible for monitoring service provider access.

If unauthorised access occurs, such as customer support representatives or platform engineers accessing encryption keys without authorisation, the service provider should immediately report the cyber security incident to its customer and make available all logs pertaining to the unauthorised access.

Control: ISM-1073; Revision: 7; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An organisation's systems are not accessed or administered by a service provider unless a contractual arrangement exists between the organisation and the service provider to do so.

Control: ISM-2124; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Access by a service provider to an organisation's systems is restricted to remote management tools, source network addresses and time windows explicitly approved by the organisation.

Control: ISM-1576; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If an organisation's systems are accessed or administered by a service provider in an unauthorised manner, it is treated as a cyber security incident and the organisation is immediately notified.

Control: ISM-2125; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All access to an organisation's systems by a service provider is independently logged by the organisation in a manner that the service provider cannot modify or delete, and analysed in a timely manner to detect any anomalous, unexpected or unauthorised activity.

Further information

Further information on the use of outsourced cloud services can be found in the 'Service continuity for online services' section of the *Guidelines for networking*.

Further information on the use of outsourced gateway services can be found in the 'Gateways' section of the *Guidelines for gateways*.

Further information on managed service providers can be found in ASD's *How to manage your security when engaging a managed service provider* and *Questions to ask managed service providers* publications.

Further information on the definition of cloud computing can be found in National Institute of Standards and Technology Special Publication 800-145, *The NIST Definition of Cloud Computing*.

Further information on securing cloud services can be found in the following ASD publications:

- *Cloud computing security for cloud service providers*
- *Cloud computing security for executives*
- *Cloud computing security for tenants*.

Further information on conducting security control assessments of cloud service providers can be found in ASD's *Cloud assessment and authorisation* and *Cloud assessment and authorisation FAQ* publications.

Further information on shared responsibility models for cloud services can be found in ASD's *Cloud shared responsibility model: Executive guidance* publication.

Further information on the purpose of IRAP is available from ASD.

Further information on unprivileged user accounts, privileged user accounts and least privilege access can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on multi-factor authentication can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on privileged operating environments and secure administrative infrastructure can be found in the 'System administration' section of the *Guidelines for system management*.

Further information on event logging and monitoring can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on reporting cyber security incidents can be found in the 'Reporting cyber security incidents' section of the *Guidelines for cyber security incidents*.

Guidelines for cyber security documentation

Development and maintenance of cyber security documentation

Cyber security strategy

A cyber security strategy articulates an organisation's vision, guiding principles, objectives and priorities for cyber security, typically over a five-year period. In addition, a cyber security strategy may also cover an organisation's threat environment, cyber security initiatives or investments the organisation plans to make as part of its cyber security program. Without a cyber security strategy, an organisation risks failing to adequately plan for and manage security and business risks within their organisation.

Control: ISM-0039; Revision: 6; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A cyber security strategy is developed, implemented and maintained.

Approval of cyber security documentation

If cyber security documentation is not reviewed and approved by an appropriate authority, system owners risk failing in their duty to ensure that appropriate security controls have been identified and implemented for systems and their operating environments. In doing so, it is important that a system's security architecture, as outlined within the system security plan and supported by the cyber security incident response plan, change and configuration management plan, and continuous monitoring plan, is approved by the system's authorising officer prior to the development of the system.

Control: ISM-0047; Revision: 6; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Organisational-level cyber security documentation is approved by the chief information security officer while system-specific cyber security documentation is approved by the system's authorising officer.

Control: ISM-1739; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A system's security architecture is approved prior to the development of the system.

Maintenance of cyber security documentation

Threat environments are dynamic. If cyber security documentation is not kept up to date to reflect the current threat environment, policies, processes and procedures may cease to be effective. In such situations, resources could be devoted to cyber security initiatives or investments that are less effective or no longer relevant.

Control: ISM-0888; Revision: 7; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cyber security documentation is reviewed at least annually and includes a 'current as at [date]' or equivalent statement.

Communication of cyber security documentation

It is important that once cyber security documentation has been approved, it is published and communicated to all stakeholders. If cyber security documentation is not communicated to stakeholders, they will be unaware of what policies and procedures have been implemented for systems.

Control: ISM-1602; Revision: 2; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cyber security documentation, including notification of subsequent changes, is communicated to all stakeholders.

Further information

Further information on system-specific cyber security documentation, such as a system security plan, cyber security incident response plan, change and configuration management plan, continuous monitoring plan, security assessment report and plan of action and milestones, can be found in the 'System-specific cyber security documentation' section of these guidelines.

Further information on system registers can be found in the 'Chief information security officer' section of the *Guidelines for cyber security roles*.

Further information on business continuity and disaster recovery plans can be found in the 'Chief information security officer' section of the *Guidelines for cyber security roles*.

Further information on cyber security communication strategies can be found in the 'Chief information security officer' section of the *Guidelines for cyber security roles*.

Further information on cyber security incident management policy can be found in the 'Managing cyber security incidents' section of the *Guidelines for cyber security incidents*.

Further information on cyber security incident registers can be found in the 'Managing cyber security incidents' section of the *Guidelines for cyber security incidents*.

Further information on supplier relationship management policy can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on approved supplier lists can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on managed service registers can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Further information on outsourced cloud service registers can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Further information on authorised radio frequency and infrared device registers can be found in the 'Facilities and systems' section of the *Guidelines for physical security*.

Further information on authorised medical device registers can be found in the 'Facilities and systems' section of the *Guidelines for physical security*.

Further information on cyber security awareness training registers can be found in the 'Cyber security awareness training' section of the *Guidelines for personnel security*.

Further information on general-purpose artificial intelligence usage policy can be found in the 'Cyber security awareness training' section of the *Guidelines for personnel security*.

Further information on web usage policy can be found in the 'Cyber security awareness training' section of the *Guidelines for personnel security*.

Further information on cable registers can be found in the 'Cabling infrastructure' section of the *Guidelines for communications infrastructure*.

Further information on floor plan diagrams can be found in the 'Cabling infrastructure' section of the *Guidelines for communications infrastructure*.

Further information on cable labelling processes and procedures can be found in the 'Cabling infrastructure' section of the *Guidelines for communications infrastructure*.

Further information on telephone system usage policy can be found in the 'Telephone systems' section of the *Guidelines for communications systems*.

Further information on denial of service response plans for video conferencing and Internet Protocol telephony services can be found in the 'Video conferencing and Internet Protocol telephony' section of the *Guidelines for communications systems*.

Further information on multifunction device usage policy can be found in the 'Multifunction devices' section of the *Guidelines for communications systems*.

Further information on mobile device management policy can be found in the 'Mobile device management' section of the *Guidelines for enterprise mobility*.

Further information on mobile device usage policy can be found in the 'Mobile device usage' section of the *Guidelines for enterprise mobility*.

Further information on mobile device emergency sanitisation processes and procedures can be found in the 'Mobile device usage' section of the *Guidelines for enterprise mobility*.

Further information on information technology (IT) equipment management policy can be found in the 'IT equipment usage' section of the *Guidelines for information technology equipment*.

Further information on networked and non-networked IT equipment registers can be found in the 'IT equipment usage' section of the *Guidelines for information technology equipment*.

Further information on IT equipment sanitisation processes and procedures can be found in the 'IT equipment sanitisation and destruction' section of the *Guidelines for information technology equipment*.

Further information on IT equipment destruction processes and procedures can be found in the 'IT equipment sanitisation and destruction' section of the *Guidelines for information technology equipment*.

Further information on IT equipment disposal processes and procedures can be found in the 'IT equipment disposal' section of the *Guidelines for information technology equipment*.

Further information on media management policy can be found in the 'Media usage' section of the *Guidelines for media*.

Further information on removable media usage policy can be found in the 'Media usage' section of the *Guidelines for media*.

Further information on removable media registers can be found in the 'Media usage' section of the *Guidelines for media*.

Further information on media sanitisation processes and procedures can be found in the 'Media sanitisation' section of the *Guidelines for media*.

Further information on media destruction processes and procedures can be found in the 'Media destruction' section of the *Guidelines for media*.

Further information on media disposal processes and procedures can be found in the 'Media disposal' section of the *Guidelines for media*.

Further information on system usage policy can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on artificial intelligence agent registers can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on system administration processes and procedures can be found in the 'System administration' section of the *Guidelines for system management*.

Further information on patch management processes and procedures can be found in the 'System maintenance' section of the *Guidelines for system management*.

Further information on software registers can be found in the 'System maintenance' section of the *Guidelines for system management*.

Further information on digital preservation policy can be found in the 'Data backup and restoration' section of the *Guidelines for system management*.

Further information on data backup processes and procedures can be found in the 'Data backup and restoration' section of the *Guidelines for system management*.

Further information on data restoration processes and procedures can be found in the 'Data backup and restoration' section of the *Guidelines for system management*.

Further information on security monitoring policy can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on secure software development policy can be found in the 'Software development fundamentals' section of the *Guidelines for software development*.

Further information on software developer cyber security knowledge and skills registers can be found in the 'Software development fundamentals' section of the *Guidelines for software development*.

Further information on vulnerability disclosure policy can be found in the 'Software development fundamentals' section of the *Guidelines for software development*.

Further information on vulnerability disclosure processes and procedures can be found in the 'Software development fundamentals' section of the *Guidelines for software development*.

Further information on database registers can be found in the 'Databases' section of the *Guidelines for database systems*.

Further information on email usage policy can be found in the 'Email usage' section of the *Guidelines for email*.

Further information on network diagrams can be found in the 'Network design and configuration' section of the *Guidelines for networking*.

Further information on cryptographic key management processes and procedures can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Further information on data transfer processes and procedures can be found in the 'Data transfers' section of the *Guidelines for data transfers*.

System-specific cyber security documentation

Context

System-specific cyber security documentation, such as a system security plan, cyber security incident response plan, change and configuration management plan, continuous monitoring plan, security assessment report, and plan of action and milestones, supports the accurate and consistent application of policies, processes and procedures for systems. As such, it is important that they are developed by personnel with a good understanding of business requirements, technologies being used and cyber security matters.

System-specific cyber security documentation may be presented in multiple formats, including in wikis or other forms of document repositories. Furthermore, depending on the documentation framework used, details common to multiple systems could be consolidated into higher-level cyber security documentation.

System security plan

The system security plan provides an overview of the system, covering the system's purpose, the system boundary and how the system is managed, as well as an annex that describes the security controls that have been identified and implemented for the system.

There can be many stakeholders involved in developing and maintaining a system security plan. This can include representatives from the following groups:

- cyber security teams
- project teams who deliver the capability (including contractors)
- support teams who operate and support the capability
- data owners for data processed, stored or communicated by the system
- users for whom the capability is being developed.

Control: ISM-0041; Revision: 7; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Systems have a system security plan that includes an overview of the system (covering the system's purpose, the system boundary and how the system is managed) as well as an annex that covers applicable security controls from this document and any additional security controls that have been identified and implemented.

Cyber security incident response plan

Having a cyber security incident response plan ensures that when a cyber security incident occurs, a plan is in place to respond appropriately to the situation. In most situations, the aim of the response will be to prevent the cyber security incident from escalating, restore any impacted system or data, and preserve any evidence.

Control: ISM-0043; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Systems have a cyber security incident response plan that covers the following:

- *guidelines on what constitutes a cyber security incident*
- *the types of cyber security incidents likely to be encountered and the expected response to each type*
- *how to report cyber security incidents, internally to an organisation and externally to relevant authorities*
- *other parties that need to be informed in the event of a cyber security incident*
- *the authority, or authorities, responsible for investigating and responding to cyber security incidents*
- *the criteria by which an investigation of a cyber security incident would be requested from a law enforcement agency, the Australian Signals Directorate or other relevant authority*
- *the steps necessary to ensure the integrity of evidence relating to a cyber security incident*
- *system contingency measures or a reference to such details if they are in a separate document.*

Change and configuration management plan

Having a change and configuration management plan ensures that changes to the configuration of systems can be made in an accountable manner, with appropriate consultation, consideration and approvals, to maintain the security of such systems. Furthermore, change management and configuration management processes and procedures provide an opportunity for the security impact of changes to configuration of systems to be considered and, if necessary, additional risk management activities to be undertaken.

Control: ISM-0912; Revision: 6; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Systems have a change and configuration management plan that includes:

- *the establishment and maintenance of authorised baseline configurations for systems*
- *what constitutes routine and urgent changes to the configuration of systems*
- *how changes to the configuration of systems will be requested, tracked and documented*
- *who needs to be consulted prior to routine and urgent changes to the configuration of systems*
- *who needs to approve routine and urgent changes to the configuration of systems*
- *who needs to be notified of routine and urgent changes to the configuration of systems*
- *what additional change management and configuration management processes and procedures need to be followed before, during and after routine and urgent changes to the configuration of systems.*

Continuous monitoring plan

A continuous monitoring plan can assist an organisation in proactively identifying, prioritising and responding to vulnerabilities in systems. Furthermore, undertaking security assessment activities as part of continuous monitoring is important as cyber threats and the effectiveness of security controls change over time.

Three types of security assessment activities that support continuously monitoring the security of systems are vulnerability scans, vulnerability assessments and penetration tests. A vulnerability scan involves using tools to conduct automated checks for known vulnerabilities whereas a vulnerability assessment typically consists of a review of a system's architecture or an in-depth hands-on assessment. In each case, the goal is to identify as many vulnerabilities as possible. A penetration test, however, is designed to exercise real-world scenarios to achieve a specific goal, such as compromising critical systems or data.

Control: ISM-1163; Revision: 11; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Systems have a continuous monitoring plan that includes:

- *conducting security assessment activities to identify vulnerabilities*
- *analysing identified vulnerabilities to determine their potential impact*

- *implementing mitigations based on risk, effectiveness and cost.*

Security assessment report

At the conclusion of a security control assessment for a system, a security assessment report should be produced by the assessor. This will assist the system owner in performing any initial remediation actions as well as guiding the development of the system's plan of action and milestones.

Control: ISM-1563; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
At the conclusion of a security control assessment for a system, a security assessment report is produced by the assessor and covers:

- *the scope of the security control assessment*
- *the system's strengths and weaknesses*
- *security risks associated with the operation of the system*
- *the effectiveness of the implementation of security controls*
- *any recommended remediation actions.*

Plan of action and milestones

At the conclusion of a security control assessment for a system, and after the production of a security assessment report by the assessor, a plan of action and milestones should be produced by the system owner. This will assist in tracking any of the system's identified weaknesses and recommended remediation actions identified during the security control assessment.

Control: ISM-1564; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
At the conclusion of a security control assessment for a system, a plan of action and milestones is produced by the system owner.

Further information

To assist with the development of system-specific cyber security documentation, a system security plan annex template can be found on the Australian Signals Directorate's *Information security manual* webpage.

Further information on cyber security incident response activities can be found in the 'Managing cyber security incidents' and 'Responding to cyber security incidents' sections of the *Guidelines for cyber security incidents*.

Further information on conducting security assessment activities as part of continuously monitoring the security of systems can be found in the 'Security assessments' section of the *Guidelines for security assurance*.

Guidelines for physical security

Facilities and systems

Physical access to systems

The application of the defence-in-depth principle to the protection of systems is enhanced through successive layers of physical security. The first layer of physical security for facilities that contain systems is generally the use of a security zone.

Deployable platforms should also meet physical security requirements. In some cases, physical security certification authorities may have specific requirements for deployable platforms that supersede the security controls in these guidelines. This may include perimeter controls, building standards and staffing levels. As such, an organisation implementing deployable platforms should contact their physical security certification authority to seek additional guidance.

Control: ISM-1973; Revision: 0; Updated: Dec-24; Applicable: NC; Essential 8: N/A
Non-classified systems are secured in suitably secure facilities.

Control: ISM-0810; Revision: 7; Updated: Dec-24; Applicable: OS, P, S, TS; Essential 8: N/A
Classified systems are secured in facilities that meet the requirements for a security zone suitable for their classification.

Physical access to servers, network devices and cryptographic equipment

The second layer of physical security is the use of an additional security zone for a server room or communications room. This is then further supplemented by security containers for the protection of servers, network devices and cryptographic equipment.

Control: ISM-1974; Revision: 0; Updated: Dec-24; Applicable: NC; Essential 8: N/A
Non-classified servers, network devices and cryptographic equipment are secured in suitably secure server rooms or communications rooms.

Control: ISM-1053; Revision: 5; Updated: Dec-24; Applicable: OS, P, S, TS; Essential 8: N/A
Classified servers, network devices and cryptographic equipment are secured in server rooms or communications rooms that meet the requirements for a security zone suitable for their classification.

Control: ISM-1975; Revision: 0; Updated: Dec-24; Applicable: NC; Essential 8: N/A
Non-classified servers, network devices and cryptographic equipment are secured in suitably secure security containers.

Control: ISM-1530; Revision: 3; Updated: Dec-24; Applicable: OS, P, S, TS; Essential 8: N/A
Classified servers, network devices and cryptographic equipment are secured in security containers suitable for their classification taking into account the combination of security zones they reside in.

Control: ISM-0813; Revision: 5; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Server rooms, communications rooms and security containers are not left in unsecured states.

Control: ISM-1074; Revision: 4; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Keys or equivalent access mechanisms to server rooms, communications rooms and security containers are appropriately controlled.

Physical access to network devices in public areas

Unprotected network devices in public areas could lead to accidental or deliberate physical damage resulting in an interruption of services. Alternatively, unauthorised access to network devices may allow malicious actors to reset them to factory default settings or connect directly to them to bypass network access controls. Even if access to network devices is not gained by resetting them to factory default settings, it is highly likely that it will cause an interruption of services.

Physical access to network devices can be restricted through the implementation of physical security, such as using enclosures that prevent access to their console ports and factory reset buttons, mounting them on ceilings or behind walls, or securing them in security containers.

Control: ISM-1296; Revision: 4; Updated: Jun-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Physical security is implemented to protect network devices in public areas from physical damage or unauthorised access.

Bringing radio frequency and infrared devices into facilities

Radio frequency (RF) devices, such as mobile devices, wireless keyboards and Bluetooth devices, as well as infrared (IR) devices, can pose a security risk to an organisation, especially when they can record or transmit audio or data. In SECRET and TOP SECRET areas, it is important that an organisation understands the security risks associated with the introduction of RF and IR devices and develops, implements, maintains and regularly verifies a register of those that have been authorised for use in such environments.

In deciding which RF or IR devices to authorise to be brought into SECRET and TOP SECRET areas, an organisation should consider any mitigating measures already in place. These include whether IR communications would be prevented from travelling outside secured spaces, whether systems of different sensitivities or classifications are used in the same spaces, and if any temporary or permanent method of blocking RF or IR transmissions has been applied to the facility.

Control: ISM-1543; Revision: 5; Updated: Jun-26; Applicable: S, TS; Essential 8: N/A
An authorised RF and IR device register for SECRET and TOP SECRET areas is developed, implemented, maintained and regularly verified.

Control: ISM-0225; Revision: 3; Updated: Sep-21; Applicable: S, TS; Essential 8: N/A
Unauthorised RF and IR devices are not brought into SECRET and TOP SECRET areas.

Control: ISM-0829; Revision: 4; Updated: Mar-19; Applicable: S, TS; Essential 8: N/A
Security measures are used to detect and respond to unauthorised RF devices in SECRET and TOP SECRET areas.

Bringing photographic and video recording devices into facilities

Photographic and video recording devices, such as cameras, video cameras and smart glasses, can pose a security risk to an organisation, especially when they can record photographs or videos in an inconspicuous manner. In SECRET and TOP SECRET areas, it is important that an organisation understands the security risks associated with the introduction of photographic and video recording devices and develops, implements, maintains and regularly verifies a register of those that have been authorised for use in such environments.

Control: ISM-2069; Revision: 1; Updated: Jun-26; Applicable: S, TS; Essential 8: N/A
An authorised photographic and video recording device register for SECRET and TOP SECRET areas is developed, implemented, maintained and regularly verified.

Control: ISM-2070; Revision: 0; Updated: Sep-25; Applicable: S, TS; Essential 8: N/A
Unauthorised photographic and video recording devices are not brought into SECRET and TOP SECRET areas.

Bringing medical devices into facilities

Medical devices are devices approved by the Therapeutic Goods Administration under the *Therapeutic Goods (Medical Devices) Regulations 2002* for diagnostic or therapeutic purposes. The use of medical devices in SECRET and TOP SECRET areas requires active management, similar to RF devices, as they may contain communications functionality that could compromise the security of SECRET or TOP SECRET areas or systems within such areas.

Control: ISM-2007; Revision: 1; Updated: Jun-26; Applicable: S, TS; Essential 8: N/A
An authorised medical device register for SECRET and TOP SECRET areas is developed, implemented, maintained and regularly verified.

Control: ISM-2008; Revision: 1; Updated: Jun-26; Applicable: S, TS; Essential 8: N/A
Medical devices authorised to be brought into SECRET and TOP SECRET areas meet, at a minimum, the following criteria:

- *are listed on the Australian Register of Therapeutic Goods*
- *have been prescribed by a legally qualified medical practitioner*
- *have been commercially purchased within Australia*
- *do not have inbuilt cellular connectivity*
- *can operate independently of mobile devices*
- *where possible, have Wi-Fi, Bluetooth and other forms of wireless connectivity disabled when operating within SECRET and TOP SECRET areas.*

Control: ISM-2009; Revision: 0; Updated: Mar-25; Applicable: S, TS; Essential 8: N/A
Unauthorised medical devices are not brought into SECRET and TOP SECRET areas.

Preventing observation by unauthorised people

Without sufficient perimeter security, the inside of a facility is often observable by unauthorised people, such as via direct observation or by using equipment with a telephoto lens. Ensuring systems, in particular workstation displays and keyboards, are not visible through windows, such as via the use of blinds, curtains, privacy films or workstation positioning, will assist in reducing this security risk.

Control: ISM-0164; Revision: 3; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unauthorised people are prevented from observing systems, in particular workstation displays and keyboards, within facilities.

Further information

Further information on the certification and accreditation authorities for physical security can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Further information on the physical security requirements for specific security zones can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Further information on selecting security zones and security containers for the protection of information technology (IT) equipment can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Further information on emanation security considerations associated with usage of RF devices in SECRET and TOP SECRET areas can be found in the 'Emanation security' section of the *Guidelines for communications infrastructure*.

Further information on medical devices approved by the Therapeutic Goods Administration for diagnostic or therapeutic purposes can be found on the Australian Register of Therapeutic Goods.

IT equipment and media

Securing IT equipment and media

IT equipment and media need to be secured when not in use. This can be achieved by implementing one of the following approaches:

- securing IT equipment and media in an appropriate security container
- using IT equipment without hard drives and sanitising memory at shut down
- encrypting hard drives of IT equipment and sanitising memory at shut down
- sanitising memory of IT equipment at shut down and removing and securing any hard drives.

If none of the above approaches are feasible, an organisation may wish to minimise the potential impact of not securing IT equipment when not in use. This can be achieved by preventing sensitive or classified data from being stored on hard drives, storing user profiles and documents on network shares, removing temporary user data at logoff, scrubbing virtual memory at shut down, and sanitising memory at shut down. However, there is no guarantee such measures will always work effectively or will not be bypassed due to unexpected circumstances, such as the loss of power. Therefore, hard drives in such cases will retain their sensitivity or classification for the purposes of reuse, reclassification, declassification, sanitisation, destruction and disposal.

Control: ISM-0161; Revision: 6; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment and media are secured when not in use.

Further information

Further information on the handling of IT equipment can be found in the 'IT equipment usage' section of the *Guidelines for information technology equipment*.

Further information on the handling of media can be found in the 'Media usage' section of the *Guidelines for media*.

Further information on encrypting media can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Further information on selecting security zones and security containers for the protection of IT equipment can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Guidelines for personnel security

Cyber security awareness training

Providing cyber security awareness training

An organisation should ensure that cyber security awareness training is provided to all personnel to assist them in understanding their security responsibilities and the cyber threats they may be exposed to in the course of their duties. Furthermore, the content of cyber security awareness training should be tailored to the needs of specific groups of personnel, such as general personnel and different classes of high-risk personnel. Finally, personnel with privileged access to systems and their resources, such as application administrators, system administrators and network administrators, will require tailored privileged user training.

Control: ISM-0252; Revision: 7; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cyber security awareness training is undertaken annually by all personnel and covers:

- *the purpose of the cyber security awareness training*
- *security appointments and contacts*
- *authorised use of systems and their resources*
- *protection of systems and their resources*
- *reporting of cyber security incidents and suspected compromises of systems and their resources.*

Control: ISM-1565; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Tailored privileged user training is undertaken annually by all personnel with privileged access to systems and their resources.

Control: ISM-2022; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A cyber security awareness training register is developed, implemented and maintained.

General-purpose artificial intelligence usage policy

As there are security risks associated with the use of general-purpose AI applications, it is important that an organisation develops, implements and maintains a general-purpose AI usage policy governing the use of such applications by personnel.

Control: ISM-2074; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A general-purpose AI usage policy is developed, implemented and maintained.

Web usage policy

As there are security risks associated with the use of web services, it is important that an organisation develops, implements and maintains a web usage policy governing its use by personnel.

Control: ISM-0258; Revision: 4; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A web usage policy is developed, implemented and maintained.

Managing requests to change banking details or transfer funds

Business email compromise, a form of financial fraud, is when malicious actors attempt to defraud an organisation of money or assets with the assistance of a compromised email account. Malicious actors will typically attempt to achieve this via invoice fraud, employee impersonation or company impersonation.

With invoice fraud, malicious actors will compromise a vendor's email account and through it have access to legitimate invoices. Malicious actors will then amend invoices and send them to customers with the compromised email account. Customers will then pay the invoices, thinking that they are paying the vendor, but instead be sending money to malicious actors' bank accounts.

With employee impersonation, malicious actors will compromise an organisation's email account and impersonate an employee via email. This is then used to commit financial fraud in several ways. One common method is to impersonate a person in a position of authority, such as a chief executive officer or chief financial officer, and have a false invoice raised. Another method is to request a change to an employee's banking details. The funds from the false invoice or the employee's salary are then sent to malicious actors' bank accounts.

With company impersonation, malicious actors register a domain with a name similar to another organisation. Malicious actors then impersonate that organisation in an email to a vendor and requests a quote for a quantity of expensive assets, such as laptop computers, and subsequently negotiate for the assets to be delivered to them prior to payment. The assets are then delivered to a location specified by malicious actors, with the invoice being sent to the legitimate organisation who never ordered or received the assets.

To mitigate business email compromise, personnel should be educated to look for the following warning signs:

- an unexpected request for a change of banking details
- an urgent payment request, or threats of serious consequences if payment is not made
- unexpected payment requests from a person in a position of authority, particularly if payment requests are unusual from this person
- an email received from a suspicious email address, such as an email address not matching an organisation's name.

In dealing with such situations, personnel should have clear guidance to verify bank account details; think critically before actioning unusual payment requests; and have a process to report threatening demands for immediate action, pressure for secrecy, or requests to circumvent normal business processes and procedures.

Control: ISM-1740; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel dealing with banking details and payment requests are advised of what business email compromise is and how to manage and report it.

Managing requests to modify user accounts

Requests to modify user accounts, such as resetting a password, changing a mobile phone number or email address, temporarily disabling multi-factor authentication, or re-enrolling for multi-factor authentication, could indicate a malicious actor attempting to conduct a help desk attack.

In dealing with such situations, personnel should have clear guidance to think critically before actioning unusual requests as well as a process to report threatening demands for immediate action, pressure for secrecy or requests to circumvent normal business processes and procedures.

Control: ISM-2071; Revision: 0; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel dealing with user account details are advised of what social engineering attacks are, how to manage such situations and how to report them.

Synthetic impersonation

Advances in artificial intelligence (AI) now allow malicious actors to convincingly impersonate executives, employees and customers using synthetic voice and video. As such, personnel dealing with user account details, banking details or financial transactions should not rely on voice or video alone to authenticate requests to modify user account details, modify banking details or conduct financial transactions. Instead, individuals should first be positively identified using a pre-established authentication method or independent trusted communications channel. Such mechanisms may include digitally signed approvals or in-built system approval mechanisms protected by phishing-resistant multi-factor authentication.

Control: ISM-2126; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel positively identify requestors using a pre-established authentication method or independent trusted communication channel before actioning requests to modify user account details, modify banking details or conduct financial transactions.

Reporting suspicious contact via online services

Online services, such as email, internet forums, messaging apps and direct messaging on social media, can be used by malicious actors to elicit sensitive or classified information from personnel. As such, personnel should be advised of what suspicious contact via online services is and how to report it.

Control: ISM-0817; Revision: 4; Updated: Jan-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised of what suspicious contact via online services is and how to report it.

Posting work-related information on online services

Personnel should be advised to take particular care not to post work-related information on online services unless authorised to do so, especially for chat services, internet forums, social media and AI tools. Even information that appears to be benign in isolation could, along with other information, have a considerable security impact or lead to increased targeting by malicious actors.

Control: ISM-0820; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised not to post work-related information on unauthorised online services, and to report cases where such information is posted.

Control: ISM-2104; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised not to post information about their security clearance and briefings on unauthorised online services, and to report cases where such information is posted.

Control: ISM-2105; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised to limit posting information about their work-related duties on unauthorised online services, and to report cases where such information is posted.

Control: ISM-2106; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised to limit posting information about their work-related skills and experience on unauthorised online services, and to report cases where such information is posted.

Posting personal information on online services

Personnel should be advised that any personal information they post on online services, such as social media, could be used by malicious actors to develop a detailed understanding of their lifestyle and interests. In turn, this information could be used to build trust to elicit sensitive or classified information from them, or influence them to undertake specific actions, such as opening malicious email attachments or visiting malicious websites. In addition, personnel posting information on their movements and activities could allow malicious actors to time attempted financial fraud to align with when their target, if in a position of authority, would be uncontactable, such as attending meetings or travelling.

Furthermore, to ensure that personal opinions are not misinterpreted as the official position of an organisation they work for, personnel should maintain separate personal user accounts from any work user accounts they use for online services, especially for social media.

Finally, encouraging personnel to use any available privacy settings for online services can reduce security risks by restricting who can view their personal information, as well as their interactions with online services.

Control: ISM-0821; Revision: 4; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised of security risks associated with posting personal information on online services.

Control: ISM-1146; Revision: 4; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised to maintain separate personal user accounts from any work user accounts they use for online services.

Control: ISM-2107; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are encouraged to use any available privacy settings to restrict who can view personal information they post on online services.

Sending and receiving files via online services

When personnel send and receive files via unauthorised online services, such as messaging apps and social media, they often bypass security controls put in place to detect and quarantine malicious code. Advising personnel to send and receive files via authorised online services instead will ensure files are appropriately protected and scanned for malicious code.

Control: ISM-0824; Revision: 2; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised not to send or receive files via unauthorised online services.

Further information

Further information on telephone system usage can be found in the 'Telephone systems' section of the *Guidelines for communications systems*.

Further information on multifunction device usage can be found in the 'Multifunction devices' section of the *Guidelines for communications systems*.

Further information on mobile device usage can be found in the 'Mobile device usage' section of the *Guidelines for enterprise mobility*.

Further information on removable media usage can be found in the 'Media usage' section of the *Guidelines for media*.

Further information on email usage can be found in the 'Email usage' section of the *Guidelines for email*.

Further information on web usage can be found in the 'Web proxies' section of the *Guidelines for gateways*.

Further information and training resources on privileged user training can be found on the Australian Signals Directorate's (ASD) Privileged User Training webpage.

Further information on business email compromise can be found in ASD's *Protecting against business email compromise* publication.

Further information on detecting socially engineered messages can be found in ASD's *Detecting socially engineered messages* publication.

Further information on the use of social media can be found in ASD's *Security tips for social media and messaging services* publication.

Further information on reporting cybercrime incidents and reporting cyber security incidents, including ASD's limited use obligation, is available from ASD.

Guidelines for communications infrastructure

Cabling infrastructure

Context

This section applies only to facilities located within Australia. In doing so, it covers common security controls for both single-tenant and shared facilities, and specific security controls for only shared facilities, such as a single floor or part of a floor within a multi-tenanted building.

For the purposes of this section, a cable is defined as any fibre-optic or copper material housed within a protective sheath for the purposes of transmitting data or control signals from one point in a facility to another. Each cable will form part of a structured cabling system and will need to comply with the Australian Standards associated with that system.

In addition to network communications and data systems, some common building management structured cabling systems found within facilities include:

- fire control and sensor systems
- security control and surveillance systems
- lighting control systems
- access control systems
- voice and emergency telephony systems
- emergency control alert systems.

Finally, protective sheaths for cables are not considered a conduit and the same cable connector types can be used for all systems within a facility regardless of their sensitivity or classification.

Cabling infrastructure standards

Cabling infrastructure should be installed by an endorsed cable installer to the relevant Australian Standards to ensure personnel safety and system availability.

Control: ISM-0181; Revision: 3; Updated: Mar-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cabling infrastructure is installed in accordance with relevant Australian Standards, as directed by the Australian Communications and Media Authority.

Use of fibre-optic cables

Fibre-optic cables do not produce electromagnetic emanations and are not influenced by them. As a result, they offer the highest degree of protection from electromagnetic emanation effects.

Control: ISM-1111; Revision: 3; Updated: Mar-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Fibre-optic cables are used for cabling infrastructure instead of copper cables.

Cable register

Developing, implementing, maintaining and regularly verifying cable registers assists installers and inspectors, with the help of floor plan diagrams, to trace cables for malicious or accidental changes or damage. In doing so, cable registers should track all cabling changes throughout the life of a system.

Control: ISM-0211; Revision: 8; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A cable register is developed, implemented, maintained and regularly verified.

Control: ISM-0208; Revision: 6; Updated: Jun-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A cable register contains the following for each cable:

- *cable identifier*
- *cable colour*
- *sensitivity/classification*
- *source*
- *destination*
- *location*
- *seal numbers (if applicable).*

Floor plan diagrams

Floor plan diagrams that are developed using computer-aided design and drafting applications, and use alphanumeric grid referencing, can provide an accurate scaled view for each floor and are critical to ensuring that cabling infrastructure components can be easily located by installers and inspectors. In doing so, floor plan diagrams should track all cabling infrastructure changes throughout the life of a system.

Control: ISM-1645; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Floor plan diagrams are developed, implemented, maintained and regularly verified.

Control: ISM-1646; Revision: 0; Updated: Jun-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Floor plan diagrams contain the following:

- *cable paths (including ingress and egress points between floors)*
- *cable reticulation system and conduit paths*
- *floor concentration boxes*
- *wall outlet boxes*

- *network cabinets.*

Cable labelling processes and procedures

Well-documented cable labelling processes and procedures can make cable verification and fault finding easier.

Control: ISM-0206; Revision: 7; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cable labelling processes, and supporting cable labelling procedures, are developed, implemented and maintained.

Labelling cables

Labelling cables with the correct source and destination details minimises the likelihood of cross-patching and aids in fault finding and configuration management.

Control: ISM-1096; Revision: 2; Updated: Oct-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cables are labelled at each end with sufficient source and destination details to enable the physical identification and inspection of the cable.

Labelling building management cables

All facilities will contain structured cabling systems to support building management and control functions. As Australian Standards require some structured cabling systems to use specified colours, such as red for fire control systems, it is important that all building management cables are appropriately labelled.

Control: ISM-1639; Revision: 0; Updated: Mar-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Building management cables are labelled with their purpose in black writing on a yellow background, with a minimum size of 2.5 cm x 1 cm, and attached at five-metre intervals.

Labelling cables for foreign systems in Australian facilities

Labelling cables for foreign systems in Australian facilities helps prevent unintended cross-patching of Australian and foreign systems.

Control: ISM-1640; Revision: 0; Updated: Mar-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cables for foreign systems installed in Australian facilities are labelled at inspection points.

Cable colours

To avoid confusion, it is important that, regardless of the type of cabling involved, a consistent cable colour is used. Furthermore, the use of designated cable colours can provide an easy way to distinguish cables for SECRET and TOP SECRET systems from cables for other systems. For example, while SECRET and TOP SECRET cables have designated cable colours, cables for other systems may be any colour except for those reserved for SECRET and TOP SECRET systems. In addition, cable colours for other systems, such as non-classified, OFFICIAL: Sensitive and PROTECTED systems, may use the same colour, such as blue.

Control: ISM-1820; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cables for individual systems use a consistent colour.

Control: ISM-0926; Revision: 11; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
Non-classified, OFFICIAL: Sensitive and PROTECTED cables are coloured neither salmon pink nor red.

Control: ISM-1718; Revision: 1; Updated: Mar-23; Applicable: S; Essential 8: N/A
SECRET cables are coloured salmon pink.

Control: ISM-1719; Revision: 1; Updated: Mar-23; Applicable: TS; Essential 8: N/A
TOP SECRET cables are coloured red.

Cable colour non-conformance

In certain circumstances, it may not be possible to use the correct colour for SECRET or TOP SECRET cables. In such cases, an organisation should band such cables with the appropriate colour and ensure that the cable bands are easily visible at inspection points. In doing so, it is important that cable bands are robust enough to stand the test of time. Examples of appropriate cable bands include stick-on coloured labels, colour heat shrink, coloured ferrules or short lengths of banded conduit.

Control: ISM-1216; Revision: 4; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
SECRET and TOP SECRET cables with non-conformant cable colouring are banded with the appropriate colour and labelled at inspection points.

Cable inspectability

The ability to inspect cabling infrastructure is necessary to detect illicit tampering or degradation. This does not mean that cables need to be fully visible all the time. Rather, cable inspectability can be achieved if cables can be viewed and inspected through the easy removal of ceiling, floor or wall panels or manholes.

Control: ISM-1112; Revision: 4; Updated: Dec-24; Applicable: NC, OS, P, S; Essential 8: N/A
Cables in non-TOP SECRET areas are inspectable every five metres or less.

Control: ISM-1119; Revision: 2; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cables in TOP SECRET areas are fully inspectable for their entire length.

Common cable bundles and conduits

In some circumstances, cables for different systems can be bundled together or run in a common conduit to reduce costs, such as cables for OFFICIAL: Sensitive and PROTECTED systems.

Control: ISM-0187; Revision: 8; Updated: Mar-23; Applicable: S; Essential 8: N/A
SECRET cables, when bundled together or run in conduit, are run exclusively in their own individual cable bundle or conduit.

Control: ISM-1821; Revision: 0; Updated: Mar-23; Applicable: TS; Essential 8: N/A
TOP SECRET cables, when bundled together or run in conduit, are run exclusively in their own individual cable bundle or conduit.

Common cable reticulation systems

When cable reticulation systems are used for more than one cable bundle or conduit, it is important that there is a dividing partition or visible gap between cable bundles and conduits to facilitate easier cable inspection.

Control: ISM-1114; Revision: 4; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cable bundles or conduits sharing a common cable reticulation system have a dividing partition or visible gap between each cable bundle and conduit.

Enclosed cable reticulation systems

In shared facilities, cables should be enclosed in a sealed cable reticulation system to prevent access and enhance cable management.

Control: ISM-1130; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
In shared facilities, cables are run in an enclosed cable reticulation system.

Covers for enclosed cable reticulation systems

In shared facilities, clear covers on enclosed cable reticulation systems are a convenient method of maintaining inspection requirements. Having clear covers that face inwards increases their inspectability.

Control: ISM-1164; Revision: 3; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
In shared facilities, conduits or the front covers of ducts, cable trays in floors and ceilings, and associated fittings are clear plastic.

Sealing cable reticulation systems and conduits

In shared facilities, uniquely identifiable Security Construction and Equipment Committee (SCEC)-approved tamper-evident seals should be used to provide evidence of any tampering or illicit access to TOP SECRET cable reticulation systems. In addition, TOP SECRET conduits should be sealed with a visible smear of conduit glue to prevent access.

Control: ISM-0195; Revision: 7; Updated: Jun-22; Applicable: TS; Essential 8: N/A
In shared facilities, uniquely identifiable SCEC-approved tamper-evident seals are used to seal all removable covers on TOP SECRET cable reticulation systems.

Control: ISM-0194; Revision: 3; Updated: Dec-21; Applicable: TS; Essential 8: N/A
In shared facilities, a visible smear of conduit glue is used to seal all plastic conduit joints and TOP SECRET conduits connected by threaded lock nuts.

Labelling conduits

Labels for TOP SECRET conduits should be of sufficient size and colour to enable easy identification.

Control: ISM-0201; Revision: 3; Updated: Mar-21; Applicable: TS; Essential 8: N/A
Labels for TOP SECRET conduits are a minimum size of 2.5 cm x 1 cm, attached at five-metre intervals and marked as 'TS RUN'.

Cables in walls

Cables run correctly in walls enable neater installations while maintaining separation and inspection requirements.

Control: ISM-1115; Revision: 4; Updated: Dec-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cables from cable trays to wall outlet boxes are run in flexible or plastic conduit.

Cables in party walls

In shared facilities, TOP SECRET cables are not run in party walls. However, an inner wall can be used to run TOP SECRET cables where sufficient space exists for their inspection.

Control: ISM-1133; Revision: 3; Updated: Dec-21; Applicable: TS; Essential 8: N/A
In shared facilities, TOP SECRET cables are not run in party walls.

Wall penetrations

Penetrating a wall between a TOP SECRET area and a lower classified area requires the integrity of the TOP SECRET area to be maintained. In such scenarios, TOP SECRET cables should be encased in conduit with all gaps between the TOP SECRET conduit and the wall filled with an appropriate sealing compound.

Control: ISM-1122; Revision: 2; Updated: Dec-21; Applicable: TS; Essential 8: N/A
Where wall penetrations exit a TOP SECRET area into a lower classified area, TOP SECRET cables are encased in conduit with all gaps between the TOP SECRET conduit and the wall filled with an appropriate sealing compound.

Wall outlet boxes

Wall outlet boxes are the main method of connecting cabling infrastructure to workstations. They enable the management of cables and the types of connectors allocated to various systems.

Control: ISM-1105; Revision: 4; Updated: Mar-23; Applicable: S, TS; Essential 8: N/A
SECRET and TOP SECRET wall outlet boxes contain exclusively SECRET or TOP SECRET cables.

Labelling wall outlet boxes

Clear labelling of wall outlet boxes diminishes the possibility of incorrectly attaching information technology (IT) equipment to the wrong wall outlet box. In cases where a wall outlet box contains cables for different systems, each connector should be individually labelled.

Control: ISM-1095; Revision: 5; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Wall outlet boxes denote the systems, cable identifiers and wall outlet box identifier.

Wall outlet box colours

The use of designated wall outlet box colours can provide an easy way to distinguish wall outlet boxes for SECRET and TOP SECRET systems from wall outlet boxes for other systems. For example, while SECRET and TOP SECRET wall outlet boxes have designated wall outlet box colours, wall outlet boxes for other systems may be any colour except for those reserved for SECRET and TOP SECRET systems. In addition, wall outlet box colours for other systems, such as non-classified, OFFICIAL: Sensitive and PROTECTED systems, may use the same colour, such as blue. Ideally, wall outlet boxes should be the same colour that is used for associated cabling.

Control: ISM-1822; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Wall outlet boxes for individual systems use a consistent colour.

Control: ISM-1107; Revision: 7; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
Non-classified, OFFICIAL: Sensitive and PROTECTED wall outlet boxes are coloured neither salmon pink nor red.

Control: ISM-1720; Revision: 0; Updated: Dec-21; Applicable: S; Essential 8: N/A
SECRET wall outlet boxes are coloured salmon pink.

Control: ISM-1721; Revision: 0; Updated: Dec-21; Applicable: TS; Essential 8: N/A
TOP SECRET wall outlet boxes are coloured red.

Wall outlet box covers

Transparent wall outlet box covers enable the identification of cable cross-patching and signs of tampering.

Control: ISM-1109; Revision: 3; Updated: Dec-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Wall outlet box covers are clear plastic.

Fly lead installation

Keeping the lengths of TOP SECRET fibre-optic fly leads to a minimum prevents clutter around desks, prevents damage, and reduces the chance of cross-patching and tampering. If lengths become excessive, TOP SECRET fibre-optic fly leads should be treated as cabling infrastructure and run in TOP SECRET conduit or fixed infrastructure, such as desk partitioning.

Control: ISM-0218; Revision: 7; Updated: Jun-24; Applicable: TS; Essential 8: N/A
If TOP SECRET fibre-optic fly leads exceeding five metres in length are used to connect wall outlet boxes to IT equipment, they are run in a protective and easily inspected pathway that is clearly labelled at the IT equipment end with the wall outlet box's identifier.

Connecting cable reticulation systems to cabinets

Controlling the routing from cable reticulation systems to cabinets can assist in preventing unauthorised modifications and tampering while also providing easy inspection of cables.

Control: ISM-1102; Revision: 3; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cable reticulation systems leading into cabinets are terminated as close as possible to the cabinet.

Control: ISM-1101; Revision: 3; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
In TOP SECRET areas, cable reticulation systems leading into cabinets in server rooms or communications rooms are terminated as close as possible to the cabinet.

Control: ISM-1103; Revision: 3; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
In TOP SECRET areas, cable reticulation systems leading into cabinets not in server rooms or communications rooms are terminated at the boundary of the cabinet.

Terminating cables in cabinets

Having individual or divided cabinets can assist in preventing accidental or deliberate cross-patching and makes inspection of cables easier.

Control: ISM-1098; Revision: 5; Updated: Mar-23; Applicable: S; Essential 8: N/A
SECRET cables are terminated in an individual cabinet; or for small systems, a cabinet with a division plate between any SECRET cables and non-SECRET cables.

Control: ISM-1100; Revision: 1; Updated: Sep-18; Applicable: TS; Essential 8: N/A
TOP SECRET cables are terminated in an individual TOP SECRET cabinet.

Terminating cables on patch panels

Terminating SECRET and TOP SECRET cables on different patch panels in cabinets can assist in preventing accidental or deliberate cross-patching and makes inspection of cables easier.

Control: ISM-0213; Revision: 4; Updated: Mar-23; Applicable: S, TS; Essential 8: N/A
SECRET and TOP SECRET cables are terminated on their own individual patch panels.

Physical separation of cabinets and patch panels

Physical separation between TOP SECRET systems and non-TOP SECRET systems reduces the chance of cross-patching. This reduces the possibility of unauthorised personnel gaining access to TOP SECRET systems.

Control: ISM-0216; Revision: 3; Updated: Mar-23; Applicable: TS; Essential 8: N/A
TOP SECRET patch panels are installed in individual TOP SECRET cabinets.

Control: ISM-0217; Revision: 5; Updated: Mar-23; Applicable: TS; Essential 8: N/A
Where spatial constraints demand non-TOP SECRET patch panels be installed in the same cabinet as a TOP SECRET patch panel:

- *a physical barrier in the cabinet is provided to separate patch panels*
- *only personnel holding a Positive Vetting security clearance have access to the cabinet*
- *approval from the TOP SECRET system's authorising officer is obtained prior to installation.*

Control: ISM-1116; Revision: 4; Updated: Mar-23; Applicable: TS; Essential 8: N/A
A visible gap exists between TOP SECRET cabinets and non-TOP SECRET cabinets.

Audio secure rooms

Audio secure rooms are designed to prevent audio conversations from being overheard. The Australian Security Intelligence Organisation should be consulted before any modifications are made to TOP SECRET audio secure rooms.

Control: ISM-0198; Revision: 3; Updated: Dec-21; Applicable: TS; Essential 8: N/A
When penetrating a TOP SECRET audio secure room, the Australian Security Intelligence Organisation is consulted and all directions provided are complied with.

Power reticulation

It is important that TOP SECRET systems have control over the power system to prevent denial of service by deliberate or accidental means.

Control: ISM-1123; Revision: 4; Updated: Jun-24; Applicable: TS; Essential 8: N/A
A power distribution board with a feed from an Uninterruptible Power Supply is used to power all TOP SECRET IT equipment.

Further information

Australian cabling standards can be obtained from the Australian Communications and Media Authority.

Further information on SCEC-approved tamper-evident seals can be found on the SCEC's *Security Equipment Evaluated Products List*.

Further information on audio secure rooms can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Emanation security

Electromagnetic interference/electromagnetic compatibility standards

All IT equipment used by systems will need to meet industry and government standards relating to electromagnetic interference/electromagnetic compatibility.

Control: ISM-0250; Revision: 5; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment meets industry and government standards relating to electromagnetic interference/electromagnetic compatibility.

Emanation security doctrine

The Australian Signals Directorate (ASD) specifies emanation security requirements in its *Emanation security manual* and Australian Communications Security Instructions that must be complied with. Such requirements supplement these guidelines and, where conflicts occur, take precedence.

Control: ISM-1884; Revision: 0; Updated: Dec-23; Applicable: OS, P, S, TS; Essential 8: N/A
Emanation security doctrine produced by ASD for the management of emanation security matters is complied with.

Emanation security risk assessments

Obtaining advice from ASD on emanation security risks is vital to protecting SECRET and TOP SECRET systems, inside and outside of Australian borders. This can assist in preventing SECRET and TOP SECRET systems from emanating compromising signals, which if intercepted and analysed, could lead to serious consequences. The implementation of such advice is in addition to, and not a replacement for, industry and government standards relating to electromagnetic interference/electromagnetic compatibility.

In conducting emanation security risk assessments, it is important that they are sought by system owners as early as possible in a system's life cycle as development timeframes and costs will be much greater if changes need to be made to systems once they have been designed and implemented.

On completion of emanation security risk assessments, system owners will receive emanation security mitigation advice that contains recommended actions to be taken to reduce emanation security risks. In doing so, any recommendations not implemented by system owners will need to be accepted by a system's authorising officer.

Control: ISM-1137; Revision: 6; Updated: Mar-26; Applicable: S, TS; Essential 8: N/A
System owners deploying SECRET or TOP SECRET systems within fixed facilities contact ASD for an emanation security risk assessment.

Control: ISM-0249; Revision: 7; Updated: Mar-26; Applicable: S, TS; Essential 8: N/A
System owners deploying SECRET or TOP SECRET systems in mobile platforms, or as a deployable capability, contact ASD for an emanation security risk assessment.

Control: ISM-0246; Revision: 7; Updated: Mar-26; Applicable: S, TS; Essential 8: N/A
When an emanation security risk assessment is required, it is sought as early as possible in a system's life cycle.

Control: ISM-1885; Revision: 2; Updated: Mar-26; Applicable: S, TS; Essential 8: N/A
Recommended actions contained within emanation security mitigation advice issued for systems are implemented by system owners.

Guidelines for communications systems

Telephone systems

Telephone system usage policy

All non-secure telephone systems are subject to interception. Personnel accidentally or maliciously communicating sensitive or classified information over a public telephone network can lead to its compromise.

Control: ISM-1078; Revision: 4; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A telephone system usage policy is developed, implemented and maintained.

Personnel awareness

As there is a potential for unintended disclosure of information when using telephone systems, personnel should be made aware of the sensitivity or classification of information that may be discussed when using them. In addition, personnel should also be made aware of the security risks associated with the use of non-secure telephone systems in areas where sensitive or classified conversations may occur.

When using cryptographic equipment to enable different levels of conversation for different kinds of connections, providing a visual indication to personnel as to the sensitivity or classification of information that can be discussed over the telephone system can assist in reducing the likelihood of unintended disclosure of information.

Control: ISM-0229; Revision: 4; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised of the permitted sensitivity or classification of information that can be discussed over internal and external telephone systems.

Control: ISM-0230; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised of security risks posed by non-secure telephone systems in areas where sensitive or classified conversations can occur.

Control: ISM-0231; Revision: 2; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using cryptographic equipment to permit different levels of conversation for different kinds of connections, telephone systems give a visual indication of what kind of connection has been made.

Protecting conversations

When sensitive or classified conversations are held using telephone systems, the conversation needs to be appropriately protected by using encryption.

Control: ISM-0232; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Telephone systems used for sensitive or classified conversations encrypt all traffic that passes over external systems.

Cordless telephone systems

Cordless telephone handsets and headsets typically have minimal transmission security and are susceptible to interception. This may result in the disclosure of sensitive or classified conversations to malicious actors unless suitable encryption is used. As such, it is critical that Australian Signals Directorate (ASD)-approved cryptography is used.

Control: ISM-0233; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cordless telephone handsets and headsets are not used for sensitive or classified conversations unless all communications are encrypted using ASD-approved cryptography.

Speakerphones

As speakerphones are designed to pick up and transmit nearby conversations, using speakerphones in TOP SECRET areas presents several security risks and they should not be used. However, if personnel reduce security risks by using an audio secure room that is secure during any conversations, they may be used.

Control: ISM-0235; Revision: 5; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Speakerphones are not used on telephone systems in TOP SECRET areas unless the telephone system is located in an audio secure room, the room is audio secure during conversations and only personnel involved in conversations are present in the room.

Off-hook audio protection

Using off-hook protection features minimises the chance of background conversations being accidentally coupled into handsets, headsets and speakerphones. Limiting the time an active microphone is open minimises this security risk.

Control: ISM-0236; Revision: 5; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Off-hook audio protection features are used on telephone systems in areas where background conversations may exceed the sensitivity or classification that the telephone system is authorised for communicating.

Control: ISM-0931; Revision: 7; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
In SECRET and TOP SECRET areas, push-to-talk handsets or push-to-talk headsets are used to meet any off-hook audio protection requirements.

Further information

Further information on encrypting communications can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Video conferencing and Internet Protocol telephony

Context

This section describes security controls applicable to Internet Protocol (IP) telephony and extends the 'Telephone systems' section of these guidelines.

Furthermore, where a video conferencing or IP telephony network is connected to another network from a different security domain, the 'Gateways' section of the *Guidelines for gateways* applies.

Video conferencing and Internet Protocol telephony infrastructure hardening

Video conferencing and IP telephony infrastructure can be hardened to reduce its attack surface. For example, by ensuring that a Session Initiation Protocol server has a fully patched operating system, uses fully patched applications and only runs required services.

Control: ISM-1562; Revision: 0; Updated: Dec-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Video conferencing and IP telephony infrastructure is hardened.

Video-aware and voice-aware firewalls and proxies

The use of video-aware and voice-aware firewalls and proxies provides network security while supporting video and voice traffic. As such, when implementing a firewall or proxy in a gateway, and video conferencing or IP telephony traffic passes through the gateway, a video-aware or voice-aware firewall or proxy will need to be used. However, this does not require separate firewalls or proxies to be deployed for video conferencing, IP telephony and data traffic. In such cases, an organisation is encouraged to implement one firewall or proxy that is video-aware and data-aware; voice-aware and data-aware; or video-aware, voice-aware and data-aware depending on their needs.

Control: ISM-0546; Revision: 9; Updated: Jun-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When video conferencing or IP telephony traffic passes through a gateway containing a firewall or proxy, a video-aware or voice-aware firewall or proxy is used.

Protecting video conferencing and Internet Protocol telephony traffic

Video conferencing and IP telephony traffic can be vulnerable to eavesdropping, denial-of-service, adversary-in-the-middle and call spoofing attacks. To mitigate this security risk, video conferencing and IP telephony signalling and audio/video data can be protected with the use of Transport Layer Security. This is achieved by using the Session Initiation Protocol Secure protocol and the Secure Real-time Transport Protocol.

Control: ISM-0548; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Video conferencing and IP telephony calls are established using a secure session initiation protocol.

Control: ISM-0547; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Video conferencing and IP telephony calls are conducted using a secure real-time transport protocol.

Video conferencing unit and Internet Protocol phone authentication

Blocking unauthorised or unauthenticated devices by default will reduce the likelihood of unauthorised access to a video conferencing or IP telephony network.

Control: ISM-0554; Revision: 1; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An encrypted and non-replayable two-way authentication scheme is used for call authentication and authorisation.

Control: ISM-0553; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication and authorisation is used for all actions on a video conferencing network, including call setup and changing settings.

Control: ISM-0555; Revision: 3; Updated: Dec-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication and authorisation is used for all actions on an IP telephony network, including registering a new IP phone, changing phone users, changing settings and accessing voicemail.

Control: ISM-0551; Revision: 7; Updated: Jan-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IP telephony is configured such that:

- *IP phones authenticate themselves to the call controller upon registration*
- *auto-registration is disabled and only authorised devices are allowed to access the network*
- *unauthorised devices are blocked by default*
- *all unused and prohibited functionality is disabled.*

Control: ISM-1014; Revision: 6; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
Individual logins are implemented for IP phones used for SECRET or TOP SECRET conversations.

Traffic separation

Video conferencing and IP telephony traffic should be physically or logically separated from other data traffic to ensure availability and quality of service.

Control: ISM-0549; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Video conferencing and IP telephony traffic is physically or logically separated from other data traffic.

Control: ISM-0556; Revision: 5; Updated: Oct-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Workstations are not connected to video conferencing units or IP phones unless the workstation or the device uses virtual local area networks or similar mechanisms to maintain separation between video conferencing, IP telephony and other data traffic.

Internet Protocol phones in public areas

IP phones in public areas may give malicious actors the opportunity to access data networks or poorly protected voicemail and directory services. As such, any services accessible to IP phones in public areas should be restricted.

Control: ISM-0558; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IP phones used in public areas do not have the ability to access data networks, voicemail and directory services.

Microphones and webcams

Microphones (including headsets and Universal Serial Bus [USB] handsets) and webcams can pose a security risk in SECRET and TOP SECRET areas. Specifically, malicious actors can email or host malicious code on a compromised website and use social engineering techniques to convince human users into executing the malicious code on their workstation. Such malicious code may then activate microphones or webcams that are attached to the workstation to act as remote listening and recording devices.

Control: ISM-0559; Revision: 6; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
Microphones (including headsets and USB handsets) and webcams are not used with non-SECRET workstations in SECRET areas.

Control: ISM-1450; Revision: 3; Updated: Dec-24; Applicable: NC, OS, P, S; Essential 8: N/A
Microphones (including headsets and USB handsets) and webcams are not used with non-TOP SECRET workstations in TOP SECRET areas.

Denial of service response plan

Video conferencing and IP telephony services may be a critical service for an organisation. In such cases, a denial of service response plan will assist in responding to denial-of-service attacks against these services.

Control: ISM-1019; Revision: 9; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A denial of service response plan for video conferencing and IP telephony services is developed, implemented and maintained.

Control: ISM-1805; Revision: 0; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A denial of service response plan for video conferencing and IP telephony services contains the following:

- *how to identify signs of a denial-of-service attack*
- *how to identify the source of a denial-of-service attack*
- *how capabilities can be maintained during a denial-of-service attack*
- *what actions can be taken to respond to a denial-of-service attack.*

Further information

Further information on gateways can be found in the 'Gateways' section of the *Guidelines for gateways*.

Further information on firewalls can be found in the 'Firewalls' section of the *Guidelines for gateways*.

Further information on the use of web conferencing solutions can be found in ASD's *Web conferencing security* publication.

Multifunction devices

Multifunction device usage policy

As multifunction devices (MFDs) are a potential source of cyber security incidents, it is important that an organisation develops, implements and maintains a policy governing their use.

Control: ISM-0588; Revision: 5; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An MFD usage policy is developed, implemented and maintained.

Connecting multifunction devices to digital telephone systems

When MFDs are connected to both a network and a digital telephone system, they can act as a bridge between the two. As such, and to avoid potential data spills, MFDs should not be connected to digital telephone systems.

Control: ISM-0245; Revision: 6; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
MFDs are not connected to digital telephone systems.

Authenticating to multifunction devices

To prevent human users from printing sensitive or classified documents and forgetting to collect them, as well as assisting with the collection of sufficiently detailed event logs, MFDs should implement authentication measures that are of the same strength as used for other devices on the same network they are connected to, such as workstations. For example, if access to workstations on a network requires multi-factor authentication, so should access to MFDs before they can be used to print, scan or copy documents.

Control: ISM-1854; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Human users authenticate to MFDs before they can print, scan or copy documents.

Control: ISM-0590; Revision: 8; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication measures for MFDs are the same strength as those used for workstations on networks they are connected to.

Scanning and copying documents on multifunction devices

As MFDs residing on networks are often capable of sending scanned documents across networks they are connected to, personnel should be aware that if they scan documents at a level higher than the sensitivity or classification of the network it will cause a data spill. In addition, MFDs used to copy documents above the sensitivity or classification of the network may cause a localised data spill if copies are retained on non-volatile memory within the devices.

Control: ISM-0589; Revision: 7; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
MFDs are not used to scan or copy documents above the sensitivity or classification of networks they are connected to.

Logging multifunction device use

Centrally logging and analysing MFD events, including metadata and shadow copies of documents printed, scanned or copied, can assist in monitoring the security posture of systems, detecting malicious behaviour and supporting investigations following cyber security incidents.

Control: ISM-1855; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Use of MFDs for printing, scanning and copying purposes, including the capture of shadow copies of documents, are centrally logged.

Observing multifunction device use

Placing MFDs in public areas can help reduce the likelihood of any suspicious use going unnoticed.

Control: ISM-1036; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
MFDs are placed in areas where their use can be observed.

Further information

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Fax machines and services

Sending and receiving fax messages

As fax machines, and associated communications protocols, are legacy information technology, they should not be used for sending or receiving fax messages. Instead, more secure communications methods, such as scanning documents and attaching them to emails, should be used.

Control: ISM-2075; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Fax machines, and online fax services, are not used for sending or receiving fax messages.

Guidelines for enterprise mobility

Enterprise mobility

Context

Enterprise mobility generally refers to situations in which personnel work in a mobile manner, such as part of office hot-desking arrangements, when working from home, when travelling or simply when outside the office environment during normal business hours. While enterprise mobility has traditionally been used to refer to the use of mobile devices, such as smartphones, tablets and laptop computers, it is increasingly being applied to the use of desktop computers as part of working from home arrangements.

This section applies to privately owned and organisation-owned mobile devices and desktop computers that use either a mobile operating system or a desktop operating system.

Privately owned mobile devices and desktop computers

Allowing privately owned mobile devices and desktop computers to access an organisation's systems or data can increase liability risk. As such, an organisation should seek legal advice to ascertain whether this scenario affects compliance with relevant legislation, such as the *Privacy Act 1988* and the *Archives Act 1983*. Furthermore, if an organisation chooses to allow personnel to use privately owned mobile devices or desktop computers to access their organisation's classified systems or data, they should ensure that it does not present an unacceptable security risk. This can be achieved in part through the enforced separation of classified data and personal data, preventing the storage of classified data on privately owned mobile devices and desktop computers, and disallowing the use of unapproved artificial intelligence agents.

Control: ISM-1297; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Legal advice is sought prior to allowing privately owned mobile devices and desktop computers to access systems or data.

Control: ISM-1400; Revision: 11; Updated: Jun-26; Applicable: OS, P; Essential 8: N/A
Personnel using privately owned mobile devices or desktop computers to access OFFICIAL: Sensitive or PROTECTED systems or data have enforced separation of classified data and personal data.

Control: ISM-1866; Revision: 2; Updated: Jun-26; Applicable: OS, P; Essential 8: N/A
Personnel using privately owned mobile devices or desktop computers to access OFFICIAL: Sensitive or PROTECTED systems or data are prevented from storing classified data on their privately owned mobile devices and desktop computers.

Control: ISM-2095; Revision: 1; Updated: Jun-26; Applicable: OS, P; Essential 8: N/A
Personnel using privately owned mobile devices or desktop computers to access OFFICIAL: Sensitive or PROTECTED systems or data are disallowed from granting access to unapproved artificial intelligence agents.

Control: ISM-0694; Revision: 9; Updated: Jun-26; Applicable: S, TS; Essential 8: N/A
Privately owned mobile devices and desktop computers do not access SECRET and TOP SECRET systems or data.

Organisation-owned mobile devices and desktop computers

If an organisation chooses to issue personnel with organisation-owned mobile devices or desktop computers to access their organisation's classified systems or data, they should ensure that it does not present an unacceptable security risk. This can be achieved in part by enforcing the separation of classified data and personal data.

Control: ISM-1482; Revision: 9; Updated: Mar-26; Applicable: OS, P, S, TS; Essential 8: N/A
Personnel using organisation-owned mobile devices or desktop computers to access classified systems or data have enforced separation of classified data and personal data.

Mobile devices and desktop computers accessing the internet

When mobile devices and desktop computers access the internet, doing so via an organisation's internet gateway rather than directly can enable the provision of additional security functionality, such as web content filtering and protective Domain Name System services. However, in some cases, an organisation may instead accept the security risks associated with allowing direct connections to specific online services, such as web conferencing services and collaboration tools, for performance reasons.

When connecting mobile devices and desktop computers to an organisation's internet gateway via a virtual private network (VPN) connection, a split tunnel VPN can enable indirect access into the organisation's network from other networks, such as the internet. As such, if split tunnelling is not disabled, there is an increased security risk that the VPN connection could be used as an intrusion vector by malicious actors.

Control: ISM-0874; Revision: 7; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices and desktop computers access the internet via an organisation's internet gateway rather than via a direct connection to the internet.

Control: ISM-0705; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When accessing an organisation's network via a VPN connection, split tunnelling is disabled.

Further information

Further information on allowing the use of privately owned mobile devices and desktop computers by personnel to access their organisation's systems or data can be found in the Australian Signals Directorate's (ASD) *Bring Your Own Device for executives* publication.

Further information and specific guidance on enterprise mobility can be found in ASD's *Risk management of enterprise mobility (including Bring Your Own Device)* publication.

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on the procurement and use of online services can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Mobile device management

Context

This section describes the hardening of privately owned and organisation-owned mobile devices, such as smartphones and tablets that use a mobile operating system. Alternatively, guidance for privately owned and organisation-owned mobile devices that use a desktop operating system is available in the 'Operating system hardening' section of the *Guidelines for system hardening*.

Mobile device management policy

Since mobile devices routinely leave the office environment, and the protection it affords, it is important that a mobile device management policy is developed, implemented and maintained to ensure that mobile devices are sufficiently hardened. In doing so, it is important that Mobile Device Management solutions that have completed a Common Criteria evaluation against the *Protection Profile for Mobile Device Management*, version 4.0 or later, are used to enforce mobile device management policy.

Control: ISM-1533; Revision: 3; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A mobile device management policy is developed, implemented and maintained.

Control: ISM-1195; Revision: 2; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile Device Management solutions that have completed a Common Criteria evaluation against the Protection Profile for Mobile Device Management, version 4.0 or later, are used to enforce mobile device management policy.

Approved mobile platforms

To ensure an appropriate level of security, mobile devices that access OFFICIAL: Sensitive or PROTECTED systems or data should use mobile platforms that have completed a Common Criteria evaluation against the *Protection Profile for Mobile Device Fundamentals*, version 3.3 or later, and are operated in accordance with the latest version of their associated ASD security configuration guide. Furthermore, to ensure interoperability and maintain trust, mobile devices that access SECRET or TOP SECRET systems or data must use mobile platforms that have been issued an Approval for Use by ASD and are operated in accordance with the latest version of their associated Australian Communications Security Instruction.

Control: ISM-1867; Revision: 1; Updated: Mar-24; Applicable: OS, P; Essential 8: N/A
Mobile devices that access OFFICIAL: Sensitive or PROTECTED systems or data use mobile platforms that have completed a Common Criteria evaluation against the Protection Profile for Mobile Device Fundamentals, version 3.3 or later, and are operated in accordance with the latest version of their associated ASD security configuration guide.

Control: ISM-0687; Revision: 10; Updated: Sep-23; Applicable: S, TS; Essential 8: N/A
Mobile devices that access SECRET or TOP SECRET systems or data use mobile platforms that have been issued an Approval for Use by ASD and are operated in accordance with the latest version of their associated Australian Communications Security Instruction.

Encrypted storage

Suitably encrypting the internal storage, and any removable media, for mobile devices will help prevent malicious actors from gaining easy access to any sensitive or classified data stored on them if they are lost or stolen. As such, it is critical that ASD-approved cryptography is used.

Control: ISM-0869; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices encrypt their internal storage and any removable media using ASD-approved cryptography.

Control: ISM-1868; Revision: 0; Updated: Sep-23; Applicable: S, TS; Essential 8: N/A
SECRET and TOP SECRET mobile devices do not use removable media unless approved beforehand by ASD.

Encrypted communications

Failure to suitably encrypt mobile device communications, including those of mobile applications, when communicating sensitive or classified data presents an unacceptable security risk. As such, when encrypting data in transit, it is critical that ASD-approved cryptography is used.

Control: ISM-1085; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices encrypt all sensitive or classified data communicated over public network infrastructure using ASD-approved cryptography.

Control: ISM-2108; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile applications encrypt all sensitive or classified data communicated over public network infrastructure using ASD-approved cryptography.

Maintaining mobile device security

Poorly secured mobile devices are more vulnerable to compromise and can provide malicious actors with a potential access point into any connected systems. Although an organisation may initially provide secure mobile devices, their security posture may degrade over time if personnel can install non-approved applications and disable or modify security functionality. Furthermore, it is important that security updates are applied to mobile devices as soon as they become available to maintain their security posture.

Control: ISM-1886; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are configured to operate in a supervised (or equivalent) mode.

Control: ISM-2096; Revision: 0; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are configured to enforce separation between organisational and personal mobile applications and data.

Control: ISM-2097; Revision: 0; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are configured with always on VPN functionality.

Control: ISM-1887; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are configured with remote locate and wipe functionality.

Control: ISM-1888; Revision: 1; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are configured with secure password-based lock screens.

Control: ISM-2098; Revision: 0; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are configured to prevent data transfers over Universal Serial Bus connections.

Control: ISM-0863; Revision: 5; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices prevent personnel from installing non-approved applications once provisioned.

Control: ISM-0864; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices prevent personnel from disabling or modifying security functionality once provisioned.

Control: ISM-1366; Revision: 2; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security updates are applied to mobile devices as soon as they become available.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Further information on Common Criteria Protection Profiles for mobile devices can be found in the following United States' National Information Assurance Partnership publications:

- *Protection Profile for Mobile Device Management Version 4.0*
- *Protection Profile for Mobile Device Fundamentals Version 3.3*.

Further information on hardening mobile platforms can be found in the following ASD publications:

- *Security configuration guide: Apple iOS 14 devices*
- *Security configuration guide: Samsung Galaxy S10, S20 and Note 20 devices*
- *Security configuration guide: Viasat Mobile Dynamic Defense*.

Further information on encrypting mobile devices and their communications can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Mobile device usage

Context

This section describes the usage of privately owned and organisation-owned mobile devices that use either a mobile operating system or a desktop operating system.

Mobile device usage policy

Since mobile devices routinely leave the office environment, and the protection it affords, it is important that an organisation develops, implements and maintains a mobile device usage policy governing their use.

Control: ISM-1082; Revision: 3; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A mobile device usage policy is developed, implemented and maintained.

Personnel awareness

As mobile devices often have voice and data communication capabilities, personnel should be made aware of the sensitivity or classification of voice and data that mobile devices have been approved to process, store and communicate. In addition, personnel should be made aware of common security practices for mobile device usage.

Control: ISM-1083; Revision: 2; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised of the sensitivity or classification permitted for voice and data communications when using mobile devices.

Control: ISM-1299; Revision: 4; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised to take the following precautions when using mobile devices:

- *never leave mobile devices or removable media unattended, including by placing them in checked-in luggage or leaving them in hotel safes*
- *never store credentials with mobile devices that they grant access to, such as in laptop computer bags*
- *never lend mobile devices or removable media to untrusted people, even if briefly*
- *never allow untrusted people to connect their mobile devices or removable media to your mobile devices, including for charging*
- *never connect mobile devices to designated charging stations or wall outlet charging ports*
- *never use gifted or unauthorised peripherals, chargers or removable media with mobile devices*
- *never use removable media for data transfers or backups that have not been checked for malicious code beforehand*

- *avoid reuse of removable media once used with other parties' systems or mobile devices*
- *avoid connecting mobile devices to open or untrusted Wi-Fi networks*
- *consider disabling any communications capabilities of mobile devices when not in use, such as Wi-Fi, Bluetooth, Near Field Communication and ultra-wideband*
- *consider periodically rebooting mobile devices*
- *consider using a VPN connection to encrypt all cellular and wireless communications*
- *consider using encrypted email or messaging apps for all communications.*

Using paging, message services and messaging apps

As paging, messaging services and many messaging apps do not sufficiently encrypt data in transit, they cannot be relied upon for the communication of sensitive or classified data.

Control: ISM-0240; Revision: 7; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Paging, Multimedia Message Service, Short Message Service and messaging apps are not used to communicate sensitive or classified data.

Using Bluetooth functionality

To mitigate security risks associated with pairing mobile devices with other Bluetooth devices, Bluetooth version 4.1 introduced the Secure Connections functionality for Bluetooth Classic, while Bluetooth version 4.2 introduced the Secure Connections functionality for Bluetooth Low Energy. This functionality uses keys generated using Elliptic Curve Diffie-Hellman cryptography, offering greater security compared to previous key exchange protocols. However, personnel should still consider the location and way they pair non-classified, OFFICIAL: Sensitive and PROTECTED mobile devices with other Bluetooth devices, such as by avoiding pairing devices in public locations, and remove all Bluetooth pairings when there is no longer a requirement for their use. In contrast, the Bluetooth protocol provides inadequate protection for the communication of SECRET and TOP SECRET data. As such, Bluetooth functionality is not suitable for use with SECRET and TOP SECRET mobile devices.

Control: ISM-1196; Revision: 4; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
Non-classified, OFFICIAL: Sensitive and PROTECTED mobile devices are configured to remain undiscoverable to other Bluetooth devices except during Bluetooth pairing.

Control: ISM-1200; Revision: 7; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
Bluetooth pairing for non-classified, OFFICIAL: Sensitive and PROTECTED mobile devices is performed using Secure Connections, preferably with Numeric Comparison if supported.

Control: ISM-1198; Revision: 4; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
Bluetooth pairing for non-classified, OFFICIAL: Sensitive and PROTECTED mobile devices is performed in a manner such that connections are only made between intended Bluetooth devices.

Control: ISM-1199; Revision: 5; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
Bluetooth pairings for non-classified, OFFICIAL: Sensitive and PROTECTED mobile devices are removed when there is no longer a requirement for their use.

Control: ISM-0682; Revision: 5; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
Bluetooth functionality is not enabled on SECRET and TOP SECRET mobile devices.

Connecting mobile devices to connected vehicles

Connected vehicles often monitor, record, aggregate and communicate data on vehicle occupants, their connected mobile devices and their surrounding environment. In many cases, this data is then sent to the vehicle manufacturer, which could then be sold to or shared with third parties.

Control: ISM-2099; Revision: 0; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are not connected to the infotainment systems of connected vehicles.

Using mobile devices within or near connected vehicles

Personnel should be aware of the environment in which they use mobile devices to view or communicate sensitive or classified data. Including by ensuring that sensitive or classified data is not viewed or communicated within or near connected vehicles due to the potential for mobile device screens to be recorded by cameras or for conversations to be recorded, retained and communicated by connected vehicle infotainment systems or connected services.

Control: ISM-2100; Revision: 0; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Sensitive or classified data is not viewed on mobile devices within or near connected vehicles.

Control: ISM-2101; Revision: 0; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Sensitive or classified phone calls and conversations are not conducted within or near connected vehicles.

Using mobile devices in public spaces

Personnel should be aware of the environment in which they use mobile devices to view or communicate sensitive or classified data. Including by ensuring that sensitive or classified data is not observed by other parties in public areas, such as on public transport, in transit lounges and at coffee shops. In some cases, privacy filters can be applied to the screen of a mobile device to prevent onlookers from reading content off its screen.

In addition, personnel should maintain awareness of the environments from which they conduct sensitive or classified phone calls and the potential for their conversations to be overheard.

Control: ISM-0866; Revision: 6; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Sensitive or classified data is not viewed on mobile devices in public locations unless care is taken to reduce the chance of the screen of a mobile device being observed.

Control: ISM-1145; Revision: 4; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
Privacy filters are applied to the screens of SECRET and TOP SECRET mobile devices.

Control: ISM-1644; Revision: 1; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Sensitive or classified phone calls and conversations are not conducted in public locations unless care is taken to reduce the chance of conversations being overheard.

Maintaining control of mobile devices

As mobile devices are portable in nature, and can be easily lost or stolen, personnel should maintain continual direct supervision of them when being actively used and ensure they are carried or stored in a secured state when not being actively used. While mobile devices may be encrypted, the effectiveness of encryption might be reduced if they are lost or stolen while in sleep mode or powered on with a locked screen.

Control: ISM-0871; Revision: 3; Updated: Apr-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are kept under continual direct supervision when being actively used.

Control: ISM-0870; Revision: 3; Updated: Apr-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile devices are carried or stored in a secured state when not being actively used.

Control: ISM-1084; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If unable to carry or store mobile devices in a secured state, they are physically transferred in a security briefcase or an approved multi-use satchel, pouch or transit bag.

Mobile device emergency sanitisation processes and procedures

The sanitisation of mobile devices in emergencies can assist in reducing the potential for compromise of data by malicious actors. This may be achieved by using a remote wipe capability, a cryptographic key zeroise or sanitisation function if present.

Control: ISM-0701; Revision: 6; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Mobile device emergency sanitisation processes, and supporting mobile device emergency sanitisation procedures, are developed, implemented and maintained.

Control: ISM-0702; Revision: 5; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
If a cryptographic zeroise or sanitise function is provided for cryptographic keys on a SECRET or TOP SECRET mobile device, the function is used as part of mobile device emergency sanitisation processes and procedures.

Before travelling overseas with mobile devices

Personnel travelling overseas with mobile devices face additional security risks compared to travelling domestically, especially when travelling to high or extreme risk countries. As such, appropriate precautions should be taken. Personnel should also be aware that when they leave Australian borders, they also leave behind any expectations of privacy.

Control: ISM-1298; Revision: 2; Updated: Oct-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel are advised of privacy and security risks when travelling overseas with mobile devices.

Control: ISM-1554; Revision: 2; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If travelling overseas with mobile devices to high or extreme risk countries, personnel are:

- *issued with newly provisioned user accounts, mobile devices and removable media from a pool of dedicated travel devices which are used solely for work-related activities*
- *advised on how to apply and inspect tamper seals to key areas of mobile devices*
- *advised to avoid taking any personal mobile devices, especially if rooted or jailbroken.*

Control: ISM-1555; Revision: 3; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Before travelling overseas with mobile devices, personnel take the following actions:

- *record all details of the mobile devices being taken, such as product types, serial numbers and International Mobile Equipment Identity numbers*
- *update all operating systems and applications*
- *remove all non-essential data, applications and user accounts*
- *backup all remaining data, applications and settings.*

While travelling overseas with mobile devices

Personnel lose control of mobile devices and removable media any time they are not on their person. In addition, allowing untrusted people to access mobile devices provides an opportunity for them to be tampered with.

Control: ISM-1088; Revision: 6; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel report the potential compromise of mobile devices, removable media or credentials to their organisation as soon as possible, especially if they:

- *provide credentials to foreign government officials*
- *decrypt mobile devices for foreign government officials*
- *have mobile devices taken out of sight by foreign government officials*
- *have mobile devices or removable media stolen, including if later returned*
- *lose mobile devices or removable media, including if later found*
- *observe unusual behaviour of mobile devices.*

After travelling overseas with mobile devices

Following overseas travel with mobile devices, personnel should take appropriate precautions to ensure that they do not pose an undue security risk to their organisation's systems. In most cases, sanitising and resetting mobile devices, including all removable media, will be sufficient. However, upon returning from high or extreme risk countries, additional precautions will likely be needed.

Control: ISM-1300; Revision: 6; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Upon returning from travelling overseas with mobile devices, personnel take the following actions:

- *sanitise and reset mobile devices, including all removable media*
- *decommission any credentials that left their possession during their travel*
- *report if significant doubt exists as to the integrity of any mobile devices or removable media.*

Control: ISM-1556; Revision: 3; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If returning from travelling overseas with mobile devices to high or extreme risk countries, personnel take the following additional actions:

- *reset credentials used with mobile devices, including those used for remote access to their organisation's systems*
- *monitor user accounts for any indicators of compromise, such as failed logon attempts.*

Further information

Further information on Bluetooth security can be found in National Institute of Standards and Technology Special Publication 800-121 Rev. 2, *Guide to Bluetooth Security*.

Further information on usage of mobile devices in SECRET and TOP SECRET areas can be found in the 'Facilities and systems' section of the *Guidelines for physical security*.

Further information on security briefcases can be found in the Australian Security Intelligence Organisation's Security Equipment Guide-005, *Briefcases for the Carriage of Security Classified Information*. This publication is available from the Protective Security Policy GovTEAMS community or the Australian Security Intelligence Organisation by email.

Further information on approved multi-use satchels, pouches and transit bags can be found on the Security Construction and Equipment Committee's *Security Equipment Evaluated Products List*.

Guidelines for evaluated products

Evaluated product procurement

Context

An evaluated product provides a level of assurance in its security functionality that an unevaluated product does not. Evaluation documentation can assist an organisation in assessing the suitability of products and making informed procurement and deployment decisions.

The Australian Certification Authority within the Australian Signals Directorate (ASD) certifies product evaluations conducted by licensed commercial facilities, in accordance with the Common Criteria (i.e. the International Organization for Standardization/International Electrotechnical Commission 15408 series), as part of the Australian Information Security Evaluation Program (AISEP).

In support of Common Criteria evaluations, a Protection Profile (PP) is a technology-specific document that defines the security functionality that must be included in a Common Criteria evaluated product to mitigate specific cyber threats. PPs can support Secure by Design principles and practices by defining security functional and assurance requirements for classes of products against which individual products can be evaluated. PPs can be published by a recognised Common Criteria Recognition Arrangement (CCRA) scheme or by the CCRA body itself. PPs published by the CCRA body are referred to as collaborative PPs. ASD recognises all collaborative PPs listed on the Common Criteria website, and will consider national PPs listed on the United States' National Information Assurance Partnership website, in addition to those listed on ASD's AISEP webpage. Where a PP does not exist, an evaluation based on an Evaluation Assurance Level (EAL) may be accepted. Such evaluations are capped at EAL2+ as this represents the best balance between completion time and meaningful security assurance gains.

In addition, some CCRA schemes leverage the Cryptographic Algorithm Validation Program for the validation of cryptographic algorithm implementations used by cryptographic modules within evaluated products. In such cases, cryptographic algorithm testing is performed by Cryptographic and Security Testing laboratories that are accredited by the United States' National Voluntary Laboratory Accreditation Program.

Finally, ASD also performs evaluations for products used to protect SECRET and TOP SECRET data via its High Assurance Evaluation Program.

Evaluated product selection

A Common Criteria evaluation is traditionally conducted at a specified EAL, while evaluations against a PP exist outside of this scale. Although products evaluated against a PP will fulfil the Common Criteria EAL requirements, the EAL number will not be published. In addition, PP modules contain additional requirements that are complementary to or extend upon collaborative PPs. For example, a stateful traffic filtering PP module may apply to a firewall evaluated against a

network device collaborative PP. As such, when procuring an evaluated product that has completed a PP-based evaluation, it is important to ensure that all applicable PP modules, as well as a software bill of materials assessment if applicable, were included as part of the product's evaluation.

Furthermore, in choosing evaluated products, an organisation should determine their suitability by reviewing their evaluation documentation. This includes the security target and certification report. Products that are undergoing a Common Criteria evaluation will not have this information publicly available; however, documentation can be obtained from ASD if a product is being evaluated through the AISEP. For a product that is in evaluation through a foreign scheme, the product's vendor can be contacted directly for further information.

The Common Criteria's *Certified Products List* contains a list of products that have been evaluated, certified and mutually recognised.

Where a suitable evaluated product is not available for a particular product class or use case, an organisation should consider the associated security risks and determine its security requirements when considering alternative products. Where additional product assurance is required, an organisation may also consider seeking an evaluation of a suitable product.

Finally, the *Information security manual* identifies a number of product classes and use cases for which evaluated products are required in certain circumstances. Further information on applicable requirements can be found in the relevant sections. For cryptographic equipment, applications and libraries, an organisation should consider the assurance preferences described in the 'Cryptographic implementation assurance' section of the *Guidelines for cryptography* when selecting a suitable product.

Control: ISM-0280; Revision: 9; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If procuring an evaluated product, a product that has completed a PP-based evaluation, including against all applicable PP modules (as well as a software bill of materials assessment if applicable), is selected in preference to one that has completed an EAL-based evaluation.

Delivery of evaluated products

It is important that an organisation ensures that products they source are the actual products that are delivered. In the case of evaluated products, if the product delivered differs from an evaluated version, then the assurance gained from the evaluation may not necessarily apply.

Packaging and delivery practices can vary greatly from product to product. For most evaluated products, standard commercial packaging and delivery practices are likely to be sufficient. However, in some cases more secure packaging and delivery practices, including tamper-evident seals and secure transportation, may be required. In the case of the digital delivery of evaluated products, digital signatures or cryptographic checksums can often be used to ensure the integrity of the product that was delivered.

Control: ISM-0285; Revision: 1; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Evaluated products are delivered in a manner consistent with any delivery procedures defined in associated evaluation documentation.

Control: ISM-0286; Revision: 8; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
When procuring high assurance information technology (IT) equipment, ASD is contacted for any equipment-specific delivery procedures.

Further information

Further information on the High Assurance Evaluation Program is available from ASD.

Further information on the AISEP is available from ASD.

Further information on Common Criteria evaluated products can be found on the Common Criteria's *Certified Products List*.

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Evaluated product usage

Context

An evaluated product is operating in an evaluated configuration if:

- functionality that it uses was in the scope of the evaluation and it is implemented in the specified manner
- only product updates that have been assessed through maintenance and re-evaluation activities (known as assurance continuity) have been applied
- the environment complies with assumptions or organisational security policies stated in the evaluation documentation.

Conversely, an evaluated product is operating in an unevaluated configuration when it does not meet the requirements of the evaluated configuration and guidance provided in its certification report.

In most cases, the latest patched version of an evaluated product will be more secure than an older unpatched version. While the application of patches will not normally place an evaluated product into an unevaluated configuration, some vendors may include new functionality that has not been evaluated with their patches. In such cases, an organisation should use their judgement to determine whether this deviation from the evaluated configuration constitutes additional security risk or not.

Using evaluated products

Product evaluation provides assurance that a product and its security functionality will operate as expected when used in a clearly defined configuration. The scope of the evaluation specifies how the product is to be installed, configured, administered and operated, as well as the security functionality to be used. Using an evaluated product in an unevaluated configuration could introduce security risks that were not considered as part of the product's evaluation.

Control: ISM-0289; Revision: 3; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Evaluated products are installed, configured, administered and operated in an evaluated configuration and in accordance with vendor guidance.

Control: ISM-0290; Revision: 9; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
High assurance IT equipment is installed, configured, administered and operated in an evaluated configuration and in accordance with ASD guidance.

Further information

Further information on patching or updating IT equipment can be found in the 'System maintenance' section of the *Guidelines for system management*.

Further information on the installation, configuration, administration and operation of Common Criteria products is available from vendors and can be found in evaluation documentation on the Common Criteria's *Certified Products List*.

Further information on the installation, configuration, administration and operation of high assurance IT equipment is available from ASD.

Guidelines for information technology equipment

IT equipment usage

IT equipment management policy

Since information technology (IT) equipment can process, store or communicate sensitive or classified data, it is important that an IT equipment management policy is developed, implemented and maintained to ensure that IT equipment, and the data it processes, stores or communicates, is protected in an appropriate manner.

Control: ISM-1551; Revision: 2; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An IT equipment management policy is developed, implemented and maintained.

Hardening IT equipment configurations

When IT equipment is deployed in its default state, or with an unapproved configuration, it can lead to an insecure operating environment that may allow malicious actors to gain an initial foothold on networks. Many settings exist within IT equipment enabling them to be configured in an approved secure state to minimise this security risk. As such, the Australian Signals Directorate (ASD) and vendors often produce hardening guidance to assist in hardening the configuration of IT equipment. However, in situations where ASD and vendor hardening guidance conflicts, precedence should be given to implementing the most restrictive guidance.

Control: ISM-1913; Revision: 1; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Approved configurations for IT equipment are developed, implemented and maintained.

Control: ISM-1858; Revision: 3; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment is hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur.

IT equipment registers

Developing, implementing, maintaining and regularly verifying registers of authorised IT equipment can assist an organisation in tracking legitimate IT equipment as well as determining whether unauthorised IT equipment, such as workstations, servers and network devices, has been introduced into their organisation. In doing so, an organisation may choose to split their IT equipment register into two by focusing on whether IT equipment is connected to their network or not.

Control: ISM-0336; Revision: 10; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A networked IT equipment register is developed, implemented, maintained and regularly verified.

Control: ISM-1869; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A non-networked IT equipment register is developed, implemented, maintained and regularly verified.

Labelling IT equipment

Applying protective markings to IT equipment assists to reduce the likelihood that a human user will accidentally input data into it that it is not approved for processing, storing or communicating.

While text-based protective markings are typically used for labelling IT equipment, there may be circumstances where colour-based protective markings or other marking schemes need to be used instead. In such cases, the marking scheme will need to be documented and personnel trained in its use.

Control: ISM-0294; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment, except for high assurance IT equipment, is labelled with protective markings reflecting its sensitivity or classification.

Labelling high assurance IT equipment

High assurance IT equipment often has tamper-evident seals placed on its external surfaces. To assist human users in noticing changes to these seals, and to prevent functionality being degraded, an organisation should limit the use of labels on high assurance IT equipment.

Control: ISM-0296; Revision: 7; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
ASD's approval is sought before applying labels to external surfaces of high assurance IT equipment.

Classifying IT equipment

The purpose of classifying IT equipment is to acknowledge the sensitivity or classification of data that it is approved for processing, storing or communicating.

Classifying IT equipment also assists in ensuring that the appropriate sanitisation, destruction and disposal processes are followed at the end of its life.

Control: ISM-0293; Revision: 6; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment is classified based on the highest sensitivity or classification of data that it is approved for processing, storing or communicating.

Handling IT equipment

When IT equipment displays, processes, stores or communicates sensitive or classified data, it will need to be handled as per the sensitivity or classification of that data. However, applying encryption to media within the IT equipment may change the way it needs to be handled. Any change in handling needs to be based on the original sensitivity or classification of data residing on media within the IT equipment and the level of assurance in the cryptographic equipment, applications or libraries being used to encrypt it.

Control: ISM-1599; Revision: 1; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment is handled in a manner suitable for its sensitivity or classification.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on securing IT equipment when not in use can be found in the 'IT equipment and media' section of the *Guidelines for physical security*.

Further information on encrypting media within IT equipment can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Further information on the protection of IT equipment can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

IT equipment maintenance or repairs

Maintenance or repairs of high assurance IT equipment

Due to the nature of high assurance IT equipment, it is important that ASD's approval is sought before any maintenance or repairs are undertaken.

Control: ISM-1079; Revision: 7; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
ASD's approval is sought before undertaking any maintenance or repairs to high assurance IT equipment.

On-site maintenance or repairs

Undertaking maintenance or repairs to IT equipment could impact its integrity. As such, using an appropriately cleared technician to undertake such work is considered the most secure approach. This ensures that if data is disclosed, the technician understands the requirements for its protection. Conversely, an organisation choosing to use a technician who is not appropriately cleared to undertake such work should ensure that cleared and knowledgeable personnel escort the technician while the work is undertaken.

Control: ISM-0305; Revision: 8; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Maintenance or repairs of IT equipment are carried out on site by an appropriately cleared technician.

Control: ISM-0307; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If an appropriately cleared technician is not used to undertake maintenance or repairs to IT equipment, the IT equipment and associated media are sanitised before maintenance or repairs.

Control: ISM-0306; Revision: 8; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If an appropriately cleared technician is not used to undertake maintenance or repairs to IT equipment, the technician is escorted by someone who:

- *has the authority to direct the technician*
- *is appropriately cleared and briefed*
- *is sufficiently familiar with the IT equipment to understand the work being undertaken*
- *takes all responsible measures to ensure the integrity of the IT equipment*
- *takes due care to ensure that data is not disclosed.*

Off-site maintenance or repairs

An organisation choosing to have IT equipment maintained or repaired off site should do so at facilities approved for handling the sensitivity or classification of the IT equipment. However, an organisation may be able to sanitise the IT equipment prior to transport, and subsequent maintenance or repairs, to change how it needs to be handled.

Control: ISM-0310; Revision: 9; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment maintained or repaired off site is handled at facilities approved for handling the sensitivity or classification of the IT equipment.

Inspection of IT equipment following maintenance or repairs

Following maintenance or repairs to IT equipment, it is important that it is inspected to ensure that it retains its approved configuration and that no unauthorised modifications have been made.

Control: ISM-1598; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Following maintenance or repairs to IT equipment, it is inspected to confirm that it retains its approved configuration and that no unauthorised modifications have been made.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on the sanitisation of media can be found in the 'Media sanitisation' section of the *Guidelines for media*.

IT equipment sanitisation and destruction

IT equipment sanitisation processes and procedures

Developing, implementing and maintaining processes and procedures for IT equipment sanitisation will ensure that an organisation carries out IT equipment sanitisation in an appropriate and consistent manner.

Control: ISM-0313; Revision: 7; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment sanitisation processes, and supporting IT equipment sanitisation procedures, are developed, implemented and maintained.

IT equipment destruction processes and procedures

Developing, implementing and maintaining processes and procedures for IT equipment destruction will ensure that an organisation carries out IT equipment destruction in an appropriate and consistent manner.

Control: ISM-1741; Revision: 2; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment destruction processes, and supporting IT equipment destruction procedures, are developed, implemented and maintained.

Sanitising IT equipment

When sanitising IT equipment, any media within the IT equipment should be removed or sanitised. Once any media has been removed or sanitised, IT equipment can be considered sanitised. However, if media cannot be removed or sanitised, the IT equipment should be destroyed as per media destruction requirements.

Media typically found in IT equipment includes:

- electrostatic memory devices, such as laser printer cartridges used in multifunction devices (MFDs)
- non-volatile magnetic memory, such as hard disks
- non-volatile semiconductor memory, such as flash cards and solid-state drives
- volatile memory, such as random-access memory sticks.

Control: ISM-0311; Revision: 7; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment containing media is sanitised by removing the media from the IT equipment or by sanitising the media in situ.

Control: ISM-1742; Revision: 1; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment that cannot be sanitised is destroyed.

Sanitising highly sensitive IT equipment

IT equipment located overseas that has processed, stored or communicated Australian Eyes Only (AUSTEO) or Australian Government Access Only (AGAO) data can have more severe consequences for Australian interests if not sanitised appropriately.

Control: ISM-1218; Revision: 5; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
IT equipment, including associated media, that is located overseas and has processed, stored or communicated AUSTEO or AGAO data, is sanitised in situ.

Control: ISM-0312; Revision: 7; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
IT equipment, including associated media, that is located overseas and has processed, stored or communicated AUSTEO or AGAO data that cannot be sanitised in situ, is returned to Australia for destruction.

Destroying high assurance IT equipment

Due to the nature of high assurance IT equipment, and many of the protective mechanisms it employs, sanitisation alone is not sufficient prior to its disposal. As such, all high assurance IT equipment should be destroyed prior to its disposal.

Control: ISM-0315; Revision: 9; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
High assurance IT equipment is destroyed prior to its disposal.

Sanitising printers and multifunction devices

When sanitising printers and MFDs, the printer cartridge or MFD print drum should be sanitised in addition to the removal or sanitisation of any media. This can be achieved by printing random text with no blank areas on each colour printer cartridge or MFD print drum. In addition, image transfer rollers and platens can become imprinted with text and images over time and should be destroyed if any text or images have been retained. Finally, any paper jammed in the paper path should be removed.

When printer cartridges and MFD print drums cannot be sanitised due to a hardware failure, or when they are empty, there is no other option but to destroy them. Printer ribbons cannot be sanitised and should be destroyed.

Control: ISM-0317; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
At least three pages of random text with no blank areas are printed on each colour printer cartridge or MFD print drum.

Control: ISM-1219; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
MFD print drums and image transfer rollers are inspected and destroyed if there is remnant toner that cannot be removed or a print is visible on the image transfer roller.

Control: ISM-1220; Revision: 2; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Printer and MFD platens are inspected and destroyed if any text or images are retained on the platen.

Control: ISM-1221; Revision: 1; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Printers and MFDs are checked to ensure no pages are trapped in the paper path due to a paper jam.

Control: ISM-0318; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When unable to sanitise printer cartridges or MFD print drums, they are destroyed as per electrostatic memory devices.

Control: ISM-1534; Revision: 0; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Printer ribbons in printers and MFDs are removed and destroyed.

Sanitising televisions and computer monitors

All types of televisions and computer monitors can retain data if mitigating measures are not taken during their lifetime. Cathode Ray Tube monitors and plasma screens can be affected by burn-in while Liquid Crystal Display and Organic Light Emitting Diode screens can be affected by image persistence.

Televisions and computer monitors can be visually inspected by turning up the brightness and contrast to their maximum level to determine if any data has been burnt into or persists on the screen. If burn-in or image persistence is removed by this activity, televisions and computer monitors can be considered sanitised. However, if burn-in or persistence is not removed through these measures, televisions and computer monitors cannot be sanitised and should be destroyed.

If televisions or computer monitors cannot be powered on, such as due to a faulty power supply, they cannot be sanitised and should be destroyed.

Control: ISM-1076; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Televisions and computer monitors with minor burn-in or image persistence are sanitised by displaying a solid white image on the screen for an extended period.

Control: ISM-1222; Revision: 1; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Televisions and computer monitors that cannot be sanitised are destroyed.

Sanitising network devices

As network devices can store network configuration data or credentials in their memory, the memory should be sanitised prior to the disposal of the network devices. The correct method to sanitise network devices will depend on their configuration and the type of memory they use. As such, device-specific guidance provided in evaluation documentation, or vendor sanitisation guidance, should be consulted to determine the most appropriate method to sanitise memory in network devices.

Control: ISM-1223; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Memory in network devices is sanitised using the following processes, in order of preference:

- *following device-specific guidance provided in evaluation documentation*
- *following vendor sanitisation guidance*
- *loading a dummy configuration file, performing a factory reset and then reinstalling firmware.*

Further information

Further information on the sanitisation of media can be found in the ‘Media sanitisation’ section of the *Guidelines for media*.

Further information on the destruction of media can be found in the 'Media destruction' section of the *Guidelines for media*.

Further information on the sanitisation of network devices is available from vendors and can be found in evaluation documentation on the Common Criteria's *Certified Products List*.

IT equipment disposal

IT equipment disposal processes and procedures

Developing, implementing and maintaining processes and procedures for IT equipment disposal will ensure that an organisation carries out IT equipment disposal in an appropriate and consistent manner.

Control: ISM-1550; Revision: 3; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment disposal processes, and supporting IT equipment disposal procedures, are developed, implemented and maintained.

Disposal of IT equipment

Before IT equipment can be released into the public domain, it needs to be sanitised, destroyed or declassified. As sanitised, destroyed or declassified IT equipment still presents a security risk, albeit minor, an appropriate authority needs to formally authorise its release into the public domain. Furthermore, as part of disposal processes, removing labels and markings indicating the owner, sensitivity, classification or any other marking that can associate IT equipment with its prior use will ensure it does not draw undue attention following its disposal.

Control: ISM-1217; Revision: 3; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Labels and markings indicating the owner, sensitivity, classification or any other marking that can associate IT equipment with its prior use are removed prior to its disposal.

Control: ISM-0321; Revision: 6; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
When disposing of IT equipment that has been designed or modified to meet emanation security standards, ASD is contacted for requirements relating to its disposal.

Control: ISM-0316; Revision: 4; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Following sanitisation, destruction or declassification, a formal administrative decision is made to release IT equipment, or its waste, into the public domain.

Guidelines for media

Media usage

Media management policy

Since media can store sensitive or classified data, it is important that a media management policy is developed, implemented and maintained to ensure that all types of media, and the data it stores, is protected in an appropriate manner. In many cases, an organisation's media management policy will be closely tied to their removable media usage policy.

Control: ISM-1549; Revision: 1; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A media management policy is developed, implemented and maintained.

Removable media usage policy

Establishing a removable media usage policy can decrease the likelihood and consequence of data spills, data loss and data theft. In doing so, a removable media usage policy will likely cover the following:

- permitted types and uses of removable media
- registration and labelling of removable media
- handling and protection of removable media
- reporting of lost or stolen removable media
- sanitisation or destruction of removable media at the end of its life.

Control: ISM-1359; Revision: 4; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A removable media usage policy is developed, implemented and maintained.

Removable media register

Developing, implementing, maintaining and regularly verifying a register of removable media can assist an organisation in tracking and accounting for authorised removable media as well as identifying any unauthorised removable media in use within their organisation.

Control: ISM-1713; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A removable media register is developed, implemented, maintained and regularly verified.

Labelling media

Labelling media helps personnel to identify its sensitivity or classification and ensure that appropriate measures are applied to its storage, handling and use.

While text-based protective markings are typically used for labelling media, there may be circumstances where colour-based protective markings or other marking schemes need to be used instead. In such cases, the marking scheme will need to be documented and personnel trained in its use.

Control: ISM-0332; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media, except for internally mounted fixed media within information technology equipment, is labelled with protective markings reflecting its sensitivity or classification.

Classifying media

Media that is not correctly classified could be stored and handled inappropriately, accessed by personnel who do not have an appropriate security clearance or used with systems it is not authorised to be used with.

Control: ISM-0323; Revision: 8; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media is classified to the highest sensitivity or classification of data it stores, unless the media has been classified to a higher sensitivity or classification.

Control: ISM-0337; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media is only used with systems that are authorised to process, store or communicate its sensitivity or classification.

Reclassifying media

Some activities may necessitate or allow for a change to the sensitivity or classification of media. For example, when media is connected to a system that lacks a mechanism through which read-only access can be ensured, when media is sanitised or destroyed, or when data stored on media is subject to a sensitivity or classification change.

Control: ISM-0325; Revision: 6; Updated: Apr-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Any media connected to a system with a higher sensitivity or classification than the media is reclassified to the higher sensitivity or classification, unless the media is read-only or the system has a mechanism through which read-only access can be ensured.

Control: ISM-0330; Revision: 7; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Before reclassifying media to a lower sensitivity or classification, the media is sanitised or destroyed, and a formal administrative decision is made to reclassify it.

Encrypting media

Suitably encrypting media will help prevent malicious actors from gaining easy access to any sensitive or classified data stored on it if it is lost or stolen. As such, it is critical that Australian Signals Directorate (ASD)-approved cryptography is used.

Furthermore, applying encryption to media may change the way it needs to be handled. In doing so, any change in handling needs to be based on the original sensitivity or classification of the

media and the level of assurance in the cryptographic equipment, applications or libraries being used to encrypt it.

Finally, when encryption is applied to media, it is important that full disk encryption is used as it provides a greater level of protection than file-based encryption. This is because while file-based encryption may encrypt individual files, there is the possibility that unencrypted copies of files may be left in temporary locations used by an operating system.

Control: ISM-1059; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All data stored on media is encrypted using ASD-approved cryptography.

Control: ISM-0459; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Full disk encryption, or partial encryption where access controls only allow writing to encrypted partitions or volumes, is implemented when encrypting media.

Control: ISM-2109; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Pre-boot authentication using passwords, or managed network-based key release, is implemented for media containing encrypted system volumes.

Handling media

As media can be easily misplaced or stolen, physical handling measures should be put in place to protect the data stored on it.

Control: ISM-0831; Revision: 5; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media is handled in a manner suitable for its sensitivity or classification.

Sanitising media before first use

Sanitising media before first use can assist in reducing cyber supply chain risks, such as new media containing malicious code. In addition, sanitising media before first use in a different security domain can prevent potential data spills from occurring.

Control: ISM-1600; Revision: 1; Updated: Apr-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media is sanitised before it is used for the first time.

Control: ISM-1642; Revision: 0; Updated: Apr-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media is sanitised before it is reused in a different security domain.

Using media for data transfers

An organisation transferring data between systems belonging to different security domains is strongly encouraged to use write-once media. When done properly, such as using non-rewritable compact discs that have been finalised, this ensures that data from the destination system cannot be accidentally transferred, or maliciously exfiltrated, onto the media and then onto another system. Alternatively, if suitable write-once media is not used, the destination system should have a mechanism through which read-only access can be ensured, such as via a read-only device or

hardware write-blocker. However, the use of read-only mechanisms is not immune to failure or compromise. Therefore, rewritable media should still be sanitised following each data transfer.

It is important to note that for most non-volatile flash memory media, it will be possible to sanitise and reclassify it following a data transfer to allow it to be connected to other systems again. This is not possible for SECRET and TOP SECRET non-volatile flash memory media as it cannot be reclassified following sanitisation.

Control: ISM-0347; Revision: 5; Updated: Apr-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When transferring data manually between two systems belonging to different security domains, write-once media is used unless the destination system has a mechanism through which read-only access can be ensured.

Control: ISM-0947; Revision: 6; Updated: Apr-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When transferring data manually between two systems belonging to different security domains, rewritable media is sanitised after each data transfer.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on the protection of media can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Further information on securing media when not in use can be found in the 'IT equipment and media' section of the *Guidelines for physical security*.

Further information on encrypting media can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Further information on using media to transfer data between systems can be found in the 'Data transfers' section of the *Guidelines for data transfers*.

Media sanitisation

Context

When sanitising hybrid hard drives, first separate the non-volatile magnetic media from the circuit board containing non-volatile flash memory media and then sanitise each separately.

When sanitising solid-state drives, the method for sanitising non-volatile flash memory media applies.

Media sanitisation processes and procedures

Using approved methods to sanitise media provides a level of assurance that, to the extent possible, no data will be left following sanitisation. The methods described in these guidelines are

designed not only to prevent common data recovery practices but also to protect from those that could emerge in the future.

Control: ISM-0348; Revision: 5; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media sanitisation processes, and supporting media sanitisation procedures, are developed, implemented and maintained.

Volatile media sanitisation

When sanitising volatile media, the specified time to wait following the removal of power is based on applying a safety factor to the time recommended by research into preventing the recovery of data. In addition to the removal of power, SECRET and TOP SECRET volatile media should be overwritten at least once in its entirety with a random pattern followed by a read back for verification.

Control: ISM-0351; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Volatile media is sanitised by removing its power for at least 10 minutes.

Control: ISM-0352; Revision: 4; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
SECRET and TOP SECRET volatile media is sanitised by overwriting it at least once in its entirety with a random pattern followed by a read back for verification.

Treatment of volatile media following sanitisation

Research suggests that short-term remanence effects are likely in volatile media. For example, up to minutes at normal room temperatures and up to hours in extremely cold temperatures. Furthermore, some volatile media can suffer from long-term remanence effects resulting from physical changes due to the continuous storage of static data for extended periods. It is for these reasons that under certain circumstances TOP SECRET volatile media retains its classification following sanitisation.

Typical circumstances preventing the reclassification of TOP SECRET volatile media include a static cryptographic key being stored in the same memory location during every boot of a device, or a static image being displayed on a device and stored in volatile media for a period of months.

Control: ISM-0835; Revision: 5; Updated: Jun-26; Applicable: TS; Essential 8: N/A
Following sanitisation, TOP SECRET volatile media retains its classification if it stored static data for an extended period, or had data repeatedly stored on or written to the same memory location for an extended period.

Non-volatile magnetic media sanitisation

Non-volatile magnetic media encompasses non-volatile magnetic hard drives, magnetic tape and floppy disks. While non-volatile magnetic tape and floppy disks can be sanitised by overwriting them at least once (or three times if pre-2001 or under 15 GB) in their entirety with a random pattern followed by a read back for verification, additional considerations apply to non-volatile

magnetic hard drives due to their use of a host-protected area, device configuration overlay table and growth defects table.

The host-protected area and device configuration overlay table of non-volatile magnetic hard drives are normally not visible to a computer's Unified Extensible Firmware Interface or operating system. Therefore, any sanitisation of the readable sectors of non-volatile magnetic hard drives will leave any data contained in sectors listed in the host-protected area and device configuration overlay table untouched. Some sanitisation applications include the ability to reset non-volatile magnetic hard drives to their default state, removing any host-protected areas or device configuration overlays. This allows the sanitisation applications to see the entire contents of non-volatile magnetic hard drives during subsequent sanitisation processes.

Modern non-volatile magnetic hard drives automatically reallocate space for bad sectors at a hardware level. These bad sectors are maintained in what is known as the growth defects table or 'g-list'. If data was stored in a sector that was subsequently added to the growth defects table, sanitising the non-volatile magnetic hard drive will not overwrite such data. While these sectors may be considered bad by non-volatile magnetic hard drives, quite often this is due to the sectors no longer meeting expected performance norms and not due to an inability to read or write to them. The Advanced Technology Attachment (ATA) secure erase command was built into the firmware of post-2001 non-volatile magnetic hard drives and can access sectors that have been added to the growth defects table.

Modern non-volatile magnetic hard drives also contain a primary defects table or 'p-list'. The primary defects table contains a list of bad sectors found during post-production processes. No data is ever stored in sectors listed in the primary defects table as they are marked as inaccessible before non-volatile magnetic hard drives are used for the first time.

Control: ISM-0354; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Non-volatile magnetic media is sanitised by overwriting it at least once (or three times if pre-2001 or under 15 GB) in its entirety with a random pattern followed by a read back for verification.

Control: ISM-1065; Revision: 3; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The host-protected area and device configuration overlay table are reset prior to the sanitisation of non-volatile magnetic hard drives.

Control: ISM-1067; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The ATA secure erase command is used, in addition to block overwriting software, to ensure the growth defects table of non-volatile magnetic hard drives is overwritten.

Treatment of non-volatile magnetic media following sanitisation

Due to concerns with the sanitisation processes for non-volatile magnetic media, SECRET and TOP SECRET non-volatile magnetic media retains its classification following sanitisation.

Control: ISM-0356; Revision: 6; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
Following sanitisation, SECRET and TOP SECRET non-volatile magnetic media retains its classification.

Non-volatile erasable programmable read-only memory media sanitisation

When sanitising non-volatile erasable programmable read-only memory (EPROM), three times the manufacturer's specification for ultraviolet erasure time should be applied to provide additional certainty in sanitisation processes. Subsequently, the non-volatile EPROM media should be overwritten at least once in its entirety with a random pattern followed by a read back for verification.

Control: ISM-0357; Revision: 5; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Non-volatile EPROM media is sanitised by applying three times the manufacturer's specified ultraviolet erasure time and then overwriting it at least once in its entirety with a random pattern followed by a read back for verification.

Non-volatile electrically erasable programmable read-only memory media sanitisation

A single overwrite with a random pattern, followed by a read back for verification, is considered suitable for sanitising non-volatile electrically erasable programmable read-only memory (EEPROM) media.

Control: ISM-0836; Revision: 3; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Non-volatile EEPROM media is sanitised by overwriting it at least once in its entirety with a random pattern followed by a read back for verification.

Treatment of non-volatile erasable and electrically erasable programmable read-only memory media following sanitisation

As little research has been conducted into the recovery of data from non-volatile EPROM and EEPROM media, SECRET and TOP SECRET EPROM and EEPROM media retains its classification following sanitisation.

Control: ISM-0358; Revision: 6; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
Following sanitisation, SECRET and TOP SECRET non-volatile EPROM and EEPROM media retains its classification.

Non-volatile flash memory media sanitisation

For non-volatile flash memory media, a technique known as wear levelling ensures that writes are distributed evenly across each memory block. This feature necessitates non-volatile flash memory media being overwritten with a random pattern at least twice, and followed by a read back for verification, as this helps to ensure that all memory blocks are overwritten.

Control: ISM-0359; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Non-volatile flash memory media is sanitised by overwriting it at least twice in its entirety with a random pattern followed by a read back for verification.

Treatment of non-volatile flash memory media following sanitisation

Due to the use of wear levelling in non-volatile flash memory media, and the potential for bad memory blocks, it is possible that not all memory blocks will be overwritten during sanitisation processes. For this reason, SECRET and TOP SECRET non-volatile flash memory media retains its classification following sanitisation.

Control: ISM-0360; Revision: 6; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
Following sanitisation, SECRET and TOP SECRET non-volatile flash memory media retains its classification.

Media that cannot be successfully sanitised

In some cases, attempts to sanitise media, or verify the sanitisation of media, will be unsuccessful. For example, due to the media being faulty or damaged. In such cases, the media will need to be destroyed prior to its disposal.

Control: ISM-1735; Revision: 1; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media that cannot be successfully sanitised is destroyed prior to its disposal.

Further information

Further information on the random-access memory testing tool MemTest86 can be obtained from PassMark Software.

Further information on the graphics card random-access memory testing tools MemtestG80 and MemtestCL can be obtained from their GitHub projects.

Further information on HDDerase is available from the Center for Memory and Recording Research at the University of California San Diego. HDDerase can call the ATA secure erase command as well as reset the host-protected area and device configuration overlay table on non-volatile magnetic media.

Media destruction

Media destruction processes and procedures

Developing, implementing and maintaining processes and procedures for media destruction will ensure that an organisation carries out media destruction in an appropriate and consistent manner.

Control: ISM-0363; Revision: 4; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media destruction processes, and supporting media destruction procedures, are developed, implemented and maintained.

Media that cannot be sanitised

Some media types are incapable of being sanitised. As such, they will need to be destroyed prior to their disposal.

Control: ISM-0350; Revision: 5; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The following media types are destroyed prior to their disposal:

- *microfiche and microfilm*
- *optical discs*
- *programmable read-only memory*
- *read-only memory*
- *other types of media that cannot be sanitised.*

Media destruction equipment

When physically destroying media, using approved equipment can provide a level of assurance that the data it stores is destroyed.

Approved equipment includes destruction equipment listed on the Security Construction and Equipment Committee's *Security Equipment Evaluated Products List*, and in the Australian Security Intelligence Organisation's (ASIO) Security Equipment Guide-009, *Optical Media Shredders* and Security Equipment Guide-018, *Destructors*. ASIO's Security Equipment Guides are available from the Protective Security Policy GovTEAMS community or ASIO by email.

If using degaussers to destroy media, the United States' National Security Agency maintains the *NSA/CSS Evaluated Products List for Magnetic Degaussers* and information on common types of magnetic media and their associated magnetic field strengths and orientations.

Control: ISM-1361; Revision: 3; Updated: Jun-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security Construction and Equipment Committee-approved equipment or ASIO-approved equipment is used when destroying media.

Control: ISM-1160; Revision: 2; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If using degaussers to destroy media, degaussers evaluated by the United States' National Security Agency are used.

Media destruction methods

The destruction methods identified below are designed to ensure that recovery of data is impossible or impractical.

Control: ISM-1517; Revision: 0; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Equipment that is capable of reducing microform to a fine powder, with resultant particles not showing more than five consecutive characters per particle upon microscopic inspection, is used to destroy microfiche and microfilm.

Control: ISM-1722; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Electrostatic memory devices are destroyed using a furnace/incinerator, hammer mill, disintegrator or grinder/sander.

Control: ISM-1723; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Magnetic floppy disks are destroyed using a furnace/incinerator, hammer mill, disintegrator, degausser or by cutting.

Control: ISM-1724; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Magnetic hard disks are destroyed using a furnace/incinerator, hammer mill, disintegrator, grinder/sander or degausser.

Control: ISM-1725; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Magnetic tapes are destroyed using a furnace/incinerator, hammer mill, disintegrator, degausser or by cutting.

Control: ISM-1726; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Optical disks are destroyed using a furnace/incinerator, hammer mill, disintegrator, grinder/sander or by cutting.

Control: ISM-1727; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Semiconductor memory is destroyed using a furnace/incinerator, hammer mill or disintegrator.

Control: ISM-0368; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media destroyed using a hammer mill, disintegrator, grinder/sander or by cutting results in media waste particles no larger than 9 mm.

Treatment of media waste particles

Following the destruction of SECRET and TOP SECRET media, normal accounting and verification processes and procedures do not apply. However, if a destruction method is used that results in the generation of media waste particles, such as a hammer mill, disintegrator, grinder/sander or by cutting, it may still need to be stored and handled as classified waste.

Control: ISM-1728; Revision: 0; Updated: Dec-21; Applicable: S; Essential 8: N/A
The resulting media waste particles from the destruction of SECRET media is stored and handled as OFFICIAL if less than or equal to 3 mm, PROTECTED if greater than 3 mm and less than or equal to 6 mm, or SECRET if greater than 6 mm and less than or equal to 9 mm.

Control: ISM-1729; Revision: 0; Updated: Dec-21; Applicable: TS; Essential 8: N/A
The resulting media waste particles from the destruction of TOP SECRET media is stored and handled as OFFICIAL if less than or equal to 3 mm, or SECRET if greater than 3 mm and less than or equal to 9 mm.

Degaussing magnetic media

Degaussing magnetic media changes its magnetic properties, permanently corrupting data. When degaussing magnetic media, care needs to be taken as a degausser of insufficient magnetic field

strength will not be effective. In addition, since 2006 perpendicular magnetic media has progressively replaced longitudinal magnetic media. As some older degaussers are only capable of destroying longitudinal magnetic media, care needs to be taken to ensure that a degausser with a suitable magnetic orientation is also used. Furthermore, to ensure that degaussers are being used in the correct manner to effectively destroy magnetic media, product-specific directions provided by degausser manufacturers should be followed. Finally, to provide an additional level of assurance following the use of a degausser, magnetic media should be physically damaged by deforming any internal platters.

Control: ISM-0361; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Magnetic media is destroyed using a degausser with a suitable magnetic field strength and magnetic orientation.

Control: ISM-0362; Revision: 4; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Product-specific directions provided by degausser manufacturers are followed.

Control: ISM-1641; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Following the use of a degausser, magnetic media is physically damaged by deforming any internal platters.

Supervision of destruction

To verify that media is appropriately destroyed, destruction processes need to be supervised by at least one cleared person.

Control: ISM-0370; Revision: 6; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The destruction of media is performed under the supervision of at least one cleared person.

Control: ISM-0371; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel supervising the destruction of media supervise its handling to the point of destruction and ensure that the destruction is completed successfully.

Supervision of accountable material destruction

The successful destruction of media storing accountable material is more important than for other media. As such, its destruction should be supervised by at least two cleared personnel who sign a destruction certificate afterwards.

Control: ISM-0372; Revision: 6; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The destruction of media storing accountable material is performed under the supervision of at least two cleared personnel.

Control: ISM-0373; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel supervising the destruction of media storing accountable material supervise its handling to the point of destruction, ensure that the destruction is completed successfully and sign a destruction certificate afterwards.

Outsourcing media destruction

While media storing accountable material cannot be outsourced, media storing non-accountable material can be outsourced when using a National Association for Information Destruction AAA certified destruction service with endorsements, as specified in ASIO's Protective Security Circular-167, *External destruction of security classified information*. This publication is available from the Protective Security Policy GovTEAMS community or ASIO by email.

Control: ISM-0839; Revision: 3; Updated: Dec-21; Applicable: OS, P, S, TS; Essential 8: N/A
The destruction of media storing accountable material is not outsourced.

Control: ISM-0840; Revision: 4; Updated: Jun-22; Applicable: OS, P, S; Essential 8: N/A
When outsourcing the destruction of media storing non-accountable material, a National Association for Information Destruction AAA certified destruction service with endorsements, as specified in ASIO's Protective Security Circular-167, is used.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Media disposal

Media disposal processes and procedures

Developing, implementing and maintaining processes and procedures for media disposal will ensure that an organisation carries out media disposal in an appropriate and consistent manner.

Control: ISM-0374; Revision: 4; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Media disposal processes, and supporting media disposal procedures, are developed, implemented and maintained.

Disposal of media

Before media can be released into the public domain, it needs to be sanitised, destroyed or declassified. As sanitised, destroyed or declassified media still presents a security risk, albeit minor, an appropriate authority needs to formally authorise its release into the public domain. Furthermore, as part of disposal processes, removing labels and markings indicating the owner, sensitivity, classification or any other marking that can associate media with its prior use will ensure it does not draw undue attention following its disposal.

Control: ISM-0378; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Labels and markings indicating the owner, sensitivity, classification or any other marking that can associate media with its prior use are removed prior to its disposal.

Control: ISM-0375; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Following sanitisation, destruction or declassification, a formal administrative decision is made to release media, or its waste, into the public domain.

Guidelines for system hardening

Operating system hardening

Context

This section describes security controls applicable to operating systems used on workstations and servers. Guidance on the use of mobile operating systems is available in the 'Mobile device management' section of the *Guidelines for enterprise mobility*.

Operating system selection

When selecting operating systems, it is important that an organisation preferences vendors that have demonstrated a commitment to Secure by Design and Secure by Default principles and practices. This includes secure programming practices and either memory-safe programming languages (such as C#, Go, Java, Ruby, Rust and Swift) or less preferably memory-safe programming practices. This will assist in not only reducing the potential number of vulnerabilities in operating systems, but also increasing the likelihood that timely patches, updates or vendor mitigations will be released to remediate any vulnerabilities that are found.

Control: ISM-1743; Revision: 2; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Vendors that have demonstrated a commitment to Secure by Design and Secure by Default principles and practices, including secure programming practices and either memory-safe programming languages or less preferably memory-safe programming practices, are used for operating systems.

Operating system releases and versions

Newer releases of operating systems often introduce improvements in security functionality. This can make it more difficult for malicious actors to craft reliable exploits for vulnerabilities they discover. Using older releases of operating systems, especially those no longer supported by vendors, may expose an organisation to vulnerabilities or exploitation techniques that have since been mitigated. In addition, 64-bit versions of operating systems support additional security functionality that legacy 32-bit versions do not.

Control: ISM-1407; Revision: 5; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: ML3
The latest release, or the previous release, of operating systems are used.

Control: ISM-1408; Revision: 6; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
64-bit versions of operating systems are used.

Standard operating environments

Allowing workstations and servers to be set up, configured and maintained outside of centrally managed processes can result in an inconsistent operating environment. Such operating

environments may assist malicious actors in gaining an initial foothold on networks due to the higher likelihood of poorly configured or maintained workstations and servers. Conversely, a standard operating environment (SOE), provided via an automated build process or a golden image, is designed to facilitate a standardised and consistent operating environment within an organisation.

When SOEs are obtained from third parties, such as service providers, there are additional cyber supply chain risks that should be considered, such as the accidental or deliberate inclusion of malicious code or configurations. To reduce the likelihood of such occurrences, an organisation should endeavour to obtain their SOEs from trustworthy third parties while also scanning them for malicious code and configurations.

As operating environments naturally change over time, such as when patches or updates are applied, configurations are changed, and applications are added or removed, it is essential that SOEs are reviewed and updated at least annually to ensure that an up-to-date baseline is maintained.

Control: ISM-1406; Revision: 2; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SOEs are used for workstations and servers.

Control: ISM-1608; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SOEs provided by third parties are scanned for malicious code and configurations.

Control: ISM-1588; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SOEs are reviewed and updated at least annually.

Hardening operating system configurations

When operating systems are deployed in their default state, or with an unapproved configuration, it can lead to an insecure operating environment that may allow malicious actors to gain an initial foothold on networks. Many settings exist within operating systems enabling them to be configured in an approved secure state to minimise this security risk. As such, the Australian Signals Directorate (ASD) and vendors often produce hardening guidance to assist in hardening the configuration of operating systems. However, in situations where ASD and vendor hardening guidance conflicts, precedence should be given to implementing the most restrictive guidance.

Control: ISM-1914; Revision: 0; Updated: Mar-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Approved configurations for operating systems are developed, implemented and maintained.

Control: ISM-1409; Revision: 4; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Operating systems are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur.

Control: ISM-1601; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Microsoft's attack surface reduction rules are implemented.

Control: ISM-0383; Revision: 11; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Default user accounts or credentials for operating systems, including for any pre-configured user accounts, are changed, disabled or removed during initial setup.

Control: ISM-0380; Revision: 10; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unneeded user accounts, components, services and functionality of operating systems are disabled or removed.

Control: ISM-0341; Revision: 4; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Automatic execution features for removable media are disabled.

Control: ISM-1654; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Internet Explorer 11 is disabled or removed.

Control: ISM-1655; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML3
.NET Framework 3.5 (includes .NET 2.0 and 3.0) is disabled or removed.

Control: ISM-1492; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Operating system exploit protection functionality is enabled.

Control: ISM-1745; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Early Launch Antimalware, Secure Boot, Trusted Boot and Measured Boot functionality is enabled.

Control: ISM-2127; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Digital signature verification functionality for drivers is enforced before they are loaded.

Control: ISM-1896; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Memory integrity functionality is enabled.

Control: ISM-2128; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The ability to install, load or modify kernel-mode code, including drivers, kernel modules and extensions, is limited to privileged users who require such abilities as part of their duties or functions.

Control: ISM-1584; Revision: 1; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unprivileged users are prevented from bypassing, disabling or modifying security functionality of operating systems.

Control: ISM-1491; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unprivileged human users are prevented from running script execution engines, including:

- *Windows Script Host (cscript.exe and wscript.exe)*
- *PowerShell (powershell.exe, powershell_ise.exe and pwsh.exe)*
- *Command Prompt (cmd.exe)*
- *Windows Management Instrumentation (wmic.exe)*
- *Microsoft Hypertext Markup Language (HTML) Application Host (mshta.exe).*

Application management

Unprivileged human users' ability to install any application can be exploited by malicious actors using social engineering to convince them to install malicious applications. One way to mitigate this security risk, while also removing burden from system administrators, is to allow unprivileged human users the ability to install approved applications from organisation-managed application repositories or from trustworthy application marketplaces. Furthermore, to prevent unprivileged human users from removing security functionality, or breaking system functionality, unprivileged human users should not have the ability to uninstall or disable approved applications.

Control: ISM-1592; Revision: 3; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unprivileged human users do not have the ability to install unapproved applications.

Control: ISM-0382; Revision: 9; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unprivileged human users do not have the ability to uninstall or disable approved applications.

Application control

Application control can be an effective way to both prevent malicious code from executing on workstations and servers and ensure only approved applications can execute. When developing application control rulesets, determining approved executables (e.g. .exe and .com files), libraries (e.g. .dll and .ocx files), scripts (e.g. .ps1, .bat, .cmd, .vbs and .js files), installers (e.g. .msi, .msp and .mst files), compiled HTML (e.g. .chm files), HTML applications (e.g. .hta files), control panel applets (e.g. .cpl files) and drivers based on business requirements is a more secure method than simply approving those already residing on a workstation or server. Furthermore, it is preferable that an organisation defines their own application control rulesets, rather than relying on those from application control vendors, and validates them at least annually.

In implementing application control, an organisation should use a reliable method, or combination of methods, such as cryptographic hash rules, publisher certificate rules or path rules. Depending on the method chosen, further hardening may be required to ensure that application control mechanisms and application control rulesets cannot be bypassed by malicious actors.

Finally, centrally logging and analysing application control events can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-0843; Revision: 9; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Application control is implemented on workstations.

Control: ISM-1490; Revision: 3; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Application control is implemented on internet-facing servers.

Control: ISM-1656; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Application control is implemented on non-internet-facing servers.

Control: ISM-1870; Revision: 0; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Application control is applied to user profiles and temporary folders used by operating systems, web browsers and email clients.

Control: ISM-1871; Revision: 0; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Application control is applied to all locations other than user profiles and temporary folders used by operating systems, web browsers and email clients.

Control: ISM-1657; Revision: 1; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Application control restricts the execution of executables, libraries, scripts, installers, compiled HTML, HTML applications and control panel applets to an organisation-approved set.

Control: ISM-1658; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Application control restricts the execution of drivers to an organisation-approved set.

Control: ISM-0955; Revision: 6; Updated: Apr-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Application control is implemented using cryptographic hash rules, publisher certificate rules or path rules.

Control: ISM-1471; Revision: 3; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When implementing application control using publisher certificate rules, publisher names and product names are used.

Control: ISM-1392; Revision: 4; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When implementing application control using path rules, only approved users can modify approved files and write to approved folders.

Control: ISM-1746; Revision: 1; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When implementing application control using path rules, only approved users can change file system permissions for approved files and folders.

Control: ISM-1544; Revision: 3; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Microsoft's recommended application blocklist is implemented.

Control: ISM-1659; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Microsoft's vulnerable driver blocklist is implemented.

Control: ISM-1582; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Application control rulesets are validated at least annually.

Control: ISM-0846; Revision: 10; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Users cannot disable or bypass application control, and are not exempted from application control, except when using local administrator accounts or break glass accounts.

Control: ISM-1660; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Allowed and blocked application control events are centrally logged.

Command Shell

The Command shell was the first shell developed by Microsoft to assist with the automation of routine system administration tasks, such as running Windows Commands via batch scripts. However, the Command shell can also be used by malicious actors to run Windows Commands on compromised systems. As such, centrally logging and analysing command line process creation events can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1889; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Command line process creation events are centrally logged.

PowerShell

PowerShell is a powerful scripting language developed by Microsoft and, due to its ubiquity and ease with which it can be used to control operating systems, is an important part of system administrator toolkits. However, PowerShell can also be a dangerous exploitation tool in the hands of malicious actors.

To prevent attacks leveraging vulnerabilities in earlier PowerShell versions, Windows PowerShell 2.0 should be disabled or removed from operating systems. Additionally, PowerShell's language mode should be set to Constrained Language Mode to achieve a balance between security and functionality.

Finally, centrally logging and analysing PowerShell events can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1621; Revision: 1; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Windows PowerShell 2.0 is disabled or removed.

Control: ISM-1622; Revision: 0; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: ML3
PowerShell is configured to use Constrained Language Mode.

Control: ISM-1623; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
PowerShell module logging, script block logging and transcription events are centrally logged.

Control: ISM-1624; Revision: 0; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
PowerShell script block logs are protected by Protected Event Logging functionality.

Windows Management Instrumentation

Malicious actors increasingly avoid deploying their own malware and instead live off the land by using management frameworks, such as Windows Management Instrumentation (WMI), that are already present on systems. As these management frameworks are required for legitimate administration activities, blocking them outright is often not feasible. As such, centrally logging and analysing WMI activity, including the creation of permanent event subscriptions, can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-2129; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
WMI activity, including the creation of permanent event subscriptions, is centrally logged.

Host-based intrusion detection and response solution

Many security products rely on signatures to detect malicious code. This approach is only effective when malicious code has already been profiled, and signatures are available from security vendors. Unfortunately, malicious actors can easily create variants of known malicious code to bypass traditional signature-based detection. A host-based intrusion prevention system (HIPS) or endpoint detection and response (EDR) solution can use behaviour-based detection to assist in identifying and blocking anomalous behaviour as well as detecting malicious code that has yet to be identified by security vendors. As such, it is important that either a HIPS or EDR solution is implemented on workstations, critical servers and high-value servers.

Control: ISM-1341; Revision: 3; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A HIPS or EDR solution is implemented on workstations.

Control: ISM-1034; Revision: 8; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A HIPS or EDR solution is implemented on critical servers and high-value servers.

Software firewall

Traditional network firewalls often fail to prevent the propagation of malicious code on networks, or malicious actors from exfiltrating data from networks, as they only control which ports or protocols can be used between different network segments. Many forms of malicious code are designed specifically to take advantage of this by using common protocols, such as Hypertext Transfer Protocol, Hypertext Transfer Protocol Secure, Simple Mail Transfer Protocol or Domain Name System. Software firewalls are more effective than traditional network firewalls as they can control which applications and services can communicate to and from workstations and servers. As such, a software firewall should be implemented on workstations and servers to restrict inbound and outbound network connections to an organisation-approved set of applications and services.

Control: ISM-1416; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A software firewall is implemented on workstations and servers to restrict inbound and outbound network connections to an organisation-approved set of applications and services.

Antivirus application

When vendors develop operating systems and applications, they may make coding mistakes that lead to vulnerabilities. Malicious actors can take advantage of this by developing malicious code to exploit any vulnerabilities that have not been detected and remedied by vendors. As significant time and effort is often involved in developing functioning and reliable exploits, malicious actors will often attempt to reuse their exploits as much as possible. While exploits may have been previously identified by security vendors, they often remain viable against an organisation that does not have an antivirus application in place.

Control: ISM-1417; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An antivirus application is implemented on workstations and servers with:

- *signature-based detection functionality enabled and set to a high level*
- *heuristic-based detection functionality enabled and set to a high level*
- *reputation rating functionality enabled*
- *ransomware protection functionality enabled*
- *detection signatures configured to update at least daily*
- *regular scanning configured for all fixed disks and removable media.*

Device access control

A device access control application, or disabling external communication interfaces, can be used to prevent removable media and mobile devices from being connected to workstations and servers via external communication interfaces. This can assist in preventing the introduction of malicious code or the exfiltration of data by malicious actors.

In addition, malicious actors can connect to locked workstations and servers via external communication interfaces that allow direct memory access (DMA). In doing so, malicious actors can gain access to encryption keys in memory or write malicious code to memory. The best defence against this security risk is to disable access to external communication interfaces that allow DMA, such as FireWire, ExpressCard and Thunderbolt.

Control: ISM-1418; Revision: 5; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If there is no business requirement for reading from removable media and devices, such functionality is disabled via the use of a device access control application or by disabling external communication interfaces.

Control: ISM-0343; Revision: 7; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If there is no business requirement for writing to removable media and devices, such functionality is disabled via the use of a device access control application or by disabling external communication interfaces.

Control: ISM-0345; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
External communication interfaces that allow DMA are disabled.

Operating system event logging

Centrally logging and analysing security-relevant events, including configuration changes, for operating systems can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Typical security-relevant events for operating systems that can be logged include:

- changes to security policies
- failed user logons and account lockouts
- failures, restarts and changes to important processes, services and scheduled tasks
- operating system and application usage, error messages and crashes
- security product-related events
- successful process creations and terminations
- successful user logons and logoffs
- system startups and shutdowns.

Control: ISM-1976; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for Apple macOS operating systems are centrally logged.

Control: ISM-1977; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for Linux operating systems are centrally logged.

Control: ISM-0582; Revision: 10; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for Microsoft Windows operating systems are centrally logged.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on vendors that have made a pledge to implement Secure by Design and Secure by Default principles and practices can be found on the United States' Cybersecurity & Infrastructure Security Agency's Secure by Design Pledge website.

Further information on patching or updating operating systems can be found in the 'System maintenance' section of the *Guidelines for system management*.

Further information on hardening Microsoft Windows operating systems can be found in ASD's *Hardening Microsoft Windows 10 workstations* and *Hardening Microsoft Windows 11 workstations* publications.

Further information on hardening Microsoft Windows operating systems can also be found in Microsoft's *Windows 11 Security Book* and on the Microsoft Security Baselines Blog website.

Further information on hardening Linux workstations and servers can be found in ASD's *Hardening Linux workstations and servers* publication.

Further information on Microsoft's attack surface reduction rules can be found on Microsoft's attack surface reduction rules overview website.

Further information on exploit protection functionality within Microsoft Windows is available from Microsoft.

Further information on memory integrity functionality is available from Microsoft.

Further information on implementing application control can be found in ASD's *Implementing application control* publication.

Further information on Microsoft's recommended application blocklist and vulnerable driver blocklist is available from Microsoft.

Further information on command line process logging is available from Microsoft.

Further information on the use of PowerShell can be found in ASD's *Securing PowerShell in the enterprise* publication.

Further information on the use of PowerShell by blue teams is available from Microsoft.

Further information on obtaining greater visibility through PowerShell logging is available from Google.

Further information on independent testing of security products' ability to detect or prevent various stages of network intrusions is available from MITRE.

Further information on independent testing of antivirus applications is available from AV-Comparatives and AV-TEST.

Further information on the use of removable media can be found in the 'Media usage' section of the *Guidelines for media*.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on security-relevant events to monitor for Apple macOS, Linux and Microsoft Windows operating systems can be found in the following ASD publications:

- *Hardening Microsoft Windows 10 workstations*
- *Hardening Microsoft Windows 11 workstations*
- *Priority logs for SIEM ingestion: Practitioner guidance*
- *Windows event logging and forwarding*.

User application hardening

Context

This section describes security controls applicable to user applications typically installed on workstations, such as artificial intelligence (AI) applications, email clients, office productivity suites, Portable Document Format (PDF) applications, security products (e.g. antivirus applications, device access control applications, HIPS and software firewalls) and web browsers, including their extensions. Additional information on cloud-based versions of user applications can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*. Information on server applications can be found in the 'Server application hardening' section of these guidelines.

User application selection

When selecting user applications, it is important that an organisation preferences vendors that have demonstrated a commitment to Secure by Design and Secure by Default principles and practices. This includes secure programming practices and either memory-safe programming languages (such as C#, Go, Java, Ruby, Rust and Swift) or less preferably memory-safe programming practices. This will assist in not only reducing the potential number of vulnerabilities in user applications, but also increasing the likelihood that timely patches, updates or vendor mitigations will be released to remediate any vulnerabilities that are found.

Control: ISM-0938; Revision: 7; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Vendors that have demonstrated a commitment to Secure by Design and Secure by Default principles and practices, including secure programming practices and either memory-safe programming languages or less preferably memory-safe programming practices, are used for user applications.

User application releases

Newer releases of user applications often introduce improvements in security functionality. This can make it more difficult for malicious actors to craft reliable exploits for vulnerabilities they discover. In addition, using older releases of user applications, especially those no longer supported by vendors, may expose an organisation to vulnerabilities or exploitation techniques that have since been mitigated. This is particularly important for email clients, office productivity suites, PDF applications, security products and web browsers, including their extensions.

Control: ISM-1467; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The latest release of email clients, office productivity suites, PDF applications, security products and web browsers, including their extensions, are used.

Hardening user application configurations

When user applications are deployed in their default state, or with an unapproved configuration, it can lead to an insecure operating environment that may allow malicious actors to gain an initial

foothold on networks. Many settings exist within user applications enabling them to be configured in an approved secure state to minimise this security risk. As such, ASD and vendors often produce hardening guidance to assist in hardening the configuration of user applications. However, in situations where ASD and vendor hardening guidance conflicts, precedence should be given to implementing the most restrictive guidance.

Control: ISM-1915; Revision: 0; Updated: Mar-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Approved configurations for user applications are developed, implemented and maintained.

Control: ISM-2110; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User applications are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur.

Control: ISM-1806; Revision: 4; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Default user accounts or credentials for user applications, including for any pre-configured user accounts, are changed, disabled or removed during initial setup.

Control: ISM-1470; Revision: 7; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unneeded user accounts, components, services and functionality of user applications are disabled or removed.

Control: ISM-1235; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Extensions for user applications are restricted to an organisation-approved set.

Control: ISM-2111; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All temporary installation files created during user application installation processes are removed after user applications have been installed.

Artificial intelligence applications

Allowing AI applications that process classified data to directly access external public data sources, such as by performing web searches, or accessing third-party cloud services or application programming interfaces, could lead to data spills involving classified prompts or responses. For this reason, AI applications processing classified data should not be granted direct access to external public data sources.

Furthermore, allowing AI applications to perform sensitive or high-impact actions without human oversight could result in unintended cyber security incidents. For example, actions that change privileges, that disable security controls, that initiate financial commitments, that transfer data outside the system boundary or that are otherwise irreversible. In such cases, AI applications should show human users the proposed action, target, data being disclosed and expected consequences. Dual approval should be considered for exceptionally consequential actions.

Control: ISM-2112; Revision: 0; Updated: Jun-26; Applicable: OS, P, S, TS; Essential 8: N/A
AI applications that process classified data have their ability to directly access external public data sources disabled.

Control: ISM-2113; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
AI applications are configured to require human approval before executing sensitive or high-impact actions.

Control: ISM-2114; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Baselines of expected behaviour and performance for AI applications are established and monitored for unexpected deviations.

Email clients

Human users' ability to change the security settings of email clients can be exploited by malicious actors using social engineering. To prevent human users from removing security functionality, or breaking security functionality, human users should not have the ability to change security settings for email clients.

Control: ISM-1748; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Email client security settings cannot be changed by human users.

Office productivity suites

When office productivity suites, such as Microsoft Office, are deployed in their default state, or with an unapproved configuration, it can lead to an insecure operating environment that may allow malicious actors to gain an initial foothold on networks. Many settings exist within office productivity suites enabling them to be configured in an approved secure state to minimise this security risk. As such, ASD and vendors often produce hardening guidance to assist in hardening the configuration of office productivity suites. However, in situations where ASD and vendor hardening guidance conflicts, precedence should be given to implementing the most restrictive guidance.

In addition, human users' ability to change the security settings of office productivity suites can be exploited by malicious actors using social engineering. To prevent human users from removing security functionality, or breaking security functionality, human users should not have the ability to change security settings for office productivity suites.

Finally, Microsoft Office files can contain embedded code, known as a macro, written in the Visual Basic for Applications programming language. A macro can contain a series of commands that can be coded or recorded and replayed later to automate repetitive tasks. Macros are powerful tools that can be easily created by human users to improve their productivity. However, malicious actors can also create macros to perform a variety of malicious activities, such as assisting to compromise workstations to exfiltrate or deny access to data. To reduce this security risk, an organisation should disable Microsoft Office macros for human users that do not have a demonstrated business requirement and secure their use for those that do.

Control: ISM-1859; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Office productivity suites are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur.

Control: ISM-1667; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Microsoft Office is blocked from creating child processes.

Control: ISM-1668; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Microsoft Office is blocked from creating executable content.

Control: ISM-1669; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Microsoft Office is blocked from injecting code into other processes.

Control: ISM-1542; Revision: 0; Updated: Jan-19; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Microsoft Office is configured to prevent activation of Object Linking and Embedding packages.

Control: ISM-1823; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Office productivity suite security settings cannot be changed by human users.

Control: ISM-1671; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Microsoft Office macros are disabled for human users that do not have a demonstrated business requirement.

Control: ISM-1488; Revision: 1; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Microsoft Office macros in files originating from the internet are blocked.

Control: ISM-1672; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Microsoft Office macro antivirus scanning is enabled.

Control: ISM-1673; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Microsoft Office macros are blocked from making Win32 API calls.

Control: ISM-1674; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Only Microsoft Office macros running from within a sandboxed environment, a Trusted Location or that are digitally signed by a trusted publisher are allowed to execute.

Control: ISM-1890; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Microsoft Office macros are checked to ensure they are free of malicious code before being digitally signed or placed within Trusted Locations.

Control: ISM-1487; Revision: 3; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Only privileged human users responsible for checking that Microsoft Office macros are free of malicious code can write to and modify content within Trusted Locations.

Control: ISM-1675; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Microsoft Office macros digitally signed by an untrusted publisher cannot be enabled via the Message Bar or Backstage View.

Control: ISM-1891; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Microsoft Office macros digitally signed by signatures other than V3 signatures cannot be enabled via the Message Bar or Backstage View.

Control: ISM-1676; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Microsoft Office's list of trusted publishers is validated at least annually.

Control: ISM-1489; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Microsoft Office macro security settings cannot be changed by human users.

Portable Document Format applications

When PDF applications suites are deployed in their default state, or with an unapproved configuration, it can lead to an insecure operating environment that may allow malicious actors to gain an initial foothold on networks. Many settings exist within PDF applications enabling them to be configured in an approved secure state to minimise this security risk. As such, ASD and vendors often produce hardening guidance to assist in hardening the configuration of PDF applications. However, in situations where ASD and vendor hardening guidance conflicts, precedence should be given to implementing the most restrictive guidance.

In addition, human users' ability to change the security settings of PDF applications can be exploited by malicious actors using social engineering. To prevent human users from removing security functionality, or breaking security functionality, human users should not have the ability to change the security settings for PDF applications.

Control: ISM-1670; Revision: 1; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
PDF applications are blocked from creating child processes.

Control: ISM-1860; Revision: 3; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
PDF applications are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur.

Control: ISM-1824; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
PDF application security settings cannot be changed by human users.

Security products

Human users' ability to change the security settings of security products can be exploited by malicious actors using social engineering. To prevent human users from removing security

functionality, or breaking security functionality, human users should not have the ability to change security settings for security products.

Control: ISM-1825; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security product security settings cannot be changed by human users.

Web browsers

When web browsers are deployed in their default state, or with an unapproved configuration, it can lead to an insecure operating environment that may allow malicious actors to gain an initial foothold on networks. Many settings exist within web browsers enabling them to be configured in an approved secure state to minimise this security risk. As such, ASD and vendors often produce hardening guidance to assist in hardening the configuration of web browsers. However, in situations where ASD and vendor hardening guidance conflicts, precedence should be given to implementing the most restrictive guidance.

In addition, human users' ability to change the security settings of web browsers can be exploited by malicious actors using social engineering. To prevent human users from removing security functionality, or breaking security functionality, human users should not have the ability to change the security settings for web browsers.

Control: ISM-1486; Revision: 1; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Web browsers do not process Java from the internet.

Control: ISM-1485; Revision: 1; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Web browsers do not process web advertisements from the internet.

Control: ISM-1412; Revision: 6; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Web browsers are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur.

Control: ISM-1585; Revision: 3; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Web browser security settings cannot be changed by human users.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on vendors that have made a pledge to implement Secure by Design and Secure by Default principles and practices can be found on the United States' Cybersecurity & Infrastructure Security Agency's Secure by Design Pledge website.

Further information on patching or updating user applications can be found in the 'System maintenance' section of the *Guidelines for system management*.

Further information on the use of AI agents can be found in ASD's *Careful adoption of agentic AI services* publication.

Further information on hardening AI applications can be found in the United States' National Security Agency's *Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems* publication.

Further information on hardening Microsoft Office can be found in ASD's *Hardening Microsoft 365, Office 2021, Office 2019 and Office 2016* and *Restricting Microsoft Office macros* publications.

Further information on hardening Microsoft Office can also be found on the Microsoft Security Baselines Blog website.

Further information on hardening Adobe Reader and Adobe Acrobat can be found in Adobe's *Security Configuration Guide for Acrobat* publication.

Further information on the implementation and configuration of security products can be found in the 'Operating system hardening' section of these guidelines.

Further information on hardening Microsoft Edge can be found on the Microsoft Security Baselines Blog website.

Further information on hardening Google Chrome can be found in Google's *Chrome Browser Enterprise Security Configuration Guide (Windows)*.

Server application hardening

Context

This section describes security controls applicable to server applications associated with specific server functionality, such as Microsoft Active Directory services, database management system applications, email server applications and web hosting applications. Information on user applications can be found in the 'User application hardening' section of these guidelines.

Server application selection

When selecting server applications, it is important that an organisation preferences vendors that have demonstrated a commitment to Secure by Design and Secure by Default principles and practices. This includes secure programming practices and either memory-safe programming languages (such as C#, Go, Java, Ruby, Rust and Swift) or less preferably memory-safe programming practices. This will assist in not only reducing the potential number of vulnerabilities in server applications, but also increasing the likelihood that timely patches, updates or vendor mitigations will be released to remediate any vulnerabilities that are found.

Control: ISM-1826; Revision: 1; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Vendors that have demonstrated a commitment to Secure by Design and Secure by Default principles and practices, including secure programming practices and either memory-safe programming languages or less preferably memory-safe programming practices, are used for server applications.

Server application releases

Newer releases of server applications often introduce improvements in security functionality. This can make it more difficult for malicious actors to craft reliable exploits for vulnerabilities they discover. In addition, using older releases of server applications, especially those no longer supported by vendors, may expose an organisation to vulnerabilities or exploitation techniques that have since been mitigated. This is particularly important for internet-facing server applications.

Control: ISM-1483; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The latest release of internet-facing server applications is used.

Hardening server application configurations

When server applications are deployed in their default state, or with an unapproved configuration, it can lead to an insecure operating environment that may allow malicious actors to gain an initial foothold on networks. Many settings exist within server applications enabling them to be configured in an approved secure state to minimise this security risk. As such, ASD and vendors often produce hardening guidance to assist in hardening the configuration of server applications. However, in situations where ASD and vendor hardening guidance conflicts, precedence should be given to implementing the most restrictive guidance.

Control: ISM-1916; Revision: 0; Updated: Mar-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Approved configurations for server applications are developed, implemented and maintained.

Control: ISM-1246; Revision: 6; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Server applications are hardened using ASD and vendor hardening guidance, with the most restrictive guidance taking precedence when conflicts occur.

Control: ISM-1260; Revision: 7; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Default user accounts or credentials for server applications, including for any pre-configured user accounts, are changed, disabled or removed during initial setup.

Control: ISM-1247; Revision: 5; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unneeded user accounts, components, services and functionality of server applications are disabled or removed.

Control: ISM-2115; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Extensions for server applications are restricted to an organisation-approved set.

Control: ISM-1245; Revision: 4; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All temporary installation files created during server application installation processes are removed after server applications have been installed.

Restricting privileges for server applications

If a server application operating as a local administrator or root account is compromised by malicious actors, it can present a significant security risk to the underlying server. In addition, server applications by default are often capable of widely accessing their underlying server's file system. Therefore, restricting the ability of server applications to access their underlying server's file system can limit damage should malicious actors compromise the server application.

Control: ISM-1249; Revision: 4; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Server applications are configured to run as a separate user account with the minimum privileges needed to perform their functions.

Control: ISM-1250; Revision: 3; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The user accounts under which server applications run have limited access to their underlying server's file system.

Microsoft Active Directory services

Due to the critical role that Microsoft Active Directory services perform for domain services, certification services, federated services and identity services within networks, it is crucial that servers performing these services are hardened and access to them is strictly limited, including to their backups. Specifically, this includes servers for Microsoft Active Directory Domain Services (AD DS), Microsoft Active Directory Certificate Services (AD CS), Microsoft Active Directory Federation Services (AD FS) and Microsoft Entra Connect.

In addition, centrally logging and analysing security-relevant events, including configuration changes, for Microsoft Active Directory services can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1926; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Microsoft AD DS domain controllers, Microsoft AD CS servers, Microsoft AD FS servers and Microsoft Entra Connect servers are only used for their designed role and no other applications or services are installed, unless they are security-related.

Control: ISM-1927; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Access to Microsoft AD DS domain controllers, Microsoft AD CS servers, Microsoft AD FS servers and Microsoft Entra Connect servers is limited to privileged users that require access.

Control: ISM-1928; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Backups of Microsoft AD DS domain controllers, Microsoft AD CS servers, Microsoft AD FS servers and Microsoft Entra Connect servers are encrypted using ASD-approved cryptography, stored securely and only accessible to backup administrator accounts.

Control: ISM-1830; Revision: 3; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for Microsoft AD DS domain controllers, Microsoft AD CS servers, Microsoft AD FS servers and Microsoft Entra Connect servers are centrally logged.

Microsoft Active Directory Domain Services

Microsoft AD DS domain controllers hold sensitive data for systems, such as hashed credentials for all user accounts. As such, particular care should be taken to secure these servers. This can be achieved by hardening their configuration while using dedicated domain administrator user accounts exclusively for their administration. In doing so, technical security controls should ensure these dedicated domain administrator user accounts cannot be used to connect to or administer other systems.

Control: ISM-1827; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Microsoft AD DS domain controllers are administered using dedicated domain administrator user accounts that are not used to administer other systems.

Control: ISM-1929; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Lightweight Directory Access Protocol signing is enabled on Microsoft AD DS domain controllers.

Control: ISM-1828; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The Print Spooler service is disabled on Microsoft AD DS domain controllers.

Control: ISM-1829; Revision: 1; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Passwords are not stored in Group Policy Preferences.

Control: ISM-1930; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Passwords are prevented from being stored in Group Policy Preferences.

Control: ISM-1931; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SID Filtering is enabled for domain and forest trusts.

Microsoft Active Directory Domain Services account hardening

Misconfigured user accounts and computer accounts within Microsoft AD DS can pose a significant threat to the security of a system. For example, when malicious actors obtain credentials for a user account, along with associated system access, they may further compromise the system by querying Microsoft AD DS to assist in gaining an understanding of the environment, moving laterally through the network and escalating privileges by compromising privileged user accounts. Furthermore, malicious actors with this level of access can become difficult to detect and remove, as they may not need to use exploits for vulnerabilities to achieve their goals. Malicious activities performed by compromised user accounts or computer accounts may also appear very similar to legitimate system activities.

Control: ISM-1832; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Only service accounts and computer accounts are configured with Service Principal Names (SPNs).

Control: ISM-1932; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The number of service accounts configured with an SPN is minimised.

Control: ISM-1933; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Service accounts configured with an SPN do not have DCSync permissions.

Control: ISM-2010; Revision: 0; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Service accounts configured with an SPN use the Advanced Encryption Standard for encryption.

Control: ISM-1834; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Duplicate SPNs do not exist within the domain.

Control: ISM-1833; Revision: 1; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User accounts are provisioned with the minimum privileges required.

Control: ISM-1934; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User accounts with DCSync permissions are reviewed at least every six months, and those without an ongoing requirement for the permissions have them removed.

Control: ISM-1835; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Privileged user accounts are configured as sensitive and cannot be delegated.

Control: ISM-1935; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Computer accounts are not configured for unconstrained delegation.

Control: ISM-1836; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User accounts require Kerberos pre-authentication.

Control: ISM-1838; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The UserPassword attribute for user accounts is not used.

Control: ISM-1936; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The sIDHistory attribute for user accounts is not used.

Control: ISM-1937; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User accounts are checked at least weekly for the presence of the sIDHistory attribute.

Control: ISM-1839; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Account properties accessible by unprivileged users are not used to store passwords.

Control: ISM-1840; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User account passwords do not use reversible encryption.

Control: ISM-1841; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unprivileged user accounts cannot add machines to the domain.

Control: ISM-1842; Revision: 1; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Dedicated privileged service accounts are used to add machines to the domain.

Control: ISM-1843; Revision: 1; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User accounts with unconstrained delegation are reviewed at least annually, and those without an SPN or demonstrated business requirement are removed.

Control: ISM-1844; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Computer accounts that are not Microsoft AD DS domain controllers are not trusted for delegation to services.

Control: ISM-1938; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The Domain Computers security group does not have write or modify permissions to any Microsoft Active Directory objects.

Microsoft Active Directory Domain Services security group memberships

Microsoft AD DS contains several built-in security groups that have elevated permissions or deliberately relaxed security policies. These security groups are often required for a specific purpose; however, overuse or inappropriate use may allow malicious actors to more easily move laterally throughout a network or escalate their privileges. Highly privileged security groups, such as the Domain Admins and Enterprise Admins security groups, should have their membership limited to the smallest set of possible user accounts to limit malicious actors' opportunities for privilege escalation. In doing so, such highly privileged security groups should exclude service accounts and computer accounts. In addition, the Domain Computers security group should be excluded from belonging to any privileged or highly privileged security groups.

Control: ISM-1620; Revision: 1; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Privileged user accounts are members of the Protected Users security group.

Control: ISM-1939; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The number of user accounts that are members of the Domain Admins, Enterprise Admins or other highly privileged security groups is minimised.

Control: ISM-1940; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Service accounts are not members of the Domain Admins, Enterprise Admins or other highly privileged security groups.

Control: ISM-1941; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Computer accounts are not members of the Domain Admins, Enterprise Admins or other highly privileged security groups.

Control: ISM-1942; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The Domain Computers security group is not a member of any privileged or highly privileged security groups.

Control: ISM-1845; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When a user account is disabled, it is removed from all security group memberships.

Control: ISM-1846; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The Pre-Windows 2000 Compatible Access security group does not contain user accounts.

Microsoft Active Directory Certificate Services

Microsoft AD CS is responsible for the management of public key infrastructure certificates used to secure authentication and communication protocols for systems, and presents significant opportunities for privilege escalation and persistence by malicious actors. As such, particular care should be taken to secure servers that perform this role. For example, in addition to baseline configuration hardening, web-based enrolment interfaces should be disabled or hardened against authentication-relay attacks, certificate templates should be periodically audited, and certificate enrolment activity should be centrally logged.

Control: ISM-1943; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Strong mapping between certificates and users is enforced.

Control: ISM-1944; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The EDITF_ATTRIBUTESUBJECTALTNAME2 flag is removed from Microsoft AD CS certification authority configurations.

Control: ISM-1945; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT flag is removed from certificate templates.

Control: ISM-1946; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unprivileged user accounts do not have write access to certificate templates.

Control: ISM-1947; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Extended Key Usages that enable user authentication are removed.

Control: ISM-1948; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Certificate manager approval is required for certificate templates that allow a Subject Alternative Name to be supplied.

Control: ISM-2130; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Web-based enrolment interfaces for Microsoft AD CS servers are disabled unless required, and where enabled, are configured to require HTTPS and Extended Protection for Authentication.

Control: ISM-2131; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Certificate templates are reviewed at least every three months to identify and remediate misconfigurations that could enable privilege escalation or unauthorised certificate enrolment.

Control: ISM-2132; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Certificate enrolment events, including successful and unsuccessful requests and changes to certificate templates or Microsoft AD CS configurations, are centrally logged.

Microsoft Active Directory Federation Services

Microsoft AD FS is responsible for the sharing of identity and access management rights across security boundaries. As such, particular care should be taken to secure servers that perform this role.

Control: ISM-1949; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Microsoft AD FS servers are administered using a dedicated service account that is not used to administer other systems.

Microsoft Entra Connect

Microsoft Entra Connect is responsible for synchronising identity information between Microsoft AD DS and Microsoft Entra ID services within hybrid on-premises and cloud-based environments. As such, particular care should be taken to secure servers that perform this role.

Control: ISM-1950; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Soft matching between Microsoft AD DS and Microsoft Entra ID is disabled following initial synchronisation activities.

Control: ISM-1951; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Hard match takeover is disabled for Microsoft Entra Connect servers.

Control: ISM-1952; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Privileged user accounts are not synchronised between Microsoft AD DS and Microsoft Entra ID.

Server application event logging

Centrally logging and analysing security-relevant events, including configuration changes, for server applications can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1978; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for server applications on internet-facing servers are centrally logged.

Control: ISM-1979; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for server applications on non-internet-facing servers are centrally logged.

Further information

Further information on cyber supply chain risk management can be found in the ‘Cyber supply chain risk management’ section of the *Guidelines for procurement and outsourcing*.

Further information on vendors that have made a pledge to implement Secure by Design and Secure by Default principles and practices can be found on the United States’ Cybersecurity & Infrastructure Security Agency’s Secure by Design Pledge website.

Further information on patching or updating server applications can be found in the ‘System maintenance’ section of the *Guidelines for system management*.

Further information on the use of privileged user accounts can be found in the ‘Identity and access management’ section of the *Guidelines for system access*.

Further information on administering Microsoft Active Directory services can be found in the ‘System administration’ section of the *Guidelines for system management*.

Further information on hardening Microsoft Active Directory services can be found in ASD's *Detecting and mitigating Active Directory compromises* publication.

Further information on hardening Microsoft Active Directory services can also be found in Microsoft's *Best practices for securing Active Directory* publication.

Further information on hardening Microsoft Entra Connect can be found in Microsoft's *Prerequisites for Microsoft Entra Connect* publication.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on security-relevant events to monitor for Microsoft Active Directory can be found in ASD's *Detecting and mitigating Active Directory compromises* and *Priority logs for SIEM ingestion: Practitioner guidance* publications.

Further information on security-relevant events to monitor for Microsoft Active Directory can also be found in Microsoft's *Events to monitor* publication.

Further information on database servers can be found in the 'Database servers' section of the *Guidelines for database systems*.

Further information on email servers can be found in the 'Email gateways and servers' section of the *Guidelines for email*.

Virtualisation hardening

Context

This section describes security controls applicable to Type 1 hypervisors (those that run on bare metal) and Type 2 hypervisors (those that run on top of a general-purpose operating system). In doing so, Type 1 hypervisors should be treated as operating systems while Type 2 hypervisors should be treated as applications. As Type 1 hypervisors are themselves lightweight operating systems, they can be treated as a combination of a software-based isolation mechanism and an underlying operating system. Conversely, Type 2 hypervisors will run on top of a general-purpose operating system that may be provided by a different vendor to that of the software-based isolation mechanism.

Furthermore, containers enable versatile deployment of systems and, in doing so, should be treated the same as any other system. However, security controls in a containerised environment may take a different form when compared to other types of systems. For example, patching the operating system of a workstation may be performed differently to ensuring that a patched image is used for a container; however, the principle is the same. In general, the same security risks that apply to non-containerised systems will likely apply to containerised systems.

Functional separation between operating environments

Physical computing resources can be shared among multiple operating environments via software-based isolation mechanisms. In doing so, an operating environment only has access to the virtual resources provided via the software-based isolation mechanism. In some cases, multiple layers of virtualisation, known as nested virtualisation, can exist. This is particularly prevalent with cloud services.

Examples of software-based isolation include:

- an operating system installed in a virtual machine where the isolation mechanism is a hypervisor, such as an Infrastructure as a Service offering
- an application that uses the shared kernel of the underlying operating system of the physical computing resource where the isolation mechanism is an application container or application sandbox, such as a Platform as a Service offering
- a containerised service hosted in a cloud environment, such as a Platform as a Service offering.

The logical separation of data within a single application, such as a Software as a Service offering, is not considered the same as multiple operating environments.

Malicious actors who have compromised a single operating environment, or who legitimately control a single operating environment, might exploit a misconfiguration or vulnerability in an underlying software-based isolation mechanism. This can lead to the compromise of other operating environments that share the same software-based isolation mechanism or the compromise of the underlying operating system of the physical computing resource. As such, it is important that additional security controls be implemented when using a software-based isolation mechanism that consumes shared physical computing resources.

Control: ISM-1460; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using a software-based isolation mechanism that consumes shared physical computing resources, the isolation mechanism is from a vendor that has demonstrated a commitment to Secure by Design and Secure by Default principles and practices, including secure programming practices and either memory-safe programming languages or less preferably memory-safe programming practices.

Control: ISM-1604; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using a software-based isolation mechanism that consumes shared physical computing resources, the configuration of the isolation mechanism is hardened by removing unneeded functionality and restricting access to the administrative interface used to manage the isolation mechanism.

Control: ISM-1605; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using a software-based isolation mechanism that consumes shared physical computing resources, the underlying operating system is hardened.

Control: ISM-1606; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using a software-based isolation mechanism that consumes shared physical computing resources, patches, updates or vendor mitigations for vulnerabilities are applied to the isolation mechanism and underlying operating system in a timely manner.

Control: ISM-1848; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using a software-based isolation mechanism that consumes shared physical computing resources, the isolation mechanism or underlying operating system is replaced when it is no longer supported by a vendor.

Control: ISM-1607; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using a software-based isolation mechanism that consumes shared physical resources, integrity monitoring and centralised event logging is performed for the isolation mechanism and underlying operating system.

Control: ISM-1461; Revision: 6; Updated: Jun-26; Applicable: S, TS; Essential 8: N/A
When using a software-based isolation mechanism that consumes shared physical computing resources for SECRET or TOP SECRET operating environments, the physical server and all operating environments are of the same classification and belong to the same security domain.

Further information

Further information on container security can be found in National Institute of Standards and Technology Special Publication 800-190, *Application Container Security Guide*.

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on vendors that have made a pledge to implement Secure by Design and Secure by Default principles and practices can be found on the United States' Cybersecurity & Infrastructure Security Agency's Secure by Design Pledge website.

Further information on the use of cloud services can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Further information on hardening operating systems can be found in the 'Operating system hardening' section of these guidelines.

Further information on patching or updating operating systems and applications can be found in the 'System maintenance' section of the *Guidelines for system management*.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on hypervisor security can be found in National Institute of Standards and Technology Special Publication 800-125A Rev. 1, *Security Recommendations for Server-based Hypervisor Platforms*.

Guidelines for system access

Identity and access management

Context

Where these guidelines refer to security clearances, this includes both Australian security clearances and those from foreign governments that are formally recognised by Australia.

In addition, while some security controls in these guidelines apply specifically to human users, security controls for identifying, authenticating, authorising and monitoring users also apply to non-human users, such as services, applications, workloads and artificial intelligence (AI) agents.

System usage policy

To enable an organisation to be capable of holding personnel accountable for the actions they perform on their systems, it is important that the organisation develops, implements and maintains a system usage policy governing the use of systems and their resources.

Control: ISM-1864; Revision: 0; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A system usage policy is developed, implemented and maintained.

System access requirements

Documenting access requirements for systems and their resources can assist in determining whether users meet requirements for access. In doing so, requirements should account for whether access is unprivileged or privileged and, for personnel, whether additional requirements apply because they are foreign nationals or contractors.

To reinforce personnel's agreement to abide by system usage policies as a condition of being granted access to a system and its resources, displaying a logon banner each time they log on to the system can provide a continual reminder of their security responsibilities. Logon banners may cover topics such as:

- the sensitivity or classification of the system
- access requirements for the system
- usage policies for the system and its resources
- details of any monitoring activities for the system.

Control: ISM-0432; Revision: 8; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Access requirements for systems and their resources are documented in their system security plan.

Control: ISM-0434; Revision: 8; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel undergo appropriate employment screening and, where necessary, hold an appropriate security clearance before being granted access to systems and their resources.

Control: ISM-0435; Revision: 4; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel receive any necessary briefings before being granted access to systems and their resources.

Control: ISM-1865; Revision: 1; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel agree to abide by system usage policies before being granted access to systems and their resources.

Control: ISM-0408; Revision: 6; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Systems have a logon banner that reminds personnel of their security responsibilities when accessing the system and its resources.

User identification

Ensuring users are uniquely identifiable enables their access and activities to be attributed to them. Furthermore, where systems process, store or communicate Australian Eyes Only (AUSTEO), Australian Government Access Only (AGAO) or Releasable To (REL) data, and foreign nationals have access, it is important that the foreign nationals are identified as such.

Control: ISM-0414; Revision: 6; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Users granted access to systems and their resources are uniquely identifiable.

Control: ISM-0415; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The use of shared user accounts is strictly controlled, and users of such accounts are uniquely identifiable.

Control: ISM-1583; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Personnel who are contractors are identified as such.

Control: ISM-0420; Revision: 12; Updated: Jun-25; Applicable: S, TS; Essential 8: N/A
Where systems process, store or communicate AUSTEO, AGAO or REL data, personnel who are foreign nationals are identified as such, including by their specific nationality.

Artificial intelligence agent identification

In addition to the general requirement for users to be uniquely identifiable, assigning each AI agent its own unique identity ensures that actions taken by an AI agent can be distinguished from actions taken directly by a user on whose behalf it acts, as well as from actions taken by other AI agents. In doing so, identities assigned to AI agents should be managed in a similar manner to service accounts, including being disabled or removed when no longer required. Where an AI agent is assigned multiple identities, such as across different environments or platforms, all identities should be recorded in an organisation's AI agent register.

Control: ISM-2133; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Each AI agent is assigned a unique identity that is distinct from the user accounts of personnel and the identities of other AI agents.

Unprivileged access to systems

Personnel seeking access to systems and their resources should have a genuine business requirement validated by their manager or another appropriate authority.

In addition, centrally logging and analysing unprivileged access events can assist in monitoring the security posture of systems and their resources, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-0405; Revision: 8; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Requests for unprivileged access to systems and their resources are validated when first requested.

Control: ISM-1852; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unprivileged access to systems and their resources is limited to only what is required for users to undertake their duties or functions.

Control: ISM-1566; Revision: 3; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Use of unprivileged access is centrally logged.

Unprivileged access to systems by foreign nationals

Due to the extra sensitivities associated with AUSTEO, AGAO and REL data, foreign access to such data is strictly controlled.

Control: ISM-0409; Revision: 9; Updated: Sep-26; Applicable: S, TS; Essential 8: N/A
Foreign nationals, including seconded foreign nationals, do not have access to systems that process, store or communicate AUSTEO or REL data unless effective security controls are in place to ensure such data is not accessible to them.

Control: ISM-0411; Revision: 8; Updated: Sep-26; Applicable: S, TS; Essential 8: N/A
Foreign nationals, excluding seconded foreign nationals, do not have access to systems that process, store or communicate AGAO data unless effective security controls are in place to ensure such data is not accessible to them.

Privileged access to systems

Privileged user accounts are considered those that can alter or circumvent security controls. This also applies to user accounts that may only have limited privileges but still have the ability to bypass some security controls.

Privileged user accounts are often targeted by malicious actors as they can potentially give full access to systems and their resources. As such, ensuring that privileged user accounts are prevented from accessing the internet, email and web services minimises opportunities for these accounts to be compromised. However, if privileged user accounts are explicitly authorised to

access online services, they should be strictly limited to only what is required for users to undertake their duties or functions.

Finally, centrally logging and analysing privileged access events, as well as privileged user account and security group management events, can assist in monitoring the security posture of systems and their resources, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1507; Revision: 4; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Requests for privileged access to systems and their resources are validated when first requested.

Control: ISM-1508; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Privileged access to systems and their resources is limited to only what is required for users to undertake their duties or functions.

Control: ISM-1175; Revision: 6; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Privileged user accounts (excluding those explicitly authorised to access online services) are prevented from accessing the internet, email and web services.

Control: ISM-1883; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Privileged user accounts explicitly authorised to access online services are strictly limited to only what is required for users to undertake their duties or functions.

Control: ISM-1649; Revision: 1; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Just-in-time administration is used for the administration of systems and their resources.

Control: ISM-0445; Revision: 9; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Privileged human users are assigned a dedicated privileged user account to be used solely for duties requiring privileged access.

Control: ISM-1263; Revision: 5; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unique privileged user accounts are used for administering individual server applications.

Control: ISM-1509; Revision: 3; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Privileged access events are centrally logged.

Control: ISM-1650; Revision: 3; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Privileged user account and security group management events are centrally logged.

Privileged access to systems by foreign nationals

As privileged user accounts often have the ability to bypass security controls, it is strongly encouraged that foreign nationals are not given privileged access to systems that process, store or communicate AUSTEO, AGAO or REL data.

Control: ISM-0446; Revision: 5; Updated: Jun-21; Applicable: S, TS; Essential 8: N/A
Foreign nationals, including seconded foreign nationals, do not have privileged access to systems that process, store or communicate AUSTEO or REL data.

Control: ISM-0447; Revision: 4; Updated: Jun-21; Applicable: S, TS; Essential 8: N/A
Foreign nationals, excluding seconded foreign nationals, do not have privileged access to systems that process, store or communicate AGAO data.

Recording authorisation for personnel to access systems

Retaining records of account requests for systems and their resources will assist in maintaining personnel accountability. Such records should include each human user's unique identifier, their agreement to abide by system usage policies, who provided the authorisation for their access, when their authorisation was granted and when their access was last reviewed.

Control: ISM-0407; Revision: 7; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A secure record is maintained for the life of systems and their resources that covers the following for each human user:

- *their unique identifier*
- *their signed agreement to abide by system usage policies*
- *who authorised their access*
- *when their access was granted*
- *the level of access they were granted*
- *when their access, and their level of access, was last reviewed*
- *when their level of access was changed, and to what extent (if applicable)*
- *when their access was withdrawn (if applicable).*

Artificial intelligence agent register

AI agents can be rapidly created and deployed across an organisation's systems, often by personnel operating outside of traditional software deployment processes. Each AI agent may be configured with its own instructions, AI models, tools, permissions, credentials and access to data repositories. Without visibility of the AI agents operating across its systems, an organisation cannot effectively restrict AI agents to the minimum permissions they require, review their continued need, identify unauthorised or abandoned AI agents, or investigate cyber security incidents involving them. As such, an organisation should develop, implement, maintain and

regularly verify an AI agent register. An AI agent register may also record additional details, such as the AI models used by each AI agent and their versions, to support change management and cyber supply chain risk management activities.

Control: ISM-2134; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An AI agent register is developed, implemented, maintained and regularly verified.

Control: ISM-2135; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An AI agent register contains the following for each AI agent:

- *its unique identifier*
- *its owner and business purpose*
- *the identities assigned to it*
- *any user accounts and credentials it uses*
- *the tools, permissions and data repositories it can access.*

Suspension of access to systems

Removing or suspending access to systems and their resources, ideally using an automatic mechanism, can prevent them from being accessed when there is no longer a legitimate business requirement for their use, such as when users change duties or functions, or are detected undertaking malicious activities.

Control: ISM-0430; Revision: 9; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Access to systems and their resources are removed or suspended the same day users no longer have a legitimate requirement for access.

Control: ISM-1591; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Access to systems and their resources are removed or suspended as soon as practicable when users are detected undertaking malicious activities.

Control: ISM-1404; Revision: 5; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unprivileged access to systems and their resources are disabled after 45 days of inactivity.

Control: ISM-1648; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Privileged access to systems and their resources are disabled after 45 days of inactivity.

Control: ISM-1647; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Privileged access to systems and their resources are disabled after 12 months unless revalidated.

Temporary access to systems

Under strict circumstances, temporary access to systems and their resources may be granted to personnel who lack an appropriate security clearance or briefing. In such circumstances, personnel

should have their access controlled in such a way that they only have access to data required for them to undertake their duties or functions.

Control: ISM-0441; Revision: 10; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When personnel are granted temporary access to systems and their resources, effective security controls are put in place to restrict their access to only data required for them to undertake their duties or functions.

Control: ISM-0443; Revision: 3; Updated: Sep-18; Applicable: S, TS; Essential 8: N/A
Temporary access is not granted to systems that process, store or communicate caveated or sensitive compartmented information.

Emergency access to systems

It is important that an organisation does not lose access to systems and their resources. As such, an organisation should always have a method for gaining access during emergencies. Typically, emergencies can occur when access cannot be gained via normal authentication processes, such as due to misconfigurations of authentication services, misconfigurations of security settings or due to a cyber security incident. In these situations, break glass accounts (also known as emergency access accounts) can be used to gain access. As break glass accounts have the highest level of privileges available, extreme care should be taken to protect them, as well as monitor them for any signs of compromise or abuse.

When break glass accounts are used, any administrative activities performed will not be directly attributable to individuals, and event logs may not be generated. As such, additional security controls need to be implemented to maintain the system's integrity. In doing so, an organisation should ensure that any administrative activities performed using break glass accounts are identified and documented in support of change management processes and procedures. This includes documenting the individuals using break glass accounts, the reasons for using break glass accounts and any administrative activities performed using break glass accounts.

As the custodian of each break glass account should be the only party who knows the break glass account's credentials, credentials will need to be changed and tested by custodians after any authorised access by another party. Modern password managers that support automated credential changes can assist in reducing the administrative overhead of such activities.

Finally, centrally logging and analysing break glass account events can assist in monitoring the security posture of systems and their resources, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1610; Revision: 1; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A method of emergency access to systems and their resources is documented and tested at least once when initially implemented and each time fundamental information technology infrastructure changes occur.

Control: ISM-1611; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Break glass accounts are only used when normal authentication processes cannot be used.

Control: ISM-1612; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Break glass accounts are only used for specific authorised activities.

Control: ISM-1614; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Break glass account credentials are changed by the account custodian after they are accessed by any other party.

Control: ISM-1615; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Break glass accounts are tested after credentials are changed.

Control: ISM-1613; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Use of break glass accounts is centrally logged.

Control of Australian systems

Due to extra sensitivities associated with AUSTEO and AGAO data, it is essential that control of systems that process, store or communicate such data is maintained by Australian nationals working for or on behalf of the Australian Government. Furthermore, AUSTEO and AGAO data should only be accessible from systems under the sole control of the Australian Government that are located within facilities authorised by the Australian Government.

Control: ISM-0078; Revision: 5; Updated: Jun-21; Applicable: S, TS; Essential 8: N/A
Systems processing, storing or communicating AUSTEO or AGAO data remain at all times under the control of an Australian national working for or on behalf of the Australian Government.

Control: ISM-0854; Revision: 6; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
AUSTEO and AGAO data can only be accessed from systems under the sole control of the Australian Government that are located within facilities authorised by the Australian Government.

Authenticating to systems

Before access to a system and its resources is granted to a user, it is essential that they are authenticated. For human users, this can be achieved via multi-factor authentication, such as a username, password and security key, or less preferably via single-factor authentication, such as a username and password.

In addition, access decisions should not rely solely on the successful presentation of authentication artefacts. Risk-based access decisions can draw upon contextual signals such as device compliance, authentication strength, privilege level and user behaviour to determine whether access should be granted, re-authentication should be required or access should be denied. In doing so, an organisation should be aware that sign-in location is a weak signal on its own, as malicious actors increasingly route their activities through residential internet protocol addresses and covert networks of compromised devices to defeat location-based and reputation-based measures.

Control: ISM-1546; Revision: 0; Updated: Aug-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Users are authenticated before they are granted access to a system and its resources.

Control: ISM-2136; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Risk-based access decisions, informed by contextual signals, are enforced for access to systems and their resources.

Insecure authentication methods

Authentication methods need to resist theft, interception, duplication, forgery, unauthorised access and unauthorised modification. For example, LAN Manager authentication protects credentials with a weak hashing algorithm, while all versions of NT LAN Manager lack mutual authentication and rely on password-derived hashes. As such, malicious actors can exploit these authentication methods via relay attacks, pass-the-hash attacks and the offline cracking of captured authentication exchanges. Instead, an organisation should use Kerberos for authentication within Microsoft Windows environments.

Control: ISM-1603; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication methods susceptible to replay attacks are disabled.

Control: ISM-1055; Revision: 4; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
LAN Manager and NT LAN Manager authentication methods are disabled.

Control: ISM-2076; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security questions are not used for authentication purposes.

Control: ISM-2077; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Email is not used for out-of-band authentication purposes.

Multi-factor authentication

Multi-factor authentication uses two or more different authentication factors. This may include:

- something people know, such as a password
- something people have, such as a security key, smart card, smartphone or one-time password token
- something people are, such as a fingerprint pattern or their facial geometry.

Human users of online services, privileged human users of systems and human users with access to data repositories are more likely to be targeted by malicious actors due to their access. For this reason, it is especially important that multi-factor authentication is used for these user accounts. In addition, multi-factor authentication is vital when human users perform administrative activities as it can limit the consequences of a compromise by preventing or slowing malicious actors' ability to gain unrestricted access to assets. In this regard, multi-factor authentication can be implemented as part of jump server authentication where assets being administered do not support multi-factor authentication themselves.

When implementing multi-factor authentication, several different authentication factors can be implemented. Unfortunately, some authentication factors, such as biometrics or codes sent via Short Message Service, Voice over Internet Protocol or email, are more susceptible to compromise

than others. For this reason, authentication factors that involve something people have should be used with something people know. Alternatively, something people have that is unlocked by something people know or are (often known as passwordless multi-factor authentication) can be used. Furthermore, for increased security, the use of phishing-resistant multi-factor authentication is recommended to protect against real-time phishing attacks.

Passkey authentication may provide either single-factor or multi-factor authentication, depending on how it is implemented and used. It typically uses a computer or smartphone, or a separate security key, to store or access a private key. Where use of the private key requires an activation factor, such as a password or biometric, passkey authentication satisfies multi-factor authentication requirements.

Finally, centrally logging and analysing multi-factor authentication events can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1504; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Multi-factor authentication is used to authenticate human users to their organisation's online services that process, store or communicate their organisation's sensitive data.

Control: ISM-1679; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Multi-factor authentication is used to authenticate human users to third-party online services that process, store or communicate their organisation's sensitive data.

Control: ISM-1680; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Multi-factor authentication (where available) is used to authenticate human users to third-party online services that process, store or communicate their organisation's non-sensitive data.

Control: ISM-1892; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Multi-factor authentication is used to authenticate human users to their organisation's online customer services that process, store or communicate their organisation's sensitive customer data.

Control: ISM-1893; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Multi-factor authentication is used to authenticate human users to third-party online customer services that process, store or communicate their organisation's sensitive customer data.

Control: ISM-1681; Revision: 3; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Multi-factor authentication is used to authenticate customers to online customer services that process, store or communicate sensitive customer data.

Control: ISM-1919; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When multi-factor authentication is used to authenticate human users or customers to online

services or online customer services, all other authentication protocols that do not support multi-factor authentication are disabled.

Control: ISM-1173; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Multi-factor authentication is used to authenticate privileged human users of systems.

Control: ISM-0974; Revision: 7; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Multi-factor authentication is used to authenticate unprivileged human users of systems.

Control: ISM-1505; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Multi-factor authentication is used to authenticate human users of data repositories.

Control: ISM-1401; Revision: 6; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Multi-factor authentication uses either: something people have and something people know, or something people have that is unlocked by something people know or are.

Control: ISM-1872; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Multi-factor authentication used for authenticating human users of online services is phishing-resistant.

Control: ISM-1873; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2
Multi-factor authentication used for authenticating customers of online customer services provides a phishing-resistant option.

Control: ISM-1874; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Multi-factor authentication used for authenticating customers of online customer services is phishing-resistant.

Control: ISM-1682; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Multi-factor authentication used for authenticating human users of systems is phishing-resistant.

Control: ISM-1894; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Multi-factor authentication used for authenticating human users of data repositories is phishing-resistant.

Control: ISM-2011; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When phishing-resistant multi-factor authentication is used by human users, other non-phishing-resistant multi-factor authentication options are disabled for their user accounts.

Control: ISM-1920; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When multi-factor authentication is used to authenticate human users to online services, online customer services, systems or data repositories – that process, store or communicate their organisation's sensitive data or sensitive customer data – human users are prevented from self-enrolling into multi-factor authentication from untrustworthy devices.

Control: ISM-1683; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Successful and unsuccessful multi-factor authentication events are centrally logged.

Single-factor authentication

A significant threat to the compromise of user accounts is password cracking tools. When malicious actors gain access to a list of usernames and hashed passwords from a system, they can attempt to recover username and password pairs by comparing the hashes of known passwords with the hashed passwords they have gained access to. By finding a match, malicious actors will know the password associated with a given username. To reduce this security risk, an organisation should implement multi-factor authentication.

In addition, centrally logging and analysing single-factor authentication events can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-0417; Revision: 6; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When systems cannot support multi-factor authentication, single-factor authentication using passwords is implemented instead.

Control: ISM-1895; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Successful and unsuccessful single-factor authentication events are centrally logged.

User account lockouts

Locking user accounts after a specified number of repeated failed logon attempts reduces the likelihood of successful forms of credential brute-force attacks by malicious actors, such as credential guessing attacks, credential spraying attacks and credential stuffing attacks. However, care should be taken when implementing indefinite account lockouts in response to repeated failed logon attempts as this can increase the likelihood of a denial of service. Alternatively, some systems can be configured with risk-based lockout mechanisms in combination with automated lockout durations to slow down repeated failed logon attempts. Implementing multi-factor authentication is also an effective way of reducing the likelihood of successful credential brute-force attacks.

Control: ISM-1403; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User accounts, except for break glass accounts, are protected by fixed or risk-based lockout mechanisms aligned to a maximum of five failed logon attempts, with either indefinite or automated lockout durations.

Session locking

Session locking prevents unauthorised access to services that a human user has already authenticated to.

Control: ISM-0428; Revision: 11; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Services are configured with a session lock that:

- *activates after a maximum of 15 minutes of human user inactivity, a maximum of 12 hours of overall session time or when manually activated*
- *blocks access to all session content*
- *requires re-authentication by human users using all authentication factors to unlock the session*
- *denies human users the ability to disable the session locking mechanism.*

Screen locking

Screen locking prevents unauthorised access to a system that a human user has already authenticated to.

Control: ISM-2012; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Systems are configured with a screen lock that:

- *activates after a maximum of 15 minutes of human user inactivity, or when manually activated*
- *conceals all content on the screen*
- *ensures that the screen does not enter a power saving state before the screen lock is activated*
- *requires re-authentication by human users using all authentication factors to unlock the system*
- *denies human users the ability to disable the screen locking mechanism.*

Session termination

Implementing measures to terminate interactive user sessions and restart workstations at least daily can assist in system maintenance activities and removing malicious actors that may have compromised a system but failed to gain persistence.

Control: ISM-0853; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Interactive user sessions are terminated and workstations are restarted at least daily.

Third-party application access and device code authentication

Malicious actors can abuse legitimate Open Authorization (OAuth) flows to obtain enduring access to data without stealing credentials. In an illicit consent grant attack, a human user is tricked into granting a malicious third-party application consent to access data, after which the application holds OAuth tokens that operate independently of the human user's credentials and survive

credential resets. Separately, the device code authentication flow can be abused so that a human user, believing they are signing themselves in, authorises a malicious actor's session.

Importantly, malicious actors do not need to establish new consent grants if they can compromise an existing third-party application that has already been granted access, such as via a cyber supply chain attack against the application's vendor. As such, in addition to controlling how new consent is granted, an organisation should regularly review existing consent grants, revoke those that are unused or hold excessive permissions, and centrally log consent and token issuance activity to support the detection of anomalous use.

Finally, while the device code authentication flow should be disabled by default, an organisation may have a legitimate business requirement for its use, such as for input-constrained devices. In such cases, its use should be restricted to the specific user accounts and managed devices that require it.

Control: ISM-2137; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Human users are prevented from granting consent to third-party OAuth applications, with such consent granted only by an authorised administrator.

Control: ISM-2138; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
OAuth application consents, including their granted permissions, are reviewed at least every six months, with unused applications and excessive permissions revoked.

Control: ISM-2139; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Consent grants, token issuance and token use for third-party OAuth applications are centrally logged.

Control: ISM-2140; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The OAuth device code authentication flow is disabled unless required, and where required, is restricted to authorised user accounts and managed devices.

Further information

Further information on access to government resources, including required security clearances, can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Further information on access to highly sensitive government resources, including required briefings, can be found in the Government Security Committee's *Australian Government Security Caveat Guidelines*. This publication is available from the Protective Security Policy GovTEAMS community or the Australian Security Intelligence Organisation by email.

Further information on restricting the use of privileged user accounts can be found in ASD's *Restricting administrative privileges* publication.

Further information on administering systems and their resources can be found in the 'System administration' section of the *Guidelines for system management*.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on the use of AI agents can be found in ASD's *Careful adoption of agentic AI services* publication.

Further information on implementing multi-factor authentication can be found in ASD's *Implementing multi-factor authentication* publication.

Credential management

Context

The guidance within this section is equally applicable to all user accounts unless specified otherwise. This includes unprivileged user accounts and privileged user accounts, which include break glass accounts and service accounts. In addition, the guidance is equally applicable to interactive authentication and non-interactive authentication.

Password strength

When implementing passwords as an authentication factor, it is important that suitably robust and secure passwords are used. In doing so, the degree of password security required will depend on the sensitivity or classification of the system involved and whether passwords are implemented as part of multi-factor authentication or single-factor authentication.

Control: ISM-1559; Revision: 4; Updated: Dec-25; Applicable: NC, OS, P; Essential 8: N/A
Passwords used for multi-factor authentication on non-classified, OFFICIAL: Sensitive and PROTECTED systems are a minimum of 6 characters.

Control: ISM-1560; Revision: 3; Updated: Dec-25; Applicable: S; Essential 8: N/A
Passwords used for multi-factor authentication on SECRET systems are a minimum of 8 characters.

Control: ISM-1561; Revision: 3; Updated: Dec-25; Applicable: TS; Essential 8: N/A
Passwords used for multi-factor authentication on TOP SECRET systems are a minimum of 10 characters.

Control: ISM-0421; Revision: 11; Updated: Dec-25; Applicable: NC, OS, P; Essential 8: N/A
Passwords used for single-factor authentication on non-classified, OFFICIAL: Sensitive and PROTECTED systems are a minimum of 15 characters.

Control: ISM-1557; Revision: 3; Updated: Dec-25; Applicable: S; Essential 8: N/A
Passwords used for single-factor authentication on SECRET systems are a minimum of 17 characters.

Control: ISM-0422; Revision: 9; Updated: Dec-25; Applicable: TS; Essential 8: N/A
Passwords used for single-factor authentication on TOP SECRET systems are a minimum of 20 characters.

Control: ISM-1558; Revision: 3; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Passwords using a sequence of words for single-factor authentication are not constructed using:

- *a list of categorised words*
- *a real sentence in a natural language*
- *song lyrics, movie or television show quotes, literature, or any other publicly available material*
- *less than 4 random words for non-classified, OFFICIAL: Sensitive and PROTECTED systems; 5 random words for SECRET systems; or 6 random words for TOP SECRET systems.*

Control: ISM-2078; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Passwords appearing in lists of commonly used passwords or lists of compromised passwords are not used.

Control: ISM-2079; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Maximum length limits for passwords are not less than 64 characters.

Control: ISM-2080; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Password complexity requirements are not imposed for passwords.

Control: ISM-2081; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All ASCII printable characters are supported for passwords.

Setting credentials for user accounts

Before any credentials are set, reset, temporarily disabled or re-enrolled for user accounts assigned to human users, it is important that human users provide sufficient evidence to verify their identity, such as by physically presenting themselves and their pass to a service desk, answering a set of challenge-response questions, or by demonstrating control of a linked mobile device. Following the verification of user identity, credentials should be randomly generated and provided via a secure communications channel or, if not possible, split into two parts with one part provided to the human user and the other part provided to their supervisor. Subsequently, credentials provided to human users should be reset on first use to ensure that they are not known by other parties.

Control: ISM-1593; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Human users provide sufficient evidence to verify their identity when first requesting credentials, when requesting the reset of any credentials, when requesting the temporary disabling of any credentials, and when requesting the enrolment or re-enrolment of any credentials.

Control: ISM-1227; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials set for user accounts are randomly generated.

Control: ISM-1594; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials for human users are provided via a secure communications channel or, if not possible, split into two parts with one part provided to the human user and the other part provided to their supervisor.

Control: ISM-1595; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials provided to human users are changed on first use.

Control: ISM-1596; Revision: 3; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials are not reused by users across different systems.

Setting credentials for built-in Administrator accounts, break glass accounts, local administrator accounts and service accounts

When built-in Administrator accounts, break glass accounts, local administrator accounts and service accounts use common usernames or weak credentials, it may allow malicious actors that compromise credentials on one workstation or server to compromise other workstations and servers. As such, it is critical that credentials for the built-in Administrator account, break glass accounts, local administrator accounts and service accounts in each domain are long, unique, unpredictable and managed.

To provide additional security and credential management functionality for service accounts, Microsoft introduced group Managed Service Accounts to Microsoft Windows Server. In doing so, service accounts that are created as group Managed Service Accounts do not require manual credential management by system administrators, as the operating system automatically ensures that they are long, unique, unpredictable and managed. This ensures that service account credentials are secure, not misplaced or forgotten, and that they are automatically changed regularly. However, in cases where the use of group Managed Service Accounts is not possible, credentials for service accounts should still be unique, unpredictable and random with a minimum length of 30 characters.

Control: ISM-1953; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials for the built-in Administrator account in each domain are long, unique, unpredictable and managed.

Control: ISM-1685; Revision: 2; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Credentials for break glass accounts, local administrator accounts and service accounts are long, unique, unpredictable and managed.

Control: ISM-1795; Revision: 2; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials for built-in Administrator accounts, break glass accounts, local administrator accounts and service accounts are a minimum of 30 characters.

Control: ISM-1954; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials for built-in Administrator accounts, break glass accounts, local administrator accounts and service accounts are randomly generated.

Control: ISM-1619; Revision: 0; Updated: Oct-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Service accounts are created as group Managed Service Accounts.

Application and workload credentials

Applications and workloads may require credentials to authenticate to systems, services and data repositories without direct human involvement. Where such credentials are long-lived or reused by multiple applications, workloads or operating environments, their compromise can provide malicious actors with persistent access to systems and increase the extent of a compromise.

Applications and workloads should use short-lived dynamically issued credentials in preference to long-lived static credentials. Where static credentials are required, centrally managing them using a credential or secrets management solution can assist with their secure storage, access control and lifecycle management. In addition, applications and workloads should use unique credentials that are not shared with other applications or workloads, or across development, testing, staging and production environments.

Control: ISM-2141; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Applications and workloads use short-lived dynamically issued credentials in preference to long-lived static credentials.

Control: ISM-2142; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Static credentials used by applications and workloads are centrally managed using a credential or secrets management solution.

Control: ISM-2143; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Applications and workloads use unique credentials that are not shared with other applications or workloads, or across development, testing, staging and production environments.

Changing credentials

Generally, credentials should not need to be changed; however, some events may necessitate a requirement for credentials to be changed. For user accounts, this can include credentials being compromised (such as appearing in an online data breach database) or being suspected of being compromised (such as when malicious actors gain access to a network), being discovered stored on systems in the clear, being transferred across networks in the clear, or when membership of a shared user account changes.

Similarly, static credentials used by applications and workloads should be changed when they are compromised or suspected of being compromised, discovered stored on systems in the clear, or discovered being transferred across networks in the clear.

Control: ISM-1590; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials for user accounts are changed if:

- *they are compromised or suspected of being compromised*
- *they are discovered stored on systems in the clear*
- *they are discovered being transferred across networks in the clear*
- *membership of a shared user account changes.*

Control: ISM-2144; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Static credentials used by applications and workloads are changed if:

- *they are compromised or suspected of being compromised*
- *they are discovered stored on systems in the clear*
- *they are discovered being transferred across networks in the clear.*

Control: ISM-1955; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials for computer accounts are changed if they are compromised, they are suspected of being compromised or they have not been changed in the past 30 days.

Control: ISM-1847; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials for the Kerberos Key Distribution Center's service account (KRBTGT) are changed twice, allowing for replication to all Microsoft AD DS domain controllers in-between each change, if the domain has been directly compromised, the domain is suspected of being compromised or they have not been changed in the past six months.

Control: ISM-1956; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Microsoft AD FS token-signing and encryption certificates are changed twice in quick succession if they are compromised, they are suspected of being compromised or they have not been changed in the past 12 months.

Revoking credentials

Credentials that are no longer required should be revoked to prevent their subsequent use to gain unauthorised access to systems and their resources. This includes credentials associated with user accounts that are no longer required, as well as static credentials used by applications and workloads that have been decommissioned or are no longer required for access.

Control: ISM-2145; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials for user accounts are revoked when they are no longer required.

Control: ISM-2146; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Static credentials used by applications and workloads are revoked when they are no longer required.

Protecting credentials

Obscuring credentials as they are entered into systems can assist in protecting them against screen scrapers and shoulder surfers. In addition, physical credentials, such as written down credentials (e.g. passwords) and dedicated devices that store or generate credentials (e.g. security keys, smart cards and one-time password tokens), when kept together with systems they are used to authenticate to, can increase the likelihood of malicious actors gaining unauthorised access to systems. For example, when smart cards are left on card readers, one-time password tokens are left in laptop computer bags, security keys are left connected to computers or passwords are written down and stuck to computer monitors. To reduce this security risk, physical credentials

should be kept separate from systems they are used to authenticate to, except for when performing authentication activities.

If storing credentials on systems, sufficient protection should be implemented to prevent them from being compromised. For example, credentials can be stored in a password manager or hardware security module, while credentials stored in a database should be hashed, salted and stretched.

When using Microsoft Windows systems, Local Security Authority protection, Credential Guard and Remote Credential Guard functionality, all preferably with a Unified Extensible Firmware Interface lock, can be enabled to provide additional protection for credentials. In addition, malicious actors that have access to systems may attempt to steal cached credentials. To reduce this security risk, cached credentials should be limited to only one previous logon.

Finally, an organisation should regularly scan their systems to detect and remediate any credentials that are being stored in an unprotected manner, such as in the clear in documents, configuration files, network file shares, software repositories, cloud storage or other data repositories.

Control: ISM-1597; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials are obscured as they are entered into systems.

Control: ISM-1980; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credential hint functionality is not used for systems.

Control: ISM-0418; Revision: 7; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Physical credentials are kept separate from systems they are used to authenticate to, except for when performing authentication activities.

Control: ISM-1402; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Credentials stored on systems are protected by a password manager; a hardware security module; or by salting, hashing and stretching them before storage within a database.

Control: ISM-1957; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Private keys for Microsoft AD CS certification authority servers are protected by a hardware security module.

Control: ISM-1861; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Local Security Authority protection functionality is enabled.

Control: ISM-1686; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Credential Guard functionality is enabled.

Control: ISM-1897; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Remote Credential Guard functionality is enabled.

Control: ISM-1749; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cached credentials are limited to one previous logon.

Control: ISM-1875; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Systems are scanned at least monthly to identify any credentials that are being stored in the clear.

Protecting authentication artefacts

Once a user has authenticated, malicious actors may target the resulting authentication artefacts rather than the user's credentials. Adversary-in-the-middle phishing and information-stealing malware can capture these authentication artefacts and replay them to bypass authentication measures, including multi-factor authentication. As such, it is important that authentication artefacts are protected to limit their usefulness to malicious actors if stolen. This includes cryptographically binding authentication artefacts to the devices on which they were issued to help prevent successful replay from other devices.

In addition, revoking active sessions and refresh tokens when trust in a user account or device changes reduces the window in which stolen authentication artefacts remain useful to malicious actors. This includes when credentials are reset or re-enrolled, when credentials are compromised or suspected of being compromised, when a device no longer meets compliance requirements, or when high-risk sign-in activity is detected. Notably, revoking active sessions and refresh tokens following credential resets and re-enrolments is an important companion to verifying human user identities when such requests are made, as malicious actors that have socially engineered a credential reset may seek to establish durable access via stolen authentication artefacts before the activity is discovered.

Control: ISM-2147; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication tokens, session cookies and refresh tokens are cryptographically bound to the device on which they were issued.

Control: ISM-2148; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Active sessions, refresh tokens and other authentication artefacts are revoked when credentials are reset or re-enrolled, when credentials are compromised or suspected of being compromised, when a device no longer meets compliance requirements, or when high-risk sign-in activity is detected.

Further information

Further information on randomly generating passphrases is available from the Electronic Frontier Foundation while a random dice roller is available from RANDOM.ORG.

Further information on how to secure group Managed Service Accounts in Microsoft Windows Server is available from Microsoft.

Further information on changing credentials for the Kerberos Key Distribution Center's service account can be found in Microsoft's *Active Directory accounts* and *Active Directory Forest Recovery - Reset the krbtgt password* publications. A script for changing credentials for this service account is also available from Microsoft.

Further information on Local Security Authority protection functionality is available from Microsoft.

Further information on Credential Guard functionality and Remote Credential Guard functionality is available from Microsoft.

Guidelines for system management

System administration

Context

System administration of cloud services brings unique challenges when compared to system administration of on-premises assets. Importantly, responsibility for system administration of cloud services is often shared between service providers and their customers. As the system administration processes and procedures implemented by service providers are often opaque to their customers, customers should consider a service provider's control plane to operate within a different security domain.

System administration processes and procedures

A key component of system administration is ensuring that administrative activities are undertaken in a repeatable and accountable manner using system administration processes and procedures. In doing so, requirements for administrative activities may cover:

- configuring applications, operating systems, network devices or networked information technology (IT) equipment
- applying patches, updates or vendor mitigations to applications, drivers, firmware or operating systems
- installing or removing applications, operating systems, network devices or networked IT equipment
- implementing system changes or enhancements
- resolving problems identified by users.

Furthermore, in support of change management processes and procedures, system administrators should document requirements for administrative activities, consider potential security impacts, obtain any necessary approvals, notify any affected parties of disruptions or outages, and maintain system and cyber security documentation.

Control: ISM-0042; Revision: 6; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System administration processes, and supporting system administration procedures, are developed, implemented and maintained.

Control: ISM-1211; Revision: 7; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System administration activities are performed in accordance with the system's change and configuration management plan.

Separate privileged operating environments

One of the greatest threats to the security of networks is the compromise of privileged user accounts. Providing a separate privileged operating environment for system administrators, in addition to their unprivileged operating environment, makes it much harder for administrative activities and privileged user accounts to be compromised by malicious actors.

Using different physical workstations, with one being a dedicated Secure Admin Workstation, is the most secure approach to separating privileged and unprivileged operating environments for system administrators. However, a trusted and hardened virtualisation-based solution may be sufficient for separating privileged and unprivileged operating environments on the same Secure Admin Workstation. In such cases, privileged operating environments should not be virtualised within unprivileged operating environments.

Control: ISM-1898; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Secure Admin Workstations are used in the performance of administrative activities.

Control: ISM-1380; Revision: 6; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Privileged human users use separate privileged and unprivileged operating environments.

Control: ISM-1687; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Privileged operating environments are not virtualised within unprivileged operating environments.

Control: ISM-1688; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Unprivileged user accounts cannot be used to log on to privileged operating environments.

Control: ISM-1689; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Privileged user accounts (excluding local administrator accounts) cannot be used to log on to unprivileged operating environments.

Control: ISM-1958; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User accounts with DCSync permissions cannot be used to log on to unprivileged operating environments.

Administrative infrastructure

The security of administrative activities can be improved by segregating administrative infrastructure from the wider network and the internet. In doing so, the use of a jump server (also known as a jump host or jump box) that allows only necessary ports and services to be used can be an effective way of simplifying and securing administrative activities. Specifically, a jump server can provide filtering of network management traffic while also acting as a focal point to perform multi-factor authentication; store and manage administrative tools; and perform logging, monitoring and alerting activities. In addition, using separate jump servers for the administration of critical servers (such as Microsoft Active Directory Domain Services domain controllers,

Microsoft Active Directory Certificate Services servers, Microsoft Active Directory Federation Services servers and Microsoft Entra Connect servers), high-value servers (such as Domain Name System servers, database servers, email servers, file servers and web servers) and regular servers can further assist in protecting these assets.

Control: ISM-1385; Revision: 4; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Administrative infrastructure is segregated from the wider network and the internet.

Control: ISM-1750; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Administrative infrastructure for critical servers, high-value servers and regular servers is segregated from each other.

Control: ISM-1386; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network management traffic can only originate from administrative infrastructure.

Control: ISM-1387; Revision: 2; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Administrative activities are conducted through jump servers.

Control: ISM-1899; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network devices that do not belong to administrative infrastructure cannot initiate connections with administrative infrastructure.

Administrative tools

Legitimate remote monitoring and management (RMM) tools and remote access tools are frequently abused by malicious actors as they are digitally signed, often permitted by application control rulesets and provide interactive access that blends with normal system administration activities. As such, an organisation should develop, enforce and maintain a list of authorised RMM tools and remote access tools, to prevent the execution of those that are not authorised, to the extent possible, and monitor for any unusual or unexpected network activity associated with their use.

Control: ISM-2149; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A list of authorised RMM tools and remote access tools is developed, enforced and maintained.

Control: ISM-2150; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network connections for unauthorised RMM tools and remote access tools are blocked at gateways.

Software registers

Maintaining accurate software registers assists an organisation in managing its systems and maintaining awareness of the software installed on them, including applications, drivers, firmware and operating systems. Software registers can support change and configuration management, vulnerability management, cyber security incident response and software lifecycle management. This includes monitoring trustworthy sources for information about relevant vulnerabilities, patches, updates and cessation of support.

Control: ISM-1493; Revision: 7; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software registers for workstations, servers, network devices and networked IT equipment are developed, implemented, maintained and regularly verified.

Control: ISM-1643; Revision: 0; Updated: Jun-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software registers contain versions and patch histories of applications, drivers, operating systems and firmware.

Further information

Further information on system administration can be found in the Australian Signals Directorate's (ASD) *Secure administration* publication.

Further information on change and configuration management plans can be found in the 'System-specific cyber security documentation' section of the *Guidelines for cyber security documentation*.

Further information on the use of privileged user accounts for system administration activities can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on network segmentation and segregation can be found in the 'Network design and configuration' section of the *Guidelines for networking*.

System maintenance

Patch management processes and procedures

Applying patches or updates is critical to ensuring the ongoing security of applications, drivers, operating systems and firmware. In doing so, it is important that patches or updates are applied consistently and in a secure manner. For example, by using a centralised and managed approach that maintains the integrity of patches or updates and confirms that they have been applied successfully.

Control: ISM-1143; Revision: 9; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Patch management processes, and supporting patch management procedures, are developed, implemented and maintained.

Control: ISM-0298; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A centralised and managed approach that maintains the integrity of patches or updates, and confirms that they have been applied successfully, is used to patch or update applications, operating systems, drivers and firmware.

Mitigating known vulnerabilities

When patches or updates are released by vendors for vulnerabilities, an organisation should apply them in a timeframe commensurate with the likelihood of attempted exploitation by malicious actors. For example, by prioritising patches or updates for vulnerabilities in online services as well as operating systems of internet-facing servers and internet-facing network devices. This is

especially important when vulnerabilities are assessed as critical by vendors or working exploits exist.

If no patches or updates are available for vulnerabilities, mitigation advice from vendors, trustworthy authorities or security researchers may provide some protection until patches or updates are made available. Such mitigation advice may be published in conjunction with, or soon after, announcements made relating to vulnerabilities. Mitigation advice may cover how to disable or block access to vulnerable functionality, how to reconfigure vulnerable functionality, or how to detect attempted or successful exploitation of vulnerable functionality.

If a patch or update is released for high assurance IT equipment, ASD will assess the patch or update. Subsequently, if the patch or update is approved for deployment, ASD will provide guidance on the methods and timeframes in which it is to be applied.

Control: ISM-1876; Revision: 0; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist.

Control: ISM-1690; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Patches, updates or other vendor mitigations for vulnerabilities in online services are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist.

Control: ISM-1691; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2
Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF applications, and security products are applied within two weeks of release.

Control: ISM-1692; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF applications, and security products are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist.

Control: ISM-1901; Revision: 1; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Patches, updates or other vendor mitigations for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF applications, and security products are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist.

Control: ISM-1693; Revision: 3; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Patches, updates or other vendor mitigations for vulnerabilities in applications other than office

productivity suites, web browsers and their extensions, email clients, PDF applications, and security products are applied within one month of release.

Control: ISM-1877; Revision: 0; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist.

Control: ISM-1694; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Patches, updates or other vendor mitigations for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices are applied within two weeks of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist.

Control: ISM-1695; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2
Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within one month of release.

Control: ISM-1696; Revision: 1; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist.

Control: ISM-1902; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Patches, updates or other vendor mitigations for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist.

Control: ISM-1878; Revision: 1; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Patches, updates or other vendor mitigations for vulnerabilities in operating systems of IT equipment other than workstations, servers and network devices are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist.

Control: ISM-1751; Revision: 4; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Patches, updates or other vendor mitigations for vulnerabilities in operating systems of IT equipment other than workstations, servers and network devices are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist.

Control: ISM-1879; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Patches, updates or other vendor mitigations for vulnerabilities in drivers are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist.

Control: ISM-1697; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Patches, updates or other vendor mitigations for vulnerabilities in drivers are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist.

Control: ISM-1903; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Patches, updates or other vendor mitigations for vulnerabilities in firmware are applied within 48 hours of release when vulnerabilities are assessed as critical by vendors or when working exploits exist.

Control: ISM-1904; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Patches, updates or other vendor mitigations for vulnerabilities in firmware are applied within one month of release when vulnerabilities are assessed as non-critical by vendors and no working exploits exist.

Control: ISM-0300; Revision: 10; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
Patches, updates or other vendor mitigations for vulnerabilities in high assurance IT equipment are applied only when approved by ASD, and in doing so, using methods and timeframes prescribed by ASD.

Cessation of support

When applications, operating systems, network devices and networked IT equipment reach their cessation date for support, and become legacy IT, an organisation will find it increasingly difficult to protect them against vulnerabilities as patches, updates and other forms of support will no longer be made available by vendors. As such, unsupported applications, operating systems, network devices and networked IT equipment should be removed or replaced.

In planning for cessation of support, it is important to note that while vendors generally advise the cessation date for support of operating systems well in advance, some applications, network devices and networked IT equipment may cease to receive support immediately after newer versions are released.

Finally, when the immediate removal or replacement of unsupported applications, operating systems, network devices or networked IT equipment is not possible, compensating security controls should be implemented until such time that they can be removed or replaced.

Control: ISM-1905; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Online services that are no longer supported by vendors are removed.

Control: ISM-1704; Revision: 3; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Office productivity suites, web browsers and their extensions, email clients, PDF applications, Adobe Flash Player, and security products that are no longer supported by vendors are removed.

Control: ISM-0304; Revision: 8; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Applications other than office productivity suites, web browsers and their extensions, email clients,

PDF applications, Adobe Flash Player, and security products that are no longer supported by vendors are removed.

Control: ISM-1501; Revision: 1; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Operating systems that are no longer supported by vendors are replaced.

Control: ISM-1753; Revision: 2; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Internet-facing network devices that are no longer supported by vendors are replaced.

Control: ISM-1981; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Non-internet-facing network devices that are no longer supported by vendors are replaced.

Control: ISM-1982; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Networked IT equipment that is no longer supported by vendors is replaced.

Control: ISM-1809; Revision: 3; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When applications, operating systems, network devices or networked IT equipment that are no longer supported by vendors cannot be immediately removed or replaced, compensating security controls are implemented until such time that they can be removed or replaced.

Further information

Further information on system patching can be found in ASD's *Patching applications and operating systems* publication.

Further information on patching evaluated products can be found in the 'Evaluated product usage' section of the *Guidelines for evaluated products*.

Further information on managing risks associated with legacy IT can be found in ASD's *Managing the risks of legacy IT: Executive guidance* and *Managing the risks of legacy IT: Practitioner guidance* publications.

Further information on cessation of support for Microsoft Windows operating systems, including potential compensating security controls for use beyond their cessation date for support, can be found in ASD's *End of support for Microsoft Windows and Microsoft Windows Server* publication.

Further information on hardening user applications can be found in the 'User application hardening' section of the *Guidelines for system hardening*.

Further information on hardening server applications can be found in the 'Server application hardening' section of the *Guidelines for system hardening*.

Data backup and restoration

Digital preservation policy

Developing, implementing and maintaining a digital preservation policy, as part of digital continuity planning, can assist in ensuring the long-term integrity and availability of data is

maintained, especially when taking into account the potential for data degradation and removable media, hardware and software obsolescence.

Control: ISM-1510; Revision: 2; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A digital preservation policy is developed, implemented and maintained.

Data backup and restoration processes and procedures

Having data backup and restoration processes and procedures is an important part of business continuity and disaster recovery planning. Such activities will also form an integral part of an overarching digital preservation policy.

Control: ISM-1547; Revision: 2; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data backup processes, and supporting data backup procedures, are developed, implemented and maintained.

Control: ISM-1548; Revision: 2; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data restoration processes, and supporting data restoration procedures, are developed, implemented and maintained.

Performing and retaining backups

To mitigate the security risk of losing system availability or data as part of a ransomware attack, or other form of destructive attack, backups of data, applications and settings should be performed and retained in accordance with an organisation's business criticality and business continuity requirements. In doing so, backups of all data, applications and settings should be synchronised to enable restoration to a common point in time. Furthermore, it is essential that all backups are retained in a secure and resilient manner. This will ensure that should systems fall victim to a ransomware attack, or other form of destructive attack, data will not be lost and, if necessary, they can be quickly restored.

Control: ISM-1511; Revision: 4; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Backups of data, applications and settings are performed and retained in accordance with business criticality and business continuity requirements.

Control: ISM-1810; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Backups of data, applications and settings are synchronised to enable restoration to a common point in time.

Control: ISM-1811; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Backups of data, applications and settings are retained in a secure and resilient manner.

Backup access

To mitigate the security risk of unauthorised access to backups, an organisation should ensure that access to backups is controlled by using appropriate access controls.

Control: ISM-1812; Revision: 1; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Unprivileged user accounts cannot access backups belonging to other user accounts.

Control: ISM-1813; Revision: 1; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Unprivileged user accounts cannot access their own backups.

Control: ISM-1705; Revision: 2; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Privileged user accounts (excluding backup administrator accounts) cannot access backups belonging to other user accounts.

Control: ISM-1706; Revision: 2; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Privileged user accounts (excluding backup administrator accounts) cannot access their own backups.

Backup modification and deletion

To mitigate the security risk of backups being accidentally or maliciously modified or deleted, an organisation should ensure that backups are sufficiently protected from unauthorised modification and deletion by using appropriate access controls during their retention period. Furthermore, as malicious actors routinely seek to access backup infrastructure using credentials harvested from production environments, backup infrastructure should be segregated from such environments and use a separate authentication mechanism for administrative access.

Control: ISM-1814; Revision: 1; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Unprivileged user accounts are prevented from modifying and deleting backups.

Control: ISM-1707; Revision: 2; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Privileged user accounts (excluding backup administrator accounts) are prevented from modifying and deleting backups.

Control: ISM-1708; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Backup administrator accounts are prevented from modifying and deleting backups during their retention period.

Control: ISM-2151; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Backups are stored using a technically enforced immutability mechanism that prevents their modification or deletion for the duration of their retention period.

Control: ISM-2152; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Backup infrastructure, including backup servers, repositories and management consoles, is

segregated from production environments and uses a separate authentication mechanism for administrative access.

Testing restoration of backups

To ensure that backups can be restored when the need arises, and that any dependencies can be identified and managed beforehand, it is important that the restoration of data, applications and settings from backups to a common point in time is tested in a coordinated manner as part of disaster recovery exercises.

Control: ISM-1515; Revision: 4; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
Restoration of data, applications and settings from backups to a common point in time is tested as part of disaster recovery exercises.

Further information

Further information on digital preservation planning and data retention is available from the National Archives of Australia.

Further information on the retention of records created using artificial intelligence is also available from the National Archives of Australia.

Further information on the collection and retention of personal information can be found in the Office of the Australian Information Commissioner's *Australian Privacy Principles* and the associated *Australian Privacy Principles guidelines*.

Further information on business continuity and disaster recovery planning can be found in the 'Chief information security officer' section of the *Guidelines for cyber security roles*.

Guidelines for security assurance

Security monitoring

Context

This section describes security controls applicable to security-relevant event logs. It is not intended for non-security-relevant event logs, such as operating system and application performance-related event logs.

Detecting cyber security events

One of the core elements of detecting cyber security events is the availability of appropriate data sources, such as event logs. The following types of event logs can be used by an organisation to assist in detecting cyber security events:

- **Artificial intelligence (AI) applications:** May assist in identifying anomalous or malicious code or user behaviour indicating an exploitation attempt or successful compromise.
- **Cross domain solutions:** May assist in identifying anomalous or malicious network traffic indicating an exploitation attempt or successful compromise.
- **Databases:** May assist in identifying anomalous or malicious code or user behaviour indicating an exploitation attempt or successful compromise.
- **Domain Name System services:** May assist in identifying attempts to resolve malicious domain names or Internet Protocol addresses indicating an exploitation attempt or successful compromise.
- **Email servers:** May assist in identifying human users targeted with phishing emails, helping to identify the initial vector of a compromise.
- **Gateways:** May assist in identifying anomalous or malicious network traffic indicating an exploitation attempt or successful compromise.
- **Identity providers:** May assist in identifying anomalous or malicious use of user accounts, credentials, authentication artefacts or consent grants indicating an exploitation attempt or successful compromise.
- **Mobile applications:** May assist in identifying anomalous or malicious code or user behaviour indicating an exploitation attempt or successful compromise.
- **Multifunction devices:** May assist in identifying anomalous or malicious user behaviour indicating a cyber security incident.
- **Operating systems:** May assist in identifying anomalous or malicious activity indicating an exploitation attempt or successful compromise.

- **Remote access services:** May assist in identifying unusual locations of access or times of access indicating an exploitation attempt or successful compromise.
- **Security products:** May assist in identifying anomalous or malicious code or network traffic indicating an exploitation attempt or successful compromise.
- **Server applications:** May assist in identifying anomalous or malicious code or user behaviour indicating an exploitation attempt or successful compromise.
- **System access:** May assist in identifying anomalous or malicious user behaviour indicating an exploitation attempt or successful compromise.
- **User applications:** May assist in identifying anomalous or malicious code or user behaviour indicating an exploitation attempt or successful compromise.
- **Web applications:** May assist in identifying anomalous or malicious code or user behaviour indicating an exploitation attempt or successful compromise.
- **Web proxies:** May assist in identifying anomalous or malicious network traffic indicating an exploitation attempt or successful compromise.

Security monitoring policy

By developing a security monitoring policy, taking into consideration any shared responsibilities between service providers and their customers, an organisation can improve their ability to detect malicious behaviour on their systems. In doing so, the security monitoring policy should cover the types of events to be logged, the event logging facilities to be used, how event logs will be monitored and how long event logs will be retained.

Control: ISM-0580; Revision: 8; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A security monitoring policy is developed, implemented and maintained.

Centralised event logging facility

A centralised event logging facility can be used to capture, protect and manage event logs from multiple sources in a coordinated manner. This may be achieved by using a security information and event management (SIEM) platform, a security orchestration, automation and response (SOAR) platform, or both. Furthermore, in support of a centralised event logging facility, it is important that an accurate and consistent time source is used to assist with identifying connections between events.

Control: ISM-1405; Revision: 4; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A centralised event logging facility is implemented.

Control: ISM-1983; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs sent to a centralised event logging facility are sent as soon as possible after they occur.

Control: ISM-1984; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs sent to a centralised event logging facility are encrypted in transit using Australian Signals Directorate (ASD)-approved cryptography.

Control: ISM-1985; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs are protected from unauthorised access.

Control: ISM-1815; Revision: 1; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Event logs are protected from unauthorised modification and deletion.

Control: ISM-0988; Revision: 7; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An accurate and consistent time source is used for event logging.

Event log details

For each event logged, sufficient detail needs to be captured for event logs to be useful. In doing so, event logs should be captured and stored in a consistent and structured format.

Control: ISM-0585; Revision: 7; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
For each event logged, the date and time of the event, the relevant user or process, the relevant filename, the event description, and the information technology equipment involved are captured.

Control: ISM-1959; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
To the extent possible, event logs are captured and stored in a consistent and structured format.

Event log monitoring

Event log monitoring is critical to maintaining the security posture of systems. It involves the timely analysis of event logs to detect cyber security events and identify potential cyber security incidents. In doing so, successful detection of cyber security events, and identification of cyber security incidents, requires trained cyber security personnel with access to sufficient tools that support manual and automated analysis of system behaviour.

Control: ISM-0120; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cyber security personnel have access to sufficient tools to facilitate the detection of cyber security events and the identification of cyber security incidents.

Control: ISM-2116; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cyber threat intelligence services are used to support the detection of cyber security events and the identification of cyber security incidents.

Control: ISM-2117; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Suitable AI models are used to augment the detection of cyber security events and the identification of cyber security incidents.

Control: ISM-1986; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs from critical servers are analysed in a timely manner to detect cyber security events.

Control: ISM-1906; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Event logs from internet-facing servers are analysed in a timely manner to detect cyber security events.

Control: ISM-1907; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Event logs from non-internet-facing servers are analysed in a timely manner to detect cyber security events.

Control: ISM-0109; Revision: 9; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
Event logs from workstations are analysed in a timely manner to detect cyber security events.

Control: ISM-1987; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs from security products are analysed in a timely manner to detect cyber security events.

Control: ISM-1960; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs from internet-facing network devices are analysed in a timely manner to detect cyber security events.

Control: ISM-1961; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs from non-internet-facing network devices are analysed in a timely manner to detect cyber security events.

Control: ISM-1228; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
Cyber security events are analysed in a timely manner to identify cyber security incidents.

Threat hunting

Threat hunting activities can assist in identifying malicious actors who have established persistent access to systems but have not triggered event log monitoring capabilities. Threat hunting complements event log monitoring activities by actively searching for indicators of compromise and adversary tradecraft using current strategic and sector-specific cyber threat intelligence. Threat hunting activities may be scoped to specific cyber threats, such as searching systems for indicators of compromise or adversary tradecraft identified in current ASD alerts and advisories. In doing so, threat hunting activities should be conducted by personnel with sufficient skills and tools, with any findings documented, actioned and used to improve automated event log monitoring capabilities.

Control: ISM-2153; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Threat hunting activities, informed by current strategic and sector-specific cyber threat intelligence, are conducted at least every three months.

Event log retention

The retention of event logs is integral to event log monitoring, threat hunting and cyber security incident response activities. As such, event logs should be retained for a suitable period to facilitate these activities.

Control: ISM-1988; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs are retained in a searchable manner for at least 12 months.

Control: ISM-1989; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs are retained as per minimum retention requirements for various classes of records as set out by the National Archives of Australia's Administrative Functions Disposal Authority Express (AFDA Express) Version 2 publication.

Further information

Further information on logging intrusion activity can be found in the 'Managing cyber security incidents' section of the *Guidelines for cyber security incidents*.

Further information on event logging for AI applications can be found in the 'Software development fundamentals' section of the *Guidelines for software development*.

Further information on event logging for application-based security products can be found in the 'Operating system hardening' section of the *Guidelines for system hardening*.

Further information on event logging for cross domain solutions can be found in the 'Cross domain solutions' section of the *Guidelines for gateways*.

Further information on event logging for databases can be found in the 'Databases' section of the *Guidelines for database systems*.

Further information on event logging for gateways can be found in the 'Gateways' section of the *Guidelines for gateways*.

Further information on event logging for mobile applications can be found in the 'Software development fundamentals' section of the *Guidelines for software development*.

Further information on event logging for multifunction devices can be found in the 'Multifunction devices' section of the *Guidelines for communications systems*.

Further information on event logging for network-based security products can be found in the 'Network design and configuration' section of the *Guidelines for networking*.

Further information on event logging for operating systems can be found in the 'Operating system hardening' section of the *Guidelines for system hardening*.

Further information on event logging for server applications can be found in the 'Server application hardening' section of the *Guidelines for system hardening*.

Further information on event logging for system access can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on event logging for user applications can be found in the 'User application hardening' section of the *Guidelines for system hardening*.

Further information on event logging for web applications can be found in the 'Software development fundamentals' section of the *Guidelines for software development*.

Further information on event logging for web proxies can be found in the 'Web proxies' section of the *Guidelines for gateways*.

Further information on event logging can be found in the following ASD publications:

- *Best practices for event logging and threat detection*
- *Detecting and mitigating Active Directory compromises*
- *Hardening Microsoft Windows 10 workstations*
- *Hardening Microsoft Windows 11 workstations*
- *Priority logs for SIEM ingestion: Practitioner guidance*
- *Windows event logging and forwarding*.

Further information on ASD's cyber threat intelligence service, that is available to ASD Cyber Security Network Partners, can be found on ASD's Cyber Threat Intelligence Sharing service webpage.

Further information on using AI models for security monitoring activities can be found in ASD's *Opportunities for AI in cyber defence* publication.

Further information on SIEM and SOAR platforms can be found in ASD's *Implementing SIEM and SOAR platforms: Executive guidance* and *Implementing SIEM and SOAR platforms: Practitioner guidance* publications.

Further information on current ASD alerts and advisories can be found on ASD's Alerts and advisories webpage.

Further information on prioritising the collection and storage of event logs can be found in the United States' Cybersecurity & Infrastructure Security Agency's *Guidance for Implementing M-21-31: Improving the Federal Government's Investigative and Remediation Capabilities* publication.

Further information on the National Archives of Australia's requirements for event log retention can be found in their *AFDA Express Version 2 – Technology & Information Management* publication.

Security assessments

Context

Security assessments are activities designed to provide assurance in the security posture of systems and their operating environments. Security assessments can include security control assessments, vulnerability scanning, vulnerability assessments and penetration tests.

Regardless of the security assessment activity performed, they should be conducted by suitably skilled personnel. In doing so, personnel can be internal to an organisation or from a third party, however, such personnel should be independent of the system being assessed. This ensures that

there is no conflict of interest, perceived or otherwise, and that the activities are undertaken in an objective manner.

Vulnerability scanning

To ensure that patches or updates are being applied to applications, operating systems, drivers and firmware, it is essential that an organisation regularly identify all assets within their environment using an automated method of asset discovery, such as an asset discovery tool or a vulnerability scanner with equivalent functionality. To maximise the effectiveness of these activities, asset discovery and vulnerability scanning should be conducted from both internal and external perspectives, where applicable, to identify vulnerabilities based on how assets are exposed to malicious actors.

Following asset discovery, identified assets can be scanned for missing patches or updates using a vulnerability scanner with an up-to-date vulnerability database. Ideally, vulnerability scanning should be conducted in an automated manner and take place at twice the frequency at which patches or updates need to be applied. For example, if patches or updates are to be applied within two weeks of release, then vulnerability scanning should be undertaken at least weekly.

Control: ISM-1807; Revision: 0; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
An automated method of asset discovery is used at least fortnightly to support the detection of assets for subsequent vulnerability scanning activities.

Control: ISM-1808; Revision: 0; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
A vulnerability scanner with an up-to-date vulnerability database is used for vulnerability scanning activities.

Control: ISM-1698; Revision: 1; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in online services.

Control: ISM-1699; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
A vulnerability scanner is used at least weekly to identify missing patches or updates for vulnerabilities in office productivity suites, web browsers and their extensions, email clients, PDF applications, and security products.

Control: ISM-1700; Revision: 3; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: ML2, ML3
A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in applications other than office productivity suites, web browsers and their extensions, email clients, PDF applications, and security products.

Control: ISM-1701; Revision: 1; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
A vulnerability scanner is used at least daily to identify missing patches or updates for vulnerabilities in operating systems of internet-facing servers and internet-facing network devices.

Control: ISM-1702; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML1, ML2, ML3
A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in operating systems of workstations, non-internet-facing servers and non-internet-facing network devices.

Control: ISM-1752; Revision: 4; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in operating systems of IT equipment other than workstations, servers and network devices.

Control: ISM-1703; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in drivers.

Control: ISM-1900; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: ML3
A vulnerability scanner is used at least fortnightly to identify missing patches or updates for vulnerabilities in firmware.

Control: ISM-1921; Revision: 0; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The likelihood of system compromise is frequently assessed when working exploits exist for unmitigated vulnerabilities.

Vulnerability assessments and penetration tests

Security assessment activities designed to identify and triage vulnerabilities in systems can provide an organisation with a wealth of valuable information about their exposure to cyber threats, as well as assisting them to determine security risks associated with the operation of their systems. The use of suitable AI models to augment such activities is encouraged.

Control: ISM-2118; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Vulnerability assessments and penetration tests are conducted for systems prior to their deployment, including prior to the deployment of significant changes, and at least every six months thereafter.

Control: ISM-2119; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Suitable AI models are used to augment vulnerability assessments and penetration tests.

Further information

Further information on responsibilities for ensuring systems undergo a security control assessment can be found in the 'System owners' section of the *Guidelines for cyber security roles*.

Further information on conducting security control assessments for managed service providers and outsourced cloud service providers can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Further information on conducting security control assessments for gateways can be found in the 'Gateways' section of the *Guidelines for gateways*.

Further information on the cyber security documentation requirements for security control assessments can be found in the 'System-specific cyber security documentation' section of the *Guidelines for cyber security documentation*.

Further information on using AI models for security assessment activities can be found in ASD's *Opportunities for AI in cyber defence* publication.

Guidelines for software development

Software development fundamentals

Context

This section applies to human, artificial intelligence (AI)-assisted, AI-powered and AI-driven software development activities for traditional applications (including user applications and server applications), AI applications, mobile applications and web applications. Additional sections of these guidelines should also be consulted depending on the type of software development being undertaken. For example, the 'Web application development' section of these guidelines should be consulted for additional security controls applicable to web applications. Where references are made to software developers, they apply to humans and AI.

Development, testing, staging and production environments

Segregating development, testing, staging and production environments, and their associated data, can minimise the likelihood of faulty or malicious content being introduced into a production environment. Furthermore, protecting the authoritative source for software is critical to preventing malicious content being surreptitiously introduced into software.

Control: ISM-0400; Revision: 6; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Development, testing, staging and production environments are segregated.

Control: ISM-1419; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Development and modification of software only take place in development environments.

Control: ISM-1420; Revision: 5; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data from production environments is not used in non-production environments unless the non-production environment is secured to at least the same level as the production environment.

Authoritative source for software

Software developers need to ensure that they are using a secure authoritative source for software as part of their development environment, as doing so can reduce the security risks related to unauthorised access to software artefacts, tampering of software artefacts and other possible cyber supply chain attacks on software artefacts. In doing so, the authoritative source for software should be able to provide sufficient access control and event logging for access to, and modification of, any software artefacts.

Control: ISM-2023; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An authoritative source for software is established and maintained.

Control: ISM-2024; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The authoritative source for software is used for all software development activities.

Control: ISM-1422; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unauthorised access to the authoritative source for software is prevented.

Control: ISM-1816; Revision: 0; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unauthorised modification of the authoritative source for software is prevented.

Issue tracking

To provide visibility into code changes and support traceability, software developers should be able to link all changes, including security updates, change or feature updates, or bug fixes to a request or decision that is documented within an issue tracking solution.

Control: ISM-2025; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An issue tracking solution is used to link software development tasks to security issues and decisions, change or feature requests, programming issues, or bug fixes.

Secure software development

The use of Secure by Design principles and practices, including secure programming practices and either memory-safe programming languages (such as C#, Go, Java, Ruby, Rust and Swift) or less preferably memory-safe programming practices, along with threat modelling and mitigation of common security risks, is an important part of secure software development. In addition, providing mechanisms to assist in determining the authenticity and integrity of software, while configuring it in a secure manner, can assist with cyber supply chain security activities.

As part of secure software development, software should be designed and built to be Secure by Default, that is, the software is secure 'out of the box' with little to no additional setup or configuration required to achieve an adequate level of security. Importantly, all built-in security measures, such as multi-factor authentication and event logging, are included in the base product at no extra cost to consumers.

Control: ISM-2120; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A secure software development policy is developed, implemented and maintained.

Control: ISM-2033; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All software security requirements are documented, stored securely and maintained throughout the software development life cycle.

Control: ISM-2034; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security design decisions are documented and reviewed throughout the software development cycle.

Control: ISM-2035; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security roles, responsibilities and knowledge required to support the software development life cycle are identified and documented.

Control: ISM-2036; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security responsibilities for software developers are identified and documented.

Control: ISM-2121; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software developers that lack sufficient cyber security knowledge and skills required for their projects or tasks are not used.

Control: ISM-2037; Revision: 2; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software developers that lack sufficient cyber security knowledge and skills required for their projects or tasks undertake suitable training or upskilling on secure software development and programming practices.

Control: ISM-2038; Revision: 2; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A software developer cyber security knowledge and skills register is developed, implemented and maintained.

Control: ISM-0401; Revision: 8; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Secure by Design principles and practices are followed throughout the software development life cycle.

Control: ISM-1238; Revision: 6; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Threat modelling is used in support of the software development life cycle.

Control: ISM-2039; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The software threat model is reviewed throughout the software development life cycle to ensure it reflects the as-built software and any changes to the threat environment.

Control: ISM-2040; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Secure programming practices for the chosen programming language are used for software development.

Control: ISM-2041; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Memory-safe programming languages, or less preferably memory-safe programming practices, are used for software development.

Control: ISM-2042; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Secure by Default principles and practices are followed throughout the software development life cycle, including by ensuring that all built-in security measures are included and enabled in the base product at no extra cost to consumers.

Control: ISM-1780; Revision: 1; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SecDevOps practices are used for software development.

Control: ISM-2043; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software is architected and structured to support readability and maintainability.

Control: ISM-1796; Revision: 1; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files containing executable content are digitally signed by a certificate with a verifiable chain of trust as part of software development.

Control: ISM-1797; Revision: 1; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Installers, patches and updates are digitally signed or provided with cryptographic checksums as part of software development.

Control: ISM-2044; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software has no default credentials; however, if credentials are required, they are created on first install by the installing organisation.

Control: ISM-2045; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Application backwards compatibility does not compromise any security measures or features.

Control: ISM-2046; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Where software allows user impersonation, sensitive data is not logged and appropriate permissions are set.

Control: ISM-2047; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Where software allows an authentication factor to be reset for a human user, the human user is notified of the reset through a secondary channel.

Control: ISM-2048; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Where software supports multiple user roles, non-administrative users are prevented from altering their profile permissions or privileges.

Control: ISM-2049; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When user permissions or credentials are changed, software forces all impacted users to re-authenticate.

Control: ISM-2050; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When digital signatures are processed by software, they are validated against a certificate trust chain and checked for revocation using a Certificate Revocation List or with the Online Certificate Status Protocol.

Control: ISM-2051; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software generates sufficient event logs to support the detection of cyber security events.

Control: ISM-2052; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Event logs produced by software ensure that any sensitive data is protected.

Control: ISM-1798; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Secure configuration guidance, in the form of a hardening guide or loosening guide, is produced and made available to consumers as part of software development.

Control: ISM-2053; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
End of life procedures for software, including procedures for software removal and the archival or destruction of user accounts and data, are produced and made available to consumers.

Software artefacts

Software artefacts can include compiled code, third-party libraries, configuration files and any other files consumed by the software development process. Software artefacts, whether developed internally or externally, may include malicious content or weaknesses designed for exploitation at a later stage. To assist in preventing the introduction of malicious content or weak software artefacts into an authoritative source for software, all software artefacts should be

scanned for malicious content and undergo security testing (where appropriate) before being stored in the authoritative source for software. Software artefact dependencies should also be pinned to approved versions to prevent unexpected changes, while being periodically tested for known weaknesses and updated where necessary to address identified vulnerabilities.

Control: ISM-2026; Revision: 1; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All software artefacts are scanned for malicious content before being imported into the authoritative source for software.

Control: ISM-2027; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All software artefacts are verified by a digital signature, or a secure hash provided over a secure channel, before being imported into the authoritative source for software.

Control: ISM-2028; Revision: 1; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All software artefacts are tested to detect known weaknesses using static application security testing (SAST), dynamic application security testing (DAST) or software composition analysis (SCA), depending on the software artefact type, before being imported into the authoritative source for software.

Control: ISM-2102; Revision: 0; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Existing software artefacts in the authoritative source for software are periodically tested to detect known weaknesses using SAST, DAST or SCA, depending on the software artefact type, throughout the software development life cycle.

Control: ISM-2029; Revision: 1; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The authoritative source for software restricts the use and import of third-party libraries and software components to trustworthy sources.

Control: ISM-2154; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software artefact dependencies are pinned to approved versions in source code.

Control: ISM-2030; Revision: 1; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Scanning is used during commits to identify plain text or encoded credentials, keys and secrets, which are then blocked from being stored in the authoritative source for software.

Build solution

The build process for software can unintentionally allow vulnerabilities in software to make it into production environments. This security risk can be reduced by ensuring the build solution uses all available security features and that all automated testing is completed as part of the build process. Furthermore, software should be built in a manner that allows independent verification that release artefacts correspond to their source code.

Control: ISM-2031; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Compilers, interpreters and build tools (including pipelines) that provide security features to improve executable file security are implemented and such security features are used.

Control: ISM-2155; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software is built using reproducible build practices that enable independent verification that release artefacts were produced from the stated source code.

Control: ISM-2032; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The build solution ensures that all automated testing is completed without warnings, alerts or errors before building software artefacts.

Software bill of materials

A software bill of materials is a list of open source and commercial software components used in software development. This can assist software developers in ensuring they are not using software components with known vulnerabilities. It can also assist in providing greater cyber supply chain transparency for consumers of software by enabling easier identification and management of security risks associated with individual software components used by software.

Control: ISM-2054; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If a software bill of materials is available for imported third-party software components, it is used during software development to ensure such software components have no known vulnerabilities.

Control: ISM-1730; Revision: 0; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A software bill of materials is produced and made available to consumers of software.

Cryptographic bill of materials

A cryptographic bill of materials acts as an extension of a software bill of materials by communicating information about relevant cryptographic dependencies and implementations that are relied upon by software. At a high level, a cryptographic bill of materials will map the use of cryptography to the security function it performs and where it performs it. In practice, a cryptographic bill of materials will capture details on cryptographic libraries, algorithms, protocols, parameters and configurations. This can be used to ensure software components are providing support for standardised implementations of cryptographic algorithms that are approved by the Australian Signals Directorate (ASD).

While the format for a cryptographic bill of materials is not yet subject to formal standardisation, there are emerging tools to assist with their generation and management. This is particularly important for software developers in managing their migration to post-quantum cryptographic standards as part of software development activities.

Control: ISM-2082; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If a cryptographic bill of materials is available for imported third-party software components, it is used during software development to ensure such software components provide support for standardised implementations of ASD-Approved Cryptographic Algorithms.

Control: ISM-2083; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A cryptographic bill of materials is produced and made available to consumers of software.

Software build provenance

A software build provenance is a manifest that describes the software components used in the build process, the set of commands executed during the build process, any relevant environmental context for the build process and the materials that were generated by the build process. A software build provenance assists in providing greater cyber supply chain transparency for consumers by enabling the build process to be verified and, if needed, recreated.

However, software build provenance does not, by itself, establish that the source code, build process or software artefacts are trustworthy and should be considered alongside other software supply chain security measures.

Control: ISM-2055; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If a software build provenance is available for imported third-party software components, it is used during software development to ensure such software components are built to an appropriate standard.

Control: ISM-2056; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A software build provenance is produced and made available to consumers of software.

Network application programming interfaces

Network application programming interfaces (APIs) can facilitate the exchange of data between computing devices. As such, common security risks associated with their use should be mitigated during their development, especially for network APIs that are accessible over the internet. This includes mitigating poorly secured network APIs that facilitate unauthorised modification of data or access to data not authorised for release into the public domain. In such cases, ensuring authentication and authorisation of clients is performed when clients call network APIs can assist in mitigating unauthorised modification of, or access to, data. Finally, centrally logging and analysing network API use can assist in detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1818; Revision: 2; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication and authorisation of clients is performed when clients call network APIs that facilitate modification of data and are accessible over the internet.

Control: ISM-2013; Revision: 0; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication and authorisation of clients is performed when clients call network APIs that facilitate modification of data but are not accessible over the internet.

Control: ISM-1817; Revision: 2; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication and authorisation of clients is performed when clients call network APIs that facilitate access to data not authorised for release into the public domain and are accessible over the internet.

Control: ISM-2014; Revision: 0; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Authentication and authorisation of clients is performed when clients call network APIs that

facilitate access to data not authorised for release into the public domain but are not accessible over the internet.

Control: ISM-1910; Revision: 1; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network API calls that facilitate modification of data, or access to data not authorised for release into the public domain, and are accessible over the internet, are centrally logged.

Control: ISM-2015; Revision: 0; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network API calls that facilitate modification of data, or access to data not authorised for release into the public domain, but are not accessible over the internet, are centrally logged.

Software input handling

Many vulnerabilities in software are caused by a lack of secure input handling. As such, it is essential that software does not trust any input, such as website addresses and their parameters, Hypertext Markup Language (HTML) form data, cookie values, or request headers, without performing validation or sanitisation. Examples of validation and sanitisation include ensuring a telephone form field contains only numerals, ensuring data used in a Structured Query Language query is sanitised properly and ensuring Unicode input is handled appropriately.

Control: ISM-1240; Revision: 5; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Validation and sanitisation are performed on all input received over the internet by software.

Control: ISM-2016; Revision: 1; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Validation and sanitisation are performed on all input received over a local network by software.

Control: ISM-2057; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All input validation rules are documented, implemented in code, and tested using both positive and negative unit tests and integration tests.

Control: ISM-2058; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data sources and serialised data inputs are validated before being deserialised.

Control: ISM-2059; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
File uploads or input are restricted to specific file types, with malicious content scanning occurring prior to file access, file execution or file storage.

Software interaction with databases

Structured Query Language (SQL) injection attacks, facilitated by dynamically generated queries, are a significant threat to the confidentiality, integrity and availability of database contents. Specifically, SQL injection attacks can allow malicious actors to steal database contents, modify database contents, delete an entire database or even in some circumstances gain control of the underlying database server. Furthermore, when database queries from software fail, they may display detailed error information about the structure of databases. This can be used by malicious actors to tailor their SQL injection attacks.

Finally, centrally logging and analysing all queries to databases from software can assist in monitoring the security posture of databases, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1275; Revision: 2; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All queries to databases from software are filtered for legitimate content and correct syntax.

Control: ISM-1276; Revision: 5; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Parameterised queries or stored procedures, instead of dynamically generated queries, are used by software for database interactions.

Control: ISM-1278; Revision: 5; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software is designed or configured to provide as little error information as possible about the structure of databases.

Control: ISM-1536; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All queries to databases from software, and any resulting crash or error messages, are centrally logged.

Software security testing

Software security testing can assist software developers to identify vulnerabilities in their software. In doing so, software security testing should be designed to be repeatable and scalable while ensuring vulnerabilities in software are identified and remediated as early as possible. Such software security testing should include peer reviews, code reviews, unit testing, integration testing, SAST, DAST and SCA to achieve comprehensive test coverage.

As part of software security testing, software developers may wish to replicate testing within typical consumer environments. Additionally, software developers may choose to use independent testing to assist with removing any potential for bias that might occur when they test their own software. Overall, software needs to be comprehensively tested for vulnerabilities during development, prior to all releases and periodically to help identify any previously unidentified vulnerabilities.

Finally, AI models are becoming increasingly capable of supporting software security testing through the identification of potential vulnerabilities, known weaknesses and insecure coding practices. The use of such AI models can be highly beneficial for software security testing provided they supplement, and not replace, traditional software security testing practices and all of their findings are validated by appropriately skilled personnel.

Control: ISM-2061; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Peer reviews are conducted on all critical and security-related software components.

Control: ISM-2060; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Code reviews are utilised to ensure software components meets Secure by Design principles and practices as well as secure programming practices.

Control: ISM-2062; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unit testing and integration testing, covering both positive and negative use cases, are used for software components to ensure code quality and correctness.

Control: ISM-0402; Revision: 10; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Software is comprehensively tested for vulnerabilities using SAST, DAST and SCA prior to its initial release, any subsequent release, and periodically to help identify any previously unidentified vulnerabilities.

Control: ISM-2122; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Suitable AI models are used to augment software security testing.

Vulnerability disclosure program

Implementing a vulnerability disclosure program, based on responsible disclosure, can assist an organisation to improve the security of their products and services as it provides a way for internal and external parties to responsibly notify the organisation of vulnerabilities in a coordinated manner. Furthermore, following the resolution of reported vulnerabilities, it can assist an organisation in notifying their consumers of vulnerabilities that have been discovered in their products and services, and any patches, updates or vendor mitigations that should be applied.

A vulnerability disclosure program should include processes and procedures for receiving, identifying, documenting, validating and prioritising vulnerabilities disclosed by internal and external parties. In support of this, a vulnerability disclosure policy should be made publicly available that covers:

- the purpose of the vulnerability disclosure program
- types of security research that are and are not allowed
- how to report any vulnerabilities and their severities
- actions, and associated timeframes, upon notification of vulnerabilities
- expectations regarding the public disclosure of vulnerabilities
- any recognition or reward for finders of vulnerabilities.

Finally, ASD encourages security researchers and other members of the public to report vulnerabilities directly to an organisation. However, ASD recognises that this is not always practical, initial attempts at communication may be unsuccessful or the person making the report may not wish to do so directly. In such cases, vulnerabilities can be reported to ASD as an independent coordinator. Under ASD's limited use obligation, any information voluntarily provided to ASD about vulnerabilities cannot be used for regulatory purposes.

Control: ISM-1616; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A vulnerability disclosure program is implemented to assist with the secure development and maintenance of products and services.

Control: ISM-1755; Revision: 1; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A vulnerability disclosure policy is developed, implemented and maintained.

Control: ISM-1756; Revision: 1; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Vulnerability disclosure processes, and supporting vulnerability disclosure procedures, are developed, implemented and maintained.

Control: ISM-1717; Revision: 3; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A 'security.txt' file is hosted for each of an organisation's internet-facing website domains to assist in the responsible disclosure of vulnerabilities in the organisation's products and services.

Reporting and resolving vulnerabilities

Following the identification of vulnerabilities in software, via either internal software security testing or external security researchers, it is important that they are publicly disclosed in a responsible and timely manner. This allows organisations using impacted software to determine their risk exposure as part of their own cyber supply chain risk management activities. In doing so, such vulnerabilities should be resolved in a timely manner. In support of this, root cause analysis should be performed and, to the greatest extent possible, entire vulnerability classes should be remediated.

If vulnerabilities cannot be resolved in a timely manner via patches or updates, advice should be provided on how, to the greatest extent possible, the likelihood of vulnerabilities being exploited can be reduced, the impact of vulnerabilities being exploited can be reduced or both.

Control: ISM-1908; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Vulnerabilities identified in software are publicly disclosed in a responsible and timely manner, including with Common Weakness Enumeration and Common Platform Enumeration information.

Control: ISM-1754; Revision: 4; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Vulnerabilities identified in software are resolved in a timely manner.

Control: ISM-1909; Revision: 1; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
In resolving vulnerabilities, root cause analysis is performed and, to the greatest extent possible, entire vulnerability classes are remediated.

Software event logging

Centrally logging and analysing security-relevant usage, error messages and crashes for software can assist in monitoring the security posture of software, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1911; Revision: 3; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant usage, error messages and crashes for software are centrally logged.

Further information

Further information on a secure software development framework can be found in National Institute of Standards and Technology Special Publication 800-218, *Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities*.

Further information on Secure by Design and Secure by Default principles and practices can be found in the following publications:

- ASD's *Secure by Design foundations*
- ASD's *IoT Secure by Design guidance for manufacturers*
- United Kingdom's National Cyber Security Centre's *Secure development and deployment guidance*
- United Kingdom's Central Digital and Data Office's *Secure by Design Principles* and *Secure by Design Activities*
- United States' Cybersecurity & Infrastructure Security Agency's *Safe Software Deployment: How Software Manufacturers Can Ensure Reliability for Customers*
- United States' Cybersecurity & Infrastructure Security Agency's *Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Secure by Design Software*.

Further information on secure programming practices is available from the Carnegie Mellon University's Software Engineering Institute.

Further information on the need for memory-safe programming languages can be found the following publications:

- United States' Cybersecurity & Infrastructure Security Agency's *The Case for Memory Safe Roadmaps: Why Both C-Suite Executives and Technical Experts Need to Take Memory Safe Coding Seriously*
- United States' Cybersecurity & Infrastructure Security Agency's *Exploring Memory Safety in Critical Open Source Projects*
- United States' National Security Agency's *Software Memory Safety*
- United States' National Security Agency and Cybersecurity & Infrastructure Security Agency's *Memory Safe Languages: Reducing Vulnerabilities in Modern Software Development*.

Further information on the management of keys and secrets can be found in ASD's *Managing cryptographic keys and secrets* publication.

Further information on cyber supply chain transparency, and recommended content for a software bill of materials, can be found in the United States' National Telecommunications and Information Administration's *2026 Minimum Elements for a Software Bill of Materials (SBOM)* publication.

Further information on software bill of materials can also be found in the United States' Cybersecurity & Infrastructure Security Agency's *A Shared Vision of Software Bill of Materials (SBOM) for Cybersecurity* publication.

Further information on strong authentication can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on software security testing can be found on the Open Worldwide Application Security Project's (OWASP) DevSecOps Guidelines and Source Code Analysis Tools websites.

Further information on using AI models for software security testing activities can be found in ASD's *Opportunities for AI in cyber defence* publication.

Further information on vulnerability identification success rates using frontier AI models is available from the CyberGym website.

Further information on implementing a vulnerability disclosure program can be found in the following publications:

- ASD's *Vulnerability disclosure programs explained*
- United States' Cybersecurity & Infrastructure Security Agency's *Establishing a Coordinated Vulnerability Disclosure Program to Work With Security Researchers*
- Google's *Starting a Vulnerability Disclosure Program*
- Carnegie Mellon University's Software Engineering Institute's *The CERT Guide to Coordinated Vulnerability Disclosure*
- International Organization for Standardization/International Electrotechnical Commission 29147:2018, *Information technology – Security techniques – Vulnerability disclosure*
- International Organization for Standardization/International Electrotechnical Commission 30111:2019, *Information technology – Security techniques – Vulnerability handling processes*.

Further information on developing a vulnerability disclosure policy is available from the disclose.io project to assist an organisation with their implementation.

Further information on recommended contents for a 'security.txt' file is available to assist an organisation with their implementation.

Further information on reporting vulnerabilities to ASD as an independent coordinator, including ASD's limited use obligation, is available from ASD.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Artificial intelligence application development

Context

This section describes security controls applicable to AI application and AI model development and extends the 'Software development fundamentals' section of these guidelines.

Secure artificial intelligence application development

Secure coding resources for software developers should be followed when developing AI applications. In addition, AI applications should be designed to reduce their attack surface with AI models being stored in a non-executable file format that does not allow arbitrary code execution.

Control: ISM-2084; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
AI-specific documentation, including AI model cards and AI system cards (or equivalent artefacts), is used to document AI model characteristics, system architectures, use cases and security risks.

Control: ISM-2072; Revision: 1; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
AI models are stored in a non-executable file format that does not allow arbitrary code execution.

Control: ISM-2085; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The exposure of exact AI model confidence scores in API outputs or user interfaces is prevented.

Data collection, retention and use

To ensure organisational data is not used to train AI models without explicit data owner consent, organisational data generated, collected or processed by AI applications should not be used for training, fine-tuning or improving AI models unless informed and explicit consent has been obtained in advance. Furthermore, to prevent excessive retention of data, all prompts and outputs associated with chat sessions should be securely deleted when chat sessions are removed from AI applications.

Control: ISM-2103; Revision: 0; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Organisational data generated, collected or processed by AI applications is not used for training, fine-tuning or improving AI models unless informed and explicit consent has been obtained from data owners in advance.

Control: ISM-2123; Revision: 0; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All prompts and outputs associated with chat sessions are securely deleted when chat sessions are removed from AI applications.

Artificial intelligence model poisoning

AI models, especially when embedded in other applications, risk exposing sensitive data, proprietary algorithms or confidential details through their output. This can result in unauthorised data access, privacy violations and intellectual property breaches.

Control: ISM-2086; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The source and integrity of AI models, structures and weights are verified.

Control: ISM-2087; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The source and integrity of training data for AI models is verified.

Control: ISM-2088; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data validation and verification techniques are used to ensure the reliability and accuracy of training data used by AI models.

Unbounded consumption

Cyber attacks designed to disrupt services, deplete a target's financial resources or steal intellectual property by cloning an AI model's behaviour depend on unbounded consumption vulnerabilities to succeed.

Control: ISM-2089; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
AI model performance metrics are monitored and anomalies are investigated.

Control: ISM-2090; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Rate limiting is applied to inference queries for AI models.

Control: ISM-2091; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Resource limits are enforced for AI models.

Excessive agency

Excessive agency vulnerabilities allow for damaging actions to be performed in response to unexpected, ambiguous or manipulated output from AI applications, regardless of the cause of the malfunction. Furthermore, agentic AI applications that can autonomously invoke tools, browse external content, execute code or call other systems introduce risks beyond those of conversational AI applications. In particular, untrusted content retrieved by an agentic AI application, whether via web browsing, email, document processing or retrieval-augmented generation, may contain instructions that the underlying AI model treats as legitimate, allowing malicious actors to indirectly control the agentic AI application's actions. Validation, sanitisation and delimitation can reduce this security risk but cannot be relied upon to make retrieved content trustworthy or eliminate indirect prompt injection. As such, agentic AI applications should treat retrieved content as untrusted throughout processing and prevent it from modifying or overriding system instructions, security policies, access controls, tool permissions or human approval requirements.

Control: ISM-2092; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Access control policies are implemented to enforce fine-grained permissions for AI applications.

Control: ISM-2093; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Role-based access controls are implemented for AI applications to restrict access to sensitive data.

Control: ISM-2156; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Agentic AI applications are restricted to the minimum set of tools, functions and permissions required for their intended purpose.

Control: ISM-2157; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Tools invoked by agentic AI applications are subject to both the access controls of the invoking user and agent-specific, task-scoped authorisation, with effective permissions limited to the minimum permitted by both.

Control: ISM-2158; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
External content retrieved by agentic AI applications is treated as untrusted data throughout processing, is clearly delimited from system instructions, is subject to validation and sanitisation measures applied to other untrusted input, remains untrusted following such processing, and is prevented from modifying or overriding system instructions, security policies, access controls, tool permissions or human approval requirements.

Control: ISM-2159; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All tool invocations, external requests and outputs generated by agentic AI applications are centrally logged with sufficient detail to support cyber security incident investigations.

Prompt injection

Prompt injection vulnerabilities exist in how AI applications process user prompts, and how such input may force AI models to incorrectly pass prompt data to other parts of the model, potentially causing them to violate guidelines, generate harmful content, enable unauthorised access or influence critical decisions.

Control: ISM-1924; Revision: 1; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Generative AI applications evaluate user prompts to detect and mitigate adversarial inputs or suffixes designed to elicit unintended behaviour or assist in the generation of sensitive or harmful content.

Sensitive data exposure and improper output

AI applications, especially when embedded in other applications, risk exposing sensitive data, proprietary algorithms or confidential details through their output. This can result in unauthorised data access, privacy violations and intellectual property breaches. In addition, improper output handling vulnerabilities can occur when output from AI applications is not sufficiently validated, sanitised or handled before being passed downstream to other applications.

Control: ISM-2094; Revision: 0; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Content filtering is implemented by AI applications to detect and block sensitive data exposure and improper output.

Further information

Further information on conversational AI application security risks can be found in the *OWASP Top 10 for LLM Applications 2025* publication.

Further information on agentic AI application security risks can be found in the *OWASP Top 10 For Agentic Applications 2026* publication.

Further information on AI security risks can be found in the following ASD publications:

- *An introduction to artificial intelligence*
- *Artificial intelligence and machine learning*
- *Engaging with artificial intelligence*.

Further information on AI security risks can also be found in the following publications:

- MITRE's *Adversarial Threat Landscape for Artificial-Intelligence Systems*
- National Institute of Standards and Technology AI 100-2 E2023, *Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations*
- United Kingdom's National Cyber Security Centre and United States' Cybersecurity & Infrastructure Security Agency's *Guidelines for secure AI system development*
- United States' National Security Agency's *AI Data Security: Best Practices for Securing Data Used to Train & Operate AI Systems*
- United States' National Security Agency's *Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems*.

Mobile application development

Context

This section describes security controls applicable to mobile application development and extends the 'Software development fundamentals' section of these guidelines.

Secure mobile application development

OWASP provides comprehensive resources for software developers that should be followed when developing mobile applications.

Control: ISM-1922; Revision: 0; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The OWASP Mobile Application Security Verification Standard is used in the development of mobile applications.

Further information

Further information on mobile application security can be found in the *OWASP Mobile Application Security Verification Standard version 2.1.0* publication.

Web application development

Context

This section describes security controls applicable to web application development and extends the 'Software development fundamentals' section of these guidelines.

Secure web application design and development

Web application frameworks can be leveraged by software developers to enhance the security of web applications while decreasing development time. These resources can assist in securely implementing complex software functions, such as session management, input handling and cryptographic operations. In addition, OWASP provides comprehensive resources for software developers that should be followed when developing web applications.

Control: ISM-1239; Revision: 4; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Robust web application frameworks are used in the development of web applications.

Control: ISM-0971; Revision: 8; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The OWASP Application Security Verification Standard is used in the development of web applications.

Control: ISM-1849; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The OWASP Top 10 Proactive Controls are used in the development of web applications.

Control: ISM-1850; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The OWASP Top 10 are mitigated in the development of web applications.

Control: ISM-2063; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If supported, web application session cookies set the HttpOnly flag, Secure flag and the SameSite flag by default.

Control: ISM-2064; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Web application session cookies contain only digitally signed opaque bearer tokens.

Control: ISM-2065; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Web application session cookies using opaque bearer tokens that are not digitally signed use non-sequential random identifiers with a minimum of 128 bits of entropy, preferably 256 bits of entropy.

Control: ISM-2066; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Web application sessions are centrally managed server side.

Control: ISM-2067; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Web applications that support Single Sign On equally support Single Logout.

Web security policy response headers

Web security policy response header measures, such as Content-Security-Policy, Hypertext Transfer Protocol Strict Transport Security and X-Frame-Options, can be applied by web browsers to help protect themselves. This is achieved by web server software specifying security policy in response headers that web browsers then apply.

Control: ISM-1424; Revision: 5; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Content-Security-Policy, Hypertext Transfer Protocol Strict Transport Security and X-Frame-Options are specified by web server software via security policy in response headers.

Web application interactions

Hypertext Transfer Protocol Secure (HTTPS) is the Hypertext Transfer Protocol secured by Transport Layer Security (TLS) encryption. The use of HTTPS for web applications ensures that interactions with web applications are confidential and that the integrity of such interactions is maintained.

Control: ISM-1552; Revision: 0; Updated: Oct-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All web application content is offered exclusively using HTTPS.

Web application programming interfaces

Web APIs can facilitate the exchange of data between computing devices. As such, common security risks associated with their use should be mitigated during their development.

Control: ISM-1851; Revision: 0; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The OWASP API Security Top 10 are mitigated in the development of web APIs.

Web application output encoding

The likelihood of cross-site scripting and other content injection attacks can be reduced by using output encoding. Output encoding is particularly useful when external data sources, which may not be subject to the same level of input filtering, are output to users. The most common example of output encoding is the conversion of potentially dangerous HTML characters into their encoded equivalents, such as '<', '>' and '&' into '<', '>' and '&'.

Control: ISM-1241; Revision: 4; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Output encoding is performed on all output produced by web applications.

Further information

Further information on web application security can be found in the *OWASP Application Security Verification Standard 5.0.0* and *OWASP Top 10 Proactive Controls 2024* publications.

Further information on web application security risks can be found in the *OWASP Top 10:2025* publication.

Further information on implementing HTTPS can be found in ASD's *Implementing certificates, TLS, HTTPS and opportunistic TLS* publication.

Further information on using TLS in HTTPS can be found in the 'Transport Layer Security' section of the *Guidelines for cryptography*.

Further information on web API security can be found in the *OWASP API Security Top 10 2023* publication.

Guidelines for database systems

Database servers

Functional separation between database servers and web servers

Due to the higher threat environment that web servers are typically exposed to, hosting database servers and web servers within the same operating environment increases the likelihood of database servers being compromised by malicious actors. This security risk can be mitigated by ensuring that database servers are functionally separated from web servers.

Control: ISM-1269; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Database servers and web servers are functionally separated.

Communications between database servers and web servers

Data communicated between database servers and web servers, especially over the internet, is susceptible to capture by malicious actors. As such, it is important that all data communicated between database servers and web servers is suitably encrypted using Australian Signals Directorate-approved cryptography.

Control: ISM-1277; Revision: 5; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data communicated between database servers and web servers is encrypted using Australian Signals Directorate-approved cryptography.

Network environment

Placing database servers on the same network segment as workstations can increase the likelihood of database servers being compromised by malicious actors. Additionally, in cases where databases will only be accessed from their own database server, allowing remote access to the database server poses an unnecessary security risk.

Control: ISM-1270; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Database servers are placed on a different network segment to workstations.

Control: ISM-1271; Revision: 3; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network access controls are implemented to restrict database server communications to strictly defined network resources that require access to the database server.

Control: ISM-1272; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If only local access to a database is required, networking functionality of database management system applications is disabled or directed to listen solely to the localhost interface.

Segregation of development, testing, staging and production database servers

Using database servers across different environments, such as development, testing, staging and production environments, could result in accidental damage to their integrity or exposure of their hosted database contents.

Control: ISM-1273; Revision: 4; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Database servers for development, testing, staging and production environments are segregated.

Further information

Further information on the functional separation of operating environments can be found in the 'Virtualisation hardening' section of the *Guidelines for system hardening*.

Further information on encrypting communications can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Further information on network segmentation and segregation can be found in the 'Network design and configuration' section of the *Guidelines for networking*.

Further information on database management system applications can be found in the 'Server application hardening' section of the *Guidelines for system hardening*.

Databases

Database register

Without knowledge of all the databases in an organisation, and their contents, an organisation will be unable to protect all of their assets. As such, it is important that a database register is developed, implemented, maintained and regularly verified.

Control: ISM-1243; Revision: 7; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A database register is developed, implemented, maintained and regularly verified.

Protecting databases

Databases can be protected from unauthorised copying, and subsequent offline analysis, by applying file-based access controls to database files.

Control: ISM-1256; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
File-based access controls are applied to database files.

Protecting database contents

The sensitivity or classification associated with databases and their contents should be determined to ensure that they are appropriately protected when administered or accessed by database

users. In cases where a database's contents are all the same sensitivity or classification, an organisation should classify the entire database at this level and protect it as such. Alternatively, in cases where a database's contents are of varying sensitivities or classifications, and database users have varying levels of access to the database's contents, an organisation should protect the database's contents at a more granular level.

Restricting database users' ability to access, insert, modify or remove database contents, based on their duties or functions, ensures that the likelihood of unauthorised access, modification or deletion of database contents is reduced. Furthermore, where concerns exist that the aggregation of separate pieces of content from within a database could lead to malicious actors determining more sensitive or classified content, the need-to-know principle can be enforced by using minimum privileges, database views and database roles. Alternatively, the content of concern could be separated by implementing multiple databases, each with restricted data sets.

Control: ISM-0393; Revision: 8; Updated: Jun-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Databases and their contents are classified based on the sensitivity or classification of data that they contain.

Control: ISM-1255; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Database users' ability to access, insert, modify and remove database contents is restricted based on their duties or functions.

Control: ISM-1268; Revision: 2; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The need-to-know principle is enforced for database contents through the application of minimum privileges, database views, database roles and data tokenisation.

Segregation of development, testing, staging and production databases

Using database contents from production environments in non-production environments, such as development, testing or staging environments, could result in inadequate protection being applied to the database contents.

Control: ISM-1274; Revision: 7; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Database contents from production environments are not used in non-production environments unless the non-production environment is secured to at least the same level as the production environment.

Database event logging

Centrally logging and analysing security-relevant events, including configuration changes, for databases can assist in monitoring the security posture of databases, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1537; Revision: 5; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for databases are centrally logged, including:

- *access or modification of particularly important content*

- *addition of new users, especially privileged users*
- *changes to user roles or privileges*
- *attempts to elevate user privileges*
- *queries containing comments*
- *queries containing multiple embedded queries*
- *database and query alerts or failures*
- *database structure changes*
- *database administrator actions*
- *use of executable commands*
- *database logons and logoffs.*

Further information

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Guidelines for email

Email usage

Email usage policy

As there are many security risks associated with the use of email services, it is important that an organisation develops, implements and maintains an email usage policy governing its use.

Control: ISM-0264; Revision: 4; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An email usage policy is developed, implemented and maintained.

Webmail services

When human users access non-approved webmail services, they often bypass security controls that have been implemented by an organisation, such as email content filtering. To mitigate this security risk, access to non-approved webmail services should be blocked.

Control: ISM-0267; Revision: 7; Updated: Mar-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Access to non-approved webmail services is blocked.

Protective markings for emails

Implementing protective markings for emails helps to prevent data spills, such as unauthorised data being released into the public domain. In doing so, it is important that protective markings reflect the highest sensitivity or classification of the subject, body and attachments of emails.

Control: ISM-0270; Revision: 6; Updated: Jun-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Protective markings are applied to emails and reflect the highest sensitivity or classification of the subject, body and attachments.

Protective marking tools

Requiring human user involvement in the protective marking of emails ensures a conscious decision is made. This lessens the chance of incorrect protective markings being automatically applied to emails. In addition, only allowing the selection of protective markings for which a system is authorised to process, store or communicate lessens the chance of inadvertently over-classifying emails.

Email content filters may only check the most recent protective marking applied to emails. Therefore, when responding to or forwarding emails, requiring protective markings that are at least as high as that of emails that are received will help email content filters prevent emails being sent to systems that are not authorised to handle their original sensitivity or classification.

Control: ISM-0271; Revision: 3; Updated: Mar-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Protective marking tools do not automatically insert protective markings into emails.

Control: ISM-0272; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Protective marking tools do not allow the selection of protective markings that a system has not been authorised to process, store or communicate.

Control: ISM-1089; Revision: 6; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When replying to or forwarding emails, protective marking tools do not allow the selection of protective markings lower than previously used.

Handling emails with inappropriate, invalid or missing protective markings

It is important that email servers are configured to block emails with inappropriate protective markings. For example, blocking inbound and outbound emails with protective markings higher than the sensitivity or classification of the receiving system, as this will help prevent a data spill from occurring. In doing so, it is important to inform the intended recipients of blocked inbound emails, and the senders of blocked outbound emails, that this has occurred.

If emails are received with invalid or missing protective markings, they may still be passed to their intended recipients. However, the recipients will have an obligation to determine appropriate protective markings if emails are to be responded to, forwarded or printed. If unsure, original senders of emails should be contacted to provide guidance on appropriate protective markings.

Control: ISM-0565; Revision: 4; Updated: Mar-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Email servers are configured to block, log and report emails with inappropriate protective markings.

Control: ISM-1023; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The intended recipients of blocked inbound emails, and the senders of blocked outbound emails, are notified.

Email distribution lists

In some cases, the membership and nationality of members of email distribution lists will be unknown. As such, emails containing Australian Eyes Only, Australian Government Access Only or Releasable To data that are sent to email distribution lists could accidentally cause a data spill.

Control: ISM-0269; Revision: 5; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
Emails containing Australian Eyes Only, Australian Government Access Only or Releasable To data are not sent to email distribution lists unless the nationality of all members of email distribution lists can be confirmed.

Further information

Further information on protective markings for emails, where applicable, can be found in the Department of Home Affairs' *Protective Security Policy Framework* and its associated *Australian Government Email Protective Marking Standard*.

Email gateways and servers

Centralised email gateways

When routing emails via centralised email gateways, it will be easier for an organisation to deploy Sender Policy Framework (SPF), DomainKeys Identified Mail (DKIM), Domain-based Message Authentication, Reporting and Conformance (DMARC) and protective marking checks.

Control: ISM-0569; Revision: 5; Updated: Jun-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Emails are routed via centralised email gateways.

Control: ISM-0571; Revision: 7; Updated: Jun-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When users send or receive emails, an authenticated and encrypted channel is used to route emails via their organisation's centralised email gateways.

Email gateway maintenance activities

As backup and alternative email gateways are often poorly maintained in terms of patches and email content filtering, malicious actors will often seek to exploit this when sending malicious emails to an organisation. As such, it is important that backup and alternative email gateways are maintained at the same standard as an organisation's primary email gateway.

Control: ISM-0570; Revision: 4; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Where backup or alternative email gateways are in place, they are maintained at the same standard as the primary email gateway.

Open relay email servers

An open relay email server (or open mail relay) is an email server that is configured to allow anyone on the internet to send emails through it. Such configurations are highly undesirable as spammers and worms can exploit them.

Control: ISM-0567; Revision: 5; Updated: Sep-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Email servers only relay emails destined for or originating from their domains (including subdomains).

Email server transport encryption

Emails can be intercepted anywhere between originating email servers and destination email servers. Implementing opportunistic Transport Layer Security (TLS) encryption can mitigate this security risk. However, opportunistic TLS encryption is susceptible to downgrade attacks. To mitigate this security risk, Mail Transfer Agent Strict Transport Security (MTA-STS) allows domain owners to indicate that email transfers should only occur if satisfactory TLS encryption is negotiated beforehand.

In support of MTA-STS implementations, TLS Reporting provides a mechanism for a domain owner to publish a location where reports can be submitted regarding the success or failure of attempts to initiate encrypted connections when sending emails to a specified domain.

Control: ISM-0572; Revision: 4; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Opportunistic TLS encryption is enabled on email servers that make incoming or outgoing email connections over public network infrastructure.

Control: ISM-1589; Revision: 3; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
MTA-STS is enabled to prevent the unencrypted transfer of emails between email servers.

Sender Policy Framework

SPF aids in the detection of spoofed emails by specifying a list of hosts or Internet Protocol (IP) addresses that are allowed to send emails on behalf of a specified domain or subdomain. If an email server is not in the SPF record for a domain or subdomain, SPF verification will not pass. In specifying SPF records, domain owners should ensure that they delegate the minimum necessary set of hosts or IP addresses necessary for sending emails. In addition, extra care should be taken when delegating to hosts or IP addresses not under an organisation's control.

Control: ISM-0574; Revision: 7; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SPF is used to specify authorised email servers (or lack thereof) for an organisation's domains (including subdomains).

Control: ISM-1183; Revision: 3; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A hard fail SPF record is used when specifying authorised email servers (or lack thereof) for an organisation's domains (including subdomains).

Control: ISM-1151; Revision: 3; Updated: Oct-19; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SPF is used to verify the authenticity of incoming emails.

DomainKeys Identified Mail

DKIM enables the detection of spoofed email contents. This is achieved by DKIM records specifying the public key used to verify the digital signature in an email. Specifically, if the signed digest in an email header does not match the signed contents of the email, verification will not pass.

Control: ISM-0861; Revision: 3; Updated: Sep-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
DKIM signing is enabled on emails originating from an organisation's domains (including subdomains).

Control: ISM-1026; Revision: 6; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
DKIM signatures on incoming emails are verified.

Control: ISM-1027; Revision: 5; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Email distribution list applications used by external senders is configured such that it does not break the validity of the sender's DKIM signature.

Domain-based Message Authentication, Reporting and Conformance

DMARC enables a domain owner to specify what action receiving email servers should take as a result of domain alignment, SPF and DKIM checks. For emails that do not pass DMARC checks, this includes 'reject' (emails are rejected), 'quarantine' (emails are marked as spam) or 'none' (no action is taken).

DMARC also provides a reporting feature that enables a domain owner to receive reports on the actions taken by receiving email servers. While this feature does not mitigate malicious emails sent to the domain owner's organisation, it can give the domain owner some visibility of attempts by malicious actors to spoof their organisation's domains.

Control: ISM-1540; Revision: 3; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
DMARC records are configured for an organisation's domains (including subdomains) such that emails are rejected if they do not pass DMARC checks.

Control: ISM-1799; Revision: 0; Updated: Sep-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Incoming emails are rejected if they do not pass DMARC checks.

Email content filtering

Content filtering performed on email bodies and attachments provides a defence-in-depth approach to preventing malicious code being introduced into networks.

Control: ISM-1234; Revision: 5; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Email content filtering is implemented to filter potentially harmful content in email bodies and attachments.

Blocking suspicious emails

Blocking specific types of suspicious emails, such as where the email source address uses an internal domain, or internal subdomain, reduces the likelihood of phishing emails entering an organisation's network.

Control: ISM-1502; Revision: 2; Updated: Sep-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Emails arriving via an external connection where the email source address uses an internal domain, or internal subdomain, are blocked at the email gateway.

Notifications of undeliverable emails

Notifications of undeliverable emails are commonly sent by receiving email servers when emails cannot be delivered, usually because destination addresses are invalid. Due to the common spamming practice of spoofing sender addresses, this often results in many undeliverable email notifications being sent to innocent third parties. Sending notifications of undeliverable emails only to senders that can be verified via SPF, or other trusted means, avoids contributing to this problem while allowing legitimate senders to be notified.

Control: ISM-1024; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Notifications of undeliverable emails are only sent to senders that can be verified via SPF or other trusted means.

Further information

Further information on hardening Microsoft Exchange can be found in the United States' National Security Agency's *Microsoft Exchange Server Security Best Practices* publication.

Further information on implementing opportunistic TLS encryption for email servers can be found in the Australian Signals Directorate's (ASD) *Implementing certificates, TLS, HTTPS and opportunistic TLS* publication.

Further information on implementing SPF, DKIM and DMARC can be found in ASD's *How to combat fake emails* publication.

Further information on engaging the services of email service providers for marketing or filtering purposes can be found in ASD's *Marketing and filtering email service providers* publication.

Further information on email content filtering can be found in the 'Content filtering' section of the *Guidelines for gateways*.

Further information on email content filtering can be found in ASD's *Malicious email mitigation strategies* publication.

Further information on email security can be found in the following National Institute of Standards and Technology (NIST) publications:

- NIST Special Publication (SP) 800-45 Version 2, *Guidelines on Electronic Mail Security*
- NIST SP 800-177 Rev. 1, *Trustworthy Email*
- NIST SP 1800-6, *Domain Name System-Based Electronic Mail Security*.

Guidelines for networking

Network design and configuration

Network documentation

It is important that accurate and sufficiently detailed network documentation is developed as this can assist in troubleshooting network problems as well as responding to and recovering from cyber security incidents. As such, network documentation should include high-level network diagrams showing all connections into networks; logical network diagrams showing all critical servers, high-value servers, network devices and network security appliances; and device settings for all critical servers, high-value servers, network devices and network security appliances. Finally, as network documentation could be used by malicious actors to assist in compromising networks, it is important that it is appropriately protected.

Control: ISM-0518; Revision: 6; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network documentation is developed, implemented and maintained.

Control: ISM-0516; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network documentation includes high-level network diagrams showing all connections into networks and logical network diagrams showing all critical servers, high-value servers, network devices and network security appliances.

Control: ISM-1912; Revision: 0; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network documentation includes device settings for all critical servers, high-value servers, network devices and network security appliances.

Control: ISM-1178; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network documentation provided to a third party, or published in public tender documentation, only contains details necessary for other parties to undertake contractual services.

Network segmentation and segregation

Network segmentation and segregation is one of the most effective security controls in preventing malicious actors from easily propagating throughout networks once initial access has been gained. To achieve this, networks can be segregated into multiple network zones to protect servers, services and data. For example, administrative infrastructure used for managing critical servers, high-value servers and regular servers should be segregated from each other. In addition, all administrative infrastructure should be segregated from other assets on networks.

Control: ISM-1181; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Networks are segregated into multiple network zones according to the criticality of servers, services and data.

Control: ISM-1577; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An organisation's networks are segregated from their service providers' networks.

Using virtual local area networks

Virtual local area networks (VLANs) can be used to implement network segmentation and segregation when networks belong to the same security domain. In such cases, if a data spill occurs the impact will be less than if a data spill occurred between two networks of different classifications or between an organisation's network and public network infrastructure. Should an organisation choose to risk manage implementing VLANs between networks belonging to different security domains, such as at the same classification, additional security controls for network devices will apply, such as not sharing VLAN trunks and terminating VLANs on separate physical network interfaces.

For the purposes of this topic, Multiprotocol Label Switching is considered equivalent to VLANs and subject to the same security controls.

Control: ISM-1532; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
VLANs are not used to separate network traffic between an organisation's networks and public network infrastructure.

Control: ISM-0529; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
VLANs are not used to separate network traffic between networks belonging to different security domains.

Control: ISM-0530; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network devices managing VLANs are administered from the most trusted security domain.

Control: ISM-0535; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network devices managing VLANs belonging to different security domains do not share VLAN trunks.

Control: ISM-1364; Revision: 3; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network devices managing VLANs terminate VLANs belonging to different security domains on separate physical network interfaces.

Functional separation between networked devices and the internet

Implementing functional separation between networked devices and the internet reduces the exposure of such devices to attacks originating from the internet.

Control: ISM-2068; Revision: 0; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Internet connectivity for networked devices is strictly limited to those that require access.

Networked management interfaces

To assist in reducing the attack surface of networks, IT equipment residing on networks (such as servers) or constituting the makeup of network infrastructure (such as network devices) should not directly expose their networked management interfaces to the internet. In situations where this is not possible, such as for some cloud services and web applications, alternative measures will need to be implemented to protect weak or vulnerable networked management interfaces

from being exploited by malicious actors to remotely compromise networks. Ideally, IT equipment on networks, or constituting the makeup of network infrastructure, should be managed via a dedicated management network that is segregated from the wider network and the internet.

Control: ISM-1863; Revision: 1; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Networked management interfaces for IT equipment are not directly exposed to the internet.

Control: ISM-2160; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Networked management interfaces for IT equipment are only accessible from a dedicated management network that is segregated from the wider network and the internet.

Functional separation between servers

Implementing functional separation between servers reduces the likelihood that a server compromised by malicious actors will pose an increased security risk to other servers.

Control: ISM-0385; Revision: 7; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Servers maintain effective functional separation from each other.

Control: ISM-1479; Revision: 1; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Servers minimise communications with other servers at the network and file system level.

Network encryption

While physical security can provide a degree of protection against unauthorised physical access to network infrastructure, unauthorised access to unencrypted data can still be gained via other means, such as compromised network devices. For this reason, all data communicated over network infrastructure should be suitably encrypted, even within appropriately secure areas. As such, it is critical that Australian Signals Directorate (ASD)-approved cryptography is used. However, where protocols do not have encrypted equivalents, an organisation should consider transitioning to alternative protocols that support suitable encryption where practical and feasible.

Control: ISM-1781; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All data communicated over network infrastructure is encrypted using ASD-approved cryptography.

Using Internet Protocol version 6

The use of Internet Protocol version 6 (IPv6) can introduce additional security risks to networks if not managed appropriately. As such, IPv6 capable network security appliances should be used on IPv6 and dual-stack networks to ensure security coverage equivalent to that provided for Internet Protocol version 4 (IPv4) networks while assisting in ensuring that IPv6 cannot be exploited by malicious actors.

To aid in the transition from IPv4 to IPv6, numerous tunnelling protocols have been developed to enable interoperability between IPv4 and IPv6. Disabling IPv6 tunnelling protocols on networks

that do not require such functionality will prevent malicious actors from bypassing traditional network defences by encapsulating IPv6 data inside IPv4 packets.

Stateless Address Autoconfiguration is a method of stateless Internet Protocol (IP) address configuration in IPv6 networks. It reduces the ability of an organisation to maintain effective logs of IP address assignments on networks. For this reason, stateless IP addressing should be avoided.

Control: ISM-1186; Revision: 4; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IPv6 capable network security appliances are used on IPv6 and dual-stack networks.

Control: ISM-1428; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unless explicitly required, IPv6 tunnelling is disabled on all network devices.

Control: ISM-1429; Revision: 4; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IPv6 tunnelling is blocked by network security appliances at externally connected network boundaries.

Control: ISM-1430; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Dynamically assigned IPv6 addresses are configured with Dynamic Host Configuration Protocol version 6 in a stateful manner with lease data stored in a centralised event logging facility.

Network access controls

If malicious actors have reduced opportunities to connect unauthorised network devices, or networked information technology (IT) equipment, to networks, they also have reduced opportunities to compromise such networks. Network access controls can not only prevent unauthorised access to networks, but also prevent personnel from carelessly bridging networks by connecting one network to another network. Furthermore, network access controls can also be useful for limiting the flow of network traffic between network segments.

Control: ISM-0520; Revision: 9; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network access controls are implemented on networks to prevent the connection of unauthorised network devices and networked IT equipment.

Control: ISM-1182; Revision: 5; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network access controls are implemented to limit the flow of network traffic within and between network segments to only that required for business purposes.

802.1X authentication and key exchange

802.1X authentication requires the use of an Extensible Authentication Protocol (EAP), of which multiple EAP methods are available.

Extensible Authentication Protocol-Transport Layer Security (EAP-TLS) is considered one of the most secure EAP methods for 802.1X authentication and is widely supported. It uses a public key infrastructure to secure communications between devices and a Remote Authentication Dial-In User Service (RADIUS) server by using X.509 certificates. While EAP-TLS provides strong mutual authentication, it requires an organisation to have established a public key infrastructure. This

involves deploying their own certificate authority and issuing X.509 certificates, or sourcing them from a commercial certificate authority, for every device that accesses their network. While this introduces additional costs and management overheads, the security advantages are significant.

Control: ISM-1321; Revision: 3; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
802.1X with EAP-TLS is used for mutual authentication and key exchange, with all other EAP methods disabled on supplicants and authentication servers.

Control: ISM-1711; Revision: 0; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
User identity confidentiality is used if available with EAP-TLS implementations.

Evaluation of 802.1X implementations

The security of 802.1X authentication is dependent on three main elements and how they interact. These three elements include supplicants, authenticators and authentication servers. To provide assurance that these elements have been implemented correctly, they should have completed an evaluation.

Control: ISM-1322; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Evaluated supplicants, authenticators and authentication servers are used for 802.1X authentication implementations.

Generating and issuing X.509 certificates for authentication

When issuing X.509 certificates to devices to access networks, an organisation should be aware that they could be stolen by malicious code. Once compromised, X.509 certificates could be used on other devices to gain unauthorised access to networks. An organisation should also be aware that in only issuing X.509 certificates to devices, any actions taken by human users will only be attributable to specific devices.

When issuing X.509 certificates to human users to access networks, they can either be stored on devices or stored on smart cards. While issuing X.509 certificates that are stored on smart cards provides increased security, it comes at a higher cost. However, human users are more likely to notice missing smart cards and alert their security team, who are then able to revoke their credentials, which can minimise the time malicious actors have access to networks. In addition, to reduce the likelihood of stolen smart cards from being used to gain unauthorised access to networks, multi-factor authentication can be implemented by requiring the use of passwords to access X.509 certificates stored on smart cards. This is particularly important when smart cards grant human users any form of administrative access.

Control: ISM-1323; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
X.509 certificates are required for devices and human users authenticating to networks using 802.1X.

Control: ISM-1324; Revision: 5; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
X.509 certificates are generated using an evaluated certificate authority or hardware security module.

Control: ISM-1327; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
X.509 certificates are protected by logical and physical access controls and encryption, with those issued to human users requiring authentication before use.

Remote Authentication Dial-In User Service authentication

Separate to the 802.1X authentication process is the RADIUS authentication process that occurs between authenticators and a RADIUS server. RADIUS is what is known as an authentication, authorisation and accounting protocol, and is intended to mediate network access. However, RADIUS is not secure enough to be used without protection. To protect credentials communicated between authenticators and a RADIUS server, communications should be encapsulated with an additional layer of encryption, such as RADIUS over Internet Protocol Security or RADIUS over Transport Layer Security.

Control: ISM-1454; Revision: 2; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Communications between authenticators and a RADIUS server are encapsulated with an additional layer of encryption using RADIUS over Internet Protocol Security or RADIUS over Transport Layer Security.

Network management traffic

Implementing security measures specifically for network management traffic provides another layer of defence should malicious actors find an opportunity to connect to networks. In addition, this also makes it more difficult for malicious actors to enumerate networks.

Control: ISM-1006; Revision: 6; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security measures are implemented to prevent unauthorised access to network management traffic.

Using the Server Message Block protocol

The Server Message Block (SMB) protocol is used to share files and printers across networks. Unfortunately, multiple weaknesses exist in SMB version 1 that can be used by malicious actors to gain access to resources on networks, including Microsoft Active Directory Domain Services domain controllers.

Control: ISM-1962; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SMB version 1 is not used on networks.

Using the Simple Network Management Protocol

The Simple Network Management Protocol (SNMP) can be used to monitor the status of network devices. The first two iterations of SNMP were inherently insecure as they used trivial authentication methods. Furthermore, changing all default SNMP community strings on network devices, and limiting their access to read-only, is strongly encouraged.

Control: ISM-1311; Revision: 3; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SNMP version 1 and SNMP version 2 are not used on networks.

Control: ISM-1312; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All default SNMP community strings on network devices are changed and write access is disabled.

Using network-based intrusion detection and prevention systems

A network-based intrusion detection system (NIDS) or network-based intrusion prevention system (NIPS) can be an effective way of identifying and responding to network intrusions. In addition, generating event logs and alerts for network traffic that contravenes any rule in a firewall ruleset can help identify suspicious or malicious network traffic entering networks due to a failure of, or configuration change to, firewalls.

Control: ISM-1028; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A NIDS or NIPS is deployed in gateways between an organisation's networks and other networks they do not manage.

Control: ISM-1030; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A NIDS or NIPS is located immediately inside the outermost firewall for gateways and configured to generate event logs and alerts for network traffic that contravenes any rule in a firewall ruleset.

Blocking anonymity network traffic

Inbound network connections from anonymity networks, such as the Tor network, can be used by malicious actors for reconnaissance and malicious code delivery purposes with minimal risk of detection and attribution. As such, this network traffic should be blocked. However, an organisation might choose to support anonymous connections to their websites to cater for individuals who want to remain anonymous for privacy reasons. In such cases, it is suggested that network traffic from anonymity networks be logged and monitored instead. Additionally, outbound network connections to anonymity networks can be used by malicious code for command and control or data exfiltration purposes and should be blocked.

Control: ISM-1627; Revision: 1; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Inbound network connections from anonymity networks are blocked.

Control: ISM-1628; Revision: 0; Updated: Nov-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Outbound network connections to anonymity networks are blocked.

Encrypted Domain Name System Services

Domain Name System (DNS) is a hierarchical naming system built on a distributed database for resources connected to the internet. In performing this service, DNS maps human-readable domain names to their associated IP addresses. Unfortunately, malicious actors can surveil standard DNS requests for intelligence gathering. As such, it is important that DNS traffic is suitably encrypted by clients and servers using ASD-approved cryptography, such as via DNS over Hypertext Transfer Protocol Secure or DNS over Transport Layer Security.

Control: ISM-2017; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
DNS traffic is encrypted by clients and servers using ASD-approved cryptography.

Protective Domain Name System Services

A protective DNS service can be an effective way of blocking requests made by an organisation's users, or malicious actors on an organisation's network, to known malicious domain names – either as part of an initial compromise or subsequent command and control activities. DNS event logs captured by a protective DNS service can also be useful for investigating any exploitation attempt or successful compromise of a network by malicious actors.

In selecting a protective DNS service, many commercial offerings exist. In addition, ASD offers a free protective DNS service for Australia's most critical systems.

Control: ISM-1782; Revision: 1; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A protective DNS service is used to block access to known malicious domain names.

Network device integrity

Flashing network devices with trusted firmware, obtained from vendors via trusted means, before network devices are used for the first time can assist in reducing cyber supply chain risks, such as the introduction of malicious firmware resulting from a cyber supply chain interdiction attack or a compromised vendor development environment or authoritative source for software. Furthermore, to maintain the ongoing integrity of network devices, their firmware and running configurations should be verified against an approved known-good baseline following patching, on detection of anomalous behaviour and at least monthly. This is especially important for internet-facing network devices.

Control: ISM-1800; Revision: 0; Updated: Sep-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network devices are flashed with trusted firmware before they are used for the first time.

Control: ISM-2161; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The integrity of network device firmware and running configurations is verified against an approved known-good baseline following patching, on detection of anomalous behaviour and at least monthly.

Network device hardening

Network devices can come pre-configured with default user accounts and credentials. For example, wireless access points with a user account named 'admin' and a password of 'admin'. Ensuring that default user accounts or credentials are changed, disabled or removed during initial setup can assist in reducing the likelihood of network devices being exploited by malicious actors. Furthermore, any unneeded components, services and functionality of network devices should also be disabled to reduce their attack surface. This is especially important for internet-facing network devices.

Control: ISM-1304; Revision: 7; Updated: Jun-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Default user accounts or credentials for network devices, including for any pre-configured user accounts, are changed, disabled or removed during initial setup.

Control: ISM-2162; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unneeded components, services and functionality of network devices are disabled or removed.

Disabling unused physical ports on network devices

Disabling unused physical ports on network devices reduces the opportunity for malicious actors to connect to networks if they can gain physical access to network devices.

Control: ISM-0534; Revision: 2; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Unused physical ports on network devices are disabled.

Regularly restarting network devices

Implementing measures to restart network devices at least monthly can assist in maintaining network device performance as well as removing malicious actors that may have compromised a network device but failed to gain persistence.

Control: ISM-1801; Revision: 1; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Network devices are restarted at least monthly.

Network device event logging

Centrally logging and analysing security-relevant events, including configuration changes, for network devices, especially for internet-facing network devices, can assist in monitoring the security posture of systems, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-1963; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for internet-facing network devices are centrally logged.

Control: ISM-1964; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for non-internet-facing network devices are centrally logged.

Further information

Further information on secure network design can be found in ASD's *Foundations for modern defensible architecture* publication.

Further information on wired networks can be found in the 'Wired networks' section of these guidelines.

Further information on wireless networks can be found in the 'Wireless networks' section of these guidelines.

Further information on gateways can be found in the 'Gateways' section of the *Guidelines for gateways*.

Further information on encrypting communications can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Further information on network segmentation and segregation can be found in ASD's *Implementing network segmentation and segregation* publication.

Further information on network security zones can be found in Canada's Canadian Centre for Cyber Security's *Baseline security requirements for network security zones (version 2.0)* publication.

Further information on implementing network segmentation and segregation for system administration purposes can be found in the 'System administration' section of the *Guidelines for system management*.

Further information on functional separation of servers using virtualisation can be found in the 'Virtualisation hardening' section of the *Guidelines for system hardening*.

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Further information on blocking anonymity network traffic can be found in ASD's *Defending against the malicious use of the Tor network* publication.

Further information on DNS services can be found in ASD's *Domain Name System security for domain owners* and *Domain Name System security for domain resolvers* publications.

Further information on implementing encrypted DNS can be can be found in the United States' National Security Agency's *Adopting Encrypted DNS in Enterprise Environments* publication and the Cybersecurity & Infrastructure Security Agency's *Encrypted DNS Implementation Guidance* publication.

Further information on selecting a protective DNS service can be found in the United States' National Security Agency and Cybersecurity & Infrastructure Security Agency's *Selecting a Protective DNS Service* publication.

Further information on network device hardening, particularly for internet-facing network devices, can be found in the following publications:

- ASD's *Mitigation strategies for edge devices: Executive guidance*
- ASD's *Mitigation strategies for edge devices: Practitioner guidance*
- Canada's Canadian Centre for Cyber Security's *Security considerations for edge devices*

- United Kingdom's National Cyber Security Centre's *Guidance on digital forensics and protective monitoring specifications for producers of network devices and appliances*.

Further information on network device hardening can also be found in the United States' National Security Agency's *Network Infrastructure Security Guide* publication.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on event logging for network devices can also be found in ASD's *Priority logs for SIEM ingestion: Practitioner guidance* publication.

Wired networks

Context

This section describes security controls applicable to wired networks and extends the 'Network design and configuration' section of these guidelines.

Media Access Control Security

An implementation of Media Access Control Security (MACsec) that fully conforms to its standard must implement at least the GCM-AES-128 cipher suite and may optionally implement the GCM-AES-256, GCM-AES-XPN-128 and GCM-AES-XPN-256 cipher suites, with 256-bit key sizes providing more bits of effective security. These cipher suites may be used to provide only data integrity (integrity-only mode) or both data integrity and data confidentiality (confidentiality protection mode).

Using a connectivity association lifetime of less than 24 hours (86400 seconds) and a secure association lifetime of less than four hours (14400 seconds) can provide a balance between security and usability.

The use of a Pre-Shared Key as a fallback authentication method if EAP-TLS authentication attempts fail can limit the effective strength of the EAP authentication.

For interoperability and maintainability reasons, the GCM-AES-128 and GCM-AES-XPN-128 cipher suites will not be approved beyond 2030.

Control: ISM-2163; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using MACsec, confidentiality protection mode is enabled using GCM-AES-128, GCM-AES-256, GCM-AES-XPN-128 or GCM-AES-XPN-256, preferably GCM-AES-256 or GCM-AES-XPN-256.

Control: ISM-2164; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A connectivity association lifetime of less than 24 hours (86400 seconds) is used for MACsec connections.

Control: ISM-2165; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using EAP-TLS, each device performs a fresh EAP-TLS authentication each time a new Connectivity Association Key is required.

Control: ISM-2166; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A secure association lifetime of less than four hours (14400 seconds) is used for MACsec connections.

Control: ISM-2167; Revision: 0; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The use of a Pre-Shared Key as a fallback authentication method for MACsec is disabled.

Further information

Further information on encrypting communications can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Further information on 802.1X authentication and key exchange can be found in the 'Network design and configuration' section of these guidelines.

Wireless networks

Context

This section describes security controls applicable to wireless networks and extends the 'Network design and configuration' section of these guidelines.

Choosing wireless devices

Using wireless devices, such as wireless access points, wireless adapters and wireless network cards, which have been certified against a Wi-Fi Alliance certification program, provides an organisation with the assurance that they conform to wireless standards and are guaranteed to be interoperable with other wireless devices on wireless networks.

Control: ISM-1314; Revision: 2; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All wireless devices are Wi-Fi Alliance certified.

Public wireless networks

When an organisation provides a public wireless network for public use, connecting the public wireless network to, or sharing infrastructure with, any other organisation networks can create an entry point for malicious actors enabling them to target organisation networks to steal data or disrupt services.

Control: ISM-0536; Revision: 8; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Public wireless networks provided for public use are segregated from all other organisation networks.

Administrative interfaces for wireless access points

Administrative interfaces allow users to modify the configuration and security settings of wireless access points. Often, by default, wireless access points allow users to access administrative interfaces over fixed network connections or wireless network connections. To assist in reducing the attack surface for wireless access points, the administrative interface should be disabled for wireless network connections.

Control: ISM-1315; Revision: 2; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The administrative interface on wireless access points is disabled for wireless network connections.

Default settings

Some wireless access points come pre-configured with weak default settings. As such, it is important to harden the settings of wireless access points prior to their deployment in networks. In addition, some wireless access points come with default Service Set Identifiers (SSIDs). As default SSIDs are often documented on the internet, it is important to change default SSIDs of wireless access points.

When changing default SSIDs, it is important that new SSIDs do not bring undue attention to an organisation's wireless networks. In doing so, SSIDs of wireless networks should not be readily associated with an organisation, the location of their premises or the functionality of wireless networks.

A method commonly recommended to lower the profile of wireless networks is disabling SSID broadcasting. While this ensures that the existence of wireless networks is not broadcast overtly using beacon frames, SSIDs are still broadcast in probe requests, probe responses, association requests and re-association requests. As such, it is easy to determine SSIDs of wireless networks by capturing these requests and responses. By disabling SSID broadcasting, an organisation will make it more difficult for human users to connect to wireless networks. Furthermore, malicious actors could configure a malicious wireless access point to broadcast the same SSID as a hidden SSID used by a legitimate wireless network, fooling human users into connecting, or devices into automatically connecting, to the malicious wireless access point instead. In doing so, malicious actors could steal authentication credentials to gain access to the legitimate wireless network.

Control: ISM-1710; Revision: 2; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Settings for wireless access points are hardened.

Control: ISM-1316; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Default SSIDs of wireless access points are changed.

Control: ISM-1317; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SSIDs of non-public wireless networks are not readily associated with an organisation, the location of their premises or the functionality of wireless networks.

Control: ISM-1318; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SSID broadcasting is not disabled on wireless access points.

Media Access Control address filtering

Devices that connect to wireless networks generally have a unique Media Access Control (MAC) address. Using MAC address filtering can prevent rogue devices from connecting to wireless networks. However, malicious actors may be able to determine MAC addresses of legitimate devices and use this information to gain access to wireless networks. As such, MAC address filtering introduces management overhead without any tangible security benefit.

Control: ISM-1320; Revision: 2; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
MAC address filtering is not used to restrict which devices can connect to wireless networks.

Static addressing

Assigning static IP addresses for devices accessing wireless networks can prevent rogue devices connecting to wireless networks from being assigned routable IP addresses. However, malicious actors may be able to determine IP addresses of legitimate devices and use this information to gain access to wireless networks. As such, configuring devices to use static IP addresses introduces management overhead without any tangible security benefit.

Control: ISM-1319; Revision: 2; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Static addressing is not used for assigning IP addresses on wireless networks.

Confidentiality and integrity of wireless network traffic

As wireless networks are often capable of being accessed from outside the perimeter of secured spaces, all wireless network traffic requires suitable cryptographic protection. For this purpose, it is recommended that Wi-Fi Protected Access 3 (WPA3) be used as it provides equivalent or greater security than Wi-Fi Protected Access 2 (WPA2). WPA3 has also prohibited the use of various outdated and insecure cipher suites.

WPA3-Enterprise supports three enterprise modes of operation: enterprise only mode, transition mode and 192-bit mode. Preference is given to WPA3-Enterprise 192-bit mode as this mode ensures no cryptographic algorithms with known weaknesses are used. However, if any other WPA3-Enterprise modes are used then Authentication and Key Management suite 00-0F-AC:1 should be disabled (if this option is available).

Control: ISM-1332; Revision: 3; Updated: Sep-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
WPA3-Enterprise 192-bit mode is used to protect the confidentiality and integrity of all wireless network traffic.

Caching 802.1X authentication outcomes

When 802.1X authentication is used as part of WPA3-Enterprise, a shared secret key known as the Pairwise Master Key (PMK) is generated upon successful authentication of devices. This PMK is then capable of being cached to assist with fast roaming between wireless access points. For example, when devices roam away from wireless access points they have authenticated to, they will not need to perform a full re-authentication should they roam back while the cached PMK

remains valid. To further assist with roaming, wireless access points can be configured to pre-authenticate devices to neighbouring wireless access points that devices might roam to. Although requiring full authentication for devices each time they roam between wireless access points is ideal, an organisation can choose to use PMK caching and pre-authentication if they have a business requirement for fast roaming. If PMK caching is used, the PMK caching period should not be set to greater than 1440 minutes (24 hours).

Control: ISM-1330; Revision: 1; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The PMK caching period is not set to greater than 1440 minutes (24 hours).

Fast Basic Service Set Transition

The WPA3 standard specifies support for Fast Basic Service Set Transition (FT) (802.11r). FT is a feature designed to improve user mobility and combat lag introduced by the need to authenticate to each wireless access point. However, FT requires authenticators to request and send keys to other authenticators within a security domain. If any of these keys are intercepted, all security properties are lost. Therefore, it is imperative that communications are appropriately secured. As such, FT should be disabled unless it can be confirmed that authenticator-to-authenticator communications are secured by a suitable ASD-Approved Cryptographic Protocol that provides confidentiality, integrity and mutual authentication.

Control: ISM-1712; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The use of FT (802.11r) is disabled unless authenticator-to-authenticator communications are secured by an ASD-Approved Cryptographic Protocol.

Interference between wireless networks

When wireless networks are deployed in proximity, there is the potential for interference to impact their availability, especially when operating on commonly used 802.11b/g (2.4 GHz) default channels of 1 and 11. Sufficiently separating wireless networks by using frequency separation can help reduce this security risk. This can be achieved by using wireless networks that are configured to operate on channels that minimise overlapping frequencies, such as using 802.11b/g (2.4 GHz) channels and 802.11n (5 GHz) channels. It is important to note though, if implementing a mix of 2.4 GHz and 5 GHz channels, not all devices may be compatible with 802.11n and able to connect to 5 GHz channels.

Control: ISM-1334; Revision: 2; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Wireless networks implement sufficient frequency separation from other wireless networks.

Protecting management frames on wireless networks

An effective denial-of-service attack can be performed by exploiting unprotected management frames using inexpensive commercial hardware. The 802.11 standard provides no protection for management frames and therefore does not protect against spoofing or denial-of-service attacks. However, the 802.11w amendment specifically addresses the protection of management frames

on wireless networks and should be enabled for WPA2. In WPA3, this feature is built into the standard.

Control: ISM-1335; Revision: 1; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Wireless access points enable the use of the 802.11w amendment to protect management frames.

Wireless network footprint

Instead of deploying a small number of wireless access points that broadcast on high power, a greater number of wireless access points that use less broadcast power can be deployed to achieve the desired footprint for wireless networks. This has the benefit of providing service continuity should wireless access points become unserviceable. In such cases, the output power of nearby wireless access points can be increased to cover the footprint gap until the unserviceable wireless access points can be replaced.

In addition to minimising the output power of wireless access points to reduce the footprint of wireless networks, the use of radio frequency (RF) shielding can be used for an organisation's facilities. While expensive, this will limit wireless communications to areas under the control of an organisation. RF shielding on an organisation's facilities also has the added benefit of preventing the jamming of wireless networks from outside of the facilities in which wireless networks are operating.

Control: ISM-1338; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Instead of deploying a small number of wireless access points that broadcast on high power, a greater number of wireless access points that use less broadcast power are deployed to achieve the desired footprint for wireless networks.

Control: ISM-1013; Revision: 6; Updated: Dec-21; Applicable: S, TS; Essential 8: N/A
The effective range of wireless communications outside an organisation's area of control is limited by implementing RF shielding on facilities in which SECRET or TOP SECRET wireless networks are used.

Further information

Further information on Wi-Fi technologies and associated testing and certification programs is available from the Wi-Fi Alliance.

Further information on encrypting communications can be found in the 'Cryptographic fundamentals' section of the *Guidelines for cryptography*.

Further information on 802.1X authentication and key exchange can be found in the 'Network design and configuration' section of these guidelines.

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Service continuity for online services

Cloud-based hosting of online services

Using cloud service providers can enable an organisation to build highly resilient online services due to the increased computing resources, bandwidth and multiple separate physical sites made available by cloud service providers. An organisation can attempt to achieve the same results using their own infrastructure; however, doing so may require significant upfront costs and may still result in a limited capability to scale resources dynamically to meet genuine spikes in demand. In cases of denial-of-service attacks, cloud-based hosting can also provide segregation from self-hosted or other cloud-hosted services ensuring that other systems, such as email, are not affected.

Control: ISM-1437; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cloud service providers are used for hosting online services.

Capacity and availability planning and monitoring for online services

It is important that connectivity between an organisation and their cloud service providers meets requirements for bandwidth, latency and availability. In support of this, an organisation and their cloud service providers should discuss the ability to scale resources dynamically in response to genuine spikes in demand. This should include any authorised activities that can be undertaken to verify measures implemented to support such requirements, especially where high availability is required. For example, an organisation and their cloud service providers may discuss whether dedicated communication links or internet connections will be used, and whether secondary communications links will provide sufficient capacity to maintain operational requirements if the primary communication link becomes unavailable.

Furthermore, capacity and availability monitoring should be performed to manage workloads and monitor the health of online services. This can be achieved through continuous real-time monitoring of metrics, such as latency, jitter, packet loss, throughput and availability. In addition, feedback should be provided to cloud service providers when performance does not meet service level agreement targets. To assist with this, anomaly detection can be performed through network telemetry that is integrated into security monitoring tools.

Control: ISM-1579; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cloud service providers' ability to scale resources dynamically in response to genuine spikes in demand is discussed and verified as part of capacity and availability planning for online services.

Control: ISM-1580; Revision: 1; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Where a high availability requirement exists for online services, the services are architected to automatically transition between availability zones.

Control: ISM-1581; Revision: 3; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Continuous real-time monitoring of the capacity and availability of online services is performed.

Using content delivery networks

Similar to cloud-based hosting, the use of content delivery networks (CDNs) can allow an organisation to create highly resilient online services by leveraging the large bandwidth, geographically dispersed hosting locations, traffic scrubbing and other security controls offered by CDNs.

The use of CDNs is particularly effective when serving static bandwidth intensive media, such as images, sound or video files. However, the services offered by CDNs can include more than basic content hosting, such as web response caching, load balancing, web application security and denial-of-service attack mitigations.

In using CDNs, care should be taken with their configuration to ensure that the IP addresses of an organisation's web servers (referred to as origin servers) are not identifiable by malicious actors, as knowledge of origin server IP addresses could allow for protections provided by CDNs to be bypassed. Additionally, appropriate security controls should be applied to only enable communication between origin servers, CDNs and authorised management networks.

Control: ISM-1438; Revision: 2; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Where a high availability requirement exists for website hosting, CDNs that cache websites are used.

Control: ISM-1439; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If using CDNs, disclosing the IP addresses of web servers under an organisation's control (referred to as origin servers) is avoided and access to the origin servers is restricted to the CDNs and authorised management networks.

Denial-of-service attack mitigation strategies

Denial-of-service attacks are designed to disrupt or degrade online services, such as website, email and Domain Name System services. To achieve this goal, malicious actors may use multiple methods to deny access to legitimate users of online services. This includes using multiple computers to direct a large volume of unwanted network traffic at online services to consume all available network bandwidth, using multiple computers to direct tailored network traffic at online services to consume all processing resources, or hijacking online services to redirect legitimate users away from those services to other services that malicious actors control.

As an organisation often cannot avoid being targeted by denial-of-service attacks, they should discuss with their cloud service providers any denial-of-service attack detection and monitoring services that may be available for their use. For example, reporting dashboards that provide out-of-band and real-time alerts based on organisation-defined notification thresholds. Furthermore, an organisation should discuss with their cloud service providers what mitigation strategies they can implement to prepare for, and reduce the impact of, being targeted by a denial-of-service attack. Finally, with the express consent of their cloud service providers, an organisation may seek to test the effectiveness of any denial-of-service attack mitigation strategies that have been implemented.

Overall, preparing for denial-of-service attacks before they occur, such as by identifying critical online services and implementing preventative denial-of-service attack mitigation strategies, is by far the best approach as it is very difficult to respond to denial-of-service attacks once they begin and efforts at that stage are unlikely to be effective.

Control: ISM-1431; Revision: 5; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Denial-of-service attack mitigation strategies are discussed with cloud service providers, specifically:

- *their capacity to withstand denial-of-service attacks*
- *costs likely to be incurred as a result of denial-of-service attacks*
- *availability monitoring and thresholds for notification of denial-of-service attacks*
- *thresholds for turning off any online services or functionality during denial-of-service attacks*
- *pre-approved actions that can be undertaken during denial-of-service attacks*
- *any arrangements with upstream service providers to block malicious network traffic as far upstream as possible.*

Control: ISM-1436; Revision: 3; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Critical online services are segregated from other online services that are more likely to be targeted as part of denial-of-service attacks.

Control: ISM-1432; Revision: 3; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Domain names for online services are protected via registrar locking and confirming that domain registration details are correct.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on the use of cloud service providers can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Further information on business continuity and disaster recovery planning can be found in the 'Chief information security officer' section of the *Guidelines for cyber security roles*.

Further information on mitigating denial-of-service attacks can be found in ASD's *Preparing for and responding to denial-of-service attacks* publication.

Guidelines for cryptography

Cryptographic fundamentals

Context

The purpose of cryptography is to provide confidentiality, integrity, authentication and non-repudiation of data. In doing so, confidentiality protects data by making it unreadable to all but authorised entities, integrity protects data from accidental or deliberate manipulation by entities, authentication ensures that an entity is who they claim to be, and non-repudiation provides proof that an entity performed a particular action.

In employing cryptography, data at rest can be encrypted to protect sensitive or classified data stored on information technology (IT) equipment and media. Similarly, data in transit can be encrypted to protect sensitive or classified data communicated over public network infrastructure. However, while cryptography can protect data at rest and in transit, it does not reduce the sensitivity or classification of the data; it only reduces the immediate consequences of the data being accessed by malicious actors.

Communications security doctrine

The Australian Signals Directorate (ASD) specifies additional communications security requirements in Australian Communications Security Instructions and ASD Broadcasts that must be complied with when operating High Assurance Cryptographic Equipment (HACE). Such requirements supplement these guidelines and, where conflicts occur, take precedence.

Control: ISM-0499; Revision: 12; Updated: Jun-25; Applicable: S, TS; Essential 8: N/A
Communications security doctrine and policy produced by ASD for the management and operation of HACE is complied with.

High Assurance Cryptographic Equipment

To ensure interoperability and maintain trust, all HACE must be issued an Approval for Use by ASD and be operated in accordance with the latest version of their associated Australian Communications Security Instructions.

Control: ISM-1802; Revision: 1; Updated: Sep-23; Applicable: S, TS; Essential 8: N/A
HACE are issued an Approval for Use by ASD and operated in accordance with the latest version of their associated Australian Communications Security Instructions.

Cryptographic key management processes and procedures

Well-documented cryptographic key management processes and procedures can assist in the secure use and management of cryptographic keys and associated hardware and software. In doing so, cryptographic key management processes and procedures should cover cryptographic

key generation, registration, distribution, installation, usage, protection, storage, access, recovery and destruction.

Control: ISM-0507; Revision: 5; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Cryptographic key management processes, and supporting cryptographic key management procedures, are developed, implemented and maintained.

Cryptographic implementation assurance

Securely implementing cryptographic algorithms and protocols is a difficult task that requires expertise and diligence. In doing so, suppliers, and their cyber supply chains, need to carry out their duties competently and honestly as small flaws in cryptographic equipment, applications or libraries can be catastrophic and difficult to detect. Therefore, to provide a degree of cryptographic implementation assurance, cryptographic equipment, applications and libraries should be assessed by one of the following processes, listed in order of preference:

- a Common Criteria evaluation against an ASD-endorsed Protection Profile
- a Federal Information Processing Standard (FIPS) 140-3 cryptographic evaluation via the United States and Canada's Cryptographic Module Validation Program
- a cryptographic evaluation via the United States and Canada's Cryptographic Algorithm Validation Program
- a Common Criteria evaluation against an Evaluation Assurance Level
- an independent security review by a reputable process or body.

Where a suitable Common Criteria evaluated product does not exist, an alternate product capable of securely implementing ASD-Approved Cryptographic Algorithms (AACAs) and ASD-Approved Cryptographic Protocols (AACPs) may be used. However, cyber supply chain security risks still need to be considered to ensure the product does not present a high risk. For example, an organisation should still follow robust and secure procurement processes by selecting a product from a supplier with:

- a history of undertaking Common Criteria evaluations for their other products
- a demonstrated commitment to the security of their products and services, including by adopting Secure by Design principles and practices, responsively resolving known vulnerabilities, and providing clear end of life advice for consumers
- a demonstrated commitment to transparency for their products
- a strong track record of maintaining the security of their own systems
- sufficient information on how to securely configure their products.

Control: ISM-0457; Revision: 11; Updated: Sep-25; Applicable: OS, P; Essential 8: N/A
Cryptographic equipment, applications or libraries that have completed a Common Criteria

evaluation against an ASD-endorsed Protection Profile are used when encrypting media that contains OFFICIAL: Sensitive or PROTECTED data.

Control: ISM-0460; Revision: 13; Updated: Sep-23; Applicable: S, TS; Essential 8: N/A
HACE is used when encrypting media that contains SECRET or TOP SECRET data.

Control: ISM-0465; Revision: 11; Updated: Sep-25; Applicable: OS, P; Essential 8: N/A
Cryptographic equipment, applications or libraries that have completed a Common Criteria evaluation against an ASD-endorsed Protection Profile are used to protect OFFICIAL: Sensitive or PROTECTED data when communicated over insufficiently secure networks, outside of appropriately secure areas or via public network infrastructure.

Control: ISM-0467; Revision: 12; Updated: Sep-23; Applicable: S, TS; Essential 8: N/A
HACE is used to protect SECRET and TOP SECRET data when communicated over insufficiently secure networks, outside of appropriately secure areas or via public network infrastructure.

Data recovery

To ensure that access to encrypted data is not lost due to the loss, damage or failure of an encryption key, it is important that where practical cryptographic equipment, applications and libraries provide a means of data recovery.

Control: ISM-0455; Revision: 5; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Where practical, cryptographic equipment, applications and libraries provide a means of data recovery to allow for circumstances where the encryption key is unavailable due to loss, damage or failure.

Handling encrypted IT equipment and media

When a user authenticates to the encryption functionality of IT equipment or media, encrypted data is made available. At such a time, the IT equipment or media should be handled according to its original sensitivity or classification. Once the user deauthenticates from the encryption functionality, such as by locking encrypted media, shutting down a device or activating a lock screen, the IT equipment or media can be considered protected by the encryption functionality again.

Control: ISM-0462; Revision: 8; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When a user authenticates to the encryption functionality of IT equipment or media, it is treated in accordance with its original sensitivity or classification until the user deauthenticates from the encryption functionality.

Transporting cryptographic equipment

Transporting cryptographic equipment in a keyed state may expose its keying material to potential compromise. Therefore, if cryptographic equipment is transported in a keyed state, it should be done based on the sensitivity or classification of its keying material.

Control: ISM-0501; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Keyed cryptographic equipment is transported based on the sensitivity or classification of its keying material.

Reporting cryptographic-related cyber security incidents

If cryptographic equipment or associated keying material is compromised, or suspected of being compromised, then the confidentiality and integrity of previous and future communications may also be compromised. In such cases, the cyber security incident should be reported to the chief information security officer, or one of their delegates, as soon as possible after it occurs, and all keying material should be changed.

Control: ISM-0142; Revision: 5; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The compromise or suspected compromise of cryptographic equipment or associated keying material is reported to the chief information security officer, or one of their delegates, as soon as possible after it occurs.

Control: ISM-1091; Revision: 6; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Keying material is changed when compromised or suspected of being compromised.

Further information

Further information on the design and validation of hardware and software cryptographic modules can be found in International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 19790:2025, *Information security, cybersecurity and privacy protection – Security requirements for cryptographic modules* and ISO/IEC 24759:2025, *Information security, cybersecurity and privacy protection – Test requirements for cryptographic modules*.

Further information on United States standards based upon earlier versions of ISO/IEC 19790 and ISO/IEC 24759 can be found in FIPS 140-3, *Security Requirements for Cryptographic Modules* and National Institute of Standards and Technology (NIST) Special Publication (SP) 800-140, *FIPS 140-3 Derived Test Requirements (DTR): CMVP Validation Authority Updates to ISO/IEC 24759*.

Further information on cryptographic key management practices can be found in ASD's *Managing cryptographic keys and secrets* publication.

Further information on cryptographic key management practices for HACE is available from ASD.

Further information on general cryptographic key management practices can be found in NIST SP 800-57 Part 1 Rev. 5, *Recommendation for Key Management: Part 1 – General*.

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Further information on the evaluation of cryptographic modules, including testing requirements, is available as part of the Cryptographic Module Validation Program which is jointly operated by NIST and the Canadian Centre for Cyber Security.

Further information on the evaluation of the implementation of cryptographic algorithms, including testing requirements, is available as part of the Cryptographic Algorithm Validation Program which is jointly operated by NIST and the Canadian Centre for Cyber Security.

Further information on the protection of IT equipment and media can be found in the Department of Home Affairs' *Protective Security Policy Framework*.

Cryptographic algorithms

Context

There is no guarantee of a cryptographic algorithm's resistance to currently unknown attacks. However, the cryptographic algorithms listed in this section have been extensively scrutinised by industry and academic communities in a practical and theoretical setting. Approval for the use of the cryptographic algorithms listed in this section is limited to cases where they are implemented in accordance with these guidelines.

The approved asymmetric cryptographic algorithms are:

- Diffie-Hellman (DH) for agreeing on encryption session keys
- Elliptic Curve Diffie-Hellman (ECDH) for agreeing on encryption session keys
- Elliptic Curve Digital Signature Algorithm (ECDSA) for digital signatures
- Module-Lattice-Based Digital Signature Algorithm (ML-DSA) for digital signatures
- Module-Lattice-Based Key Encapsulation Mechanism (ML-KEM) for encapsulating encryption session keys (and similar keys)
- Rivest-Shamir-Adleman (RSA) for digital signatures and transporting encryption session keys (and similar keys).

The only approved hashing algorithm for general-purpose use is Secure Hashing Algorithm 2 (SHA-2). However, Secure Hashing Algorithm 3 (SHA-3), including its extendable-output functions, is approved exclusively for use within ML-DSA and ML-KEM.

The only approved symmetric cryptographic algorithm is Advanced Encryption Standard (AES).

Where there is a range of key sizes for a cryptographic algorithm, some key sizes are not approved as they are insecure against current attacks or do not provide an adequate safety margin against possible future attacks. For example, advances in integer factorisation methods have rendered some RSA moduli sizes vulnerable and could render other RSA moduli vulnerable in the future.

The minimum targets used for the effective security strength of cryptographic algorithms listed within this section are:

- 112 bits for non-classified data
- 112 bits for OFFICIAL: Sensitive data
- 112 bits for PROTECTED data
- 128 bits for SECRET data
- 192 bits for TOP SECRET data.

Certain key sizes and parameters, such as specific elliptic curves, are preferred to promote interoperability with the United States' National Security Agency's *Commercial National Security Algorithm Suite 2.0*.

High assurance cryptographic algorithms, which are not covered in this section, can be used for the protection of SECRET and TOP SECRET data if they are suitably implemented in HACE. Further information on high assurance cryptographic algorithms can be obtained from ASD.

Using cryptographic algorithms

When encryption is applied to data at rest, it provides an additional layer of defence against unauthorised access by malicious actors. In doing so, it is critical that an AACA or high assurance cryptographic algorithm is used. Furthermore, if cryptographic equipment, applications or libraries implement unapproved cryptographic algorithms, it is possible that these cryptographic algorithms could be used without a human user's knowledge. In combination with an assumed level of security confidence, this can represent a security risk. As such, an organisation should ensure that only AACAs or high assurance cryptographic algorithms can be used by disabling all unapproved cryptographic algorithms (preferred) or by advising human users not to use the unapproved cryptographic algorithms via usage policies.

Control: ISM-1080; Revision: 6; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An AACA or high assurance cryptographic algorithm is used when encrypting data at rest.

Control: ISM-0471; Revision: 9; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Only AACAs or high assurance cryptographic algorithms are used by cryptographic equipment, applications and libraries.

Asymmetric cryptographic algorithms

ECDH is vulnerable to different types of attacks than DH. Consequently, ECDH offers more effective security per bit increase in key size than DH. This leads to smaller data requirements, which in turn means that the elliptic curve variants have become de facto global standards. For reduced data cost, and to promote interoperability, ECDH should be used in preference to DH where possible.

Control: ISM-0994; Revision: 7; Updated: Mar-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
ECDH is used in preference to DH.

Using Diffie-Hellman

A modulus of 2048 bits for correctly implemented DH provides 112 bits of effective security strength, with larger modulus sizes providing more bits of effective security strength.

When DH in a prime field is used, the prime modulus impacts the security of the cryptographic algorithm. The security considerations when creating such a prime modulus can be found in NIST SP 800-56A Rev. 3, along with a collection of commonly used secure moduli.

Taking into account projected technological advances in quantum computing, DH will not be approved beyond 2030.

Control: ISM-0472; Revision: 7; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
When using DH for agreeing on encryption session keys, a modulus of at least 2048 bits is used, preferably 3072 bits.

Control: ISM-1759; Revision: 0; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
When using DH for agreeing on encryption session keys, a modulus of at least 3072 bits is used, preferably 3072 bits.

Control: ISM-1629; Revision: 1; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using DH for agreeing on encryption session keys, a modulus and associated parameters are selected according to NIST SP 800-56A Rev. 3.

Using Elliptic Curve Cryptography

The curve used within an elliptic curve cryptographic algorithm impacts the security of the cryptographic algorithm. As such, only suitable curves from NIST SP 800-186 should be used.

Control: ISM-1446; Revision: 3; Updated: Mar-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using elliptic curve cryptography, a suitable curve from NIST SP 800-186 is used.

Using Elliptic Curve Diffie-Hellman

When identifying a suitable curve from NIST SP 800-186, a base point order and key size of at least 224 bits for correctly implemented ECDH provides 112 bits of effective security strength, with larger key sizes providing more bits of effective security strength. Security of a curve selected from another source cannot be assumed to have the same security using base point order and key size alone.

Taking into account projected technological advances in quantum computing, ECDH will not be approved beyond 2030.

Control: ISM-0474; Revision: 7; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
When using ECDH for agreeing on encryption session keys, a base point order and key size of at least 224 bits is used, preferably the NIST P-384 curve.

Control: ISM-1761; Revision: 0; Updated: Mar-22; Applicable: S; Essential 8: N/A
When using ECDH for agreeing on encryption session keys, NIST P-256, P-384 or P-521 curves are used, preferably the NIST P-384 curve.

Control: ISM-1762; Revision: 0; Updated: Mar-22; Applicable: TS; Essential 8: N/A
When using ECDH for agreeing on encryption session keys, NIST P-384 or P-521 curves are used, preferably the NIST P-384 curve.

Using the Elliptic Curve Digital Signature Algorithm

When identifying a suitable curve from NIST SP 800-186, a base point order and key size of 224 bits for correctly implemented ECDSA provides 112 bits of effective security strength, with larger key sizes providing more bits of effective security strength. Security of a curve selected from another source cannot be assumed to have the same security using base point order and key size alone.

Taking into account projected technological advances in quantum computing, ECDSA will not be approved beyond 2030.

Control: ISM-0475; Revision: 7; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
When using ECDSA for digital signatures, a base point order and key size of at least 224 bits is used, preferably the P-384 curve.

Control: ISM-1763; Revision: 0; Updated: Mar-22; Applicable: S; Essential 8: N/A
When using ECDSA for digital signatures, NIST P-256, P-384 or P-521 curves are used, preferably the NIST P-384 curve.

Control: ISM-1764; Revision: 0; Updated: Mar-22; Applicable: TS; Essential 8: N/A
When using ECDSA for digital signatures, NIST P-384 or P-521 curves are used, preferably the NIST P-384 curve.

Using post-quantum cryptographic algorithms

Post-quantum cryptographic algorithms are more complex than their traditional counterparts. To reduce the risk that vulnerabilities are introduced via implementation errors, approval is given to specific post-quantum cryptographic standards. In doing so, FIPS 204 and FIPS 203 state that other foundational standards must also be adhered to, including the required use of FIPS 140-3 validated cryptographic modules. However, while the use of FIPS 140-3 validated modules is preferred, it is not required.

Control: ISM-1990; Revision: 1; Updated: Mar-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using ML-DSA and ML-KEM, as per FIPS 204 and FIPS 203 respectively, adherence to pre-requisite FIPS 140-3 validation is preferred.

Using the Module-Lattice-Based Digital Signature Algorithm

The effective security strength of ML-DSA has a complex dependency on numerous parameters with different effective security strengths targeted by different standardised parameter sets. The

ML-DSA standard contains three different parameter sets: ML-DSA-44, ML-DSA-65 and ML-DSA-87. The use of ML-DSA-65 and ML-DSA-87 is approved.

When using ML-DSA for digital signing, it may be either hedged or deterministic, with the hedged variant providing effective protection from certain side-channel attacks that apply to the deterministic variant. For this reason, the hedged variant should be used whenever possible. The deterministic variant should not be used unless the nature of the digital signing platform renders the creation of random data infeasible, which is a mandatory step for the hedged variant.

When using ML-DSA for digital signing, signing a message first involves hashing the message using SHAKE128 or SHAKE256. In environments where the message being hashed is large, and the digital signing platform lacks hardware support for SHAKE128 and SHAKE256, pre-hashed variants of ML-DSA might be used to reduce computational overheads. In such cases, pre-hashed variants of ML-DSA take as their input a hash of the message as computed by an alternative, and less computationally expensive, hashing algorithm. In such cases, care should be taken to ensure that an appropriate alternative hashing algorithm is being used, such as a SHA-2 hashing algorithm. In such cases, the hash used should be twice as long as the desired effective security strength. In practice, this requires the use of at least SHA-384 for the pre-hashed variant of ML-DSA-65 and at the use of at least SHA-512 for the pre-hashed variant of ML-DSA-87.

For interoperability and maintainability reasons, ML-DSA-65 will not be approved beyond 2030.

Control: ISM-1991; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using ML-DSA for digital signatures, ML-DSA-65 or ML-DSA-87 is used, preferably ML-DSA-87.

Control: ISM-1992; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using ML-DSA for digital signatures, the hedged variant is used whenever possible.

Control: ISM-1993; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Pre-hashed variants of ML-DSA-65 and ML-DSA-87 are only used when the performance of default variants is unacceptable.

Control: ISM-1994; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When the pre-hashed variants of ML-DSA-65 and ML-DSA-87 are used, at least SHA-384 and SHA-512 respectively are used for pre-hashing.

Using the Module-Lattice-Based Key Encapsulation Mechanism

The effective security strength of ML-KEM has a complex dependency on numerous parameters with different effective security strengths targeted by different standardised parameter sets. The ML-KEM standard contains three different parameter sets: ML-KEM-512, ML-KEM-768 and ML-KEM-1024. The use of ML-KEM-768 and ML-KEM-1024 is approved.

For interoperability and maintainability reasons, ML-KEM-768 will not be approved beyond 2030.

Control: ISM-1995; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using ML-KEM for encapsulating encryption session keys (and similar keys), ML-KEM-768 or ML-KEM-1024 is used, preferably ML-KEM-1024.

Using Rivest-Shamir-Adleman

A modulus of 2048 bits for correctly implemented RSA provides 112 bits of effective security strength, with larger modulus sizes providing more bits of effective security strength.

Taking into account projected technological advances in quantum computing, RSA will not be approved beyond 2030.

Control: ISM-0476; Revision: 8; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
When using RSA for digital signatures, and transporting encryption session keys (and similar keys), a modulus of at least 2048 bits is used, preferably 3072 bits.

Control: ISM-1765; Revision: 1; Updated: Dec-24; Applicable: S, TS; Essential 8: N/A
When using RSA for digital signatures, and transporting encryption session keys (and similar keys), a modulus of at least 3072 bits is used, preferably 3072 bits.

Control: ISM-0477; Revision: 9; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using RSA for digital signatures, and for transporting encryption session keys (and similar keys), a different key pair is used for digital signatures and transporting encryption session keys.

Using Secure Hashing Algorithms

For most purposes, a hashing algorithm with an output size of 224 bits provides 112 bits of effective security strength, with larger output sizes providing more bits of effective security strength.

Only SHA-2 hashing algorithms are approved for general-purpose use. Approval of SHA-3 and extendable-output functions (i.e. SHA3-256, SHA3-512, SHAKE128 and SHAKE256) is restricted to use within internal steps of ML-DSA and ML-KEM.

For interoperability and maintainability reasons, SHA-224 and SHA-256 will not be approved beyond 2030.

Control: ISM-1766; Revision: 1; Updated: Dec-24; Applicable: NC, OS, P; Essential 8: N/A
When using SHA-2 for hashing, an output size of at least 224 bits is used, preferably SHA-384 or SHA-512.

Control: ISM-1767; Revision: 1; Updated: Dec-24; Applicable: S; Essential 8: N/A
When using SHA-2 for hashing, an output size of at least 256 bits is used, preferably SHA-384 or SHA-512.

Control: ISM-1768; Revision: 1; Updated: Dec-24; Applicable: TS; Essential 8: N/A
When using SHA-2 for hashing, an output size of at least 384 bits is used, preferably SHA-384 or SHA-512.

Using symmetric cryptographic algorithms

When using AES, a key size of 128 bits provides 128 bits of effective security strength, with larger key sizes providing more bits of effective security strength.

The use of Electronic Codebook Mode with block ciphers allows repeated patterns in plaintext to appear as repeated patterns in ciphertext. Most plaintext, including written language and formatted files, contains significant repeated patterns. As such, malicious actors can use this to deduce possible meanings of ciphertext. The use of other modes, such as Cipher Block Chaining, Cipher Feedback, Galois/Counter Mode or Output Feedback, can prevent such attacks, although each has different properties that can make them inappropriate for certain use cases. AES is the only approved symmetric cryptographic algorithm.

For interoperability and maintainability reasons, AES-128 and AES-192 will not be approved beyond 2030.

Control: ISM-1769; Revision: 1; Updated: Dec-24; Applicable: NC, OS, P, S; Essential 8: N/A
When using AES for encryption, AES-128, AES-192 or AES-256 is used, preferably AES-256.

Control: ISM-1770; Revision: 0; Updated: Mar-22; Applicable: TS; Essential 8: N/A
When using AES for encryption, AES-192 or AES-256 is used, preferably AES-256.

Control: ISM-0479; Revision: 5; Updated: Dec-21; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Symmetric cryptographic algorithms are not used in Electronic Codebook Mode.

Transitioning to post-quantum cryptography

The consensus model for quantum computing allows for different types of quantum attacks against traditional cryptography. While the direct impact of these quantum attacks varies across different cryptographic algorithms, there is a stark difference in impact between asymmetric cryptographic algorithms and symmetric cryptographic algorithms.

One known quantum attack (using Shor's algorithm) effectively defeats all traditional cryptography that relies upon asymmetric cryptographic algorithms such as DH, ECDH, ECDSA or RSA. The efficiency of this is such that it is infeasible to securely use these AACAs in the presence of a cryptographically relevant quantum computer (CRQC). While a CRQC does not currently exist, the trajectory of technological advances in quantum computing means that these AACAs will need to be phased out in favour of alternative AACAs that offer greater protection. As such, the development or procurement of new cryptographic equipment, applications and libraries, which are intended to be used beyond 2030, should be undertaken with the goal of supporting ASD-approved post-quantum cryptographic algorithms by 2030.

The impact of quantum attacks on hashing algorithms and symmetric cryptographic algorithms, such as SHA-2 and AES, is unlikely to be felt for some time. However, for interoperability reasons, the design and provision of new cryptographic equipment, applications and libraries, which are intended to be used beyond 2030, should support SHA-384, SHA-512 and AES-256.

Control: ISM-2073; Revision: 0; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A post-quantum cryptography transition plan is developed, implemented and maintained.

Control: ISM-1917; Revision: 3; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The development and procurement of new cryptographic equipment, applications and libraries ensures support for the use of ML-DSA-87, ML-KEM-1024, SHA-384, SHA-512 and AES-256 by no later than 2030.

Post-quantum traditional hybrid schemes

A post-quantum traditional hybrid scheme is a multi-algorithm scheme where at least one cryptographic algorithm is a post-quantum cryptographic algorithm (e.g. ML-KEM) and at least one cryptographic algorithm is a traditional cryptographic algorithm (e.g. RSA). Generally, such schemes have the advantage of the security offered by the traditional cryptographic algorithm if the post-quantum cryptographic algorithm is vulnerable to an implementation flaw or new attack. This advantage comes at the cost of increased complexity, making maintenance, analysis and secure implementation more difficult, as well as having greater computational and bandwidth overheads.

The use of post-quantum traditional hybrid schemes is not recommended; however, it is not prohibited. If such schemes are to be used, at least one of the post-quantum or traditional cryptographic algorithms, or both, should be an AACA. It is important to note though, that in the presence of a CRQC, the security of such schemes is reduced to that provided by the post-quantum cryptographic algorithm. As such, there is no practical value in the use of such schemes in the presence of a CRQC. An organisation choosing to implement a post-quantum traditional hybrid scheme should also keep in mind the eventual additional cost of transitioning to a pure post-quantum scheme in the future.

Control: ISM-1996; Revision: 0; Updated: Dec-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When a post-quantum traditional hybrid scheme is used, either the post-quantum cryptographic algorithm, the traditional cryptographic algorithm or both are AACAs.

Further information

Further information on planning for the transition to post-quantum cryptography can be found in ASD's *Planning for post-quantum cryptography* and *Post-quantum questions to ask your vendors* publications.

Further information on post-quantum traditional hybrid schemes can be found in the United Kingdom's National Cyber Security Centre's *Next steps in preparing for post-quantum cryptography* guidance.

Further information on how to combine the different components of a post-quantum traditional hybrid scheme used for key encapsulation can be found in NIST SP 800-56C Rev. 2, *Recommendation for Key-Derivation Methods in Key-Establishment Schemes*. This publication does not pertain to post-quantum traditional hybrid schemes used for digital signatures.

Cryptographic protocols

Context

There is no guarantee of a cryptographic protocol's resistance to currently unknown attacks. However, the cryptographic protocols listed in this section have been extensively scrutinised by industry and academic communities in a practical and theoretical setting. Approval for the use of the cryptographic protocols listed in this section is limited to cases where they are implemented in accordance with these guidelines.

The AACPs are:

- Internet Protocol Security (IPsec)
- Media Access Control Security
- OpenPGP Message Format
- Secure Shell (SSH)
- Secure/Multipurpose Internet Mail Extensions (S/MIME)
- Transport Layer Security (TLS)
- Wi-Fi Protected Access 2
- Wi-Fi Protected Access 3.

High assurance cryptographic protocols, which are not covered in this section, can be used for the protection of SECRET and TOP SECRET data if they are suitably implemented in HACE. Further information on high assurance cryptographic protocols can be obtained from ASD.

Using cryptographic protocols

When encryption is applied to data in transit, it provides an additional layer of defence against unauthorised access or manipulation by malicious actors. In doing so, it is critical that an AACP or high assurance cryptographic protocol is used. Furthermore, if cryptographic equipment, applications or libraries implement unapproved cryptographic protocols, it is possible that these cryptographic protocols could be used without a human user's knowledge. In combination with an assumed level of security confidence, this can represent a security risk. As such, an organisation should ensure that only AACPs or high assurance cryptographic protocols can be used by disabling all unapproved cryptographic protocols (preferred) or by advising human users not to use the unapproved cryptographic protocols via usage policies.

Control: ISM-0469; Revision: 7; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An AACP or high assurance cryptographic protocol is used when encrypting data in transit.

Control: ISM-0481; Revision: 8; Updated: Sep-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Only AACPs or high assurance cryptographic protocols are used by cryptographic equipment, applications and libraries.

Further information

Further information on AACPs can be found in the following sections of these guidelines.

Further information on the use of Media Access Control Security can be found in the 'Wired networks' section of the *Guidelines for networking*.

Further information on the use of Wi-Fi Protected Access 2 and Wi-Fi Protected Access 3 can be found in the 'Wireless networks' section of the *Guidelines for networking*.

Internet Protocol Security

Context

When using IT equipment or applications that implement IPsec, security controls for using AACAs and AACPs in the 'Cryptographic algorithms' and 'Cryptographic protocols' sections of these guidelines will also need to be consulted.

Mode of operation

IPsec can be operated in tunnel mode or transport mode. The tunnel mode of operation is preferred as it provides full encapsulation of IP packets while the transport mode of operation only encapsulates the payload of IP packets.

Control: ISM-0494; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Tunnel mode is used for IPsec connections; however, if using transport mode, an IP tunnel is used.

Protocol selection

IPsec contains two major protocols, the Authentication Header (AH) protocol and the Encapsulating Security Payload (ESP) protocol. To provide a secure virtual private network style connection, authentication and encryption are needed. While the AH and ESP protocols can provide authentication, for the IP packet and the payload respectively, only the ESP protocol can provide encryption.

As the combined use of the AH protocol and the ESP protocol is not supported by Internet Key Exchange (IKE) version 2, the ESP protocol should be used for authentication and encryption of IPsec connections.

Control: ISM-0496; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The ESP protocol is used for authentication and encryption of IPsec connections.

Key exchange

There are several methods for establishing shared keying material for IPsec connections, including manual keying and the IKE protocol. As the IKE protocol addresses several security risks associated

with manual keying, it is the preferred method for key establishment. As IKE version 1 has been deprecated, IKE version 2 should be used.

Control: ISM-1233; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IKE version 2 is used for key exchange when establishing IPsec connections.

Encryption algorithms

The only approved encryption algorithm for IPsec connections is AES. IKE version 2 supports the use of AES with Cipher Block Chaining, Counter Mode, Counter with Cipher Block Chaining Message Authentication Code, and Galois/Counter Mode. However, supported modes may vary between different cryptographic equipment, applications and libraries.

Control: ISM-1771; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
AES is used for encrypting IPsec connections, preferably ENCR_AES_GCM_16.

Pseudorandom function

IKE version 2 requires the use of a PRF to generate random data for cryptographic operations. The approved hashing algorithms that can be used for the PRF are HMAC-SHA256, HMAC-SHA384 and HMAC-SHA512.

For interoperability and maintainability reasons, HMAC-SHA256 will not be approved beyond 2030.

Control: ISM-1772; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
PRF_HMAC_SHA2_256, PRF_HMAC_SHA2_384 or PRF_HMAC_SHA2_512 is used for IPsec connections, preferably PRF_HMAC_SHA2_512.

Integrity algorithms

The approved integrity algorithms for IPsec connections are HMAC-SHA256, HMAC-SHA384 and HMAC-SHA512. However, if using AES with Galois/Counter Mode as the encryption algorithm, it can also be used for authentication purposes. In such cases, the integrity algorithm should be configured as NONE.

For interoperability and maintainability reasons, HMAC-SHA256 will not be approved beyond 2030.

Control: ISM-0998; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
AUTH_HMAC_SHA2_256_128, AUTH_HMAC_SHA2_384_192, AUTH_HMAC_SHA2_512_256 or NONE (only with AES-GCM) is used for authenticating IPsec connections, preferably NONE.

Diffie-Hellman groups

A sufficiently large DH modulus provides greater security for key exchanges when establishing IPsec connections.

Taking into account projected technological advances in quantum computing, DH and ECDH will not be approved beyond 2030.

Control: ISM-0999; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
DH or ECDH is used for key establishment of IPsec connections, preferably 384-bit random ECP group, 3072-bit MODP Group or 4096-bit MODP Group.

Security association lifetimes

Using a security association lifetime of less than four hours (14400 seconds) for IKE version 2 can provide a balance between security and usability.

Control: ISM-0498; Revision: 4; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
A security association lifetime of less than four hours (14400 seconds) is used for IPsec connections.

Perfect Forward Secrecy

Using PFS reduces the impact of the compromise of a security association.

Control: ISM-1000; Revision: 4; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
PFS is used for IPsec connections.

Secure Shell

Context

When using IT equipment or applications that implement SSH, security controls for using AACAs and AACPs in the 'Cryptographic algorithms' and 'Cryptographic protocols' sections of these guidelines will also need to be consulted.

Configuring Secure Shell

SSH version 1 was found to have multiple vulnerabilities and was subsequently replaced by SSH version 2. As such, an organisation implementing SSH should disable the use of SSH version 1. In addition, several security risks exist when SSH is configured in an insecure manner. To mitigate these security risks, SSH should be configured as per the settings below.

The settings below are based on OpenSSH. An organisation using other implementations of SSH should adapt these settings to suit their SSH implementation.

Control: ISM-1506; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The use of SSH version 1 is disabled for SSH connections.

Control: ISM-0484; Revision: 7; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The SSH daemon is configured to:

- *only listen on the required interfaces (ListenAddress xxx.xxx.xxx.xxx)*

- *have a suitable login banner (Banner x)*
- *have a login authentication timeout of no more than 60 seconds (LoginGraceTime 60)*
- *disable host-based authentication (HostbasedAuthentication no)*
- *disable rhosts-based authentication (IgnoreRhosts yes)*
- *disable the ability to log in directly as root (PermitRootLogin no)*
- *disable empty passwords (PermitEmptyPasswords no)*
- *disable connection forwarding (AllowTCPForwarding no)*
- *disable gateway ports (GatewayPorts no)*
- *disable X11 forwarding (X11Forwarding no).*

Authentication mechanisms

As public key-based authentication schemes offer stronger authentication than password-based authentication schemes, due to being much less susceptible to brute-force attacks, they should be used for SSH connections. Furthermore, to protect SSH private keys, access to such keys should be protected via the use of passwords or key encryption keys.

Control: ISM-0485; Revision: 3; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Public key-based authentication is used for SSH connections.

Control: ISM-1449; Revision: 2; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SSH private keys are protected with a password or a key encryption key.

Automated remote access

If using logins without a password for automated purposes, several security risks may arise, specifically:

- if access from unknown Internet Protocol (IP) addresses is not restricted, malicious actors could automatically authenticate to systems without needing to know any passwords
- if port forwarding is not disabled, or it is not configured securely, access may be gained to forwarded ports, creating a communication channel between malicious actors and a host
- if agent credential forwarding is enabled, malicious actors could connect to the stored authentication credentials and use them to connect to other trusted hosts, or even intranet hosts if port forwarding has been allowed as well
- if X11 forwarding is not disabled, malicious actors could gain control of displays as well as keyboard and mouse control functions
- if console access is allowed, every user who logs in to the console could run applications that are normally restricted to authenticated users.

To assist in mitigating these security risks, it is essential that the 'forced command' option is used to specify what command is executed and parameter checking is enabled.

Control: ISM-0487; Revision: 6; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When using logins without a password for SSH connections, the following are disabled:

- *access from IP addresses that do not require access*
- *port forwarding*
- *agent credential forwarding*
- *X11 forwarding*
- *console access.*

Control: ISM-0488; Revision: 5; Updated: Dec-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If using remote access without the use of a password for SSH connections, the 'forced command' option is used to specify what command is executed and parameter checking is enabled.

SSH-agent

SSH-agent and similar key caching applications manage private keys stored on workstations and servers. Once a private key has been unlocked and loaded into a key cache, subsequent access to remote systems can occur without the private key being unlocked again. When such functionality is used, screen locks, where applicable, and expiring cached private keys can be used to ensure that private keys are not available for use for extended periods.

Control: ISM-0489; Revision: 7; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When SSH-agent or similar key caching applications are used, cached private keys have a maximum lifetime of four hours and, where applicable, screen locks are used on workstations and servers.

Further information

Further information on configuring OpenSSH is available from the OpenSSH project.

Secure/Multipurpose Internet Mail Extensions

Context

When using IT equipment or applications that implement S/MIME, security controls for using AACAs and AACPs in the 'Cryptographic algorithms' and 'Cryptographic protocols' sections of these guidelines will also need to be consulted.

Configuring Secure/Multipurpose Internet Mail Extensions

S/MIME version 2.0 required the use of weaker cryptography than approved for use in these guidelines. As such, S/MIME version 3.0 was the first version to be approved for use as an AACP.

Control: ISM-0490; Revision: 4; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Versions of S/MIME earlier than S/MIME version 3.0 are not used for S/MIME connections.

Transport Layer Security

Context

When using IT equipment or applications that implement TLS, security controls for using AACAs and AACPs in the 'Cryptographic algorithms' and 'Cryptographic protocols' sections of these guidelines will also need to be consulted.

Configuring Transport Layer Security

The terms Secure Sockets Layer and TLS have traditionally been used interchangeably. However, Secure Sockets Layer and TLS version 1.2 and earlier are no longer considered suitable for use as an AACP. As such, an organisation implementing TLS should use only the latest version of TLS (i.e. TLS version 1.3). In addition, several security risks exist when TLS is configured in an insecure manner. To mitigate these security risks, TLS clients and servers should be configured to enforce secure settings at the time of the TLS handshake. In situations where this is not possible, such as for some multi-tenancy environments (e.g. content delivery networks), additional security controls will need to be implemented. For example, by further restricting the permitted TLS configuration within Layer 7 authorisation logic.

Control: ISM-1139; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Only the latest version of TLS is used for TLS connections.

Control: ISM-1369; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
AES-GCM is used for encryption of TLS connections.

Control: ISM-1370; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Only server-initiated secure renegotiation is used for TLS connections.

Control: ISM-1372; Revision: 4; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The ephemeral variant of DH or ECDH is used for key establishment of TLS connections.

Control: ISM-1373; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Anonymous DH is not used for TLS connections.

Control: ISM-1374; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SHA-2-based certificates are used for TLS connections.

Control: ISM-1375; Revision: 4; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
SHA-2 is used for the Hash-based Message Authentication Code (HMAC) and pseudorandom function (PRF) for TLS connections.

Control: ISM-1553; Revision: 1; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
TLS compression is disabled for TLS connections.

Control: ISM-1453; Revision: 1; Updated: Sep-18; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Perfect Forward Secrecy (PFS) is used for TLS connections.

Further information

Further information on implementing TLS can be found in ASD's *Implementing certificates, TLS, HTTPS and opportunistic TLS* publication.

Further information on TLS filtering in gateways can be found in the 'Web content filters' section of the *Guidelines for gateways*.

Guidelines for gateways

Gateways

Context

Gateways securely manage data flows between connected networks from different security domains. In doing so, gateways take on the highest sensitivity or classification of connected security domains.

This section describes security controls applicable to all types of gateways. Additional sections of these guidelines should also be consulted depending on the types of gateways being deployed and the security domains involved. For example, the 'Cross domain solutions' section of these guidelines should be consulted for gateways between different security domains where at least one security domain is classified SECRET or TOP SECRET.

Personnel involved in the planning, design, implementation or assessment of gateways should also refer to the Australian Signals Directorate's (ASD) *Gateway security guidance package* and, where applicable, the Department of Home Affairs' *Protective Security Policy Framework* and its associated *Australian Government Gateway Security Standard*.

Implementing gateways

Gateways are critical for an organisation to reduce the security risks associated with providing external parties with access to their networks. In doing so, it is important that gateways are used not only between an organisation's networks and public network infrastructure, but also between an organisation's networks that belong to different security domains and between an organisation's networks and other organisations' networks that are connected via means other than public network infrastructure.

When implementing gateways between an organisation's networks and public network infrastructure, an organisation should place any services that external parties require access to within a demilitarised zone. This can mitigate security risks for an organisation when hosting such services in an internet-accessible manner.

Finally, in architecting gateways, it is important that they only allow explicitly authorised data flows. In support of this, gateways should inspect and filter data flows at the transport and above network layers. Furthermore, gateways should be capable of performing ingress traffic filtering to detect and prevent Internet Protocol (IP) source address spoofing.

Control: ISM-0628; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Gateways are implemented between networks belonging to different security domains.

Control: ISM-0637; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Gateways implement a demilitarised zone if external parties require access to an organisation's services.

Control: ISM-0631; Revision: 7; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Gateways only allow explicitly authorised data flows.

Control: ISM-1192; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Gateways inspect and filter data flows at the transport and above network layers.

Control: ISM-1427; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Gateways perform ingress traffic filtering to detect and prevent IP source address spoofing.

System administrators for gateways

In identifying suitable system administrators for gateways, it is important that individuals comply with any citizenship requirements, undergo appropriate employment screening, and where necessary hold an appropriate security clearance, based on the sensitivity or classification of gateways. For example, all systems administrators for gateways between OFFICIAL: Sensitive and PROTECTED networks will need to hold baseline security clearances.

In addition, when creating privileged user accounts for performing administrative activities, it is important that the principle of least privilege is followed. In turn, this should be supported by the principle of separation of duties. Adhering to these two principles can ensure that system administrators for gateways are not given enough privileges to abuse gateways on their own.

Finally, providing system administrators for gateways with formal training on the operation and management of gateways will ensure that they are fully aware of, and accept, their roles and responsibilities. In doing so, formal training should be conducted through tailored privileged user training.

Control: ISM-1520; Revision: 3; Updated: Sep-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System administrators for gateways undergo appropriate employment screening, and where necessary hold an appropriate security clearance, based on the sensitivity or classification of gateways.

Control: ISM-0613; Revision: 6; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
System administrators for gateways that connect to Australian Eyes Only or Releasable To networks are Australian nationals.

Control: ISM-1773; Revision: 0; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
System administrators for gateways that connect to Australian Government Access Only networks are Australian nationals or seconded foreign nationals.

Control: ISM-0611; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System administrators for gateways are assigned the minimum privileges required to perform their duties.

Control: ISM-0616; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Separation of duties is implemented in performing administrative activities for gateways.

Control: ISM-0612; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
System administrators for gateways are formally trained on the operation and management of gateways.

System administration of gateways

In performing administrative activities for gateways, it is important that they are conducted via a secure path isolated from all connected networks. In doing so, this will minimise threats should a connected network be compromised by malicious actors. Furthermore, where gateways exist between networks belonging to different security domains, any shared components should be managed by system administrators for the higher security domain, alternatively, it may be more appropriate to use system administrators from a mutually agreed upon third party.

Control: ISM-1774; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Gateways are managed via a secure path isolated from all connected networks.

Control: ISM-0629; Revision: 5; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
For gateways between networks belonging to different security domains, any shared components are managed by system administrators for the higher security domain or by system administrators from a mutually agreed upon third party.

Authenticating to networks accessed via gateways

Ensuring users and information technology (IT) equipment are authenticated to other networks accessed via gateways can reduce the likelihood of unauthorised access.

Control: ISM-0619; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Users authenticate to other networks accessed via gateways.

Control: ISM-0622; Revision: 7; Updated: Jun-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
IT equipment authenticates to other networks accessed via gateways.

Border Gateway Protocol routing security

Resource Public Key Infrastructure (RPKI) uses asymmetric cryptography to authenticate routing data on the internet. This allows an organisation, particularly a telecommunications carrier or cloud service provider, to verify routing data they receive, transmit and process to determine routing calculations for internet traffic. By using RPKI, an organisation may reduce Border Gateway Protocol (BGP)-related cyber threats, such as some types of denial-of-service attacks, accidental or deliberate rerouting of internet traffic, and opportunities for the undermining of IP address-based reputational services. RPKI Route Origin Authorization (ROA) records, which describe routes in terms of network/prefix and Autonomous Systems from which they are expected to originate, should be configured for the public IP addresses controlled by, or used by, an organisation. ROA records should also be configured for the unannounced IP address space controlled by an organisation.

Route Origin Validation (ROV) is a mechanism that enables the validation of ROA covered IP addresses received via BGP. For increased BGP security, ROV should be implemented with all routing data received from transit providers being filtered. In doing so, any routes received that are invalid, or have multiple transit providers where one of them does not implement ROV, should be rejected or deprioritised. In cases where an organisation chooses to deprioritise invalid routes to meet specific operational requirements, as opposed to rejecting them, such decisions should be regularly reviewed, with valid routes always being prioritised over invalid routes.

Finally, an organisation should consider the inclusion of routing security measures as part of procurement and contract requirements to ensure such functionality is available for their use.

Control: ISM-1783; Revision: 0; Updated: Jun-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Public IP addresses controlled by, or used by, an organisation are signed by valid ROA records.

Control: ISM-2018; Revision: 0; Updated: Mar-25; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Routes for RPKI-registered IP addresses that are advertised from invalid Autonomous Systems, or that are longer than allowed, are rejected or deprioritised by routers that exchange routes via BGP.

Gateway event logging

Centrally logging and analysing security-relevant events, including configuration changes, for gateways can assist in monitoring the security posture of gateways, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-0634; Revision: 11; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Security-relevant events for gateways are centrally logged, including:

- *data packets and data flows permitted through gateways*
- *data packets and data flows attempting to leave gateways*
- *real-time alerts for attempted intrusions.*

Assessment of gateways

Testing of gateways following configuration changes, and at regular intervals no more than six months apart, can assist in validating that gateways conform to expected security configurations. In addition, gateways will need to undergo regular security control assessments by an Infosec Registered Assessor Program (IRAP) assessor, or an ASD assessor (or their delegate), to determine their security posture and security risks associated with their use. Following an initial security control assessment, subsequent security control assessments should focus on any new services that are being offered as well as any security-related changes that have occurred since the previous security control assessment.

Control: ISM-1037; Revision: 7; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Gateways undergo testing following configuration changes, and at regular intervals no more than six months apart, to validate that they conform to expected security configurations.

Control: ISM-0100; Revision: 12; Updated: Mar-25; Applicable: NC, OS, P, S; Essential 8: N/A
Non-classified, OFFICIAL: Sensitive, PROTECTED and SECRET gateways undergo an IRAP assessment, using the latest release of the ISM available prior to the beginning of the IRAP assessment (or a subsequent release), at least every 24 months.

Control: ISM-2019; Revision: 1; Updated: Sep-26; Applicable: TS; Essential 8: N/A
TOP SECRET gateways undergo a security control assessment by ASD assessors (or their delegates), using the latest release of the ISM available prior to the beginning of the assessment (or a subsequent release), at least every 24 months.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on the procurement of outsourced services can be found in the 'Managed services and cloud services' section of the *Guidelines for procurement and outsourcing*.

Further information on designing, configuring and managing networks can be found in the 'Network design and configuration' section of the *Guidelines for networking*.

Further information on privileged access to systems can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on cyber security awareness training can be found in the 'Cyber security awareness training' section of the *Guidelines for personnel security*.

Further information on authenticating users can be found in the 'Identity and access management' section of the *Guidelines for system access*.

Further information on authenticating IT equipment can be found in the 'Network design and configuration' section of the *Guidelines for networking*.

Further information on RPKI and ROA records is available from the Asia Pacific Network Information Centre.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on event logging for network devices in gateways can also be found in ASD's *Priority logs for SIEM ingestion: Practitioner guidance* publication.

Further information on the purpose of IRAP is available from ASD.

Cross domain solutions

Context

A cross domain solution (CDS) is a system comprised of security-enforcing functions tailored to mitigate specific security risks associated with accessing or transferring data between different security domains. CDSs may be an integrated appliance or, more commonly, composed of discrete technologies or sub-systems, with each sub-system consisting of hardware or software components.

This section defines two types of CDSs, Transfer CDSs and Access CDSs. Transfer CDSs facilitate the transfer of data in one direction (unidirectional) or multiple directions (bi-directional) between different security domains. In comparison, Access CDSs provide users with access to multiple security domains from a single device; however, they do not allow users to move data between the different security domains.

This section describes security controls applicable to CDSs and extends the 'Gateways' section of these guidelines. Additional sections of these guidelines should also be consulted depending on the types of CDSs being deployed.

Personnel involved in the planning, design, implementation or assessment of CDSs should also refer to ASD's *Introduction to Cross Domain Solutions* and *Fundamentals of Cross Domain Solutions* publications.

Implementing cross domain solutions

As there are significant security risks associated with connecting SECRET or TOP SECRET networks to other networks in different security domains, CDSs will need to be implemented.

Control: ISM-0626; Revision: 6; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
CDSs are implemented between SECRET or TOP SECRET networks and any other networks belonging to different security domains.

Consultation on cross domain solutions

As CDSs can be complex to implement and manage securely, it is critical that when an organisation is planning, designing, implementing or introducing additional connectivity to CDSs that ASD is consulted and any directions provided by ASD are complied with.

Control: ISM-0597; Revision: 8; Updated: Sep-23; Applicable: S, TS; Essential 8: N/A
When planning, designing, implementing or introducing additional connectivity to CDSs, ASD is consulted and any directions provided by ASD are complied with.

Separation of data flows

To ensure that data flows are appropriately controlled within CDSs, it is important that isolated upward and downward network paths are implemented. This, in turn, should be supported by independent security-enforcing functions and protocol breaks at each network layer.

Control: ISM-0635; Revision: 7; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
CDSs implement isolated upward and downward network paths.

Control: ISM-1522; Revision: 3; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
CDSs implement independent security-enforcing functions for upward and downward network paths.

Control: ISM-1521; Revision: 3; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
CDSs implement protocol breaks at each network layer.

Cross domain solution use

To assist in preventing cyber security incidents, it is important that human users know how to use CDSs securely. This can be achieved by training human users on the secure use of CDSs before access is granted.

Control: ISM-0610; Revision: 9; Updated: Sep-26; Applicable: S, TS; Essential 8: N/A
Human users are trained on the secure use of CDSs before access is granted.

Cross domain solution event logging

CDSs should have comprehensive event logging capabilities to support attribution of activities to users and ensure accountability of human users for activities they undertake. Furthermore, effective security monitoring practices can increase the likelihood that operational failures will be detected.

In addition, centrally logging and analysing security-relevant events, including configuration changes, for CDSs can assist in monitoring the security posture of CDSs, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-0670; Revision: 7; Updated: Sep-24; Applicable: S, TS; Essential 8: N/A
Security-relevant events for CDSs are centrally logged.

Control: ISM-1523; Revision: 1; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
A sample of security-relevant events relating to data transfer policies are taken at least every three months and assessed against security policies for CDSs to identify any operational failures.

Further information

Further information on cyber supply chain risk management can be found in the ‘Cyber supply chain risk management’ section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Further information on designing, configuring and managing networks can be found in the 'Network design and configuration' section of the *Guidelines for networking*.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Further information on event logging for network devices in CDSs can also be found in ASD's *Priority logs for SIEM ingestion: Practitioner guidance* publication.

Further information on cyber security awareness training can be found in the 'Cyber security awareness training' section of the *Guidelines for personnel security*.

Firewalls

Using firewalls

When implementing gateways between an organisation's networks and public network infrastructure, an organisation should implement firewalls to protect themselves from intrusions that may originate from the public network infrastructure. In addition, when an organisation's networks connect to another organisation's networks, both organisations should implement independent firewalls to protect themselves from intrusions that may originate from each other's networks. This requirement may not be necessary in cases where shared network infrastructure is used only as a transport medium and encryption is applied to all network traffic.

Control: ISM-1528; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Evaluated firewalls are used between an organisation's networks and public network infrastructure.

Control: ISM-0639; Revision: 9; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Evaluated firewalls are used between networks belonging to different security domains.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Web application firewalls

Using web application firewalls

When using a web application firewall (WAF), care should be taken with their configuration to ensure that the IP addresses of an organisation's web servers (referred to as origin servers) are not identifiable by malicious actors, as knowledge of origin server IP addresses could allow for protections provided by a WAF to be bypassed. Additionally, appropriate security controls should be applied to only enable communication between origin servers, the WAF and authorised management networks.

Control: ISM-1862; Revision: 0; Updated: Jun-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
If using a WAF, disclosing the IP addresses of web servers under an organisation's control (referred to as origin servers) is avoided and access to the origin servers is restricted to the WAF and authorised management networks.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Diodes

Using diodes

Diodes enforce one-way data flows, making it more difficult for malicious actors to use the same network path to launch an intrusion and exfiltrate data afterwards. As such, diodes should be used for controlling the data flow of unidirectional gateways.

Control: ISM-0643; Revision: 7; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Evaluated diodes are used for controlling the data flow of unidirectional gateways between an organisation's networks and public network infrastructure.

Control: ISM-0645; Revision: 7; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
Evaluated diodes used for controlling the data flow of unidirectional gateways between SECRET or TOP SECRET networks and public network infrastructure complete a high assurance evaluation.

Control: ISM-1157; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Evaluated diodes are used for controlling the data flow of unidirectional gateways between networks.

Control: ISM-1158; Revision: 6; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
Evaluated diodes used for controlling the data flow of unidirectional gateways between SECRET or TOP SECRET networks and any other networks complete a high assurance evaluation.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Web proxies

Using web proxies

Web proxies are a key component in enforcing web usage policies and preventing cyber security incidents.

Control: ISM-0260; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
All web access, including that by internal servers, is conducted through web proxies.

Web proxy event logging

Centrally logging and analysing web proxy events can assist in monitoring the security posture of networks, detecting malicious behaviour and contributing to investigations following cyber security incidents.

Control: ISM-0261; Revision: 6; Updated: Dec-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
The following details are centrally logged for websites accessed via web proxies:

- *web address*
- *date and time*
- *user*
- *amount of data uploaded and downloaded*
- *internal and external IP addresses.*

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on event logging can be found in the 'Security monitoring' section of the *Guidelines for security assurance*.

Web content filters

Using web content filters

Effective web content filters can greatly reduce the likelihood of malicious code, or other inappropriate content, being accessed by users. Furthermore, web content filters can disrupt or prevent malicious actors from communicating with their malicious code if they manage to deploy it on an organisation's networks.

Control: ISM-0963; Revision: 7; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Web content filtering is implemented to filter potentially harmful web-based content.

Control: ISM-0961; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Client-side active content is restricted by web content filters to an organisation-approved list of domain names.

Control: ISM-1237; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Web content filtering is applied to outbound web traffic where appropriate.

Transport Layer Security filtering

As encrypted Hypertext Transfer Protocol Secure connections can bypass traditional web content filtering techniques, an organisation should implement Transport Layer Security (TLS) inspection. However, an organisation may choose to allow some web traffic, such as that for internet banking, to go uninspected to protect privacy.

Control: ISM-0263; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
TLS traffic communicated through gateways is decrypted and inspected.

Allowing and blocking access to domain names

Defining an organisation-approved list of domain names, and blocking all others, removes one of the most common data exfiltration paths used by malicious actors. In doing so, even a relatively permissive list of allowed domain names offers better security than relying solely on a list of malicious domain names.

Furthermore, in cases where an organisation chooses to implement a relatively permissive list of allowed domain names, or list of website categories, security risks can be further mitigated by blocking dynamic domain names, or domain names that can be registered anonymously for free, as these are often used by malicious actors due to their lack of attribution. Finally, as human users rarely have a requirement to access websites via their IP addresses instead of their domain names, the presence of such activities could indicate malicious code attempting to communicate with malicious actors' command and control infrastructure and should be blocked.

Control: ISM-0958; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
An organisation-approved list of domain names, or list of website categories, is implemented for all

Hypertext Transfer Protocol and Hypertext Transfer Protocol Secure traffic communicated through gateways.

Control: ISM-1236; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Malicious domain names, dynamic domain names and domain names that can be registered anonymously for free are blocked by web content filters.

Control: ISM-1171; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Attempts to access websites through their IP addresses instead of their domain names are blocked by web content filters.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on content filtering techniques can be found in the 'Content filtering' section of these guidelines.

Further information and examples of client-side JavaScript controls are available from the NoScript project.

Content filtering

Context

The following content filtering techniques should be considered as part of an organisation's content filtering implementation for gateways and CDSs:

- **Antivirus scans:** Scans files for viruses and other malicious code.
- **Automated dynamic analysis:** Analyses executable files run in a sandbox to detect suspicious behaviour.
- **File extension checks:** Checks file extensions to determine purported file types.
- **File format checks:** Checks files conform to defined file format specifications.
- **File type checks:** Checks file headers to determine actual file types.
- **Keyword checks:** Checks files for keywords that could indicate undesirable content.
- **Metadata checks:** Checks files for metadata that should be removed.
- **Protective marking checks:** Checks files for protective markings that may indicate undesirable content.
- **Manual inspections:** Involves the manual inspection of files for suspicious or undesirable content that an automated system may miss, which is particularly important for multimedia and content rich files.

Performing content filtering

Content filters perform an important function within gateways and CDSs by reducing the likelihood of unauthorised content or malicious code from entering or exiting networks. In performing content filtering checks, some content will be readily identifiable as malicious, or cannot be inspected, while other content, such as active content, may be deemed suspicious depending on what is considered normal behaviour for content passing through gateways and CDSs within an organisation. Finally, when content filters are used by CDSs, their assurance requirements necessitate rigorous security testing to ensure they perform as expected and cannot be bypassed.

Control: ISM-0659; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files imported or exported via gateways or CDSs undergo content filtering checks.

Control: ISM-0651; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files identified by content filtering checks as malicious, or that cannot be inspected, are blocked.

Control: ISM-0652; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files identified by content filtering checks as suspicious are quarantined until reviewed and subsequently approved or not approved for release.

Control: ISM-1524; Revision: 2; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
Content filters used by CDSs undergo rigorous security testing to ensure they perform as expected and cannot be bypassed.

Encrypted files

As encryption can be used to bypass content filtering checks, this poses a security risk in that malicious code could enter networks, or data could be exfiltrated from networks, undetected. In addition, encrypted files could mask data at a higher classification than that authorised to pass through gateways or CDSs, which could result in a data spill. As such, encrypted files should be decrypted to undergo content filtering checks.

Where a requirement to preserve the confidentiality of encrypted files exists, an organisation may also consider a dedicated system to enable encrypted files to be decrypted in an appropriately secure environment before being subjected to all applicable content filtering checks.

Control: ISM-1293; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Encrypted files imported or exported via gateways or CDSs are decrypted to undergo content filtering checks.

Archive files

Archive files can be used to bypass content filtering checks if content filters do not handle such files correctly. Ensuring content filters recognise archive files will ensure the embedded files they contain are subject to the same content filtering checks as un-archived files.

Archive files can be constructed in a manner that can result in a denial of service to content filters due to processor, memory or disk space exhaustion. To limit the likelihood of such situations, content filters can specify resource constraints while unpacking archive files. If these constraints are exceeded, content filtering checks should be terminated.

Control: ISM-1289; Revision: 3; Updated: Jun-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Archive files imported or exported via gateways or CDSs are unpacked to undergo content filtering checks.

Control: ISM-1290; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Archive files are unpacked in a controlled manner to ensure content filter performance or availability is not adversely affected.

Antivirus scanning

Antivirus scanning can be used to detect malicious files. In doing so, multiple different scanning engines should be used to increase the likelihood of identifying any malicious files.

Control: ISM-1288; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files imported or exported via gateways or CDSs undergo antivirus scanning using multiple different scanning engines.

Automated dynamic analysis

Analysing executable files in a sandbox can be an effective method to detect suspicious behaviour upon file execution, such as network traffic, creation or modification of files, or system configuration changes.

Control: ISM-1389; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Executable files imported via gateways or CDSs are automatically executed in a sandbox to detect any suspicious behaviour.

Allowing specific content types

Creating and enforcing an organisation-approved list of allowed file types can reduce the attack surface of networks. For example, a content filter in an email gateway might only allow Microsoft Office files and Portable Document Format (PDF) files.

Control: ISM-0649; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files imported or exported via gateways or CDSs are filtered for allowed file types.

Content validation

Content validation, such as file format checks, aims to ensure that files conform to defined file format specifications. In performing content validation, any malformed content may indicate the presence of unauthorised content or malicious code, such as that designed to exploit known vulnerabilities in operating systems and applications.

Control: ISM-1284; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files imported or exported via gateways or CDSs undergo content validation.

Content checking

Content checking, such as keyword checks, metadata checks and protective marking checks, aims to ensure that files do not contain any content that could cause a data spill or facilitate unauthorised export of data from systems.

Control: ISM-1965; Revision: 0; Updated: Sep-24; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files imported or exported via gateways or CDSs undergo content checking.

Content conversion

Content conversion can be an effective method to render malicious code harmless by converting one file type to another file type. However, some file types will not benefit from content conversion. Examples of content conversion include:

- converting Microsoft Word documents to PDF files
- converting Microsoft PowerPoint presentations to image files
- converting Microsoft Excel spreadsheets to comma-separated values files
- converting PDF documents to plain text files.

Control: ISM-1286; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files imported or exported via gateways or CDSs undergo content conversion.

Content sanitisation

Content sanitisation is the process of rendering files safe by removing or altering active content while leaving the original content as intact as possible, such as by removing macros from Microsoft Office files or removing JavaScript sections from PDF files.

Control: ISM-1287; Revision: 2; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files imported or exported via gateways or CDSs undergo content sanitisation.

Validating file integrity

If files passing through gateways or CDSs contain a form of integrity protection, such as a digital signature or cryptographic checksum, content filters should validate their integrity. In doing so, the failure of any integrity checks may indicate that files have been tampered with.

Control: ISM-0677; Revision: 7; Updated: Mar-23; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Files imported or exported via gateways or CDSs that have a digital signature or cryptographic checksum are validated.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on performing data transfers can be found in the 'Data transfers' section of the *Guidelines for data transfers*.

Peripheral switches

Using peripheral switches

When accessing different systems through peripheral switches, it is important that sufficient assurance be obtained in their operation to ensure that data does not pass between connected systems. As such, the level of assurance needed in peripheral switches is determined by the difference in sensitivity or classification of systems they are connected to.

There is no requirement for evaluated peripheral switches to be used when all connected systems belong to the same security domain.

Control: ISM-0591; Revision: 8; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Evaluated peripheral switches are used when sharing peripherals between systems.

Control: ISM-1457; Revision: 4; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
Evaluated peripheral switches used for sharing peripherals between SECRET and TOP SECRET systems, or between SECRET or TOP SECRET systems belonging to different security domains, preferably complete a high assurance evaluation.

Control: ISM-1480; Revision: 2; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
Evaluated peripheral switches used for sharing peripherals between SECRET or TOP SECRET systems and any non-SECRET or TOP SECRET systems complete a high assurance evaluation.

Further information

Further information on cyber supply chain risk management can be found in the 'Cyber supply chain risk management' section of the *Guidelines for procurement and outsourcing*.

Further information on evaluated products can be found in the 'Evaluated product procurement' section of the *Guidelines for evaluated products*.

Guidelines for data transfers

Data transfers

Context

This section describes security controls applicable to manual data transfers and data transfers using gateways or cross domain solutions (CDSs). For data transfers using gateways or CDSs, the 'Content filtering' section of the *Guidelines for gateways* is also applicable.

Data transfer processes and procedures

Ensuring that data transfer processes and procedures are developed, implemented and maintained can facilitate consistent data transfers. In addition, to reduce the likelihood of Australian Eyes Only (AUSTEO), Australian Government Access Only (AGAO) and Releasable To (REL) data crossing into unsuitable foreign systems, it is important that additional processes and procedures are developed, implemented and maintained to prevent this from occurring. Depending on protective markings applied to REL data, it may be suitable for export to some foreign systems but not to others.

Control: ISM-0663; Revision: 7; Updated: Dec-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data transfer processes, and supporting data transfer procedures, are developed, implemented and maintained.

Control: ISM-1535; Revision: 6; Updated: Jun-24; Applicable: S, TS; Essential 8: N/A
Processes, and supporting procedures, are developed, implemented and maintained to prevent AUSTEO, AGAO and REL data in textual and non-textual formats from being exported to unsuitable foreign systems.

Accountability for data transfers

When human users transfer data to or from systems, they should understand the potential consequences of their actions. This could include transferring data onto systems not authorised to handle the data, or the unintended introduction of malicious code to systems. As such, human users should be held accountable for all data transfers that they perform.

Control: ISM-0661; Revision: 9; Updated: Sep-26; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Human users transferring data to and from systems are held accountable for data transfers they perform.

Manual import of data

When manually importing data to systems, such as via the use of removable media, the data should be scanned for malicious and active content to reduce the likelihood of causing a malicious

code infection. In cases where security checks fail, data should be quarantined until it can be reviewed and subsequently approved or not approved for release.

Control: ISM-0657; Revision: 6; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When manually importing data to systems, the data is scanned for malicious and active content.

Control: ISM-1778; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When manually importing data to systems, all data that fails security checks is quarantined until reviewed and subsequently approved or not approved for release.

Authorising export of data

Data exported from SECRET and TOP SECRET systems should be reviewed and authorised by a trustworthy source beforehand, such as the chief information security officer or one of their delegates. In doing so, all data authorised for export should be digitally signed by the trustworthy source.

Control: ISM-0664; Revision: 8; Updated: Sep-25; Applicable: S, TS; Essential 8: N/A
Data exported from SECRET and TOP SECRET systems is reviewed and authorised by a trustworthy source beforehand.

Control: ISM-0675; Revision: 7; Updated: Sep-25; Applicable: S, TS; Essential 8: N/A
Data authorised for export from SECRET and TOP SECRET systems is digitally signed by a trustworthy source.

Control: ISM-0665; Revision: 9; Updated: Sep-26; Applicable: S, TS; Essential 8: N/A
Trustworthy sources for SECRET and TOP SECRET systems are limited to people and systems that have been verified and authorised as such by the chief information security officer.

Manual export of data

When manually exporting data from systems, such as via the use of removable media, the data should be checked for unsuitable protective markings to reduce the likelihood of causing a data spill. In addition, data manually exported from SECRET and TOP SECRET systems will require additional assurances, for example, by validating digital signatures and checking for keywords within all textual data. Finally, in cases where security checks fail, data should be quarantined until it can be reviewed and subsequently approved or not approved for release.

Control: ISM-1187; Revision: 3; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When manually exporting data from systems, the data is checked for unsuitable protective markings.

Control: ISM-0669; Revision: 6; Updated: Dec-22; Applicable: S, TS; Essential 8: N/A
When manually exporting data from SECRET and TOP SECRET systems, digital signatures are validated and keyword checks are performed within all textual data.

Control: ISM-1779; Revision: 0; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
When manually exporting data from systems, all data that fails security checks is quarantined until reviewed and subsequently approved or not approved for release.

Monitoring data import and export

To ensure the ongoing confidentiality and integrity of systems, it is important to log all data transfers. This applies to all forms of data transfers, such as those performed using removable media, gateways or CDSs. Ideally, data transfer logs should contain information on who authorised the data transfer, what data was transferred, where the data was transferred from or to, when the data was transferred, why the data was transferred, and how the data was transferred. Monitoring of such activities, via periodic verification of data transfer logs, can assist in identifying abuse of data transfer privileges and any unusual usage patterns that may indicate attempts by malicious actors to surreptitiously import malicious code or exfiltrate data from SECRET and TOP SECRET systems.

Control: ISM-1586; Revision: 0; Updated: Aug-20; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data transfer logs are used to record all data imports and exports from systems.

Control: ISM-1294; Revision: 5; Updated: Mar-22; Applicable: NC, OS, P, S, TS; Essential 8: N/A
Data transfer logs for systems are partially verified at least monthly.

Control: ISM-0660; Revision: 9; Updated: Mar-22; Applicable: S, TS; Essential 8: N/A
Data transfer logs for SECRET and TOP SECRET systems are fully verified at least monthly.

Further information

Further information on manual data transfers using removable media can be found in the ‘Media usage’ section of the *Guidelines for media*.

Further information on data transfers using gateways or CDSs can be found in the ‘Content filtering’ section of the *Guidelines for gateways*.

Cyber security terminology

Glossary of abbreviations

Abbreviation	Meaning
AACA	ASD-Approved Cryptographic Algorithm
AACP	ASD-Approved Cryptographic Protocol
AD CS	Active Directory Certificate Services
AD DS	Active Directory Domain Services
AD FS	Active Directory Federation Services
AES	Advanced Encryption Standard
AGAO	Australian Government Access Only
AH	Authentication Header
AI	artificial intelligence
AISEP	Australian Information Security Evaluation Program
API	application programming interface
ASD	Australian Signals Directorate
ASIO	Australian Security Intelligence Organisation
ATA	Advanced Technology Attachment
AUSTEO	Australian Eyes Only
BGP	Border Gateway Protocol
CCRA	Common Criteria Recognition Arrangement
CDN	content delivery network
CDS	cross domain solution
CISO	chief information security officer
CRQC	cryptographically relevant quantum computer
DAST	dynamic application security testing
DH	Diffie-Hellman
DKIM	DomainKeys Identified Mail
DMA	direct memory access

Abbreviation	Meaning
DMARC	Domain-based Message Authentication, Reporting and Conformance
DNS	Domain Name System
EAL	Evaluation Assurance Level
EAP	Extensible Authentication Protocol
EAP-TLS	Extensible Authentication Protocol-Transport Layer Security
ECDH	Elliptic Curve Diffie-Hellman
ECDSA	Elliptic Curve Digital Signature Algorithm
EDR	endpoint detection and response
EEPROM	electrically erasable programmable read-only memory
EPROM	erasable programmable read-only memory
ESP	Encapsulating Security Payload
FIPS	Federal Information Processing Standard
FT	Fast Basic Service Set Transition
HACE	High Assurance Cryptographic Equipment
HIPS	host-based intrusion prevention system
HMAC	Hash-based Message Authentication Code
HTML	Hypertext Markup Language
HTTPS	Hypertext Transfer Protocol Secure
IEC	International Electrotechnical Commission
IKE	Internet Key Exchange
IP	Internet Protocol
IPsec	Internet Protocol Security
IPv4	Internet Protocol version 4
IPv6	Internet Protocol version 6
IR	infrared
IRAP	Infosec Registered Assessors Program
ISM	*Information security manual*
ISO	International Organization for Standardization

Abbreviation	Meaning
IT	information technology
MAC	Media Access Control
MACsec	Media Access Control Security
MFD	multifunction device
ML-DSA	Module-Lattice-Based Digital Signature Algorithm
ML-KEM	Module-Lattice-Based Key Encapsulation Mechanism
MTA-STS	Mail Transfer Agent Strict Transport Security
NIDS	network-based intrusion detection system
NIPS	network-based intrusion prevention system
NIST	National Institute of Standards and Technology
OAuth	Open Authorization
OT	operational technology
OWASP	Open Worldwide Application Security Project
PDF	Portable Document Format
PFS	Perfect Forward Secrecy
PMK	Pairwise Master Key
PP	Protection Profile
PRF	pseudorandom function
RADIUS	Remote Authentication Dial-In User Service
REL	Releasable To
RF	radio frequency
RMM	remote monitoring and management
ROA	Route Origin Authorization
ROV	Route Origin Validation
RPKI	Resource Public Key Infrastructure
RSA	Rivest-Shamir-Adleman
SAST	static application security testing
SCA	software composition analysis
SCEC	Security Construction and Equipment Committee

Abbreviation	Meaning
SHA-2	Secure Hashing Algorithm 2
SHA-3	Secure Hashing Algorithm 3
SIEM	security information and event management
S/MIME	Secure/Multipurpose Internet Mail Extensions
SMB	Server Message Block
SNMP	Simple Network Management Protocol
SOAR	security orchestration, automation and response
SOE	standard operating environment
SP	Special Publication
SPF	Sender Policy Framework
SPN	Service Principal Name
SQL	Structured Query Language
SSH	Secure Shell
SSID	Service Set Identifier
TLS	Transport Layer Security
USB	Universal Serial Bus
VLAN	virtual local area network
VPN	virtual private network
WAF	web application firewall
WMI	Windows Management Instrumentation
WPA2	Wi-Fi Protected Access 2
WPA3	Wi-Fi Protected Access 3

Glossary of cyber security terms

Term	Meaning
access control	The process of granting or denying requests for access to systems. Can also refer to the process of granting or denying requests for access to facilities.
access cross domain solution	A system permitting access to multiple security domains from a single client device.

Term	Meaning
accountable material	Accountable material requires the strictest control over its access and movement. Accountable material includes TOP SECRET data, some types of caveated data and any data designated as accountable material by its originator.
application control	An approach that permits only explicitly approved applications and other executable content to execute on systems.
artificial intelligence application	An application that contains a reasonable degree of artificial intelligence (AI) functionality. This includes AI-enabled applications, AI-powered applications and AI-driven applications.
artificial intelligence model	A computational model that has been trained using data to recognise patterns; predict, classify or make decisions; or generate outputs in response to inputs, using machine-learning or AI techniques.
artificial intelligence-driven application	An application that uses AI to autonomously control most of its decisions and behaviour. Such applications typically have low human involvement, with decisions being driven by AI. Without AI functionality, such applications are unable to operate as intended.
artificial intelligence-enabled application	An application that uses AI for secondary or supporting functionality. Such applications typically have high human involvement, with decisions led by humans and informed by AI insights. Without AI functionality, such applications can still function effectively.
artificial intelligence-powered application	An application that uses AI for its primary functionality. Such applications typically have moderate human involvement, with decisions shared between humans and AI. Without AI functionality, such applications can function, but only in a severely limited capacity.
assets	In the context of technology, an overarching term used to refer to operating systems, applications, information technology (IT) equipment, operational technology (OT) equipment, services and data. Such assets may also be referred to as technology assets.

Term	Meaning
asymmetric cryptographic algorithms	Cryptographic algorithms where two different keys are used, commonly a private and a public key. Asymmetric cryptographic algorithms are also known as public key cryptographic algorithms.
attack surface	The reachable points through which a system could be accessed, manipulated or compromised. This can include hardware and software interfaces, network services, and application programming interfaces.
Australian Eyes Only data	Data not to be passed to, or accessed by, foreign nationals.
Australian Government Access Only data	Data not to be passed to, or accessed by, foreign nationals, except for seconded foreign nationals.
Australian Information Security Evaluation Program	A program under which evaluations are performed by impartial bodies against the Common Criteria. The results of these evaluations are then certified by the Australian Certification Authority within the Australian Signals Directorate (ASD).
Australian Signals Directorate-approved cryptography	Cryptography suitably implemented using an ASD-Approved Cryptographic Algorithm, an ASD-Approved Cryptographic Protocol, a high assurance cryptographic algorithm or a high assurance cryptographic protocol.
authentication	Verifying the identity of a user as a prerequisite to allowing access to a system and its resources.
authentication artefact	A digital object created or issued during authentication that represents the authenticated identity of a user, or maintains an authenticated session. For example, authentication assertions, authentication tokens and session cookies.
Authentication Header	A protocol used in Internet Protocol Security (IPsec) that provides data integrity and data origin authenticity but not confidentiality.

Term	Meaning
authorisation package	A cyber security documentation package that includes a system's system security plan, cyber security incident response plan, change and configuration management plan, continuous monitoring plan, security assessment report, and plan of action and milestones. The authorisation package is provided to a system's authorising officer to assist them in making an informed decision as to whether the security risks associated with the system's operation are acceptable or not.
authorisation to operate	The official management decision by a senior executive or senior executives to authorise a system to operate based on the acceptance of the security risks associated with its operation.
authorising officer	A senior executive with the authority to authorise the operation of a system at an acceptable level of security risk.
availability	The assurance that systems are accessible and useable by authorised entities when required.
biometrics	Measurable physical characteristics used to identify or verify an individual.
caveat	A marking that indicates that the data has special requirements in addition to those indicated by its classification. This term covers codewords, source codewords, releasability indicators and special-handling caveats.
certification report	An artefact of Common Criteria evaluations that outlines the outcomes of a product's evaluation.
change and configuration management plan	A document that describes the management of changes to the configuration of systems.
chief information security officer	A senior executive who is responsible for coordinating communication between security and business functions as well as overseeing the application of security controls and associated security risk management processes.
classification	The categorisation of systems or data according to the expected impact if compromised.

Term	Meaning
classified data	Data that would cause limited through to exceptionally grave damage to Australia's national interests, the Australian Government generally or to an individual Commonwealth entity if compromised (i.e. data assessed as OFFICIAL: Sensitive, PROTECTED, SECRET or TOP SECRET).
commercial cryptographic equipment	A subset of IT equipment that contains cryptographic components.
Common Criteria	An international standard for product evaluations.
Common Criteria Recognition Arrangement	An international agreement that facilitates the mutual recognition of Common Criteria evaluations by certificate producing schemes.
communications security	The security controls applied to protect telecommunications from unauthorised interception and exploitation, as well as ensure the authenticity of such telecommunications.
computer accounts	Accounts used to identify computers that belong to a domain, also known as machine accounts. Computer accounts provide a means for authenticating and auditing computer access to networks and domain resources.
conduit	A tube, duct or pipe used to protect cables.
confidentiality	The assurance that data is disclosed only to authorised entities.
connected vehicle	Any vehicle that is connected to the internet enabling the relay of data to or from the vehicle. Connected vehicles may be connected to the internet either via embedded internet connectivity, such as a built-in modem, or via a tethered connection to the driver's smartphone.
connection forwarding	The use of network address translation to enable a port on a node inside a network to be accessed from outside the network. Alternatively, using a Secure Shell server to forward a Transmission Control Protocol connection to an arbitrary port on the local host.

Term	Meaning
consent grant	An authorisation provided by a human user or administrator that permits an application to access specified data or resources on behalf of that user or an organisation.
content filter	A filter that examines content to assess conformance against a security policy.
continuous monitoring plan	A document that describes the plan for the continuous monitoring and assurance in the effectiveness of security controls for a system.
control plane	The administrative interface that enables the management and orchestration of a system's infrastructure and applications.
credential management	The enrolment, issuance, use, protection, change and revocation of credentials and other authentication artefacts.
critical server	A server that provides critical network or security services. For example, Microsoft Active Directory Domain Services domain controllers, Microsoft Active Directory Certificate Services servers, Microsoft Active Directory Federation Services servers and Microsoft Entra Connect servers.
cross domain solution	A system capable of implementing comprehensive data flow security policies with a high level of trust between two or more differing security domains.
cryptographic algorithm	An algorithm used to perform cryptographic functions, such as encryption, integrity, authentication, digital signatures or key establishment.
cryptographic application	An application designed to perform cryptographic functions.
cryptographic equipment	A generic term for commercial cryptographic equipment and High Assurance Cryptographic Equipment.
cryptographic hash	An algorithm (the hash function) that takes as input a string of any length (the message) and generates a fixed length string (the message digest or fingerprint) as output. The algorithm is designed to make it computationally infeasible to find any input that maps to a given digest, or to find two different messages that map to the same digest.

Term	Meaning
cryptographic module	The set of hardware and software that implements approved cryptographic functions (including key generation) that are contained within the cryptographic boundary of the module.
cryptographic protocol	An agreed standard for secure communication between two or more entities to provide one or more security properties, such as confidentiality, integrity, authentication or non-repudiation.
cryptographic system	A related set of hardware, software and supporting infrastructure used for cryptographic communication, processing or storage and the administrative framework in which it operates. Cryptographic systems may be based upon traditional cryptography, post-quantum cryptography or a combination of both.
cryptographically relevant quantum computer	A quantum computer that is capable of successfully executing attacks against traditional cryptographic systems.
customer	A person that an organisation has dealings with, typically via the consumption of goods or services. A customer does not necessarily need to purchase goods or services from the organisation.
cyber resilience	The ability to adapt to disruptions caused by cyber security incidents while maintaining continuous business operations. This includes the ability to detect, manage and recover from cyber security incidents.
cyber security	Measures used to protect the confidentiality, integrity and availability of IT and OT systems.
cyber security documentation	An organisation's cyber security strategy; system-specific cyber security documentation; and any supporting diagrams, plans, policies, processes, procedures and registers.
cyber security event	An occurrence of a system, service or network state indicating a possible breach of security policy, failure of safeguards or a previously unknown situation that may be relevant to security.

Term	Meaning
cyber security incident	An unwanted or unexpected cyber security event, or a series of such events, that has either compromised business operations or has a significant probability of doing so.
cyber security incident response plan	A document that describes the plan for responding to cyber security incidents.
cyber supply chain	The suppliers, manufacturers, distributors and retailers involved in the design, manufacture, storage, delivery, installation, operation, maintenance and decommissioning of products and services utilised within an organisation's IT and OT environments.
cyber threat	Any circumstance or event with the potential to harm systems.
data at rest	Data that resides on media or a system.
data in transit	Data that is being communicated across a communication medium.
data repository	A location where data is stored, managed and made available for use.
data security	Measures used to protect the confidentiality, integrity and availability of data.
data spill	The accidental or deliberate exposure of data into an uncontrolled or unauthorised environment, or to entities without a need-to-know.
declassification	A process whereby requirements for the protection of data are removed and an administrative decision is made to formally authorise its release into the public domain.
decommission	The process of removing something from operational service.
degausser	An electrical device or permanent magnet assembly that generates a magnetic force for the purpose of degaussing magnetic storage devices.
degaussing	A process for reducing the magnetisation of a magnetic storage device to zero by applying a reverse magnetic force, rendering any previously stored data unreadable.

Term	Meaning
demilitarised zone	A small network with one or more servers that is kept separate from the core network, typically on the outside of the firewall or as a separate network protected by the firewall. Demilitarised zones usually provide data to less trusted networks, such as the internet.
denial-of-service attack	An attempt by malicious actors to prevent legitimate access to online services (typically a website), for example, by consuming the amount of available bandwidth or the processing capacity of the server hosting the online service.
device access control application	An application that can be used to prevent removable media and mobile devices from being connected to workstations and servers via external communication interfaces.
digital preservation	The coordinated and ongoing set of processes and activities that ensure long-term, error-free storage of digital information, with means for retrieval and interpretation, for the entire time span the information is required.
digital signature	A cryptographic process that enables the proof of the source (with non-repudiation) and the verification of the integrity of that data.
diode	A device that enables data to flow in only one direction.
dual-stack network	A network that implements both Internet Protocol version 4 and Internet Protocol version 6 protocol stacks.
elliptic curve cryptography	A group of asymmetric cryptographic algorithms underpinned by the mathematics of elliptic curves.
emanation security	The countermeasures employed to reduce sensitive or classified emanations from a facility and its systems to an acceptable level. Emanations can be in the form of Radio Frequency energy, sound waves or optical signals.
Encapsulating Security Payload	A protocol used for encryption and authentication in IPsec.
event	In the context of system logs, an observable occurrence or change of state involving a system, network, application, workload or account.

Term	Meaning
extendable-output function	A function that uses a hash function to output a digest of a user-chosen length. This is different from a hash function that outputs a digest of a fixed length.
facility	A physical space where business is performed. For example, a facility can be a building, a floor of a building or a designated space on the floor of a building.
fax machine	A device that enables documents to be communicated over an analog telephone network.
firewall	A network device that filters incoming and outgoing network data based on a series of rules.
firmware	Software embedded in IT equipment or OT equipment.
fly lead	A lead that connects IT equipment to the fixed infrastructure of a facility. For example, the lead that connects a workstation to a network wall socket.
foreign national	A person who is not an Australian citizen.
foreign system	A system that is not managed by, or on behalf of, the Australian Government.
frontier artificial intelligence model	An AI model typically characterised by advanced reasoning, code understanding, natural language processing or multimodal capabilities, and trained at scale using state-of-the-art techniques. Such AI models can perform complex tasks that exceed the capabilities of conventional automated tools.
gateway	Gateways securely manage data flows between connected networks from different security domains.
hardware	A generic term for IT equipment and OT equipment.
hardware security module	A physical computing device that safeguards cryptographic keys and provides cryptographic processing. A hardware security module is or contains a cryptographic module. Hardware security modules are commonly deployed in Public Key Infrastructure, digital identity solutions and payment systems.
Hash-based Message Authentication Code	A cryptographic function that can be used to compute Message Authentication Codes using a hash function and a secret key.

Term	Meaning
High Assurance Cryptographic Equipment	Cryptographic equipment that has been authorised by ASD for the protection of SECRET and TOP SECRET data.
High Assurance Evaluation Program	The rigorous investigation, analysis, verification and validation of products by ASD to protect SECRET and TOP SECRET data.
high assurance information technology equipment	IT equipment that has been designed and authorised for the protection of SECRET and TOP SECRET data.
high-value server	A server that provides important network services or contains data repositories. For example, Domain Name System servers, database servers, email servers, file servers and web servers.
human user	A human actor who is authorised to access a system and its resources.
hybrid hard drive	Non-volatile magnetic media that uses a cache to increase read/write speeds and reduce boot times. The cache is normally non-volatile flash memory media.
identity and access management	The identification and authentication of human and non-human actors, the authorisation and control of their access, and the monitoring of access activities.
information technology	Hardware, software and supporting infrastructure used for the processing, storage or communication of data.
information technology equipment	Any device that can process, store or communicate data within IT environments, such as computers, multifunction devices, network devices, smartphones, electronic storage media and smart devices.
Infosec Registered Assessors Program	An initiative of ASD designed to register suitably qualified individuals to carry out security control assessments for systems.
Infosec Registered Assessors Program assessment	A security control assessment conducted by a registered assessor against the requirements of the *Information security manual*.
infrared device	Devices such as mice, keyboards and pointing devices that have an infrared communications capability.
insider	Any person who has, or had, authorised logical or physical access to a system and its resources.

Term	Meaning
insider threat	An insider who performs, or attempts to perform, damaging activities (either intentionally or unintentionally) to a system or its resources. Some organisations may choose to exclude unintentional damage to systems and their resources (often referred to as negligent or accidental damage) from their definition of insider threat to focus on insiders with malicious intent (often referred to as malicious insiders).
integrity	The assurance that data has been created, amended or deleted only by authorised entities.
interactive authentication	Authentication that involves direct interaction by a human user.
internet facing network device	Network devices that operate at the boundary between an organisation's network and the internet. For example, firewalls, load balancers, routers, virtual private network (VPN) concentrators and web application firewalls. Such network devices are commonly referred to as edge devices.
Internet Protocol Security	A suite of protocols for secure communications through authentication or encryption of Internet Protocol (IP) packets as well as including protocols for cryptographic key establishment.
Internet Protocol telephony	The transport of telephone calls over IP networks.
Internet Protocol version 6	A protocol used for communicating over packet switched networks. Version 6 is the successor to version 4 that is widely used on the internet.
intrusion detection system	An automated system used to identify malicious or unwanted activities. An intrusion detection system can be host-based or network-based.
intrusion prevention system	An automated system used to identify malicious or unwanted activities and react in real-time to block or prevent such activities. An intrusion prevention system can be host-based or network-based.
jump server	A computer that is used to manage important or critical resources in a separate security domain. Also known as a jump host or jump box.

Term	Meaning
key encapsulation mechanism	An asymmetric cryptographic mechanism that enables two entities to establish a shared secret by encapsulating keying material using a public key and decapsulating it using the corresponding private key.
key management	The use and management of cryptographic keys and associated hardware and software. It includes their generation, registration, distribution, installation, usage, protection, storage, access, recovery and destruction.
keying material	Cryptographic keys generated or used by cryptographic equipment, applications or libraries.
logging facility	A facility that collects and stores event logs.
malicious actors	Human or non-human entities that conduct malicious activities, such as cyber espionage, cyber attacks or cyber-enabled crime.
malicious code	Any software that attempts to subvert the confidentiality, integrity or availability of a system.
malicious code infection	The occurrence of malicious code infecting a system.
media	A generic term for hardware, often portable in nature, that is used to store data.
media destruction	The process of physically damaging media with the intent of making data stored on it inaccessible. To destroy media effectively, only the actual material in which data is stored needs to be destroyed.
media disposal	The process of relinquishing control of media when it is no longer required.
media sanitisation	The process of erasing or overwriting data stored on media so that it cannot be retrieved or reconstructed.
medical device	Devices approved by the Therapeutic Goods Administration under the *Therapeutic Goods (Medical Devices) Regulations 2002* for diagnostic or therapeutic purposes.
memory-safe programming languages	Programming languages that prevent the introduction of vulnerabilities related to memory use. Examples of memory-safe programming languages include C#, Go, Java, Ruby, Rust and Swift. Examples of non-memory-safe programming languages include Assembly and C/C++.

Term	Meaning
metadata	Descriptive data about the content and context used to identify data.
mobile device	A portable computing or communications device. For example, smartphones, tablets and laptop computers.
multifunction device	IT equipment that combines printing, scanning and copying functionality in the one device.
multi-factor authentication	Authentication using two or more different authentication factors. This may include something people know, something people have or something people are.
need-to-know	The principle of restricting access to only the data required to fulfil an authorised role or function.
network access control	Security policies used to control access to a network and actions on a network. This can include authentication checks and authorisation controls.
network device	IT equipment designed to facilitate the communication of data. For example, routers, switches and wireless access points.
network infrastructure	The infrastructure used to carry data between workstations and servers or other network devices.
network management traffic	Network traffic generated over a network to manage or control workstations, servers and network devices. This includes standard management protocols and other network traffic that contains data relating to the management of the network.
non-human user	A non-human actor, such as a service, application, workload or AI agent, that is authorised to access a system and its resources.
non-interactive authentication	Authentication that does not involve direct interaction by a human user.
non-repudiation	Providing proof that an action was performed by a particular user such that the origin of the action cannot subsequently be repudiated.
non-volatile flash memory media	A specific type of electrically erasable programmable read-only memory.

Term	Meaning
non-volatile media	A type of media that retains its data when power is removed.
off-hook audio protection	A method of mitigating the possibility of an active handset inadvertently enabling background discussions to be heard by a remote party. This can be achieved by using a hold feature, mute feature, push-to-talk handset or equivalent.
online services	Services directly accessible over the internet, including those located behind a perimeter firewall. Such services may also be referred to as internet-facing services.
OpenPGP Message Format	A message format for encrypting, digitally signing, compressing and encoding data using OpenPGP cryptography.
operating system	Software that provides the interface through which users access a system. Operating systems also facilitate access to user applications, server applications, mobile applications and web applications.
operational technology	Systems that detect or cause a direct change to the physical environment through the monitoring or control of devices, processes and events. OT is predominantly used to describe industrial control systems that include supervisory control and data acquisition systems and distributed control systems.
operational technology equipment	Any device that can process, store or communicate data or signals within OT environments, such as programmable logic controllers and remote terminal units.
passkey	A credential that uses public-key cryptography to authenticate a human user to a system or online service. A passkey typically consists of a private key stored on, or accessible through, a computer, mobile device or security key, with a corresponding public key held by the system or online service being authenticated to. Passkey authentication may provide single-factor or multi-factor authentication. It provides multi-factor authentication where use of the private key requires a separate activation factor, such as a password or biometric.
passphrase	A password consisting solely of a sequence of words.

Term	Meaning
password	A sequence of characters used for authentication. Passwords consisting solely of numbers are also known as personal identification numbers, while passwords consisting solely of a sequence of words are also known as passphrases.
password complexity	The use of different character sets, such as lower-case alphabetical characters (a-z), upper-case alphabetical characters (A-Z), numeric characters (0-9) and special characters.
passwordless authentication	Authentication that does not involve the use of something people know. Passwordless authentication may be single-factor or multi-factor, with the latter often referred to as passwordless multi-factor authentication.
passwordless multi-factor authentication	Multi-factor authentication using something people have that is unlocked by something people know or are. While a password may be used as part of passwordless multi-factor authentication (e.g. to unlock access to a cryptographic private key stored on a device) it is not a primary authentication factor.
patch	A piece of software designed to remedy vulnerabilities or improve the usability or performance of operating systems, applications, IT equipment or OT equipment.
patch cable	A metallic (copper) or fibre-optic cable used for routing signals between two components in an enclosed container or rack.
patch panel	A group of sockets or connectors that enable manual configuration changes, generally by means of connecting patch cables.
penetration test	A security assessment designed to exercise real-world scenarios to achieve a specific goal, such as compromising critical systems or data.
Perfect Forward Secrecy	A property of key establishment whereby compromise of long-term keying material does not enable recovery of previously established session keys.
peripheral switch	A device used to share a set of peripherals between multiple computers. For example, a keyboard, video monitor and mouse.
personal identification number	A password consisting solely of numbers.

Term	Meaning
plan of action and milestones	A document that describes vulnerabilities in a system and the plans for their rectification.
post-quantum cryptography	Asymmetric cryptography designed to remain secure in the presence of a cryptographically relevant quantum computer.
post-quantum traditional hybrid scheme	An asymmetric cryptographic scheme that incorporates at least two different components based on different mathematically hard problems. Generally, post-quantum traditional hybrid schemes are used to combine post-quantum cryptography and traditional cryptography such that defeating the scheme requires defeating each component.
privileged operating environments	Privileged operating environments are those used for activities that require a degree of privileged access, such as system administration activities.
privileged user accounts	User accounts that have the capability to modify system configurations, account privileges, event logs or security configurations. This also applies to user accounts that may only have limited privileges but still have the ability to bypass some security controls.
product	A generic term used to describe software or hardware.
PROTECTED area	An area that has been authorised to process, store or communicate PROTECTED data. Such areas are not necessarily tied to a specific level of security zone.
Protection Profile	A document that stipulates the security functionality that must be included in a Common Criteria evaluation to meet a range of defined threats. Protection Profiles also define the activities to be taken to assess the security function of an evaluated product.
protective marking	An administrative label assigned to data that not only shows the value of the data but also defines the level of protection to be provided.
public data	Data that has been formally authorised for release into the public domain.
public network infrastructure	Network infrastructure that an organisation has no control over, such as the internet.

Term	Meaning
push-to-talk handsets	Handsets that have a button that needs to be pressed before audio can be communicated, thus providing off-hook audio protection.
quality of service	The ability to provide different priorities to different applications, users or data flows, or to guarantee a certain level of performance to a data flow.
reclassification	An administrative decision to change the security controls used to protect data based on a reassessment of the potential impact of its unauthorised disclosure. The lowering of the security controls for media containing sensitive or classified data often requires sanitisation or destruction processes to be undertaken prior to a formal decision to lower the security controls protecting the data.
Releasable To data	Data not to be passed to, or accessed by, foreign nationals beyond those belonging to specific nations that the data has been authorised for release to.
remote access	Access to a system that originates from outside an organisation's network and enters the network through a gateway, including over the internet.
removable media	Storage media that can be easily removed from a system and is designed for removal, such as Universal Serial Bus flash drives and optical media.
seconded foreign national	A representative of a foreign government on exchange or long-term posting.
SECRET area	An area that has been authorised to process, store or communicate SECRET data. Such areas are not necessarily tied to a specific level of security zone.
Secure Admin Workstation	A hardened workstation, or virtualised privileged operating environment, used specifically in the performance of administrative activities.
Secure by Default	A software development principle whereby products and services are configured for maximum security by default.
Secure by Demand	When a customer requests that their suppliers provide evidence of their commitment to security and transparency for their products and services.

Term	Meaning
Secure by Design	A software development principle whereby security is designed into every stage of a product or service's development.
secure channel	A path for transferring data between two entities that ensures confidentiality and integrity, as well as mutual authentication, between the two entities.
Secure Shell	A network protocol that can be used to securely log into, execute commands on, and transfer files between remote workstations and servers.
Secure/Multipurpose Internet Mail Extensions	A protocol that enables the encryption and signing of email messages.
secured space	An area certified to the physical security requirements for a Security Zone Two to Security Zone Five area, as defined in the Department of Home Affairs' *Protective Security Policy Framework*.
security assessment	An activity designed to provide assurance in the security posture of a system and its operating environment. Security assessments can include security control assessments, vulnerability scanning, vulnerability assessments and penetration tests.
security assessment plan	A document that describes the agreed scope, type and extent of assessment activities as part of a security control assessment.
security assessment report	A document that describes the outcomes of a security control assessment and contributes to the development of a plan of action and milestones.
security association	A collection of connection-specific parameters used for IPsec connections.
security association lifetime	The duration a security association is valid for.
Security Construction and Equipment Committee	An Australian Government interdepartmental committee responsible for the evaluation and endorsement of security equipment and services. The committee is chaired by the Australian Security Intelligence Organisation.
security control	A safeguard implemented for a system or its operating environment to protect the confidentiality, integrity or availability of data.

Term	Meaning
security control assessment	A security assessment activity undertaken to assess security controls for a system and its environment to determine if they have been implemented correctly and are operating as intended.
security domain	A system or collection of systems operating under a consistent security policy that defines the classification, releasability and special handling caveats for data processed within the domain.
security posture	The level of security risk to which a system is exposed. A system with a strong security posture is exposed to a low level of security risk while a system with a weak security posture is exposed to a high level of security risk.
security risk	The likelihood and consequence of an event that could result in the compromise, loss of integrity or unavailability of systems, their resources or data, or deliberate harm to people.
security risk management	The process of identifying, assessing and taking steps to reduce security risks to an acceptable level.
security target	An artefact of Common Criteria evaluations that specifies conformance claims, threats and assumptions, security objectives, and security requirements for an evaluated product.
sensitive data	Data that would cause damage to an organisation or an individual if compromised.
server	A computer that provides services to users or other systems. For example, a file server, email server or database server.
service accounts	User accounts used by non-human users to perform automated tasks without manual intervention, such as machine-to-machine communications. Service accounts will typically be configured to disallow interactive logins.
shared facility	A facility shared by multiple tenants. For example, a single floor, or part of a floor, within a multi-tenanted building.

Term	Meaning
shared responsibility model	A framework that describes the management and operational responsibilities between different parties for a system. Where responsibilities relating to specific security controls are shared between multiple parties, enough detail is documented to provide clear demarcation between the parties.
software	An element of a system including, but not limited to, an operating system or application.
solid-state drive	Non-volatile media that uses non-volatile flash memory media to retain its data when power is removed and, unlike non-volatile magnetic media, contains no moving parts.
split tunnelling	Functionality that enables a device to access public network infrastructure and a VPN connection at the same time.
standard operating environment	A standardised build of an operating system and associated applications that can be used for servers, workstations and mobile devices.
supplier	Organisations, such as software developers, IT equipment manufacturers, OT equipment manufacturers, service providers and data brokers, that provide products and services. Suppliers can also include other organisations involved in distribution channels.
symmetric cryptographic algorithms	Cryptographic algorithms that use the same key for encryption and decryption. Block ciphers and stream ciphers are common types of symmetric cryptographic algorithms.
system	The cyber supply chain, infrastructure, operating systems and applications supporting the processing, storage or communication of data, including the governance framework within which they operate.
system administrator	A system administration role performed by a human user with privileged access.
system owner	The executive responsible for a system.
system security plan	A document that describes a system and its associated security controls.

Term	Meaning
system-specific cyber security documentation	A system's system security plan, cyber security incident response plan, change and configuration management plan, continuous monitoring plan, security assessment report, and plan of action and milestones.
telemetry	The automatic measurement and transmission of data collected from remote sources. Such data is often used within systems to measure the use, performance and health of one or more functions or devices that make up the system.
telephone	A device that is used for point-to-point communication over a distance. This includes digital and IP telephony.
telephone system	A system designed primarily for the transmission of voice communications.
TOP SECRET area	An area that has been authorised to process, store or communicate TOP SECRET data. Such areas are not necessarily tied to a specific level of security zone.
traditional cryptography	Common well studied and understood cryptographic algorithms that existed before the threat of a cryptographically relevant quantum computer existed.
transfer cross domain solution	A system that facilitates the transfer of data in one or more directions between different security domains.
transport mode	An IPsec mode that provides a secure connection between two endpoints by encapsulating an IP payload.
trustworthy source	A person or system formally identified as being capable of reliably producing data meeting certain defined parameters, such as a maximum data classification and reliably reviewing data produced by others to confirm compliance with certain defined parameters.
trustworthy supplier	A supplier that has been verified as trustworthy as part of a cyber supply chain risk management assessment and subsequently documented on an organisation's approved supplier list.
tunnel mode	An IPsec mode that provides a secure connection between two endpoints by encapsulating an entire IP packet.

Term	Meaning
unprivileged user accounts	User accounts that do not have the capability to modify system configurations, account privileges, event logs or security configurations.
unprivileged operating environments	Unprivileged operating environments are those used for activities that do not require privileged access, such as reading emails and browsing the web.
user	A human or non-human actor that is authorised to access a system and its resources.
user accounts	Accounts used by users to access systems and their resources, excluding computer accounts. User accounts include privileged user accounts and unprivileged user accounts.
validation	Confirmation that stakeholder requirements for the intended use of operating systems, applications, IT equipment or OT equipment have been met.
verification	Confirmation that design or compliance requirements for operating systems, applications, IT equipment or OT equipment have been met.
virtual local area network	Network devices and networked IT equipment grouped logically based on resources, security or business requirements instead of their physical location.
virtual private network	A network that maintains privacy through a tunnelling protocol and security procedures. VPNs may use encryption to protect network traffic.
virtualisation	Simulation of hardware or software resources.
volatile media	A type of media, such as random-access memory, that gradually loses its data when power is removed.
vulnerability	A weakness in a system's security requirements, design, implementation or operation that could be accidentally triggered or intentionally exploited and result in a violation of the system's security policy.
vulnerability assessment	A security assessment involving a review of a system's architecture or an in-depth hands-on assessment to identify as many potential vulnerabilities as possible.
vulnerability scan	A security assessment using tools to conduct automated checks for known vulnerabilities in a system and its environment.

Term	Meaning
wear levelling	A technique used in non-volatile flash memory media to prolong the life of the media. As data can be written to and erased from memory blocks a finite number of times, wear-levelling helps to distribute writes evenly across each memory block, decreasing wear and increasing its lifetime.
Wi-Fi Protected Access	A security standard for protecting wireless networks.
Wi-Fi Protected Access 2	A successor to Wi-Fi Protected Access that provides enhanced security for wireless networks.
Wi-Fi Protected Access 3	A successor to Wi-Fi Protected Access 2 that provides further enhanced security for wireless networks.
wireless access point	A device that enables communications between wireless clients. It is typically also the device that connects wired and wireless networks.
wireless communications	The transmission of data over a communications path using electromagnetic waves rather than a wired medium.
wireless network	A network based on 802.11 standards.
workstation	A stand-alone or networked single-user computer.
X11 forwarding	X11, also known as the X Window System, is a basic method of video display used in a variety of operating systems. X11 forwarding enables the video display from one device to be shown on another device.

Disclaimer

The material in this guide is of a general nature and should not be regarded as legal advice or relied on for assistance in any particular circumstance or emergency situation. In any important matter, you should seek appropriate independent professional advice in relation to your own circumstances.

The Commonwealth accepts no responsibility or liability for any damage, loss or expense incurred as a result of the reliance on information contained in this guide.

Copyright

© Commonwealth of Australia 2026

With the exception of the Coat of Arms and where otherwise stated, all material presented in this publication is provided under a Creative Commons Attribution 4.0 International license https://creativecommons.org/licenses/by/4.0/.

For the avoidance of doubt, this means this license only applies to material as set out in this document.



The details of the relevant license conditions are available on the Creative Commons website as is the full legal code for the CC BY 4.0 license https://creativecommons.org/licenses/by/4.0/legalcode.en.

Use of the Coat of Arms

The terms under which the Coat of Arms can be used are detailed on the Department of the Prime Minister and Cabinet website https://www.pmc.gov.au/resources/commonwealth-coat-arms-information-and-guidelines.

cyber.gov.au